CS627 – Cyber Security

Week No. 1

Cyber Security Overview

Prepared by DL...
May You All Stay Success in your Whole Life, Ameen! Summ Ameen... Just Remember us in your Deep Prayers. JazakAllah...

Week 1 Topic 1

Introduction

- An initiative to explore Cyber security

Week 1 Topic 2

Importance of Cyber Security

- Mobile Phones
- Total population of Pakistan (2020) → 219,067,896
- Number of mobile phone users in Pakistan has reached 161.183 million, as of May 2019.
    - Smart phones
    - Traditional phones:
        - SMS / Call Scams

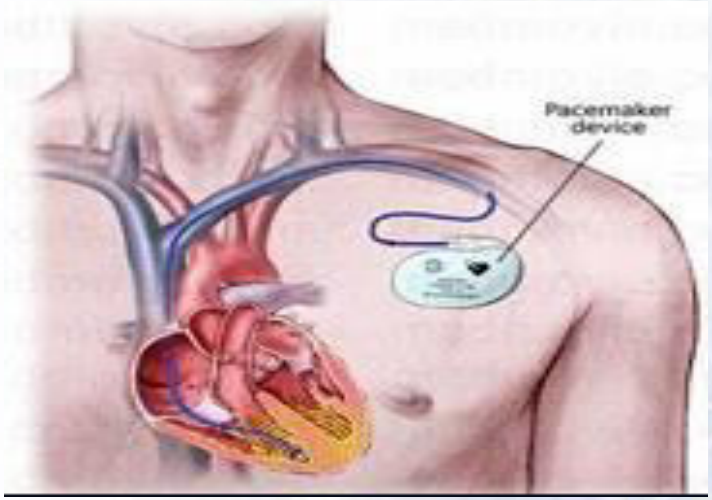
Importance of Cyber Security

Importance of Cyber Security

- Drones
- Here's How Hackers Could Have Spied On Your DJI Drone Account
- https://thehackernews.com/2018/11/dji-drone-hack_8.html

Importance of Cyber Security

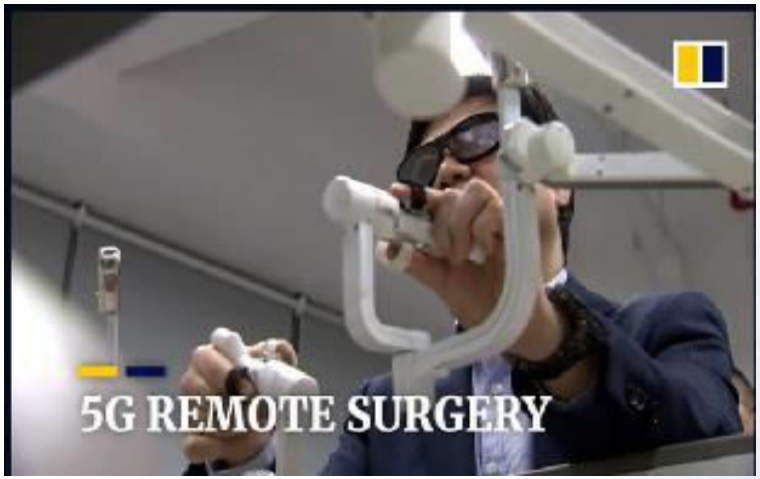
- Health / Medical
  - Pacemaker: a device for stimulating the heart muscle and regulating its contractions.
  - Robotic Surgeons
    - 5 Medical Robots Making a Difference in Healthcare
    - https://online-engineering.case.edu/blog/medical-robots-making a-difference

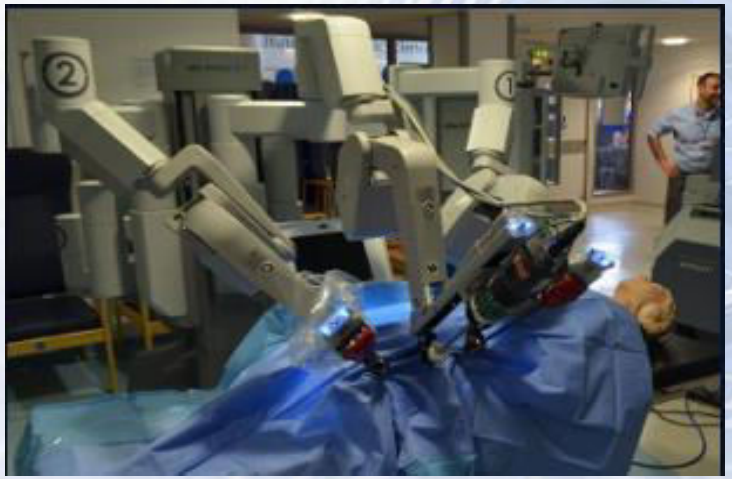


Importance of Cyber Security

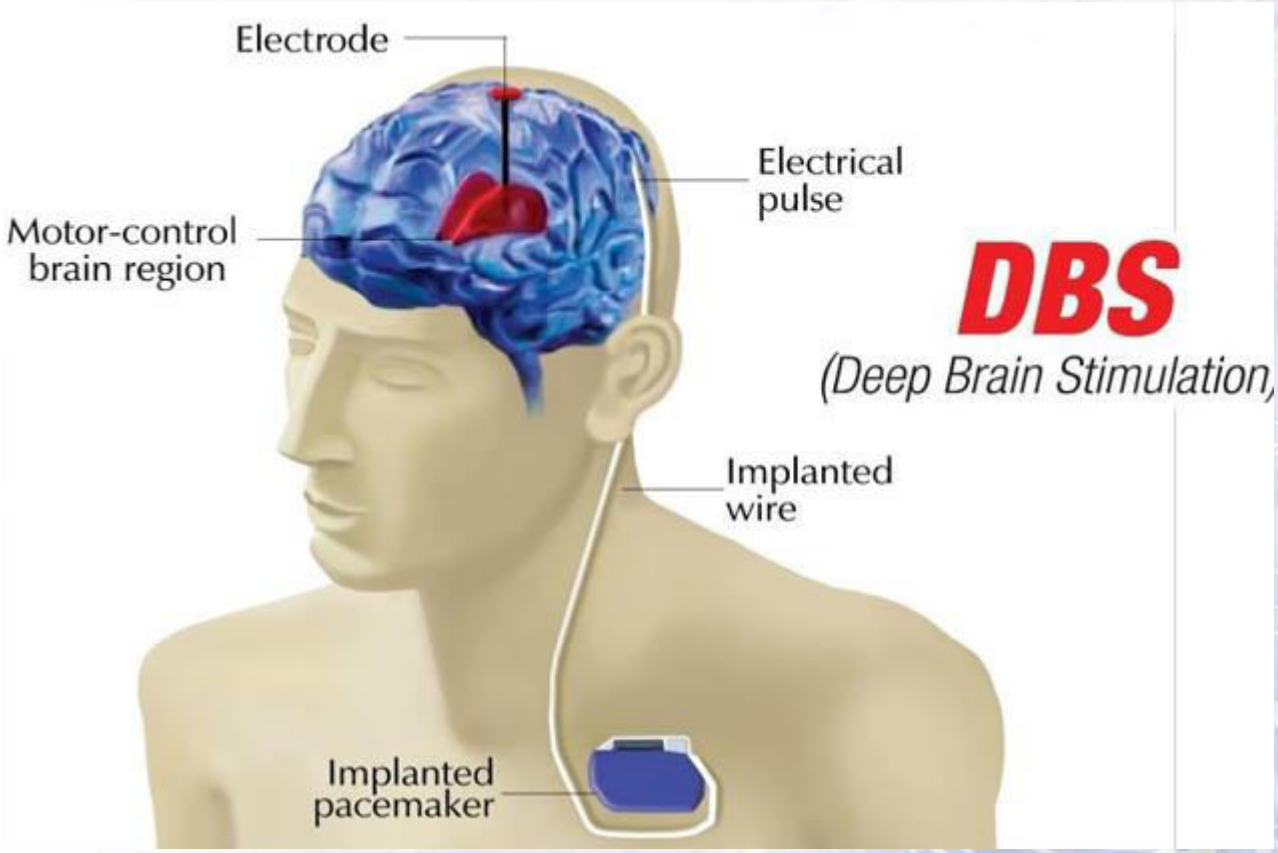
Remote Surgery

- China completes world's first 5G remote surgery in test on animal
  - https://www.youtube.com/watch?v=yFR61jjL1vo
- Robot Helps Perform First Long-Distance Heart Surgery
- A surgeon in India performed the first remote heart operation on a patient 20 miles away.
  - https://www.popularmechanics.com/technology/robots/a28941179/robot-performs-first-long-distance-heart-surgery





Bluetooth in health



The field of ‘Cyber Security’ is becoming more important due to increased reliance on

- computer systems
- the Internet
- wireless network standards
  - such as Bluetooth and Wi-Fi
- due to the growth of "smart" devices
  - including smartphones , televisions , and the "Internet of things ".

• Owing to its complexity, both in terms of politics and technology, cyber security is also one of the major challenges in the contemporary world.

- Ease of use results in increasing underlying complexity

Week 1 Topic 3

Defining Cybersecurity

- "Cyber" Relating to or characteristic of the culture of computers, information technology, and virtual reality.
- Cyberspace is a term for virtual reality coined by William Gibson.
- https://en.wikipedia.org/wiki/Cyberspace
- Cyber is derived from "cybernetic'[https://en.wikipedia.org/wiki/Cybernetics] which comes from the Greek word κυβερνητικός meaning 'skilled in steering or governing'.
- Pronunciation: [https://forvo.com/word/%CE%BA%CF%85%CE%B2%CE%B5%CF%81%CE%BD%CE%B7%CF%84%CE%B9%CE%BA%CF%8C%CF%82/]
- Cybernetics: the science of communications and automatic control systems in both machines and living things.
- Used to describe policies and politics regarding computer systems and networks.
- Term used in Information Technology industry and the Internet era.
- https://en.wikipedia.org/wiki/Internet-related_prefixes#.22Cyber-.22
- https://en.wikipedia.org/wiki/Cyber

Cyber Security

Security

- Degree of ‘protection’ [safe & secure].
- The state of being free from danger or threat.
- Security is freedom from, or resilience against, potential others. [Wikipedia]
- https://en.wikipedia.org/wiki/Securit

- Computer security, cyber security or information technology security (IT security) is the protection of computer systems the theft of or damage to their hardware, software, or from electronic data, as well as from the disruption or misdirection of the services they provided.
- https://en.wikipedia.org/wiki/Computer_securit

Week 1 Topic 4

Security Realms

- Information Security
  - IT Security
  - Cyber Security
  - Network Security
  - System Security
  - Data Security
  - Operating System Security
  - Physical Security

Information Security

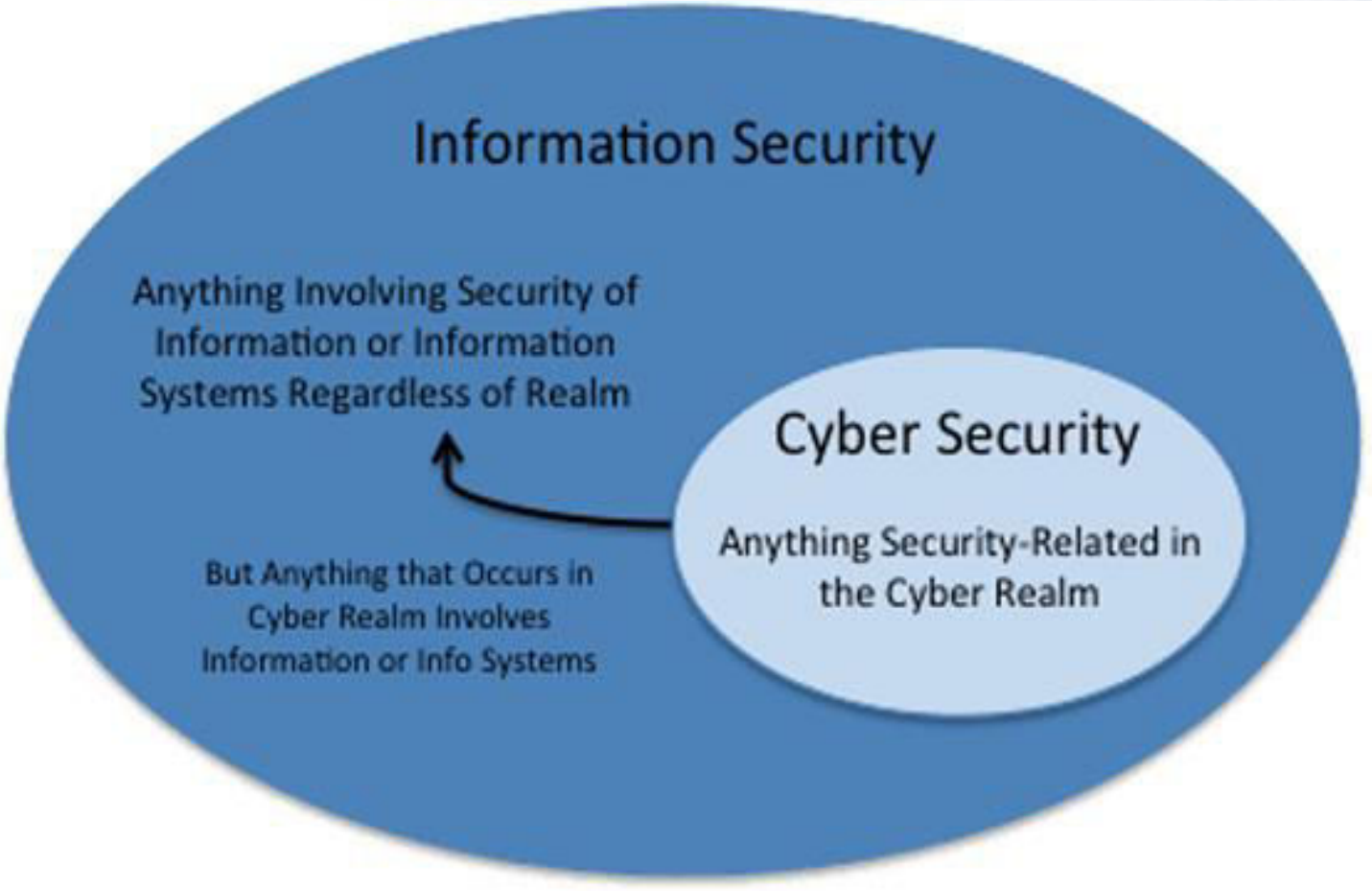
Information Security

- Information security, sometimes shortened to infosec, is the 'practice of protecting information' by mitigating information risks.
- It is part of information risk management.

- It typically involves preventing or at least reducing the probability of unauthorized/inappropriate access, use, disclosure, disruption, deletion/destruction, corruption, modification, inspection (monitor), recording or devaluation of data and/or systems.

- Information may take any form, e.g. electronic or physical

Cyber Security vs InfoSec



Cyber Security VS Information Security

Cyber Security

- Cyber security deals with protecting your data and information that is in digital or electronic form.
- t protects data that exists in the cyber realm from unauthorized digital access.
- It deals with advanced persistent threats that are imminent.
- It deals with cyber threats such as phishing, baiting, data breach, etc.

Information Security

- Information security deals with safeguarding your information assets that are in both physical and digital format.
- It's all about protecting information and their confidentiality, integrity, and availability.
- It's the foundation of data security which means it's the first step.
- It deals with all sorts of threats to make sure proper security protocols are in place.

Week 1 Topic 5

Cyber Security Jobs & Careers

https://www.cybersecurityeducation.org/careers/

- Start at any point in your life / career.
- Wide range of responsibilities.
- Crux of the job is to protect online data and systems form being compromised.
- Cyber security careers are complex.
- Many roles can be found with banks, retailers and government organizations.
- On the job, you can expect to:
    - safeguard an organization's files and network
    - install / configure firewalls
    - create security plans
    - monitor activity
    - If a breach occurs, you'll be responsible for identifying the problem and finding a solution quickly.
- Because of the frequency of cyber attacks, careers are varied and qualified professionals are in demand.
- If you're ready to get started in this fast-growing career, start exploring cyber careers now

Job titles

- Cyber Security Vendor
  - Solution Provider
  - Services
- Security Auditor
- PenTester / Ethical Hacker
- Security Analyst
- InfoSec Engineer
- InfoSec Consultant
- Malware Analyst
- Forensic Analyst/Expert/Investigator
- Incident Handler / Manager
- InfoSec / Cyber Security Specialist
- InfoSec Manager
- CISO

Top 10 Cyber Security Job Titles

Here are the top 10 Cyber Security Job Titles that are very valuable:

- Security Engineer
- Security Analyst
- Information Security Analyst
- Information Security Engineer
- Network Security Engineer
- Information Technology Security Analyst
- Information Security Manager
- Information Assurance Engineer
- Senior IT Auditor

UMUC.edu study

Highest-paying job Titles

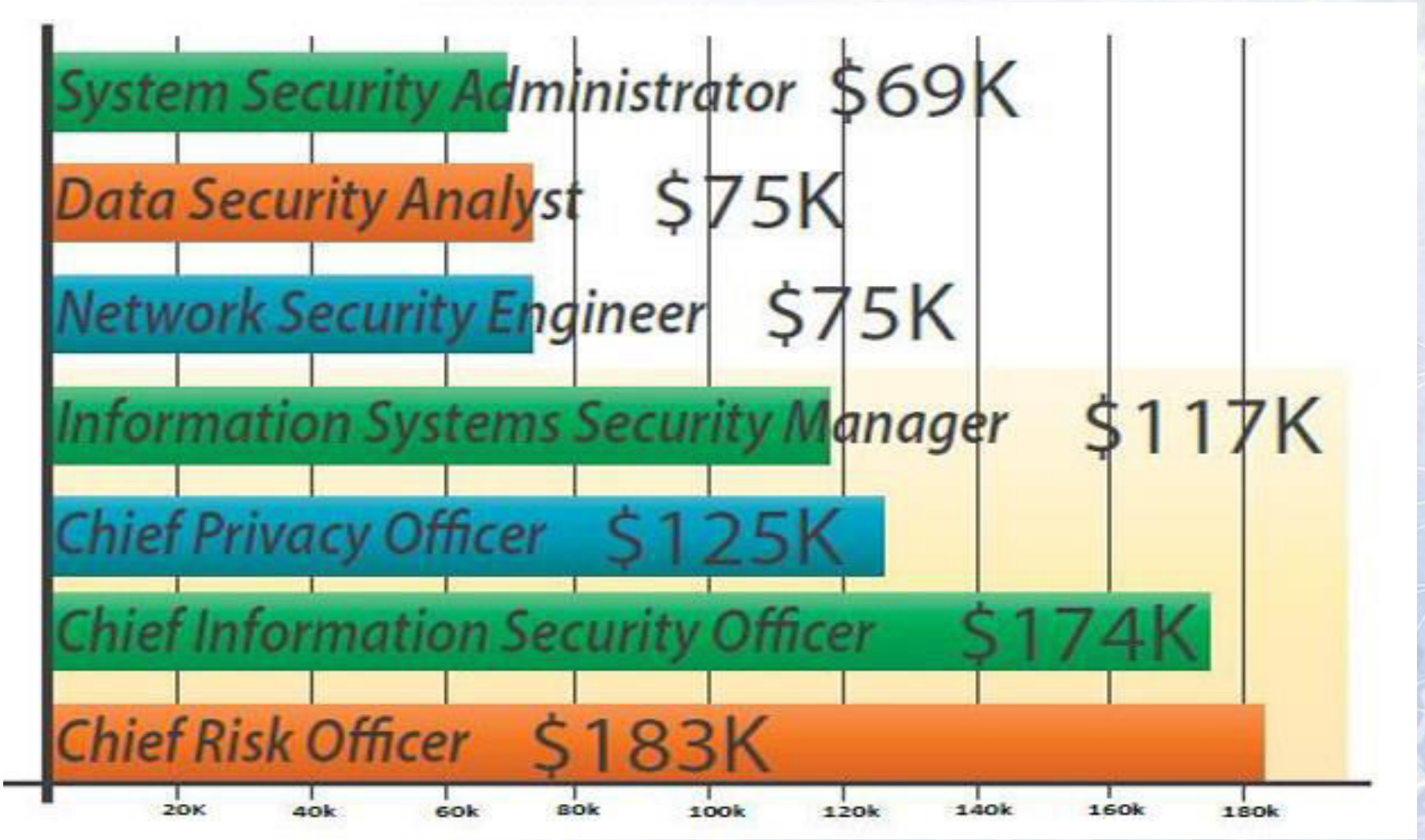
Here are the 10 highest-paying job titles in cyber security in US:

- Application security engineer
- Director of information security
- Senior security consultant
- Cloud engineer
- Software architect
- Penetration tester
- Risk manager
- Chief information officer
- Security engineer
- Information manager

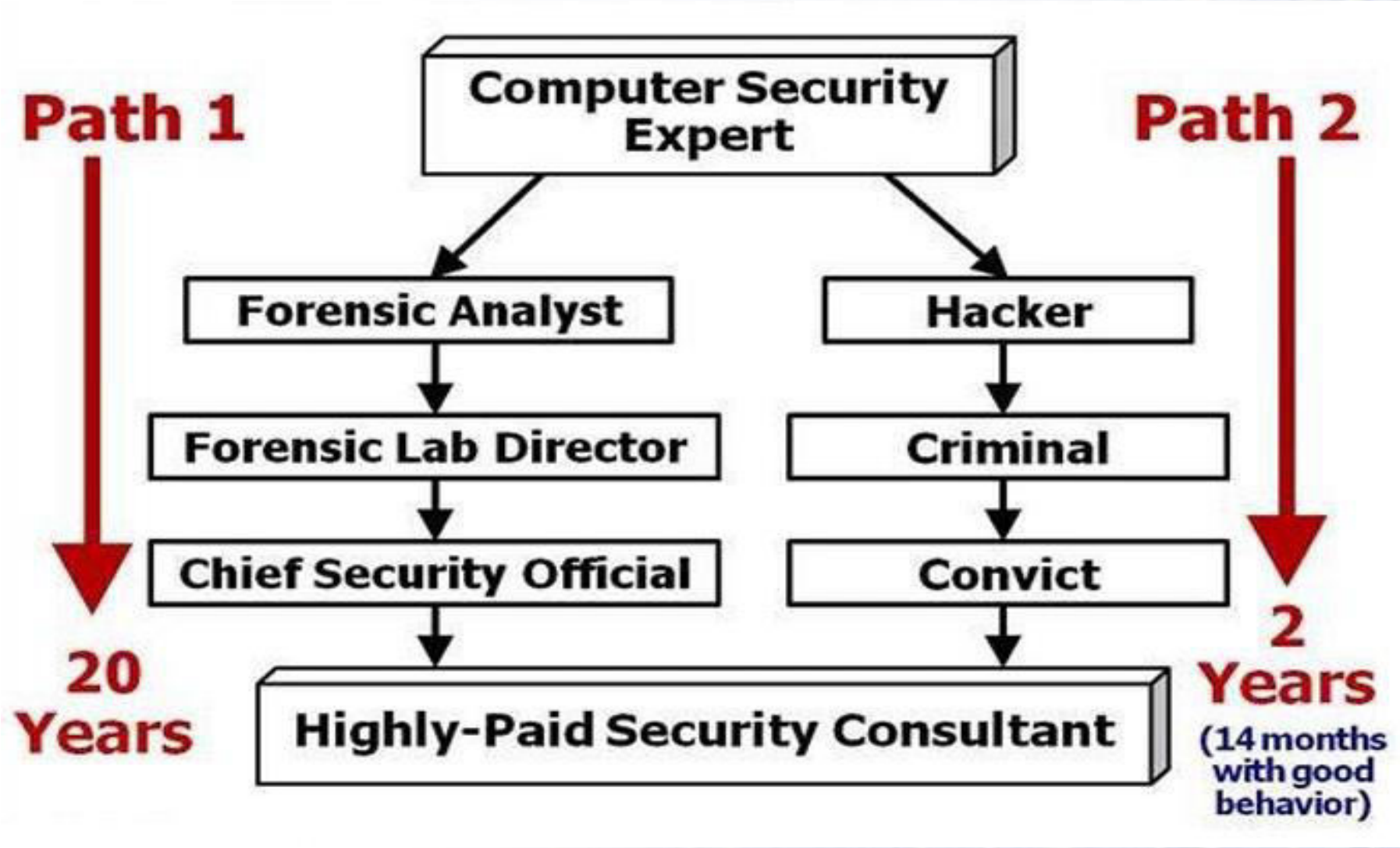
Source – indeed.com

Hot IT Career Choices

Median annual wages



Computer Security Career Path

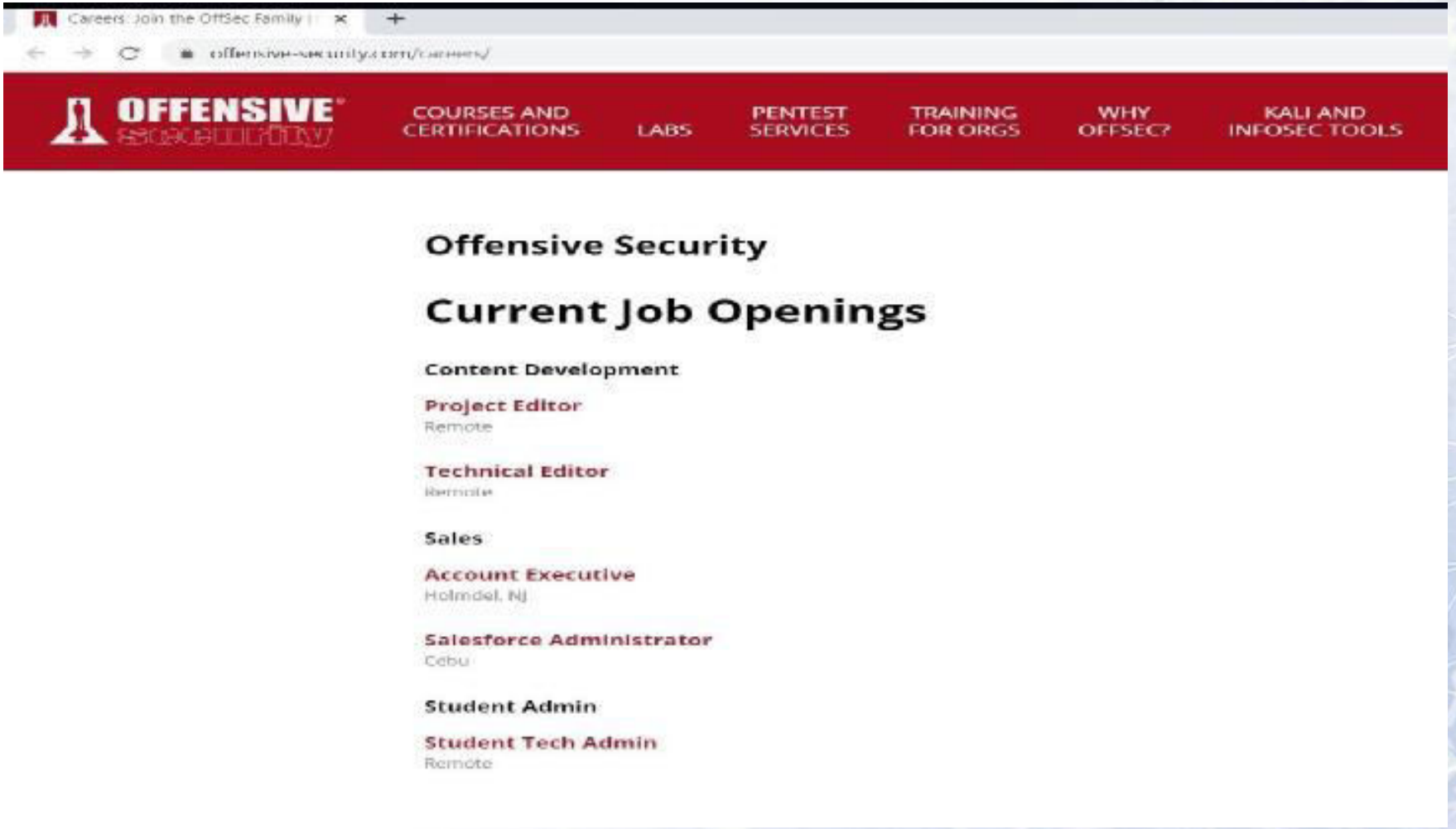


Job Sectors

- Internships
- Education
  - Teaching / Training
  - Universities / Certs
- CERTs
- Private Organizations
- Government Institutes
- Financial Sector
- Law Enforcement & Military
- Freelancing
- Independent Consultant

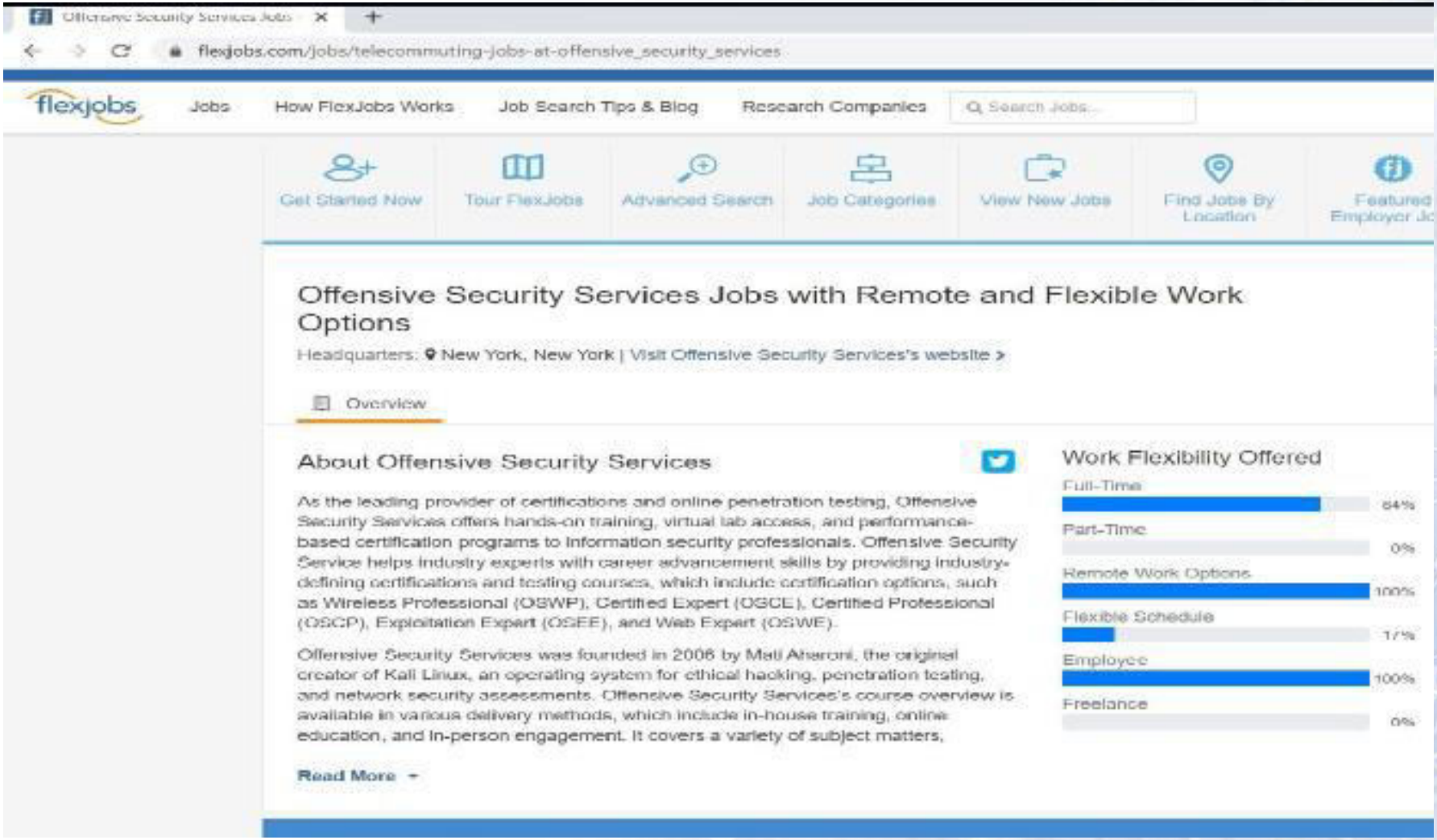
Offensive Security – Job

- https://www.offensive-security.com/careers



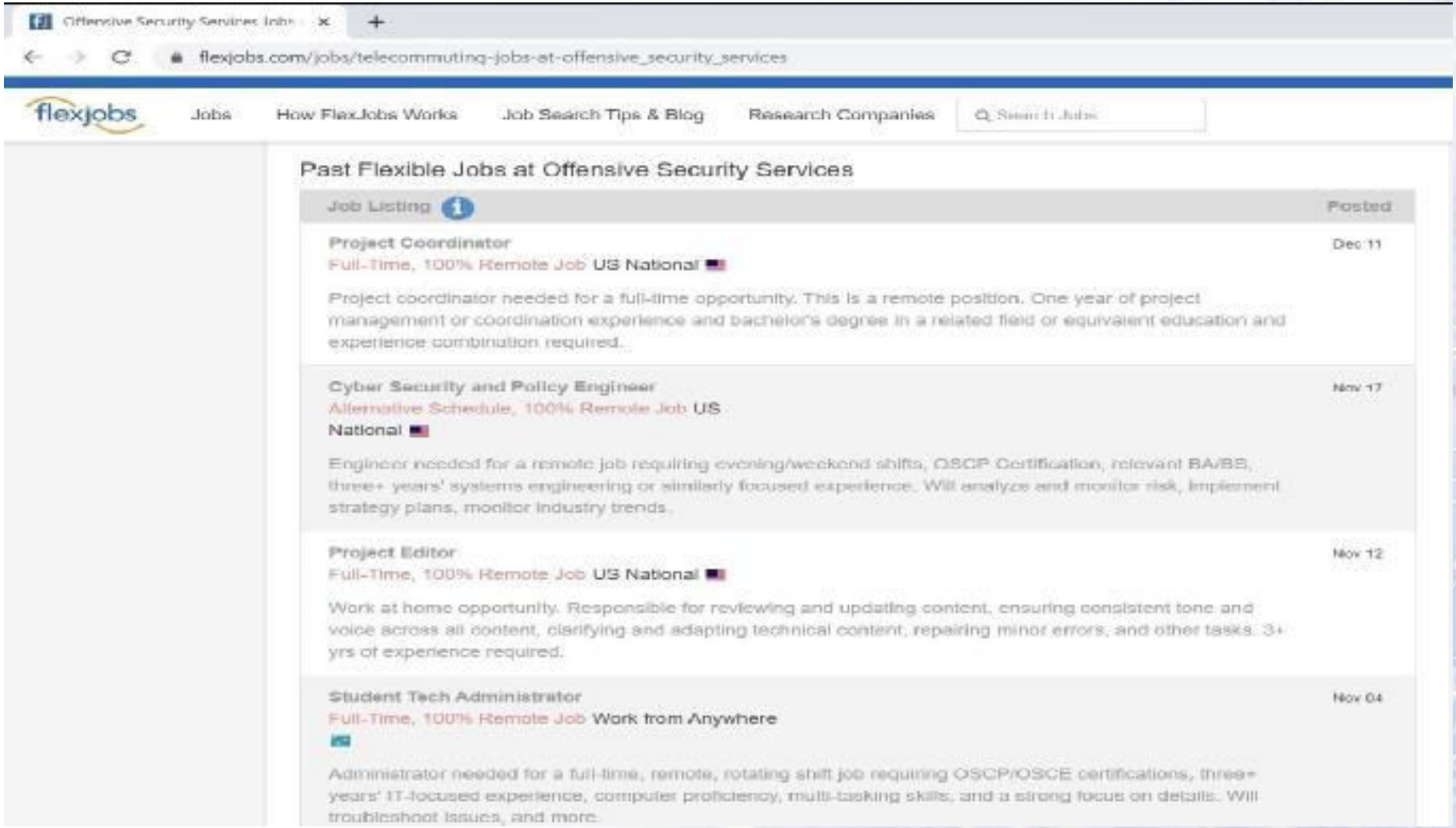
Offensive Security – Job

- https://www.flexjobs.com/jobs/telecommuting-jobs-at-offensive_security_services



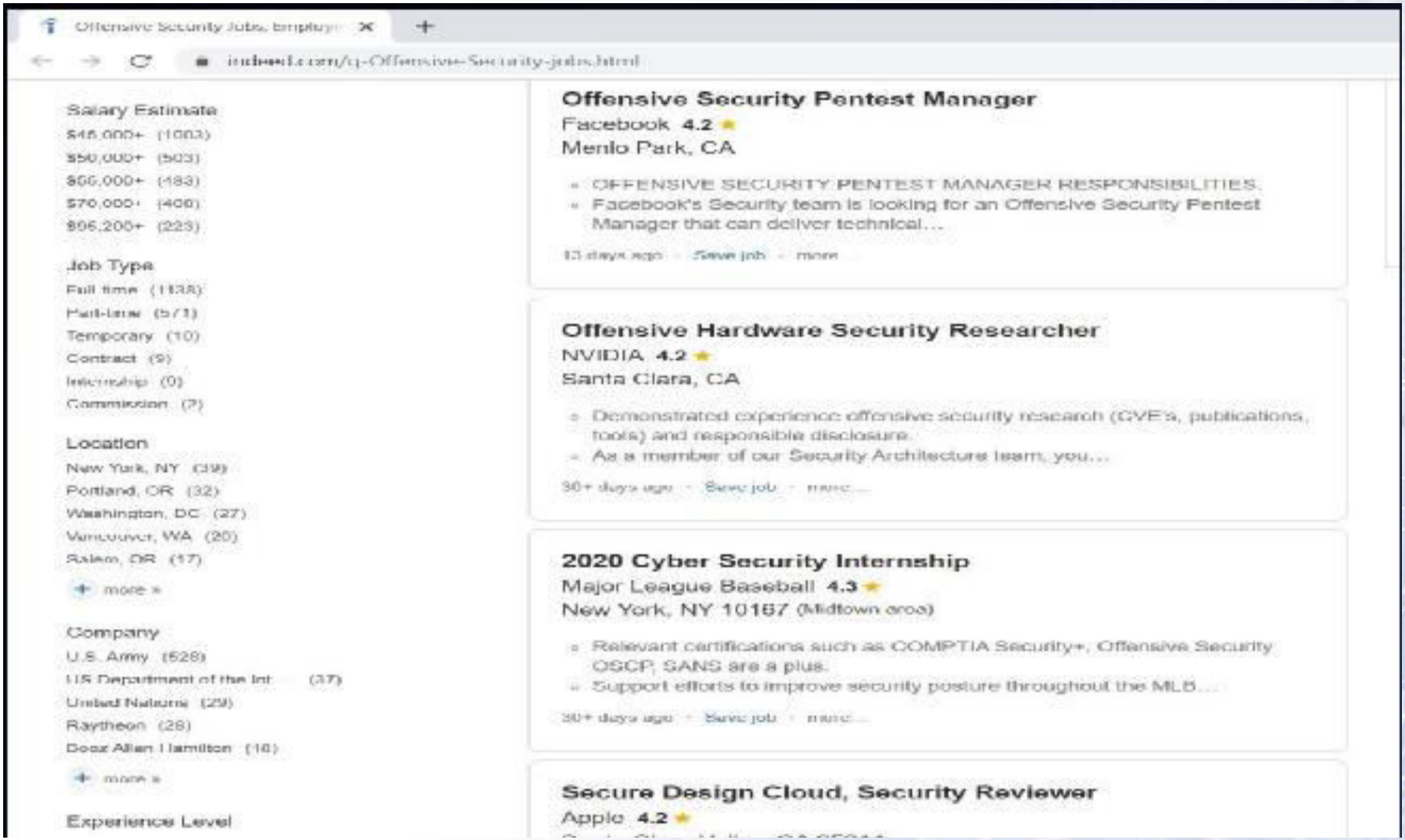
Offensive Security – Job

- https://www.flexjobs.com/jobs/telecommuting-jobs-at-offensive_security_services



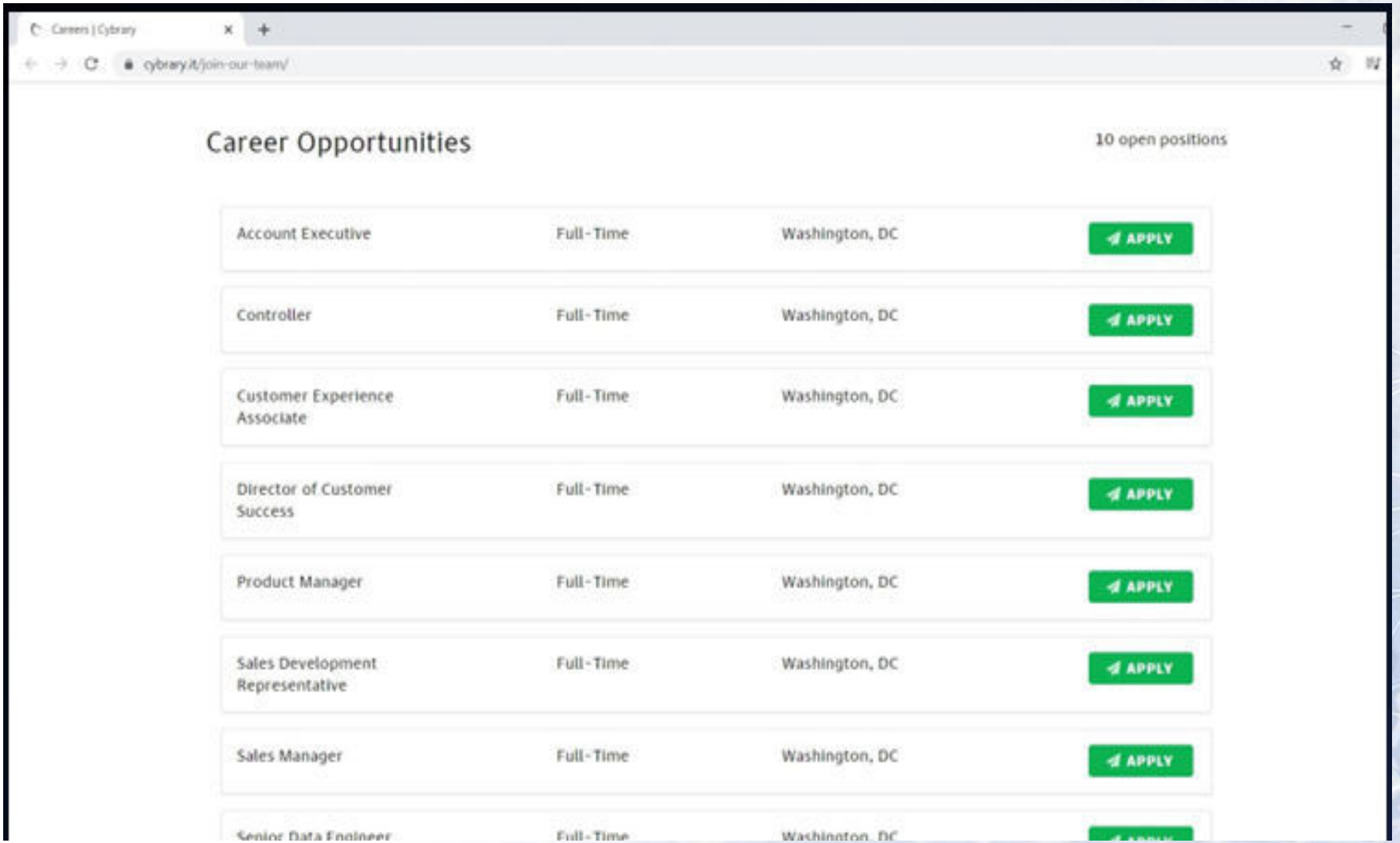
Offensive Security – Job

- [Jobs https://www.indeed.com/q-Offensive-Security-jobs.html](https://www.indeed.com/q-Offensive-Security-jobs.html)



CYBRARY Career Opportunities

- https://www.cybrary.it/join-our-team/



CYBRARY Career Opportunities

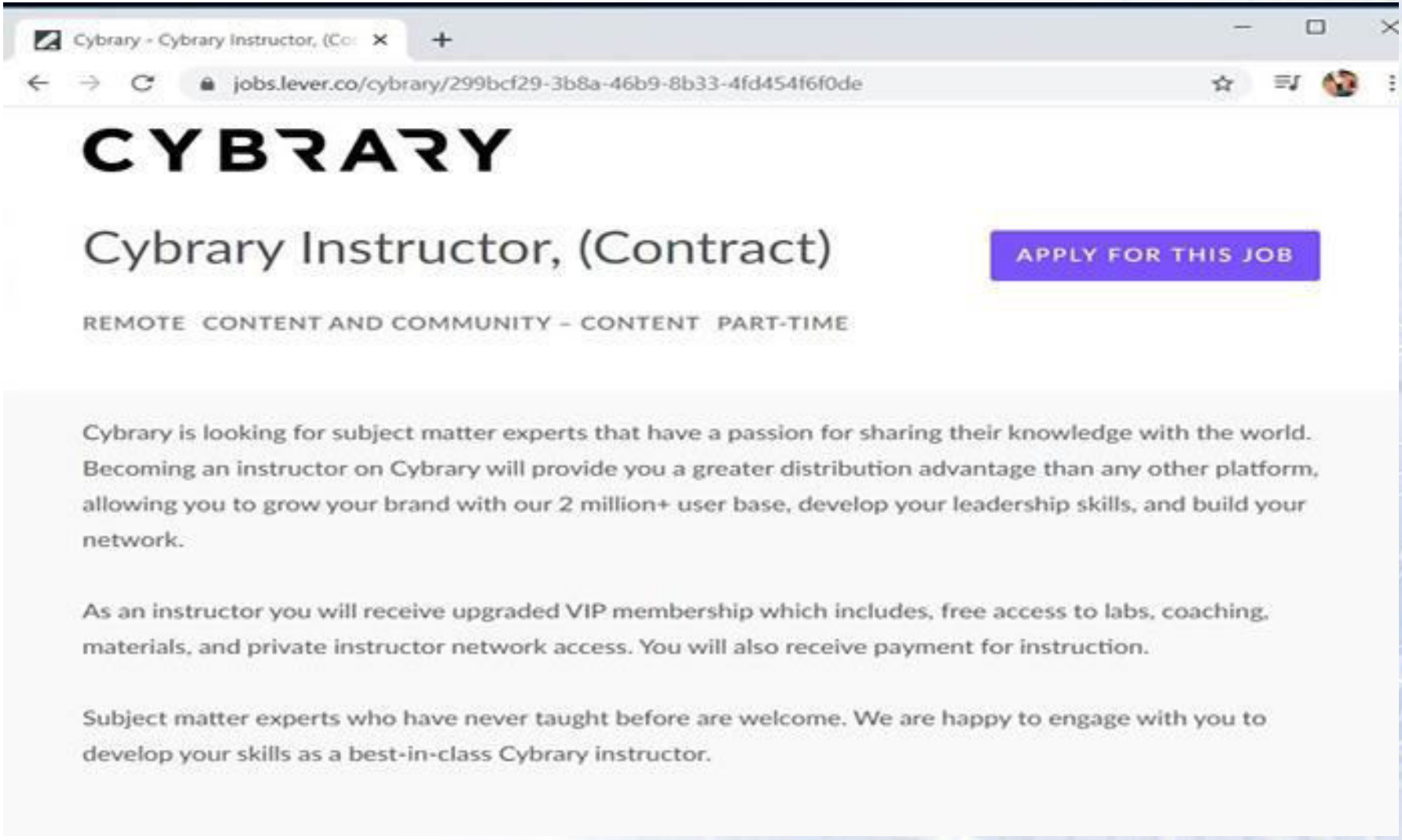
- https://www.cybrary.it/contribute/

CYBRARY Career Opportunities

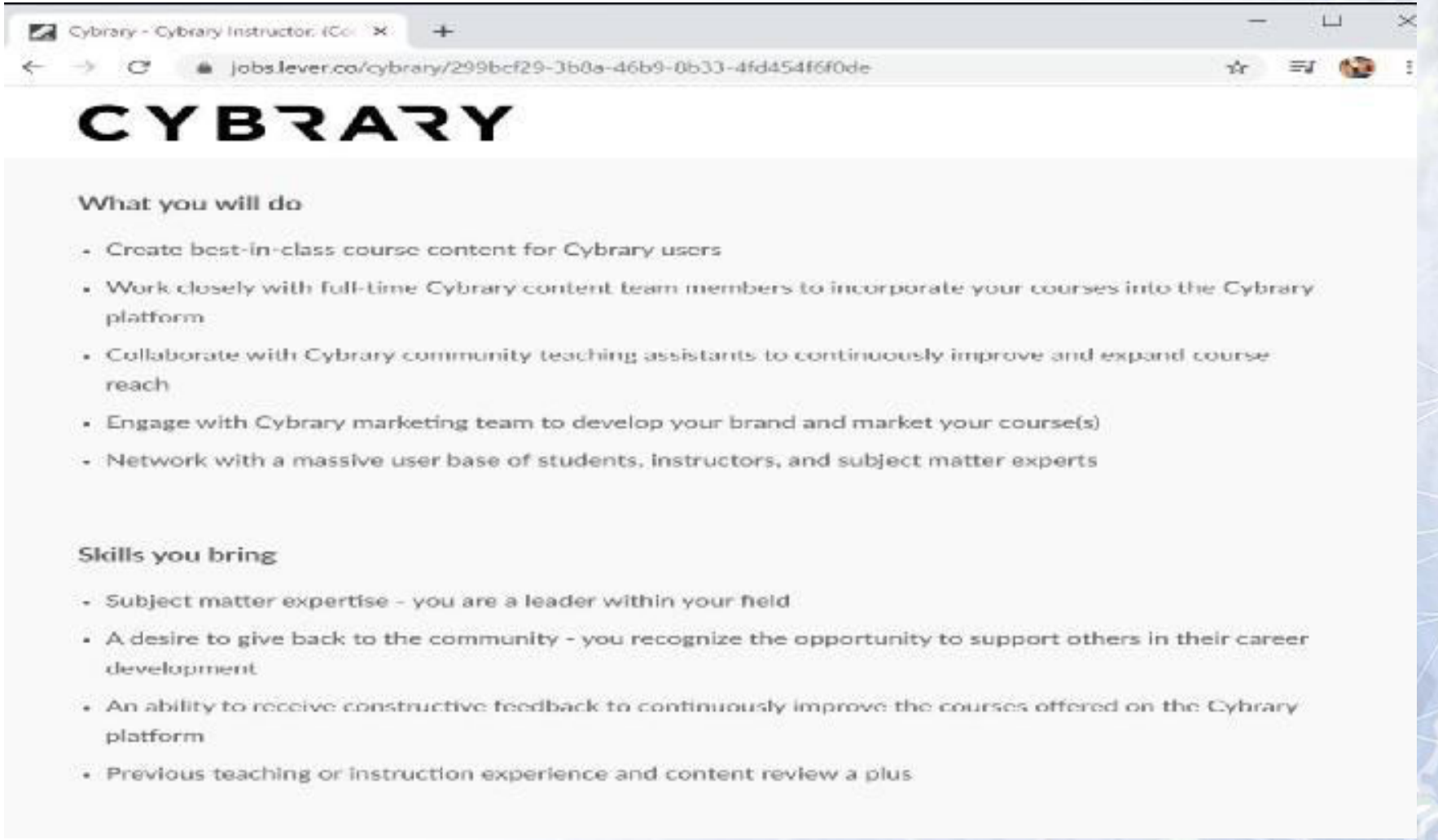
- https://www.cybrary.it/contribute/

CYBRARY Instructor

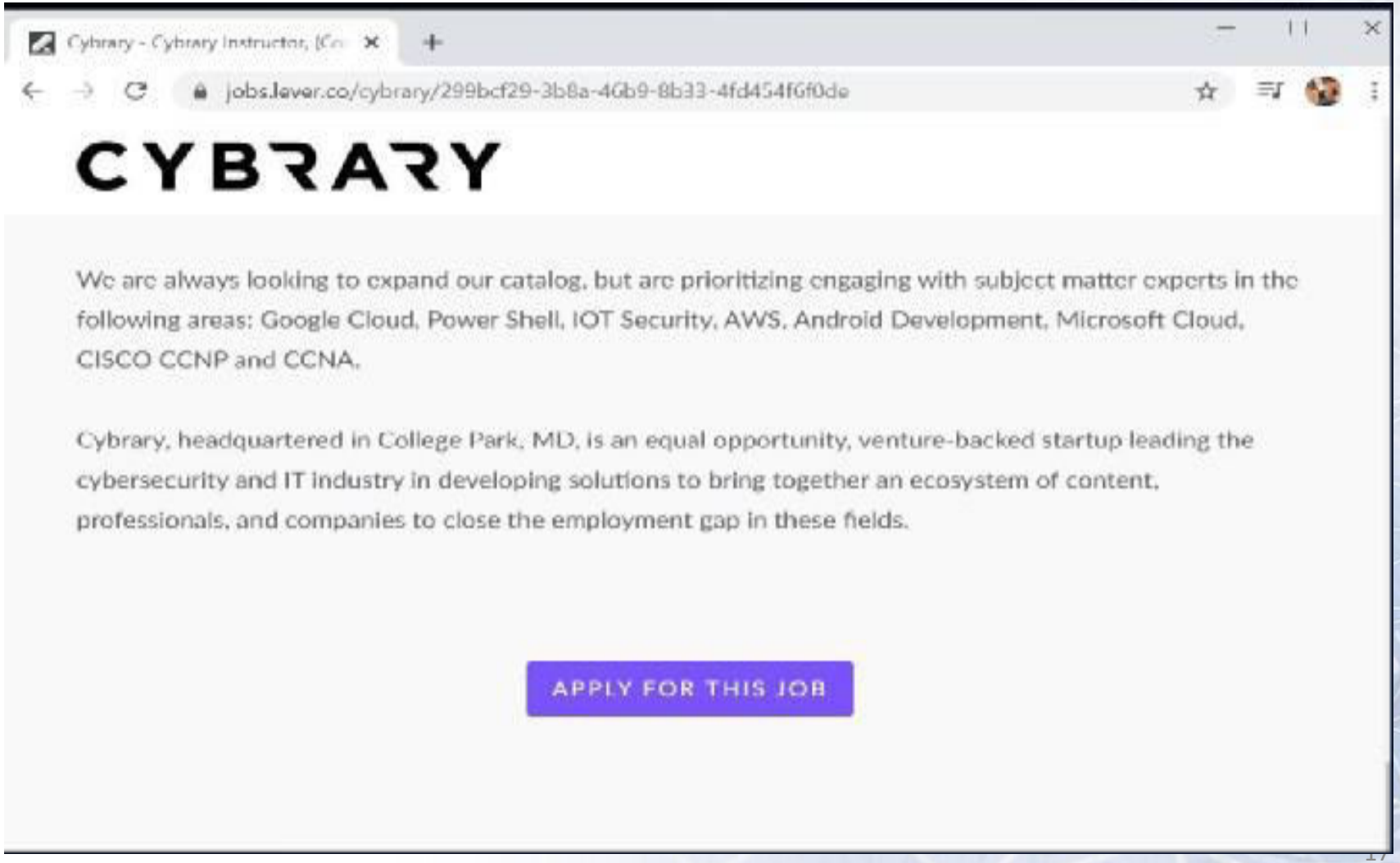
- https://jobs.lever.co/cybrary/299bcf29-3b8a-46b9-8b33-4fd454f6f0de



CYBRARY Instructor

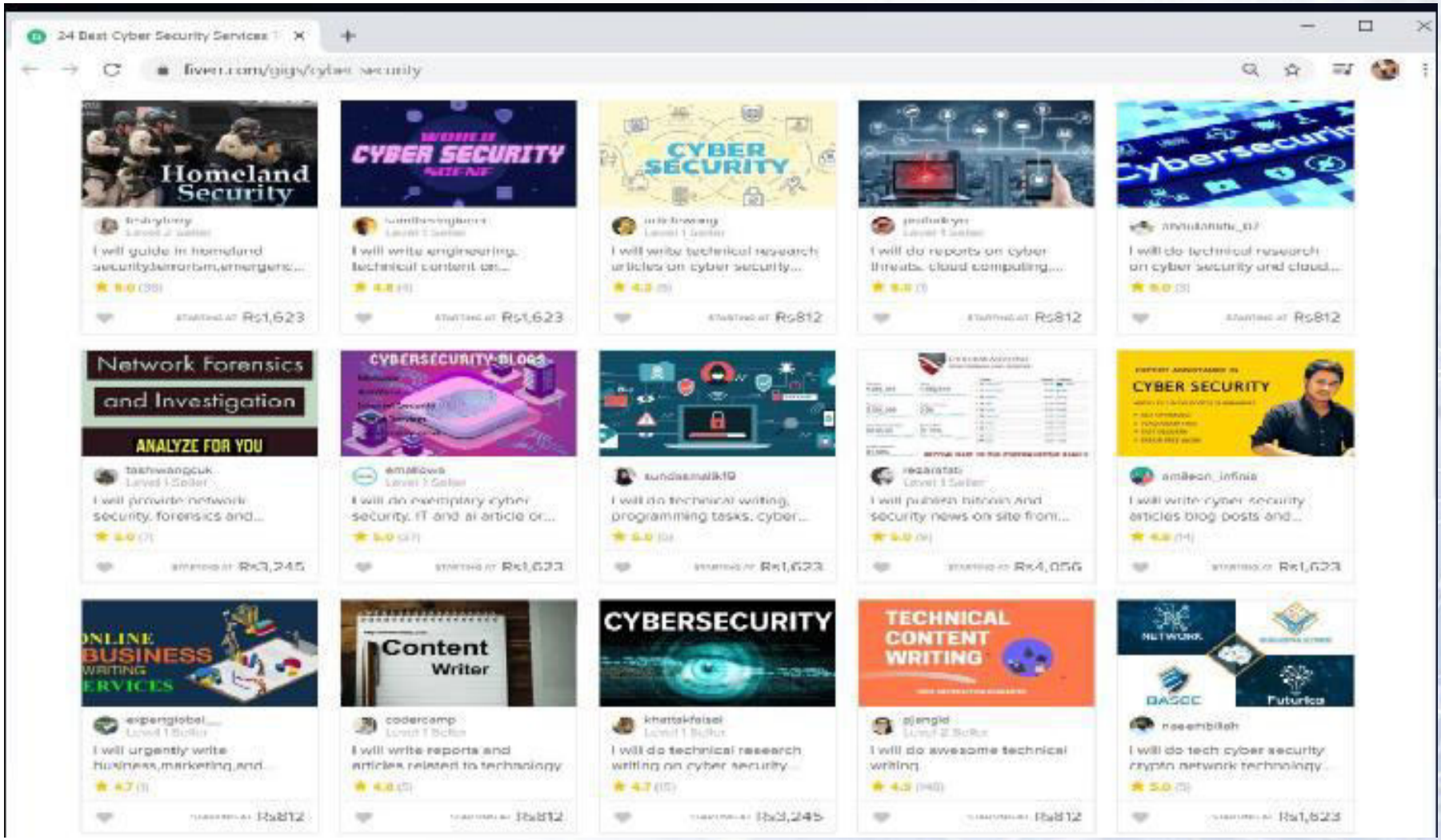


CYBRARY Instructor



Fiverr Security Projects

- https://www.fiverr.com/gigs/cyber-security



Online Job Application / Search Sources

- Job Websites / Online Career Portals
- Social Media
  - Facebook
  - LinkedIn
- Company Websites
- InfoSec Organization's career portals

Other Ways

- Search for company contact, submit CV's, turn up in-person.

- Word of mouth
  - Increase your social circle

- Attend InfoSec/IT related meetups, seminars, workshops & conferences

Jobs

Where the cybersecurity jobs are

Metros with the most job postings for cybersecurity roles

Rank	Metro area	Rank	Metro area
1	Washington, DC	6	Atlanta, GA
2	New York, NY	7	Boston, MA
3	Dallas-Fort Worth, TX	8	San Francisco, CA
4	Baltimore, MD	9	Los Angeles, CA
5	Chicago, IL	10	San Jose, CA

Source: Indeed

indeed

Week 1 Topic 8

Pre-requisites

Pre-requisites / Previous Knowledge:

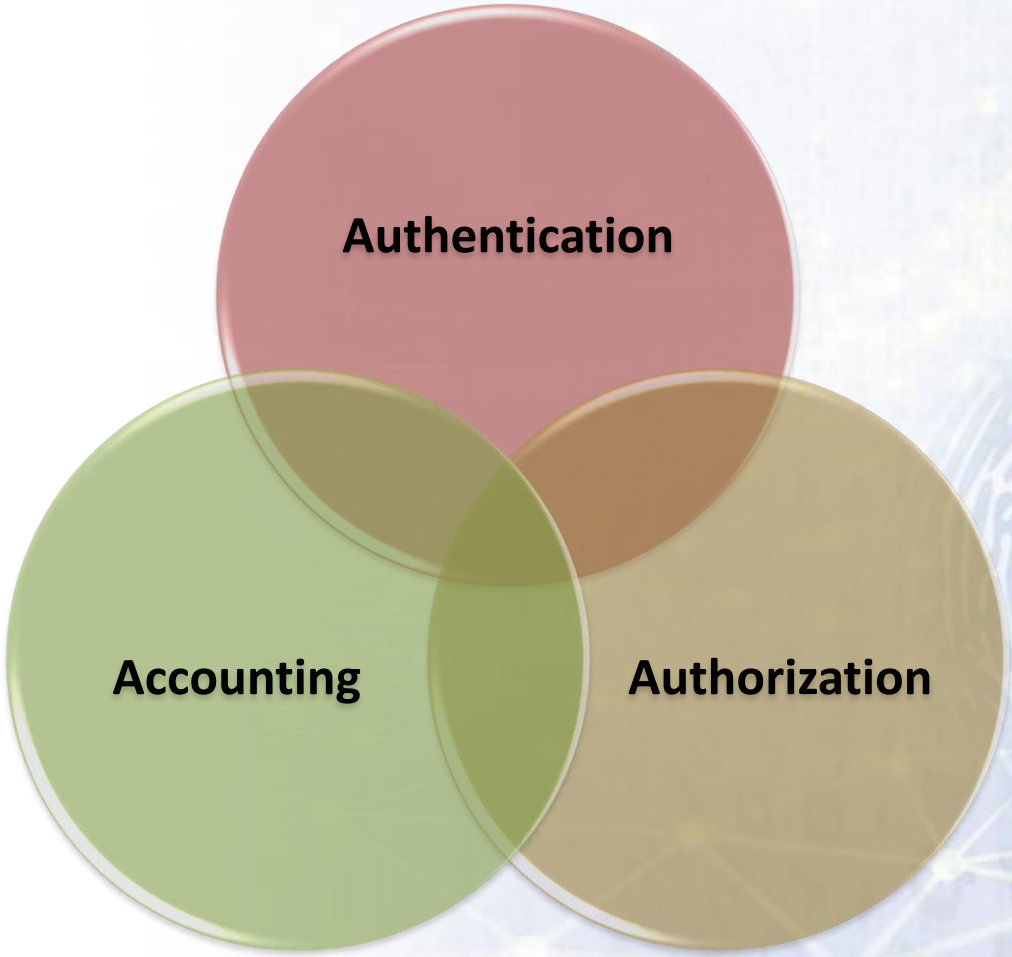
- Hardware
- PC, Server, DC
- Network Devices: Router, Switch, Load Balancer
- Operating Systems
- Microsoft Windows, Apple Mac, Unix, Linux
- Networking
- OSI, TCP/IP, Ports, Protocols, Devices
- Virtualization / Cloud Computing
- Programming / Scripting

Week No. 2

User Authentication and Access Control

Week 2 Topic 1

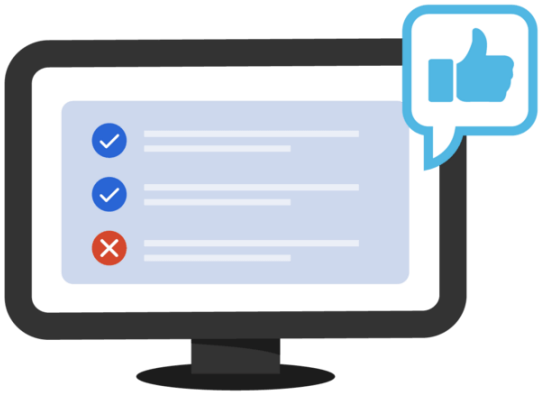
Authentication, Authorization, and Accounting (AAA)



Authentication

Confirms users
are who they say they are.

Authorization



Gives users permission
to access a resource.

Accounting

Measures the resources a user
consumes during access

Authentication, **Authorization, and Accounting** (**AAA**)

AAA is a term referred to the framework for

- Intelligently controlling access to the systems and resources
- Enforcing polices
- Auditing usage…

Source: https://www.okta.com/identity-101/authentication-vs-authorization/

Illustration – Physical World

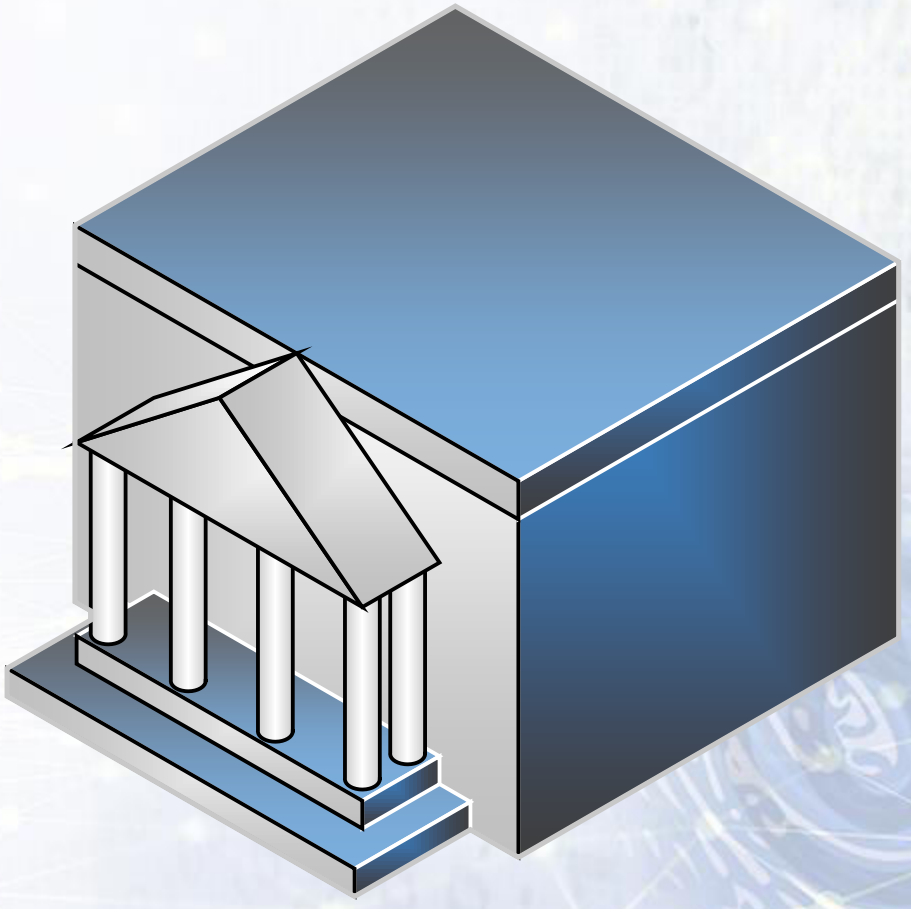
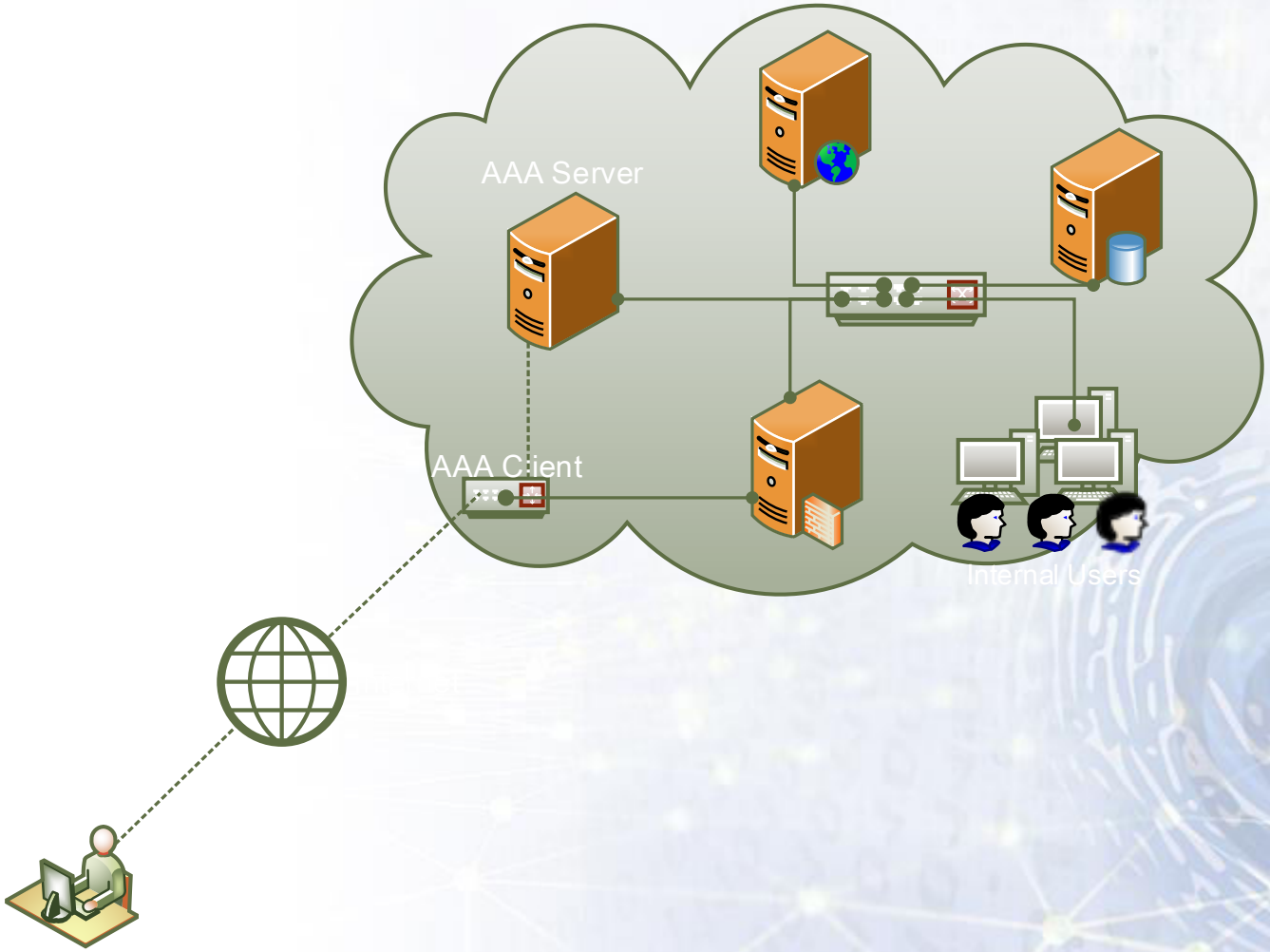


Illustration – Cyber World



Week 2 Topic 2

AAA vs. IAM

AAA

- AAA (Authentication, Authorization, and Accounting) is a general term that refers to a set of security processes that control access to computer resources.
- AAA servers are primarily used for network infrastructure.

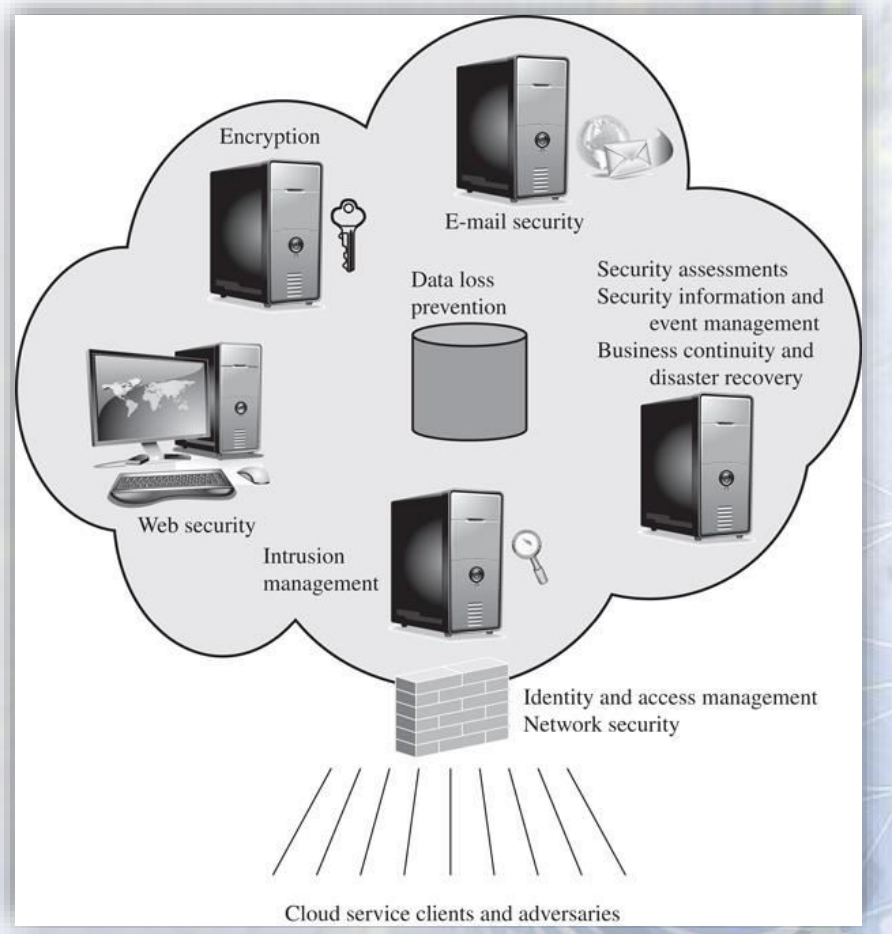
IAM

- IAM (Identity and Access Management) is a specific set of technologies and policies used to manage access to an organization's IT resources.
- IAM systems are used for managing access to enterprise applications and data.

Identity and Access Management (IAM)

- To ensure that the right people and things have:
  - ☞ the right access to
  - ☞ the right resources
  - ☞ at the right time.

- IAM include establishing trusted user profile and policy information, using it to control access within the cloud service, and doing this in an auditable way.



Elements of the Cloud Security as a Service

Identity Theft

- Consumers lost $56 billion to identity fraud in America during 2021 [CNBC]
- The COVID-19 pandemic has created more points of vulnerability
- Identity theft scams - criminals interact directly with consumers to steal their information through methods such as robocalls and phishing emails.
- Three common red flags to watch
    - **Unsolicited calls or emails**
    - **High-pressure tactics**
    - **Outdated passwords**

Source https://www.cnbc.com/2021/03/23/consumers-lost-56-billion-dollars-to-identity-fraud-last-year.html

Week 2 Topic 3

Means of User Authentication

Means Of User Authentication

Recap

Authentication

Confirms users
are who they say they are.

Authorization

Gives users permission
to access a resource.

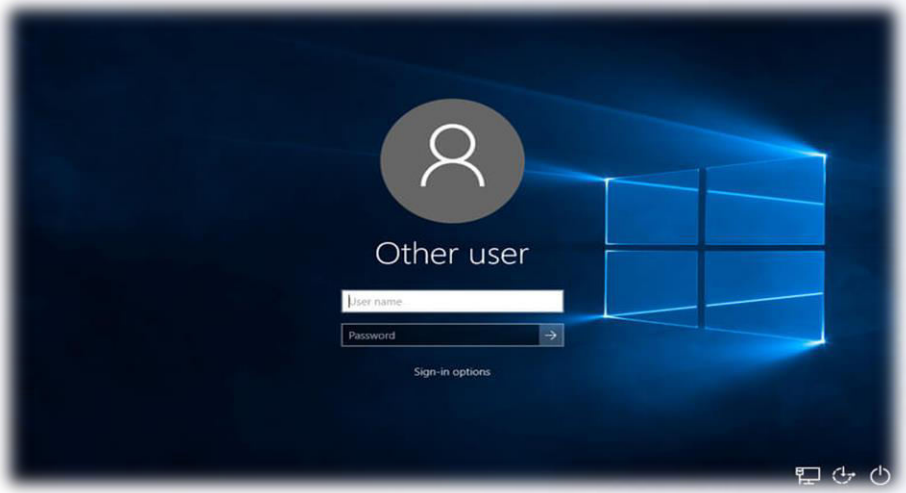
Accounting

Measures the resources a user
consumes during access

4 Means of User Authenticating

- 1/4 Something the individual knows
- 2/4 Something the individual possesses (token)
- 3/4 Something the individual is (static biometrics)
- 4/4 Something the individual does (dynamic biometrics

1/4 Something the individual knows



Examples includes:

- password,
- a personal identification number (PIN),
- answers to a prearranged set of questions.

2/4 Something the individual possesses (token

Examples include:

- electronic keycards,
- smart cards,
- physical keys.

This type of authenticator is referred to as a *token*.

3/4 Something the individual is(static biometrics)

Examples include:

- recognition by fingerprint
- retina,
- and face

4/4 Something the individual does (dynamic biometrics

Examples include:

- recognition by voice pattern,
- handwriting characteristics,
- typing rhythm

Summary

The four means of authenticating user identity are based on:

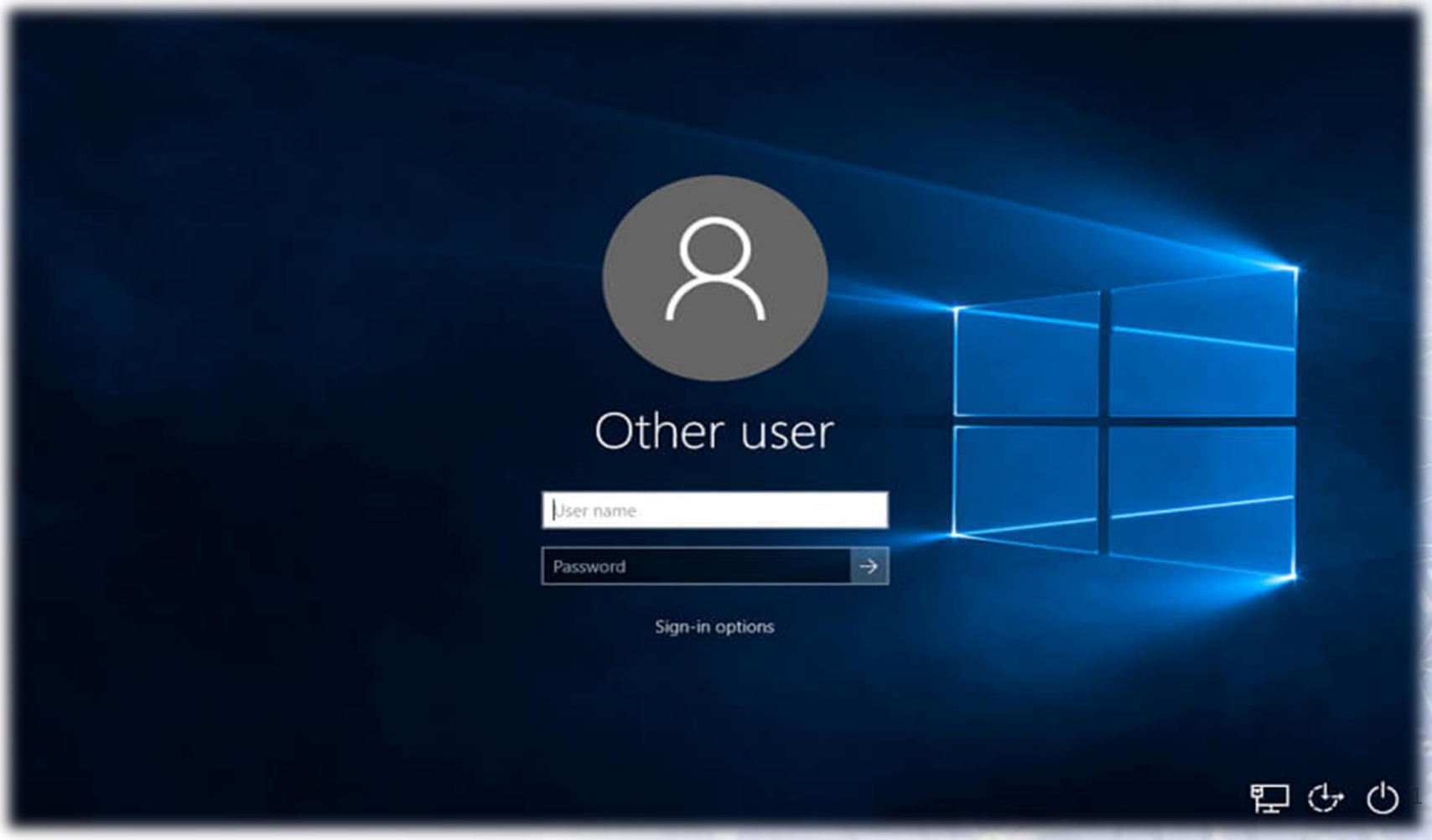
Something the individual knows	Something the individual possesses (token)	Something the individual is (static biometrics)	Something the individual does (dynamic biometrics)
Password, PIN, answers to prearranged questions	Smartcard, electronic keycard, physical key	Fingerprint, retina, face	Voice pattern, handwriting, typing rhythm

Prepared by DL...

May You All Stay Success in your Whole Life, Ameen! Summ Ameen... Just Remember us in your Deep Prayers. JazakAllah...

Week 2 Topic 4

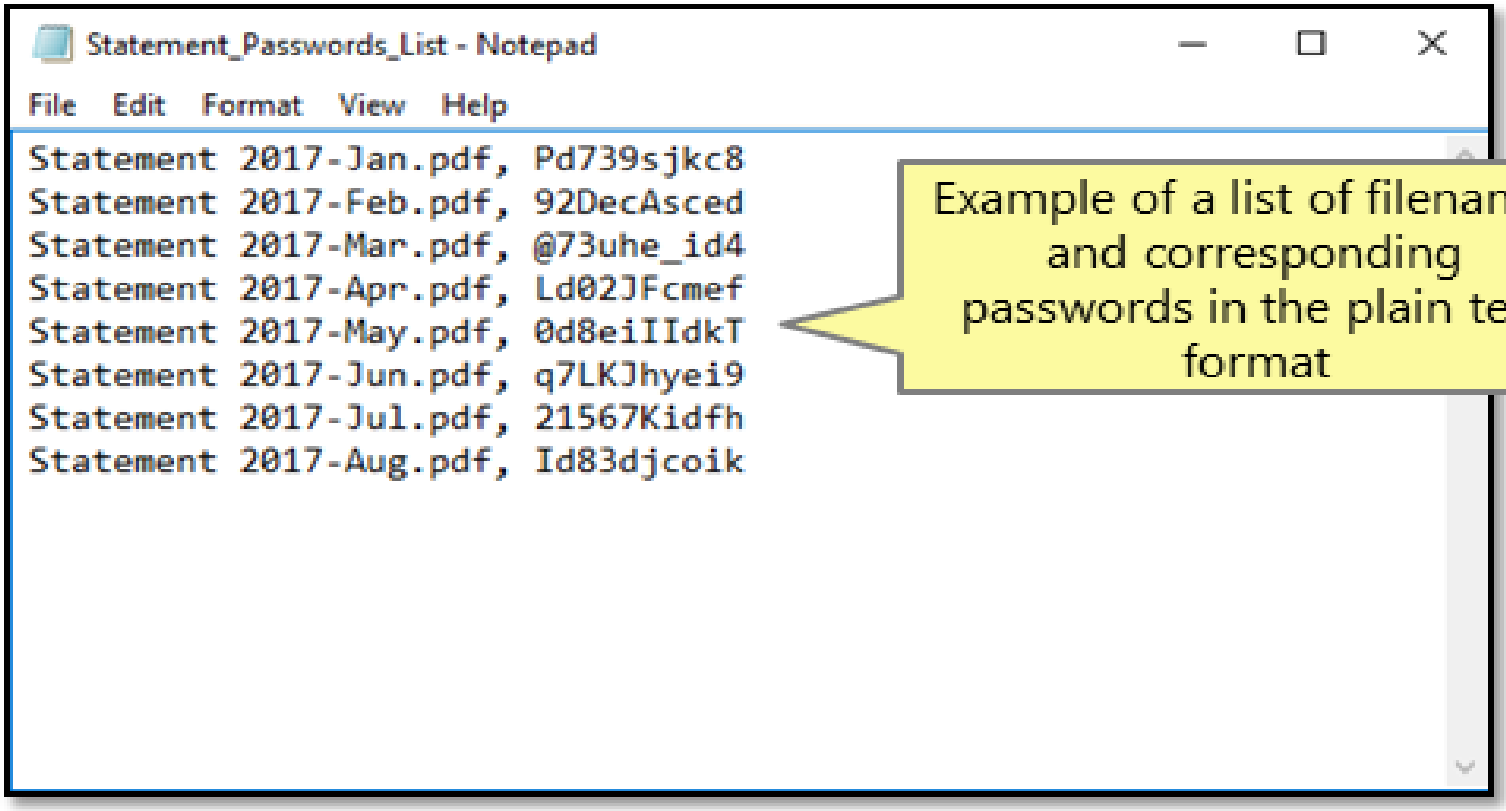
PASSWORD-BASED AUTHENTICATION



Password-Based Authentication

- Widely used line of defense against intruders
    - User provides name/login and password
    - System compares password with the one stored for that specified login
- The user ID:
    - Determines that the user is authorized to access the system
    - Determines the user's privileges
    - Is used in discretionary access control

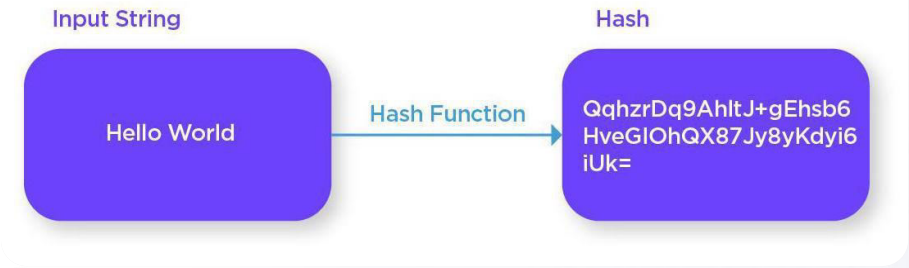
PASSWORD STORAGE (Plain Text)



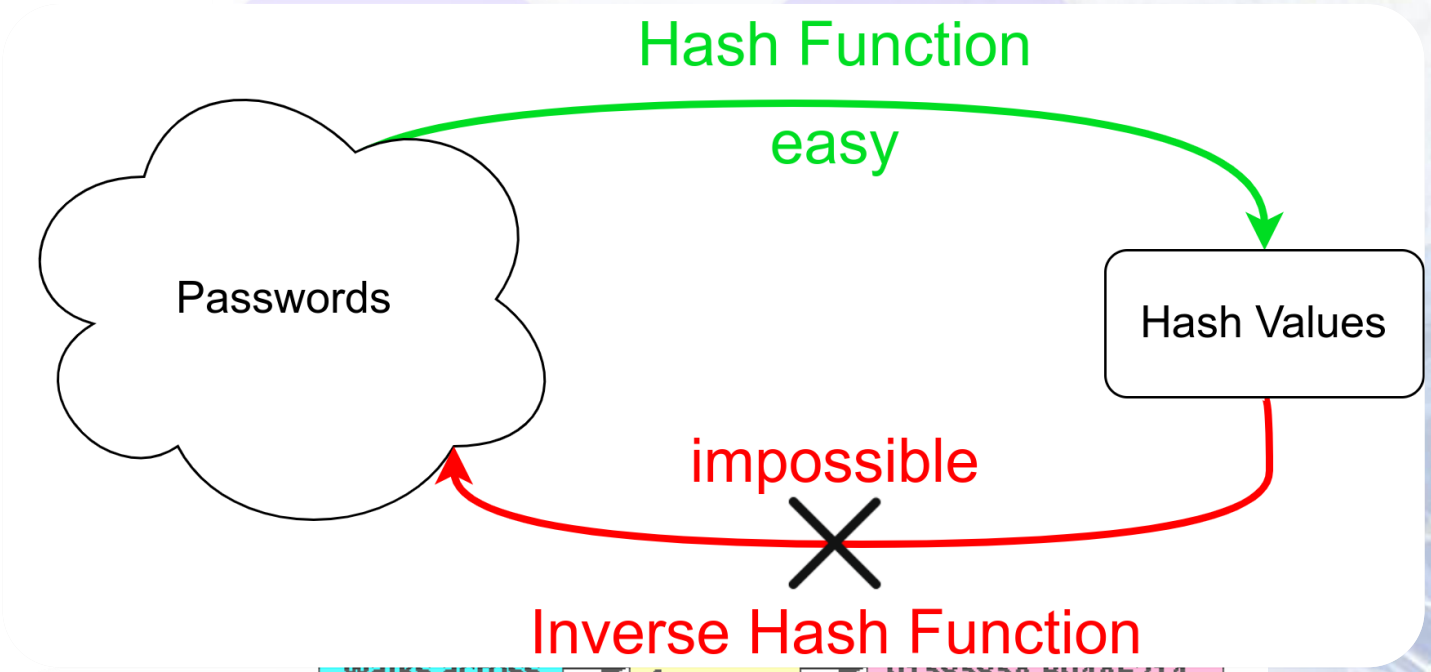
Storing passwords in plaintext dangerous

- because it puts both the system and users at risk.

PASSWORD STORAGE (Hash Function)



Demo

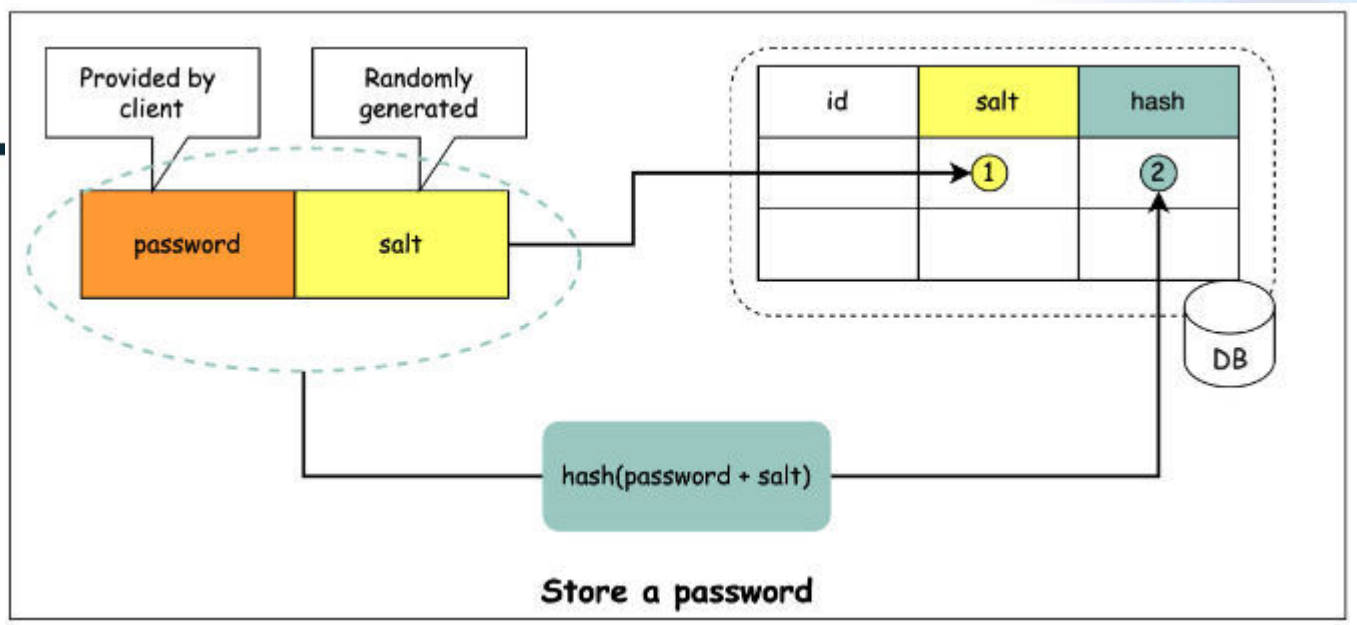


SIGN UP

Email

Password

SIGN UP



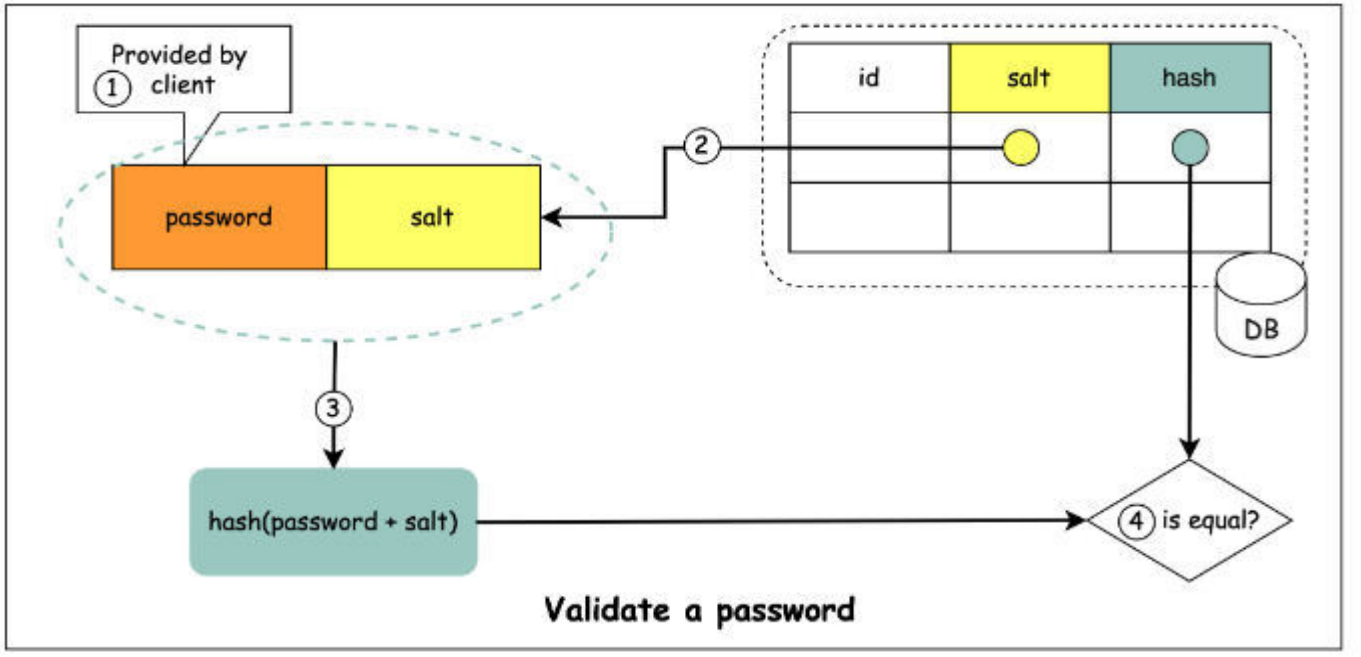
Sign up

Login

Username *

Password *

Login



Week 2 Topic 5

Password Vulnerabilities

Password Hacking and Cracking

- Password hacking and password cracking are terms that are often used interchangeably, but there is a subtle difference between the two.

- Password Hacking:

  - refers to gaining unauthorized access to a system
  - Usually, original password is changed

- Password Cracking:

  - to the process of attempting to recover a password
  - Usually, original password is NOT changed

Password Vulnerabilities

Exploiting user mistakes	• Users more likely use default passwords, write or share the passwords through social engineering tactics
Exploiting multiple password use	• Different network devices share the same or a similar password for a given user
Electronic monitoring	• Password communicated across a network in plaintext format
Brute force Attack	• Try all possible passwords
Offline dictionary attack	• Compares the password hashes against hashes of commonly used passwords
Rainbow table attacks	• Pre-compute tables of hash values of ALL passwords*

Offline Dictionary Attack

Dictionary of Commonly Used Passwords

Password	Password Hash
Jhon	Hkdjutye
Secret	Lfjaskebad
Bold	Fasf572dnas
2023	Adnskjf30
World	42n34nasd
…	…
…	…
Cooler	Af45xbc2js
…	…

Target User

UID	Password Hash
Admin	af45xbc2js

Rainbow Table Attack

Hash Values of ALL Passwords (of Length 04 in this example)

Password	Password Hash
Aaaa	Kfj8673hdb
Aaab	Hfge7w95j
Aaac	Jfhty673
Aaad	Hdg486hd
Aaae	Hdri9274
…	…
…	…
Cool	Rh75jd3h5
…	…

Target User

UID	Password Hash
Admin	Rh75jd3h5

Week 2 Topic 6

Securing Passwords

Modern Approaches

- Complex password policy
  - Forcing users to pick stronger passwords

- However, password-cracking techniques have also improved:
  - The processing capacity available for password cracking has increased dramatically
  - The use of sophisticated algorithms to generate potential passwords
  - Studying examples and structures of actual passwords in use

Password File Access Control

One way to block offline guessing attacks by denying access to encrypted passwords (password hashes)

- Make available only to privileged users
- Shadow password file

Vulnerabilities

- Weakness in the OS that allows access to the file
- Accident with permissions making it readable
- Users with same password on other systems
- Access from backup media
- Sniff passwords in network traffic

Password Selection Strategies

User education

Users can be told the importance of using hard to guess passwords and can be provided with guidelines for selecting strong passwords

Computer generated passwords

Users have trouble remembering them

Reactive password checking

System periodically runs its own password cracker to find guessable passwords

Complex password policy

User is allowed to select their own password, however the system checks to see if the password is allowable, and if not, rejects it

Goal is to eliminate guessable passwords while allowing the user to select a password that is memorable

Week 2 Topic 7

Memory Cards and Smart Cards

Recall

The four means of authenticating user identity are based on:

Something the individual knows	Something the individual possesses (token)	Something the individual is (static biometrics)	Something the individual does (dynamic biometrics)
• Password, PIN, answers to prearranged questions	• Smartcard, electronic keycard, physical key	• Fingerprint, retina, face	• Voice pattern, handwriting, typing rhythm

Memory Cards

- Can store but do not process data
- The most common is the magnetic stripe card e.g. ATM
- Can include an internal electronic memory
- Can be used alone for physical access
    - Hotel room
    - ATM
- Provides significantly greater security when combined with a password or PIN
- Drawbacks of memory cards include:
    - Requires a special reader
    - Loss/theft of token/memory card
    - User dissatisfaction

Smart Tokens

- **Physical characteristics:**
  - Include an embedded microprocessor
  - A smart token may look like a bank card
  - Can look like calculators, keys, small portable objects
- **User interface:**
  - Manual interfaces include a keypad & display for human/token interaction
- **Electronic interface**
  - A smart card or other token requires an electronic interface to communicate with a compatible reader/writer
  - Contact and contactless interfaces
- **Authentication protocol:**
  - Classified into three categories:
    - Static
    - Dynamic password generator
    - Challenge-response

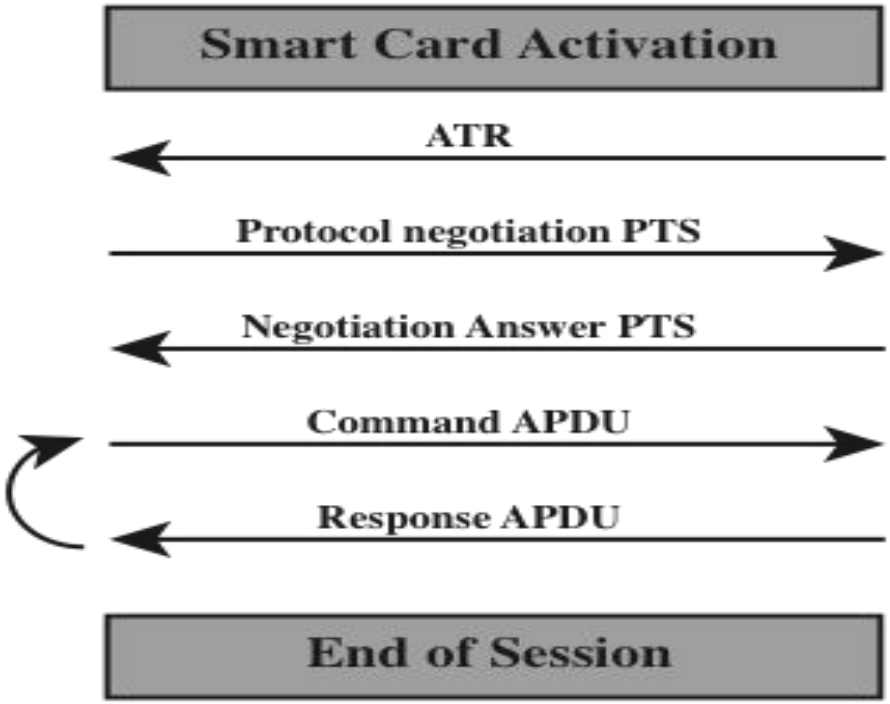
https://upload.wikimedia.org/wikipedia/commons/d/db/SecurityTokens.CryptoCard.agr.jpg

Smart Cards

- Most important category of smart token
  - Has the appearance of a credit card
  - Has an electronic interface
  - May use any of the smart token protocols
- **Contain:**
  - An entire microprocessor
    - Processor
    - Memory
    - I/O ports

- Typically include three types of memory:
  - Read-only memory (ROM)
    - Stores data that does not change during the card's life
  - Electrically erasable programmable ROM (EEPROM)
    - Holds application data and programs
  - Random access memory (RAM)
    - Holds temporary data generated when applications are executed

Interaction Between Reader and Smart Card



APDU = application protocol data unit
ATR = Answer to reset
PTS = Protocol type selection

Week 2 Topic 8

Biometric Authentication

Recall

The four means of authenticating user identity are based on:

Something the individual knows

- Password, PIN, answers to prearranged questions

Something the individual possesses (token)

- Smartcard, electronic keycard, physical key

Something the individual is (static biometrics)

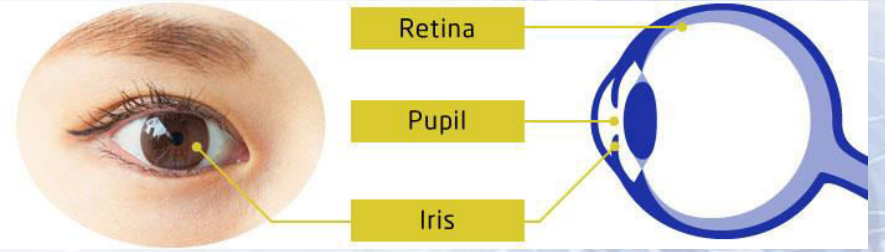
- Fingerprint, retina, face

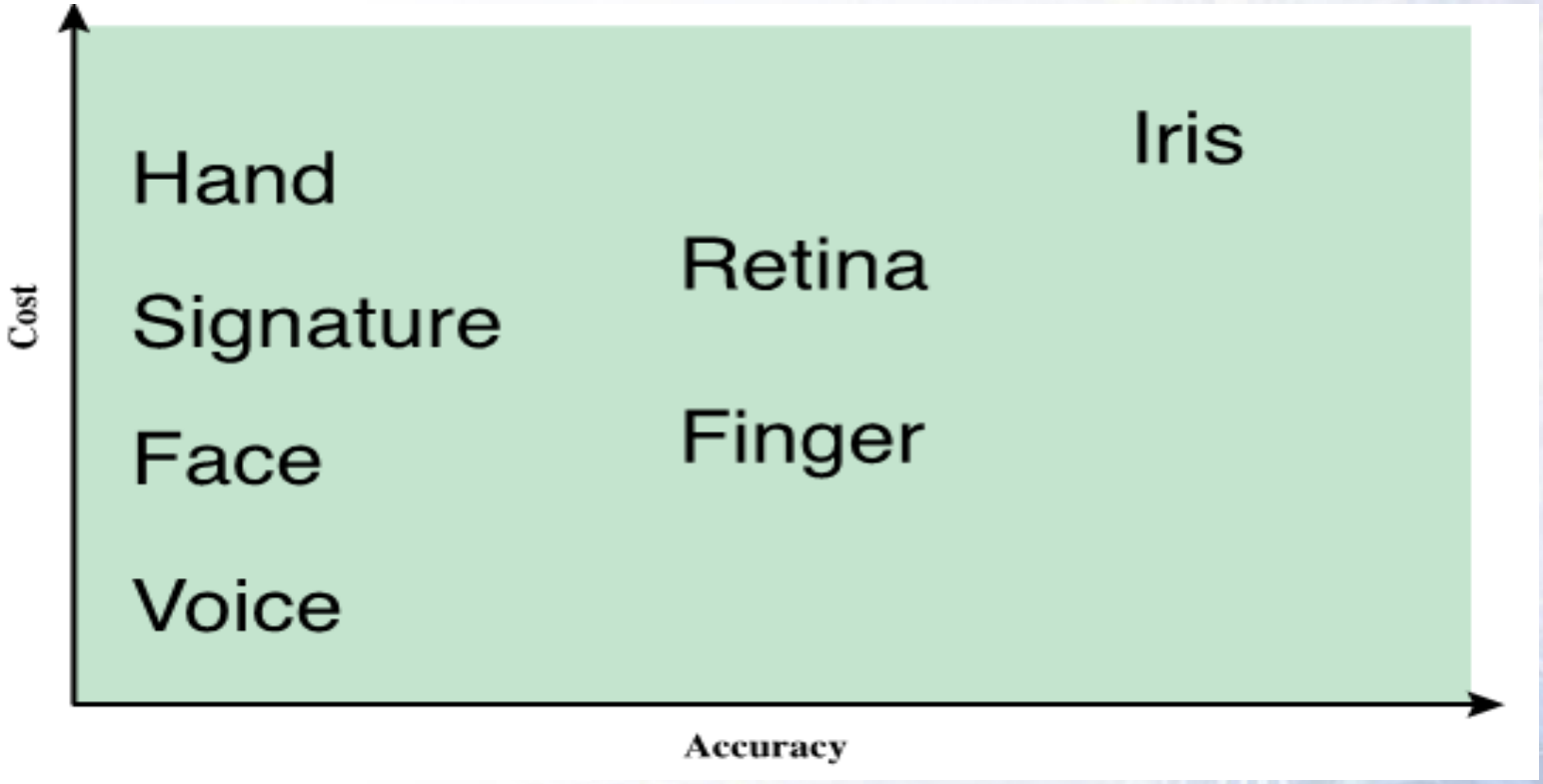
Something the individual does (dynamic biometrics)

- Voice pattern, handwriting, typing rhythm

Biometric Authentication

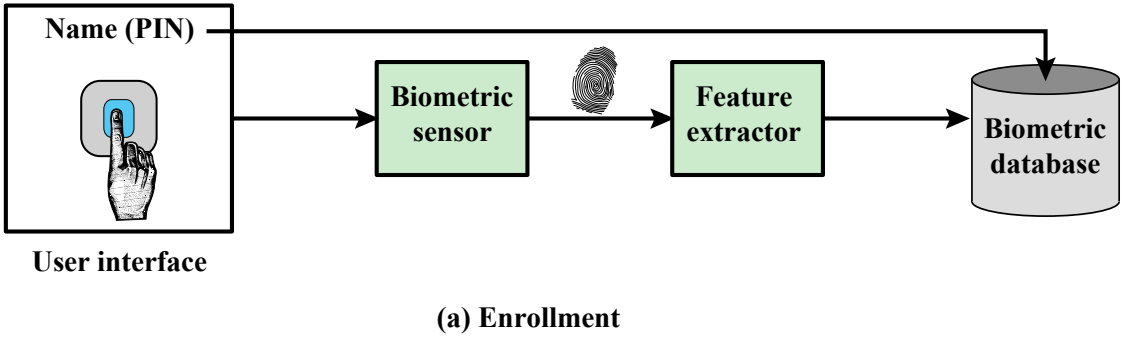
- Attempts to authenticate an individual based on unique physical characteristics
- Based on pattern recognition
- This is technically complex and expensive when compared to passwords and tokens
- Physical characteristics used include:
  - Facial characteristics
  - Fingerprints
  - Hand geometry
  - Retinal pattern
  - Iris
  - Signature
  - Voice



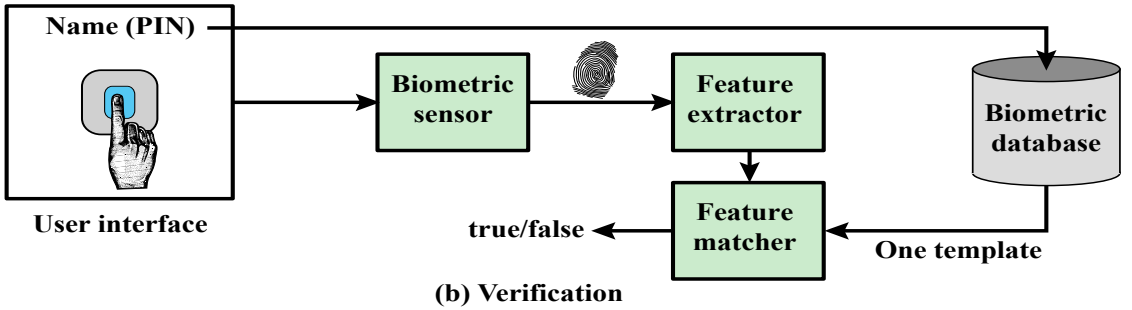


Explanation: Figure 3.8 gives a rough indication of the relative cost and accuracy of these biometric measures. The concept of accuracy does not apply to user authentication schemes using smart cards or passwords. For example, if a user enters a password, it either matches exactly the password expected for that user or not. In the case of biometric parameters, the system instead must determine how closely a presented biometric characteristic matches a stored characteristic. Before elaborating on the concept of biometric accuracy, we need to have a general idea of how biometric systems work.

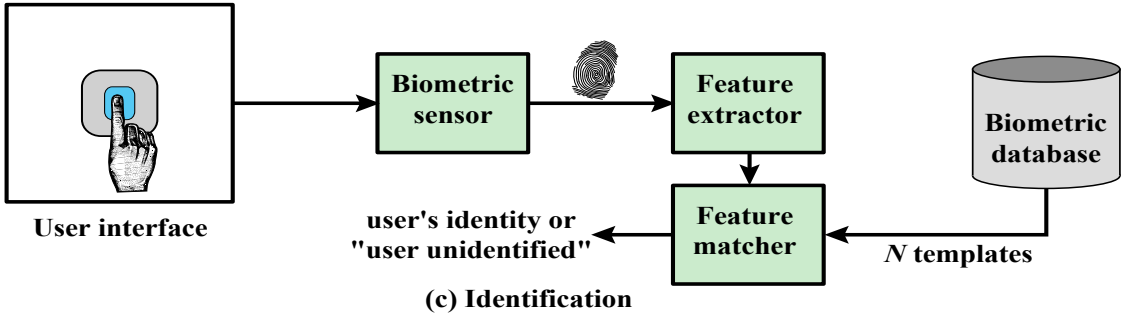
(a) Enrollment



(b) Verification



(c) Identification



Biometric Authentication

Pros

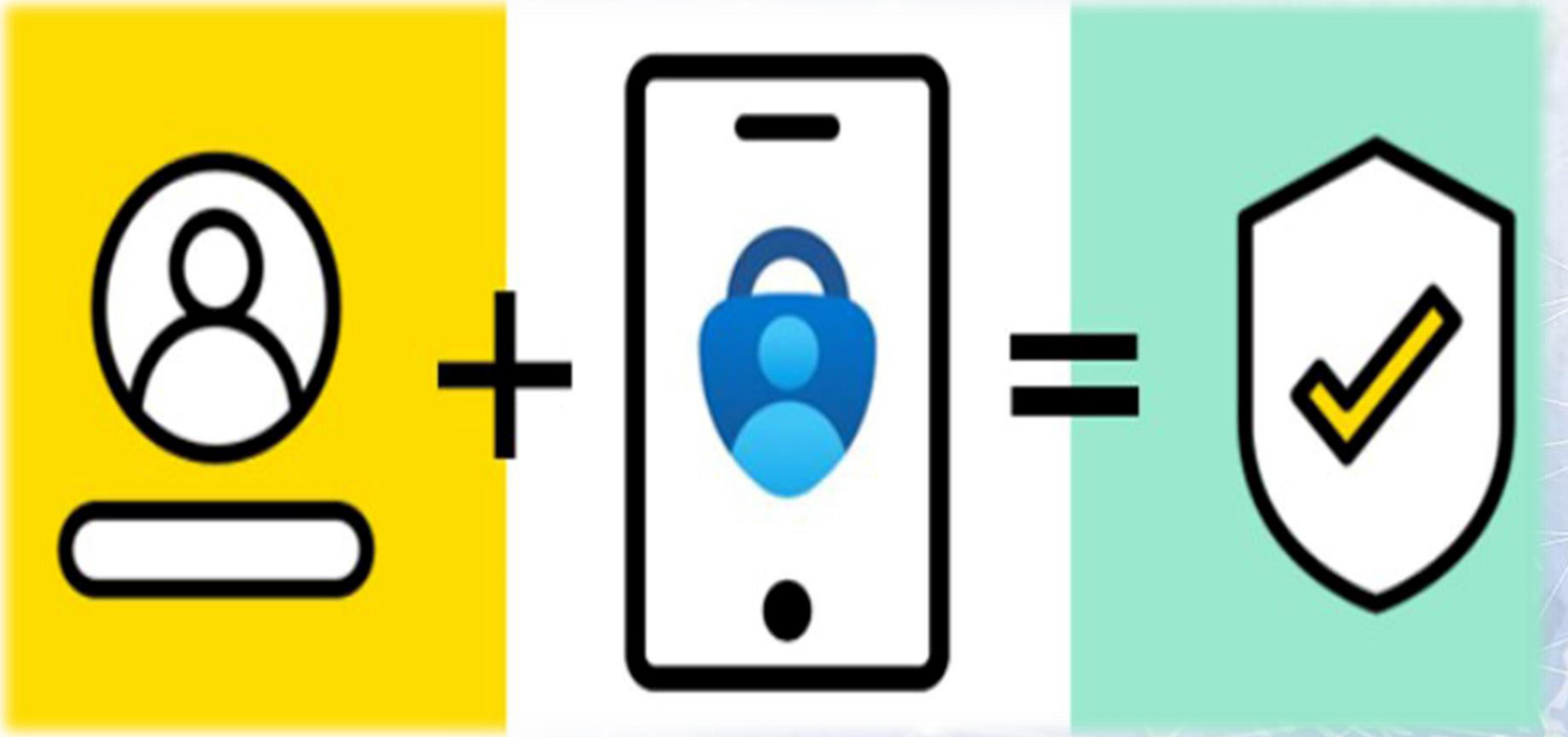
- Difficult to frog
- Convenience
- More secure and non- transferable*

Cons

- Costly
- Complex
- False Acceptance Rate (FAR) and False Rejection Rate (FRR)
- Rigid
- Attacker can fool the system

Week 2 Topic 9

Multi-factor Authentication



Recall

The four means of authenticating user identity are based on:

Something the individual knows

- Password, PIN, answers to prearranged questions

Something the individual possesses (token)

- Smartcard, electronic keycard, physical key

Something the individual is (static biometrics)

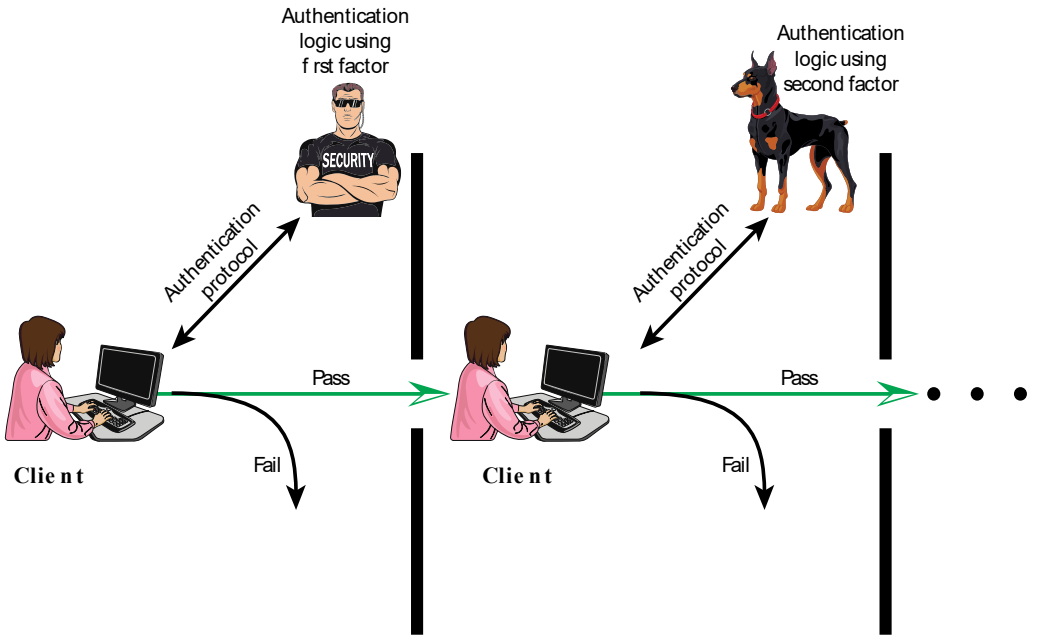
- Fingerprint, retina, face

Something the individual does (dynamic biometrics)

- Voice pattern, handwriting, typing rhythm

Multi-factor Authentication

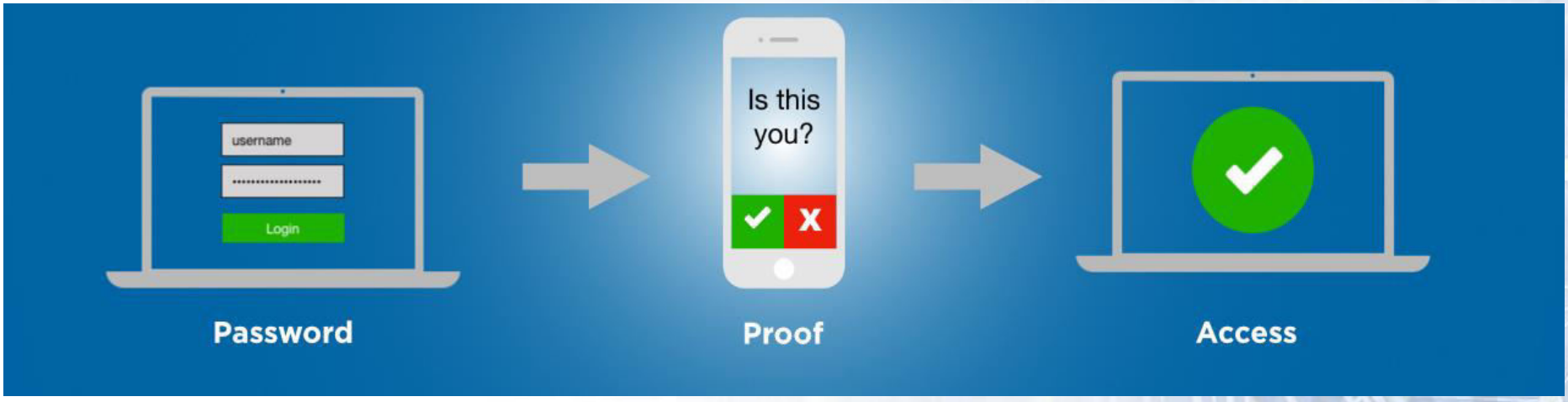
- 80% of hacking data breaches come from weak or compromised passwords, according to Verizon's 2019 Data Breach Investigations Report
- Multi-factor authentication (MFA) is the practice of requiring at least one additional form of user authentication—besides a password—when accessing a remote network .



Multifactor authentication refers to the use of more than one of the authentication means in preceding list (see Figure 3.2). The strength of authentication systems is largely determined by the number of factors incorporated by the system. Implementations that use two factors are considered to be stronger than those that use only 1 factor; systems that incorporate three factors are stronger than systems that only incorporate two of the factors, and so on.

Multi-factor Authentication

- Most Common Method for MFA
  - When logging in to a system remotely, the user first enters the regular password and is then prompted to enter the one-time password or passcode.
  - This is also commonly known as 2FA



Notes: Multifactor authentication refers to the use of more than one of the authentication means in the preceding list (see Figure 3.2).
The strength of authentication systems is largely determined by the number of factors incorporated by the system. Implementations that use two factors are considered to be stronger than those that use only one factor; systems that incorporate three factors are stronger than systems that only incorporate two of the factors, and so on.

SFA vs. 2FA vs. MFA

SFA

- Simplest form of authentication method.
- Matches one credential to verify a person online.
- The most popular example is password (credential) to a username.

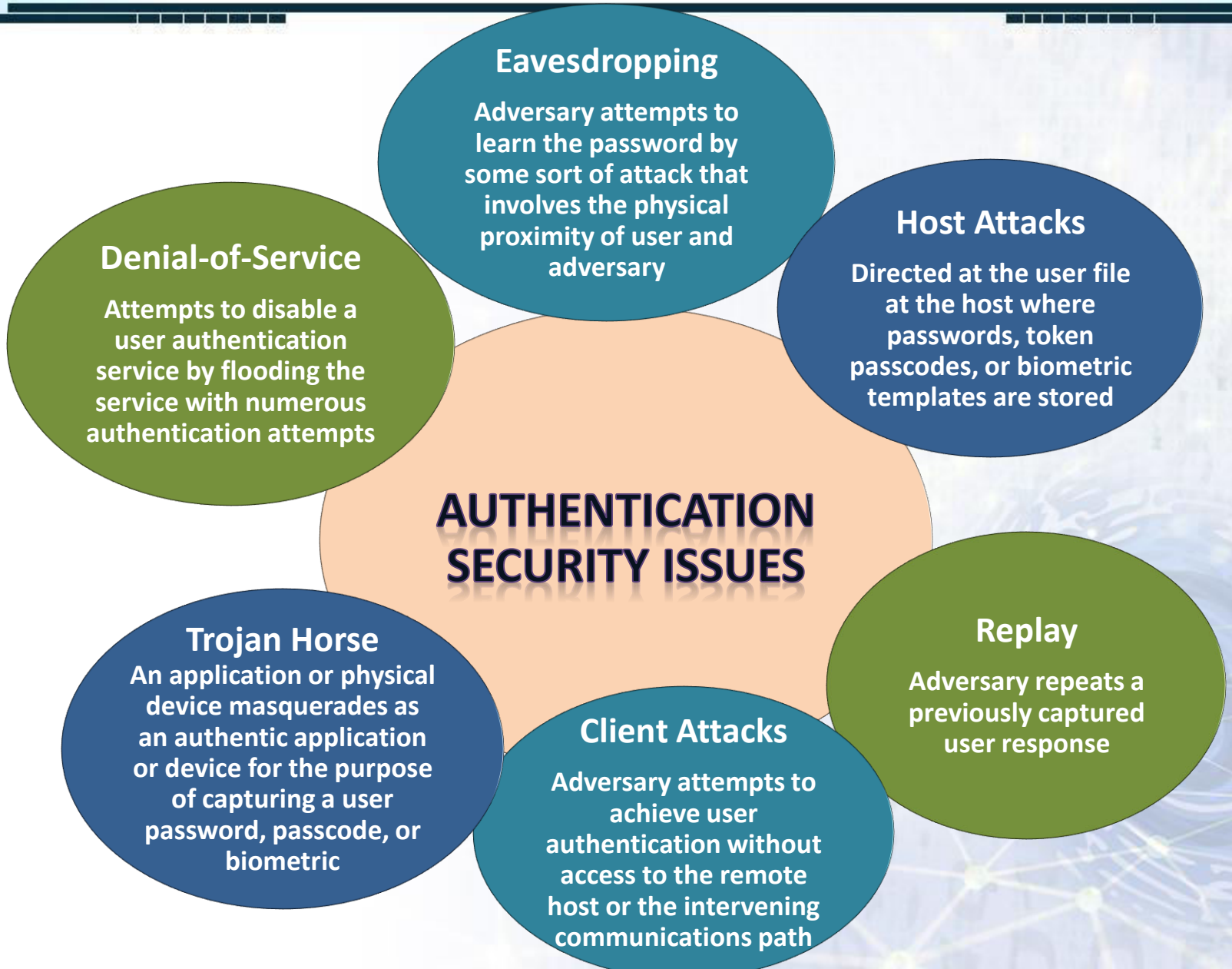
2FA

- 2FA uses the same password/username combination, but with the addition of being asked to verify who a person is by using something only he or she owns, such as a mobile device.
- Putting it simply: it uses two factors to confirm an identity.

MFA

- Multi-factor authentication uses a combination of the following factors: something you know, something you have, and something you are.
- 2FA is a subset of MFA,

Week 2 Topic 10



Week 2 Topic 11

Access Control

Recap

Authentication

Confirms users
are who they say they are.

Authorization

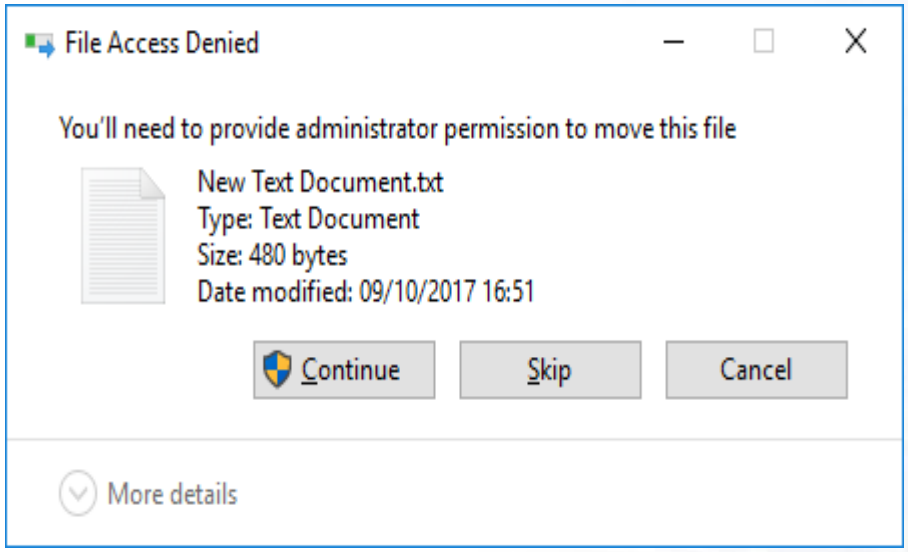
Gives users permission
to access a resource.

Accounting

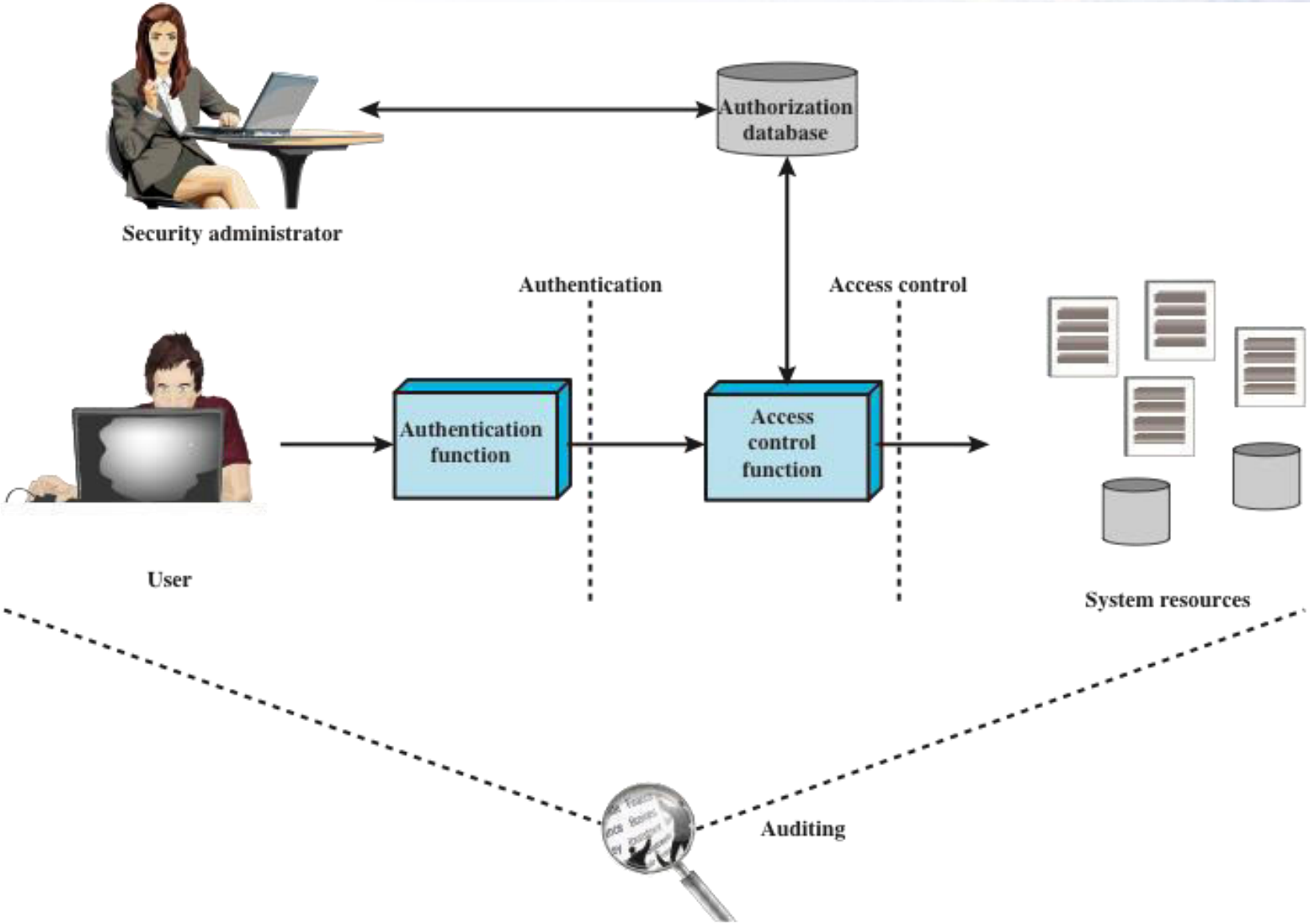
Measures the resources a user
consumes during access

Access Control

"the process of granting or denying specific requests to: (1) obtain and use information and related information processing services; and (2) enter specific physical facilities"



Notes: Two definitions of access control are useful in understanding its scope.
1. NISTIR 7298 (*Glossary of Key Information Security Terms* , May 2013), defines access control as the process of granting or denying specific requests to: (1) obtain and use information and related information processing services; and (2) enter specific physical facilities.


Authorization database
Security administrator
Authentication
Access control
Authentication function
Access control function
User
System resources
Auditing

Subjects, Objects, and Access Rights

Subject

An entity capable of accessing objects

Three classes
- Owner
- Group
- World (Everyone)

Object

A resource to which access is controlled

Entity used to contain and/or receive information

Access right

Describes the way in which a subject may access an object

Could include:
- Read
- Write
- Execute
- Delete
- Create
- Search

Week 2 Topic 12

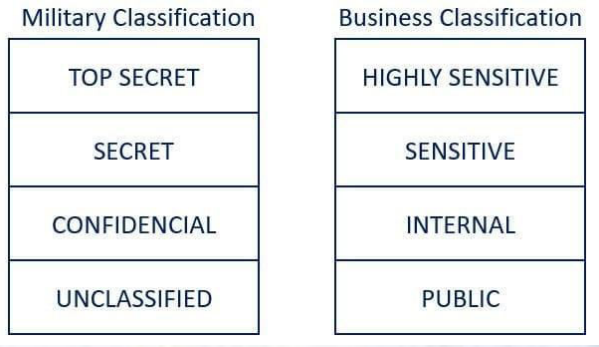
Access Control Policies

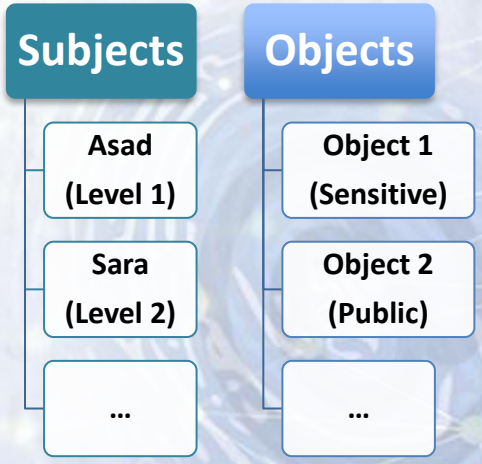
Access Control Policies

- Mandatory access control (MAC)
- Discretionary access control (DAC)
- Role-based access control (RBAC)
- Attribute-based access control (ABAC)

Mandatory Access Control (MAC)

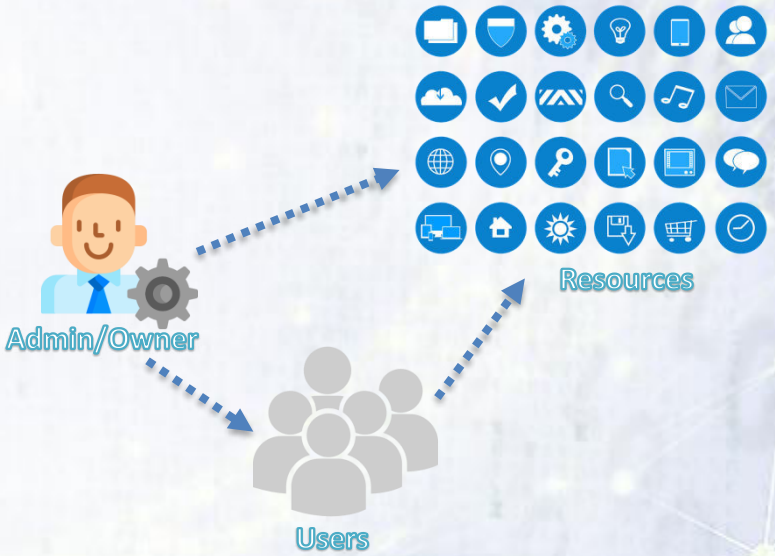
- Controls access based on comparing security labels (which indicate how sensitive or critical system resources are) with security clearances (which indicate system entities are eligible to access certain resources).
- This policy is termed *mandatory because*
  - *passing through security* clearance is *mandatory* for every user…
  - *an entity that has* clearance to access a resource may not, just by its own volition, enable another entity to access that resource.
- Commonly used in organizations where confidentiality is very important e.g. military etc.
- The higher the clearance the more in depth the background checks should be.





Discretionary Access Control (DAC)

- Scheme in which an entity may be granted access rights that permit the entity, by its own volition, to enable another entity to access some resource
- Often provided using an **Access Matrix**
  - One dimension consists of identified subjects that may attempt data access to the resources
  - The other dimension lists the objects that may be accessed
- Each entry in the matrix indicates the access rights of a particular subject for a particular object
- Controls access based on the identity
- Useful for small size organizations…

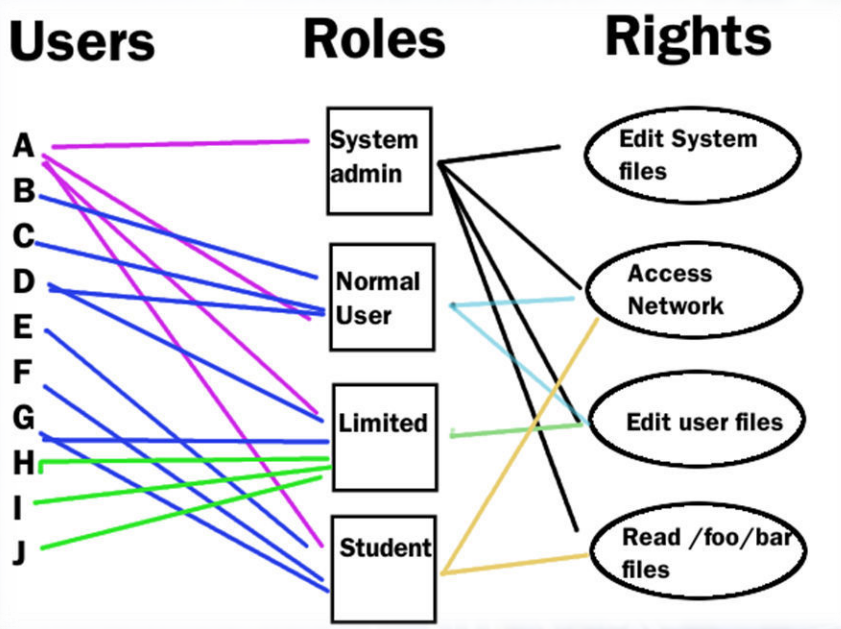


Objects	Users						
	U1	U2	U3	U4	...	Un	
O1		Read/ Write	Write	Read/ Write			
O2	Read					Write	
O3	Write			Read/ Write		Read	

Access Matrix

Role-based Access Control (RBAC)

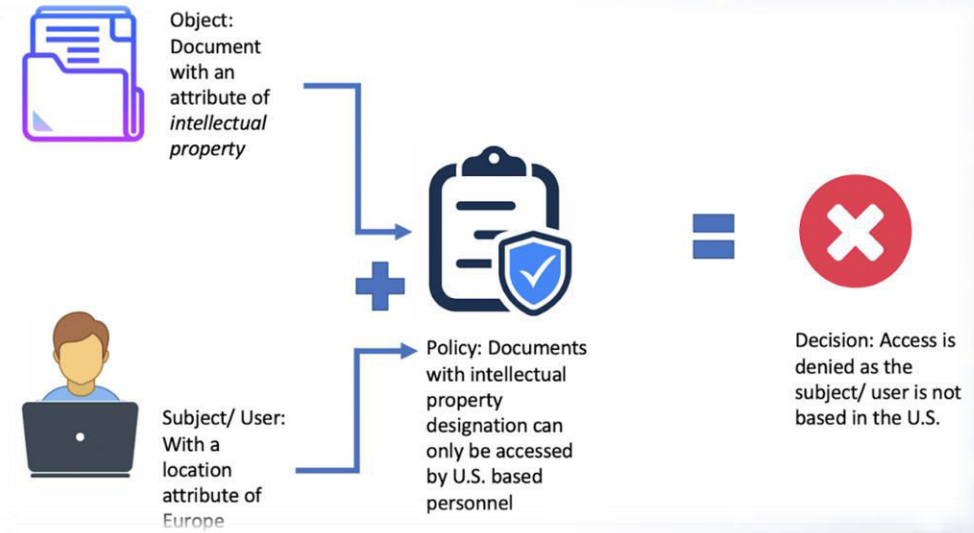
- DAC is not feasible for large size organizations…
  - Something better and easy to manage is needed
- Among such solutions is RBAC
- Controls access based on the roles that users have within the system and on rules stating what accesses are allowed to users in given roles.

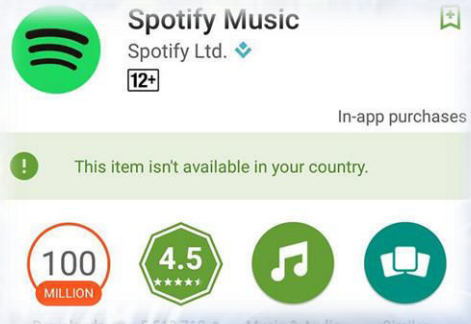


https://sites.google.com/site/cacsolin/role-based-access-control

Attribute-based Access Control (ABAC)

- Controls access based on attributes of the user, the resource to be accessed, and current environmental conditions and policies.





Object Attributes	Subject Attributes	Environment Conditions Attributes
• Type • Author • Owner • Date Created • Last Updated • Classification	• Name • Employee # • Designation • Department/ Affiliation • Clearance	• Location • Time Zone • Current time • Current Day

https://blog.privacera.com/what-is-attribute-based-access-control-and-why-is-it-important-70b91f4cad6

Summary

- **Mandatory access control (MAC)**
  - Controls access based on comparing security labels with security clearances
- **Discretionary access control (DAC)**
  - Controls access based on the identity of the requestor and on access rules (authorizations) stating what requestors are (or are not) allowed to do
- **Role-based access control (RBAC)**
  - Controls access based on the roles that users have within the system and on rules stating what accesses are allowed to users in given roles
- **Attribute-based access control (ABAC)**
  - Controls access based on attributes of the user, the resource to be accessed, and current environmental conditions

Week No. 3

Cryptography Part-I

Week 3 Topic 1

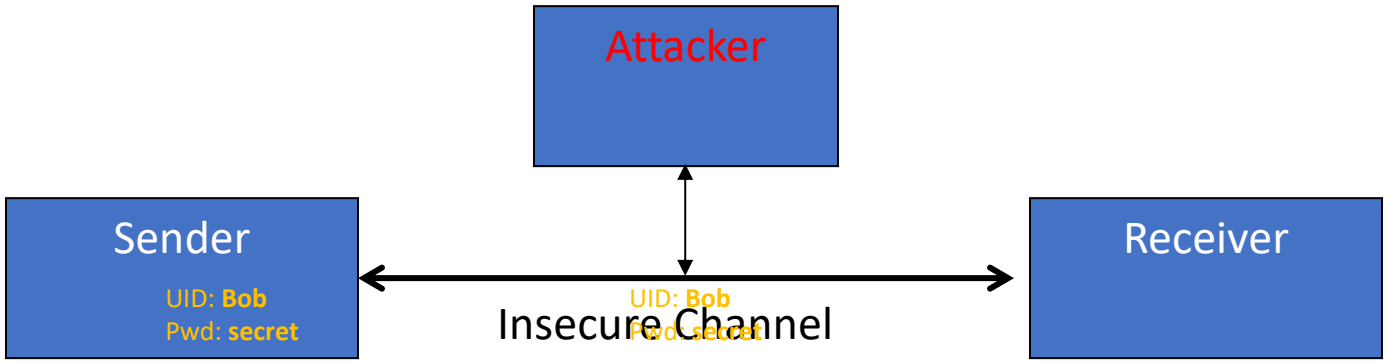
Cryptography

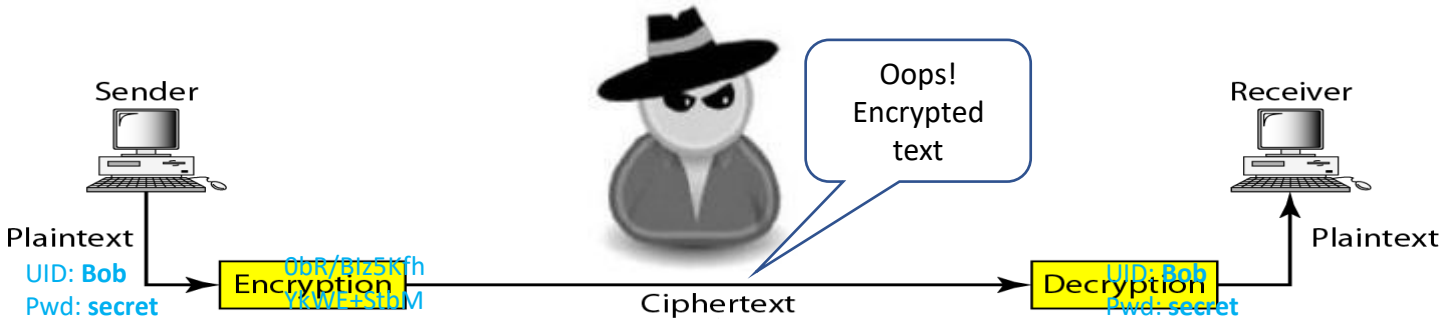
Cryptography

What is cryptography?

- **Cryptography**
  - The art of secret writing
  - Cryptography is the making
- **Cryptanalysis**
  - Cryptanalysis is the breaking

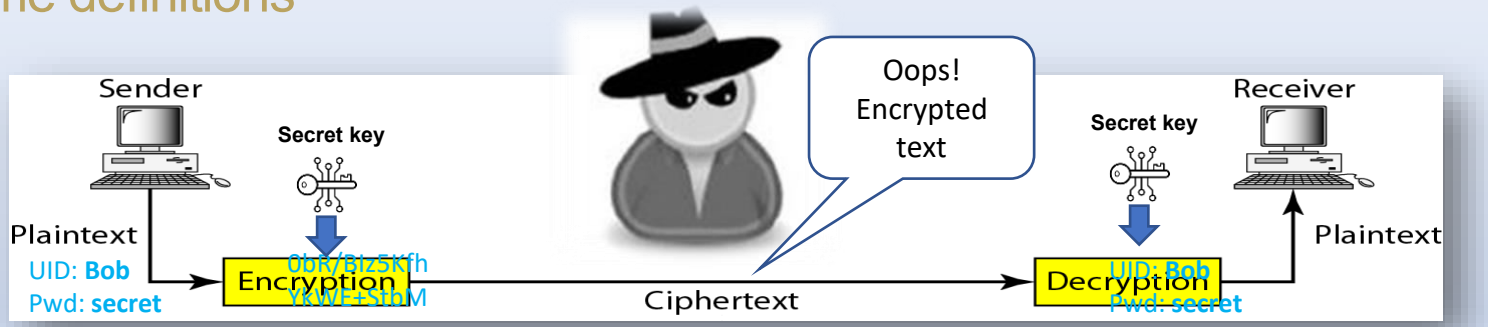
- **Why Cryptography?**
  - Cryptography aims to provide secure communications in the presence of an adversary/attacker.





Cryptography

Some definitions



Plaintext: This is the original message or data that is to be secured.

Encryption algorithm: This is the mechanism of securing the message and data. The encryption algorithm performs various substitutions and transformations on the plaintext.

Secret key: The secret key is also input to the algorithm. The exact substitutions and transformations performed by the algorithm depend on the key.

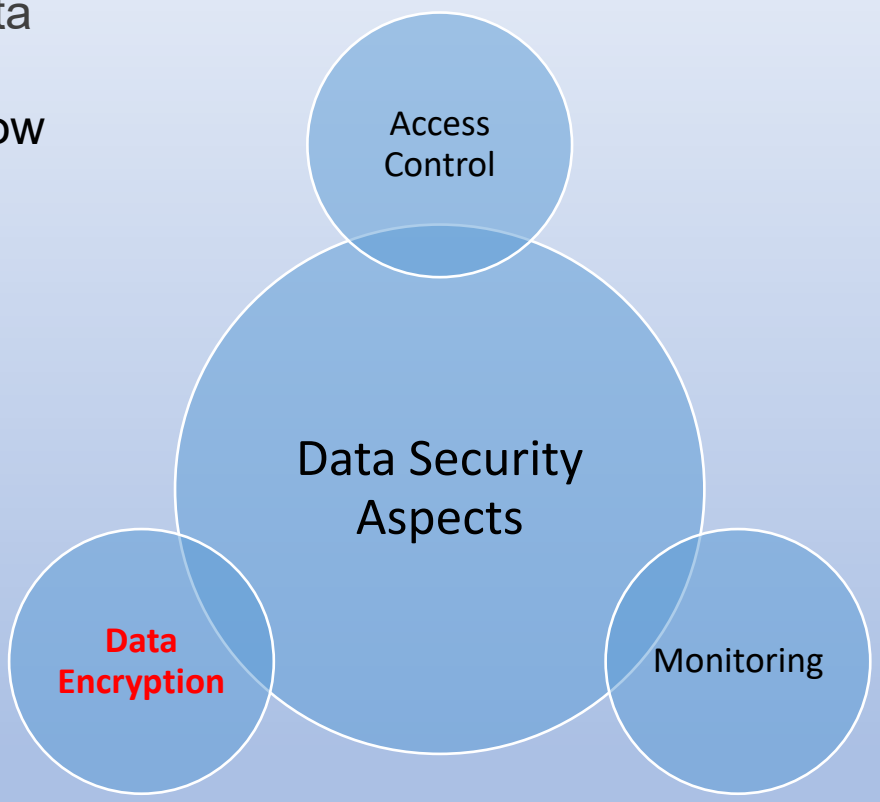
Ciphertext: This is the scrambled message produced as output. It depends on the plaintext and the secret key. For a given message, two different keys will produce two different ciphertexts.

Decryption algorithm: This is essentially the encryption algorithm run in reverse. It takes the ciphertext and the same secret key and produces the original plaintext.

Week 3 Topic 2

Data Security Aspects

- **Access Control** who can access the data
- **Monitoring** who is using the data and how
- **Data Encryption** strong encryption is required to transform the data from plaintext (or human readable format) to cipher text
- **Stages of Data**
  - Data at rest
  - Data in transit
  - Data in use
- **Cryptographic algorithms** helps to protect the data in all stages from un-authorized access and alteration

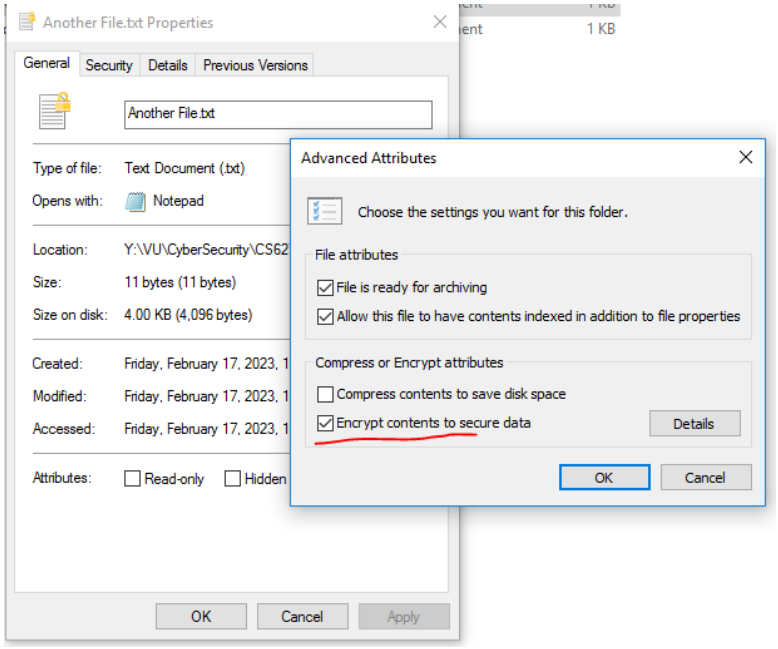


Data Security

Is it good to encrypt your files always?

- Encrypt when its needed…
- Be careful with Keys when encrypted…

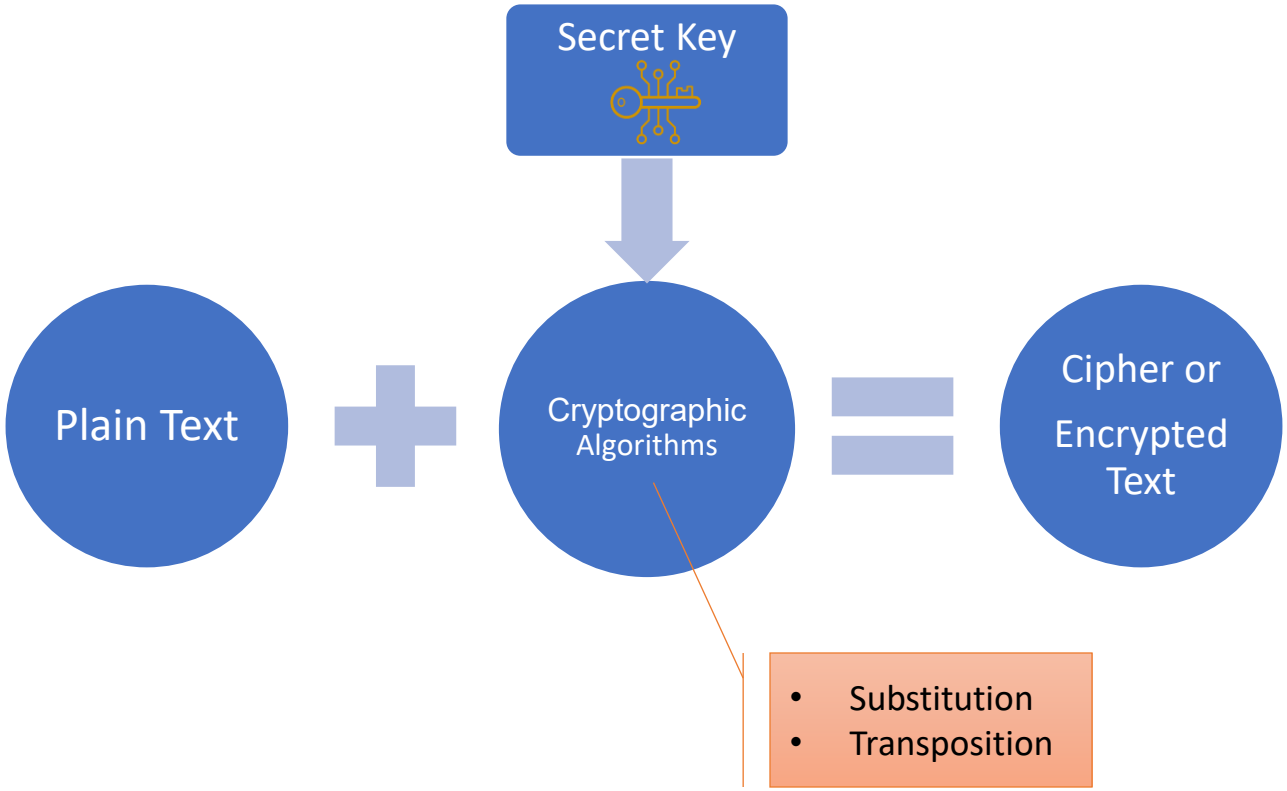
- Windows files security
  - Access rights
  - Encryption



Week 3 Topic 3

Cryptographic Algorithms

also referred as Ciphers or Encryption Algorithms

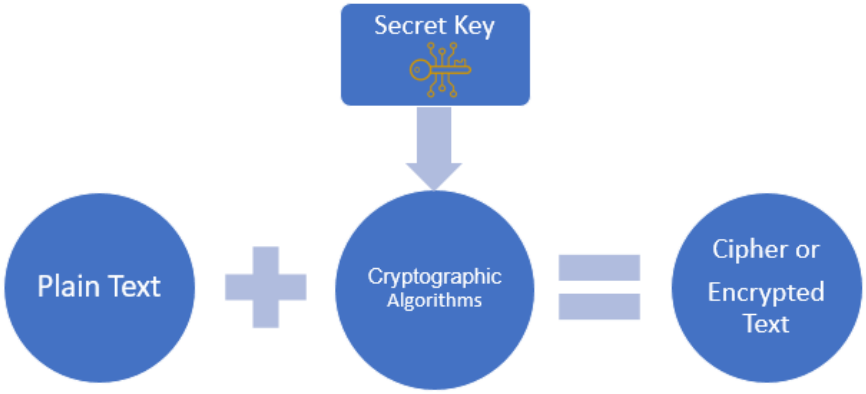


Feistel network consisting multiple rounds of processing of the plaintext, each round consisting of a “substitution” step followed by a permutation step.

Kerchoff's Principle

Kerckhoffs's principle of cryptography was stated by Dutch-born cryptographer Auguste Kerckhoffs in the 19th century.

- Kerckhoff's principle is **the concept that a Cryptographic system should be designed to be secure, even if all its details, except for the key, are publicly known**.



- In other words,
  - Secrecy of the cryptographic system should rely on the secret keys
  - No need to hide the procedure or algorithm for encryption
  - Rather, its better if procedure or algorithm for encryption are made public as this will help in identification and removing the flaws/loopholes

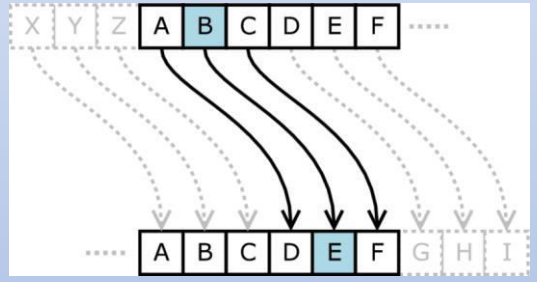
Week 3 Topic 4

Classical Ciphers

The Caesar Cipher

A B C D E F G H I J K L M N O P Q R S T U V W X Y Z

The Caesar cipher is one of the earliest and simplest methods of encryption technique and is based on substitution and involves shifting each letter of the plaintext message by a certain number of letters,



- **Caesars cipher**
  - Replace every ‘A’ in the message with a ‘D’
  - Replace every ‘B’ in the message with a ‘E’
  - Replace every ‘C’ in the message with a ‘F’, etc.

Demo https://cryptii.com/

- **Considerations**
  - Algorithms are public (Kerchoff’s Principle)
  - Encrypt/decrypt depends on a key
  - The only secret is the key
  - For Caesars cipher, key is ***n***, since shift forward ***n*** to encrypt, shift backward n to decrypt
  - Encryption: $C_i = (P_i + n) \bmod 26$
  - Decryption: $P_i = (C_i - n) \bmod 26$

Text : **ATTACKATONCE**
Shift: **4**
Cipher: EXXEGOEXSRGI

Caesar Cipher

Cryptanalysis of Caesar Cipher – Brute force

- Ciphertext = “GRR MGAR OY JOBOJKJ OT ZNXKK VGXZY”
- Perform decryption with each possible key:
- Plaintext with n= 1
- FQQ LFZQ NX INANIJI NS YMWJJ UFWYX
- Plaintext with n= 2
- EPP KEYP MW HMZMHIH MR XLVII TEVXW
- Plaintext with n= 3
- DOO JDXO LV GLYLGHG LQ WKUHH SDUWV
- Plaintext with n= 4
- CNN ICWN KU FKXKFGF KP VJTGG RCTVU
- Plaintext with n= 5
- BMM HBVM JT EJWJEFE JO UISFF QBSUT
- Plaintext with n= 6
- ALL GAUL IS DIVIDED IN THREE PARTS

Week 3 Topic 5

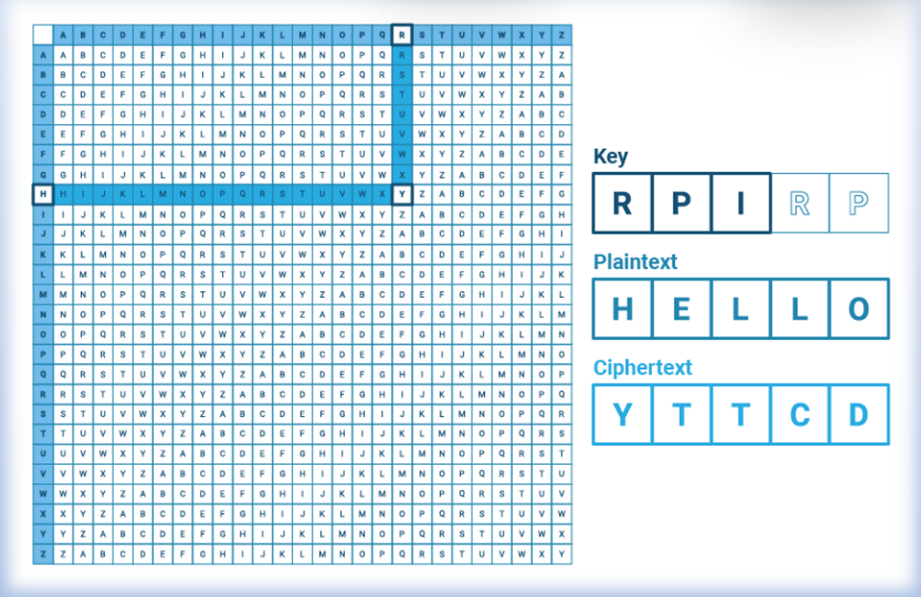
Classical Ciphers

Giovan Battista
Italian cryptologist

Blaise de Vigenère
French cryptographer

Vigenere Cipher

- Developed in 1553.
- It is a method of encrypting alphabetic text by using a series of interwoven Caesar ciphers, based on the letters of a keyword.
- Its based on polyalphabetic substitution
- **Key**: A word W of Length M.
- **Plain text** P of length N.
- Repeat the Key until it matches the length of the plain text.
- For each letter P_j of the plain text, apply a Caesar Cipher of length W_j



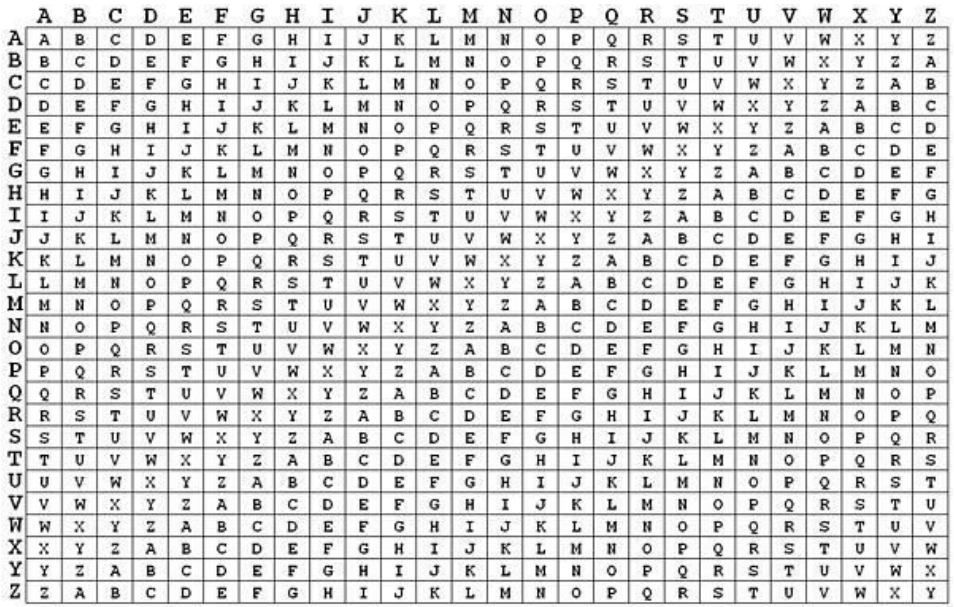
Example

- Key: **RPI**
- Plain Text: HELLO
- Expanded key: RPIRP
- Cipher Text: YTTCD

Demo https://cryptii.com/pipes/vigenere-cipher

Exercise

Vigenere Cipher



	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
A	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z
B	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A
C	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B
D	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C
E	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D
F	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E
G	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F
H	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G
I	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H
J	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I
K	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J
L	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K
M	M	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L
N	N	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M
O	O	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N
P	P	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O
Q	Q	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P
R	R	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q
S	S	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R
T	T	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S
U	U	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T
V	V	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U
W	W	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V
X	X	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W
Y	Y	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X
Z	Z	A	B	C	D	E	F	G	H	I	J	K	L	M	N	O	P	Q	R	S	T	U	V	W	X	Y

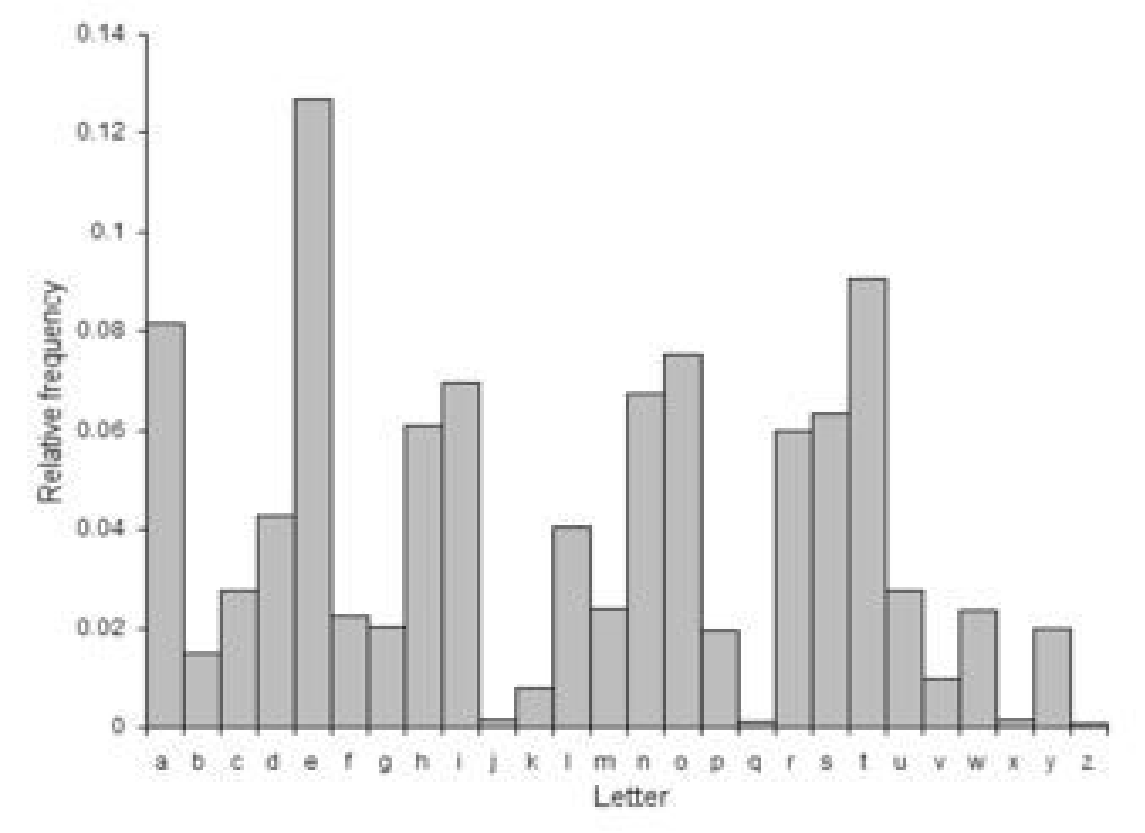
- ***The apple is in the corner and the pear is there too (plain)***
- ***cat (key)***

- ***Find the cipher?***

- ***t h e a p p l e i s i n t h e c o r n e r a n d t h e p e a r i s t h e r e t o o (plain)***
- ***c a t c a t c a t c a t c a t c a t c a t c a t c a t c a t c a t c a t c a (key)***

- ***Answer***
- ***Vhx cpi neb uig vhx eok pek cnw vhx ret til vhx tem qo (cipher)***

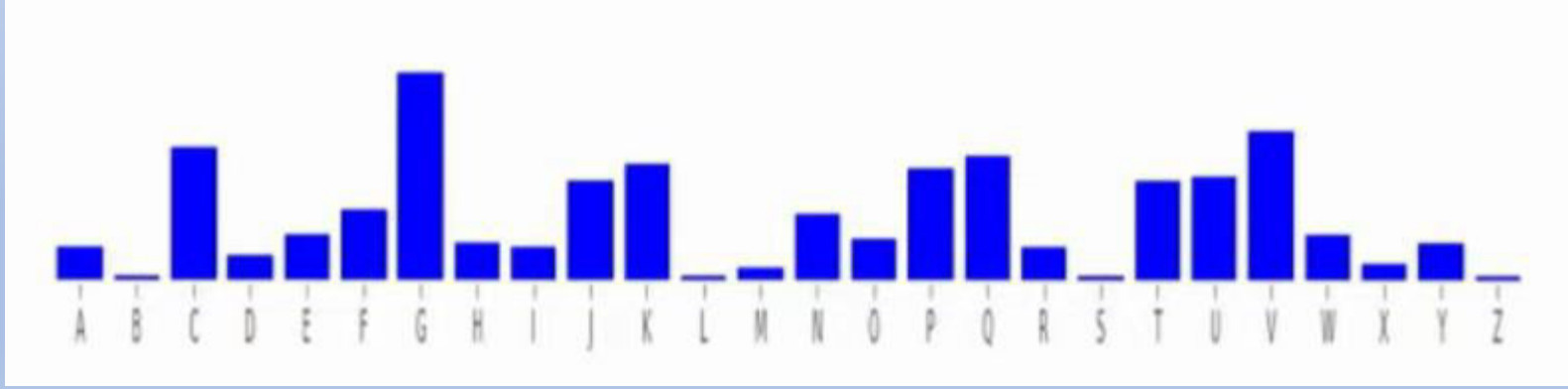
Frequency of the letters of the alphabet in English



Caesar Cipher

Cryptanalysis of Caesar Cipher

Frequency analysis of Plain Text



Frequency analysis of Caesar Cipher Text

Vigenere Cipher

Cryptanalysis of Vigenere Cipher

Frequency analysis of Plain Text

Frequency analysis of Vigenere Cipher Text

Vigenere Cipher

Cryptanalysis of Vigenere Cipher

- Three steps
  - Find the length of the key (Kasiski test)
  - Divide the message into that many shift cipher encryptions.
  - Use frequency analysis to solve the resulting shift ciphers.

Cipher Text

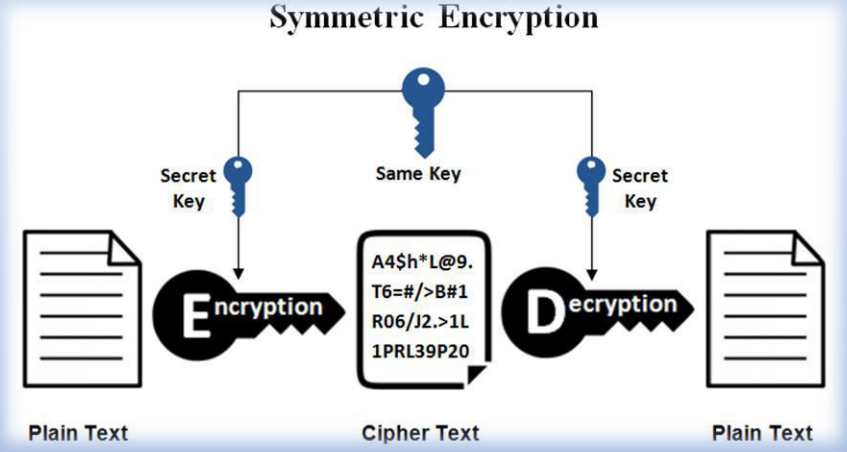
AQRTUVQSTVVXSLMPOR---
AQRTUVQSTVVXSLMPOR---

Cryptanalysis of Vigenere cipher: not just how, but why it works
https://www.youtube.com/watch?v=QgHnr8-h0xI

Week 3 Topic 6

Modern Cryptography Algorithm Types

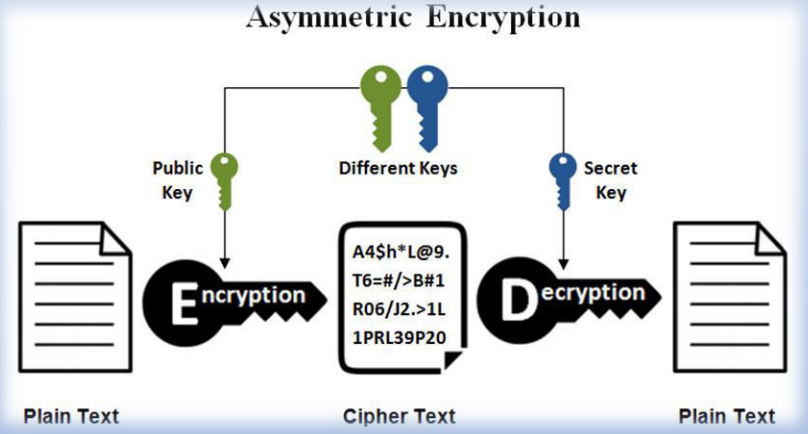
Symmetric Cryptography



- Need a strong encryption algorithm*
- Secure Key Exchange
- Its relatively fast

Asymmetric Cryptography

also knows as Public Key Cryptography



- Public and private keys are mathematically related
- **The private key** is never shared
- Its relatively slow

https://www.ssl2buy.com/wiki/symmetric-vs-asymmetric-encryption-what-are-differences

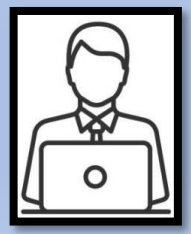
Modern Cryptography Algorithm Communication Perspective

Symmetric Cryptography

Asymmetric Cryptography

How Modern Cryptographic Algorithm Are Used?

User 1



User 2

Week 3 Topic 7

Five Aspects of Security

Confidentiality

- Assurance that information is not disclosed to unauthorized individuals even they get access to it

Encryption

Integrity

- Information is not tampered by any unauthorized entities, if tempered then receiver must be able to detect that

Hashing

Availability

- Authorized users have timely and easy access to information when needed

IDS and IPS

Authenticity

- Prevents impersonation and enables receiver to **verify the sender of the message is who he claimed to be**

Digital signature

Non-Repudiation

- Sender can't deny after sending the message

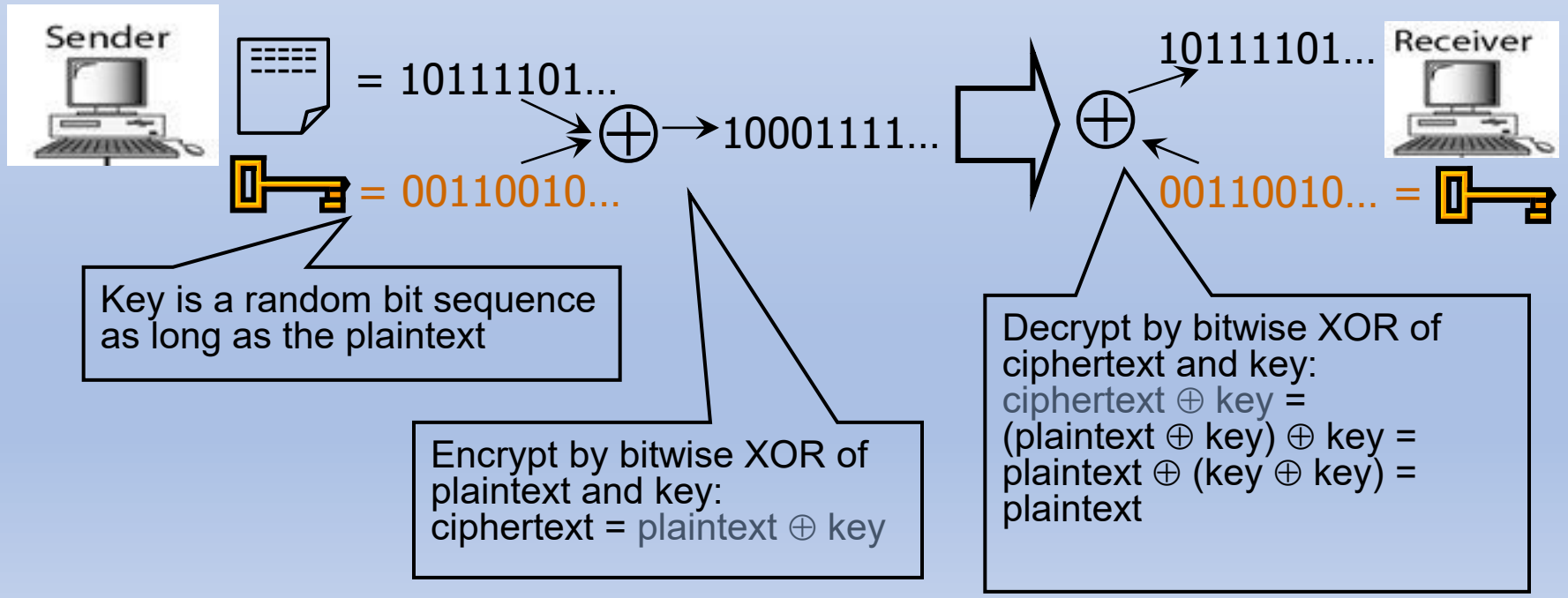
Digital signature

Week 3 Topic 8

One Time Pad

Example of Symmetric Encrpytion

- Invented by Gilbert Vernam in the 1920s
- The message is a bitstring $m \epsilon \{0,1\}^n$
- The key is a bitstring as long as the message, $k \epsilon \{0,1\}^n$
- The ciphertext is obtained by XORing each bit of the plaintext with each bit of the key: c = m ⊕ k.



One Time Pad

Advantages

- **Easy to compute**
  - Encryption and decryption are the same operation
  - Bitwise XOR is very cheap to compute
- **As secure as theoretically possible**
  - Given a ciphertext, all plaintexts are equally likely, regardless of attacker's computational resources
  - if and only if the key sequence is truly random
    - —True randomness is expensive to obtain in large quantities

One Time Pad

Disadvantages

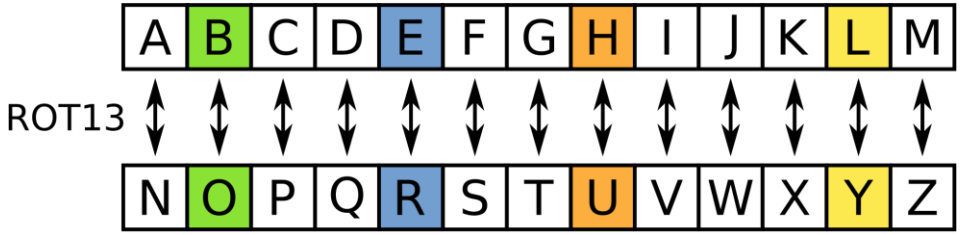
- **Key must be as long as the plaintext**
  - Impractical in most realistic scenarios
  - Still used for diplomatic and intelligence traffic
- **Does not guarantee integrity**
  - One-time pad only guarantees confidentiality
  - Attacker cannot recover plaintext, but can easily change it to something else
- **Insecure if keys are reused**
  - Attacker can obtain XOR of plaintexts

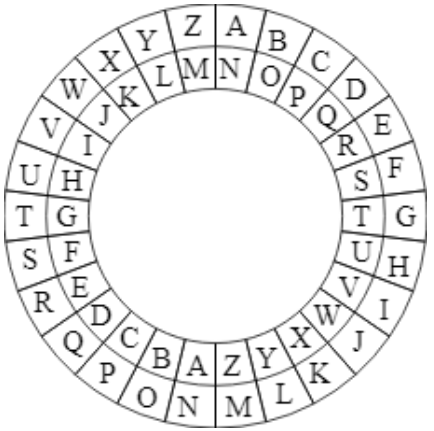
Week 3 Topic 9

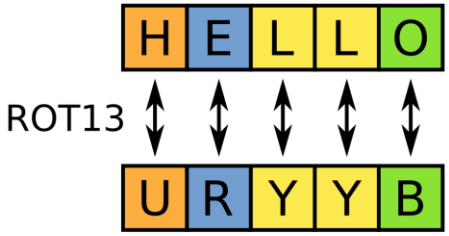
Symmetric Encryption

ROT13

- ROT13 cipher(read as – “rotate by 13 places”) is a special case of the Ceaser cipher in which the shift is always 13.
- This is an example of substitution **cipher**







Poor Encryption: ROT13

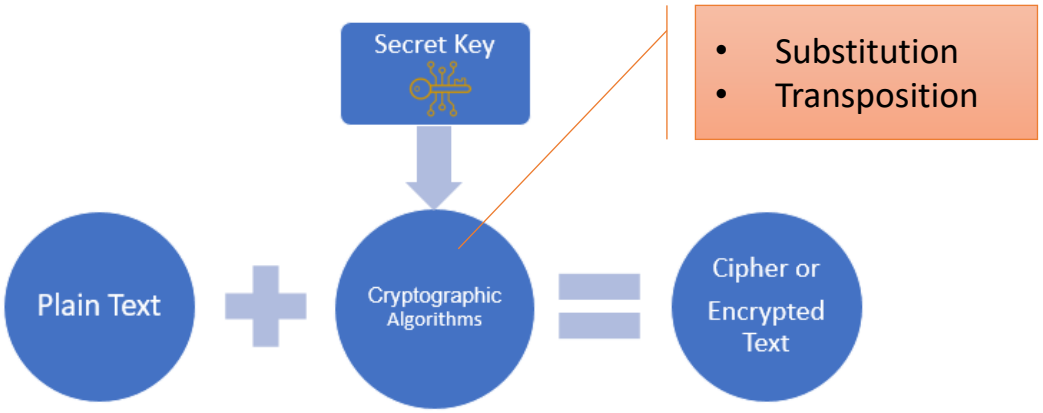
- No “key”
- Susceptible to frequency analysis
- Susceptible to brute forcing

Week 3 Topic 10

Confusion and Diffusion

Properties of the operation of a secure cipher

- Concept was originally presented by Claude Shannon in 1945



- Confusion refers to making the relationship between the Ciphertext and the Key as complex and involved as possible;
  - Make use of Substitution
- Diffusion refers to dissipating the statistical structure of Plaintext over the bulk of Ciphertext
  - Make use of Transposition

Feistel Cipher/Network consisting multiple rounds of processing of the plaintext, each round consisting of a "substitution" step followed by a permutation step.

Week 3 Topic 11

Operational Modes of Symmetric Encryption

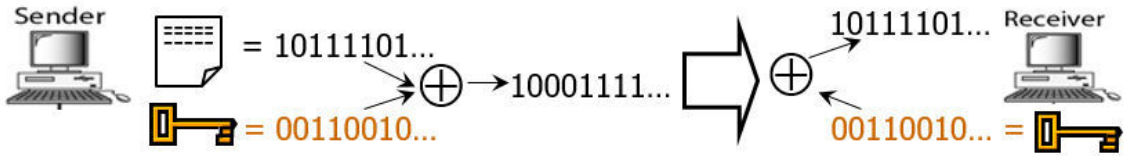
Symmetric encryption schemes follows two distinct modes of operation:

- **Stream Cipher**
  - Plain text is encrypted bit by bit
  - Plain text and key are XORed
- **Block Cipher**
  - Plain text is encrypted block by block
  - The whole block is encrypted with a key

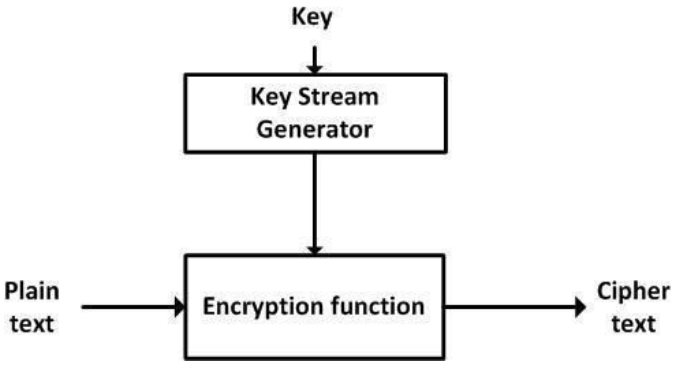
Stream Ciphers

- Each bit of plaintext is encrypted one by one, with the corresponding bit of the keystream, obtaining a bit of ciphertext.

- To describe a stream cipher, it is enough to describe the key stream generator. Once the key stream is obtained, it works like the one- time pad.
- The key stream must be generated from a random seed



One Time Pad



Stream Ciphers

Stream Encryption

XOR GATE Truth Table

INPUT		OUTPUT
A	B	A XOR B
0	0	0
0	1	1
1	0	1
1	1	0

BOOLEAN EXPRESSION

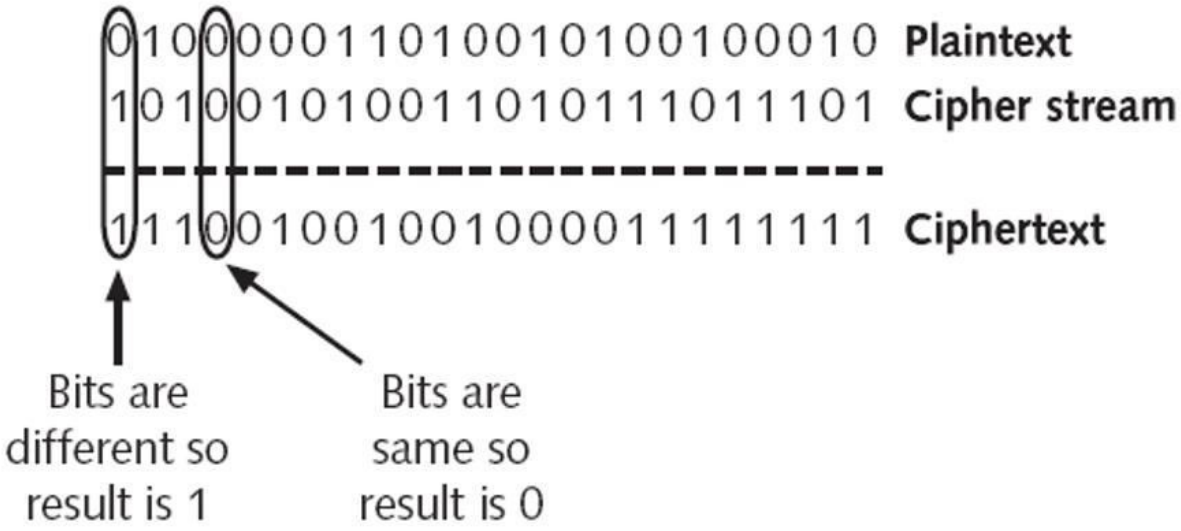
$$A \cdot \overline{B} + \overline{A} \cdot B$$
$$(A + B) \cdot (\overline{A} + \overline{B})$$

C = A⊕B

Input1

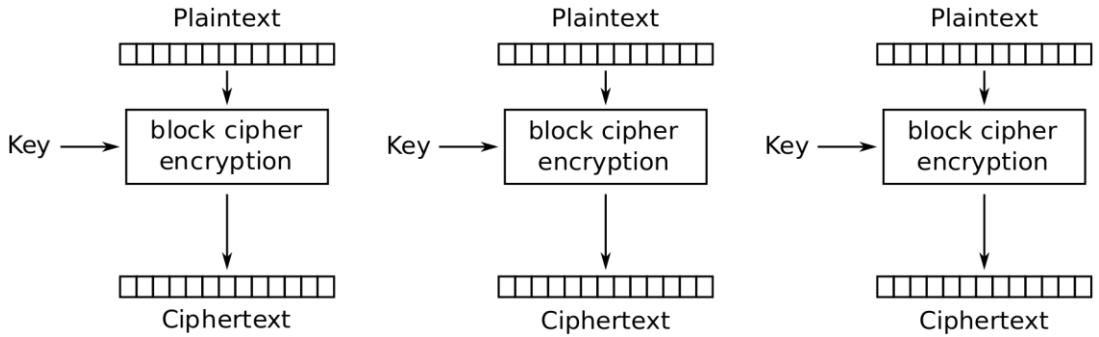
Input2

Output



Block Ciphers

- Block ciphers operate on blocks of plaintext one at a time to produce blocks of ciphertext.
- The encryption of a bit in a plaintext will depend on the other bits in the block.
- The block sizes are usually reasonably large e.g. 64 bits, 128 bits, even more.



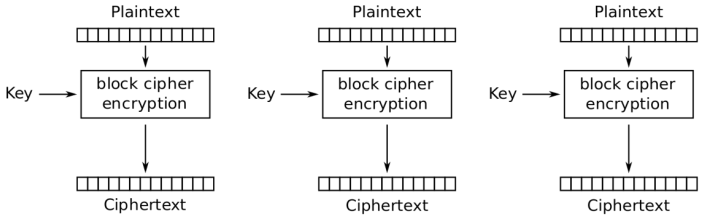
- The most famous block cipher is DES (Data Encryption Standard).
- Since DES is the most studied scheme and the design principles of DES have inspired a lot of ciphers used nowadays, we will have a slight view of DES.

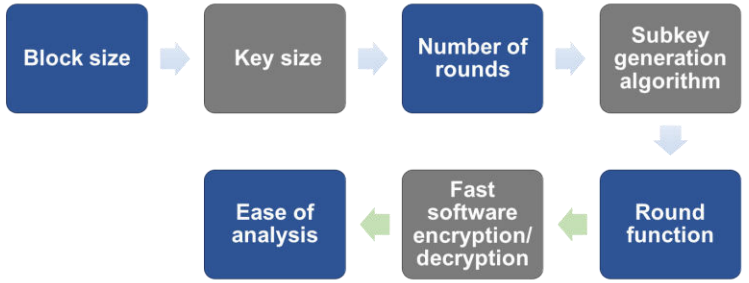
https://sandilands.info/crypto/BlockCipherModesofOperation.html

Week 3 Topic 12

Block Ciphers Design Considerations

- Processes the input one block of elements at a time
- Produces an output block for each input block
- **Block size:** Larger block sizes mean greater security (all other things being equal) but reduced encryption/decryption speed. block size of 128 bits is a reasonable trade-off.
- **Key size**: Larger key size means greater security but may decrease encryption/ decryption speed. The most common key length in modern algorithms is 128 bits.
- **Number of rounds**: The essence of a symmetric block cipher is that a single round offers inadequate security but that multiple rounds offer increasing security. A typical size is 16 rounds.
- **Subkey generation algorithm** : Greater complexity in this algorithm should lead to greater difficulty of cryptanalysis.
- **Round function**: Again, greater complexity generally means greater resistance to cryptanalysis.
- **Fast software encryption/decryption:** In many cases, encryption is embedded in applications or utility functions and the speed of execution of the algorithm becomes a concern.
- **Ease of analysis:** Although we would like to make our algorithm as difficult as possible to cryptanalyze, there is great benefit in making the algorithm easy to analyze vulnerabilities.





	DES	Triple DES	AES
Plaintext block size (bits)	64	64	128
Ciphertext block size (bits)	64	64	128
Key size (bits)	56	112 or 168	128, 192, or 256

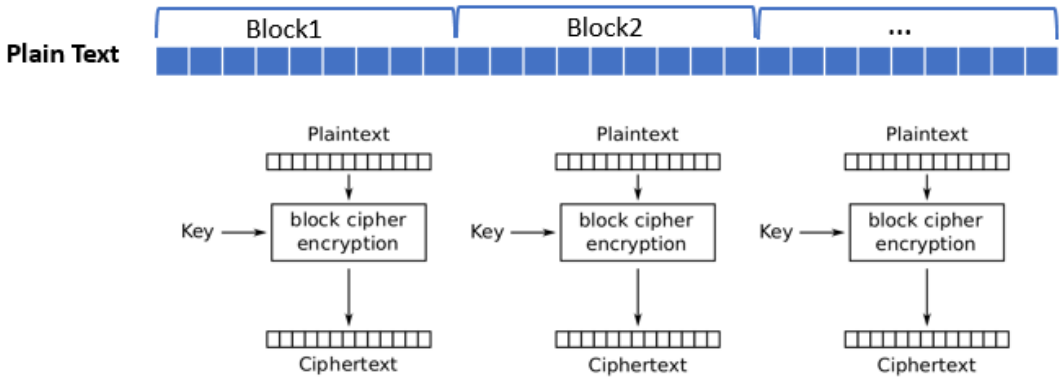
DES = Data Encryption Standard
AES = Advanced Encryption Standard

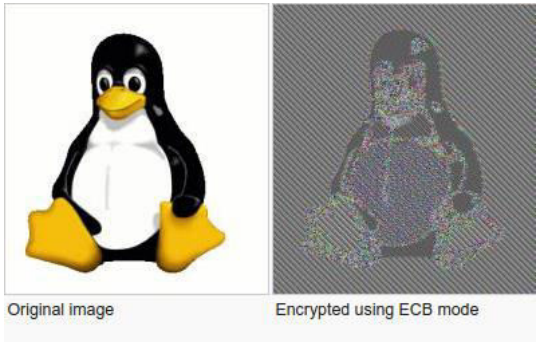
Week 3 Topic 13

Block Cipher Modes - Symmetric Encryption

Practical Security Issues

- Typically, symmetric encryption is applied to a unit of data larger than a single 64-bit or 128-bit block.
- The simplest approach to multiple-block encryption:
  - Each block of plaintext is encrypted using the same key
  - Cryptanalysts may be able to exploit regularities in the plaintext
  - This is commonly known as **Electronic Code Book (ECB) mode**





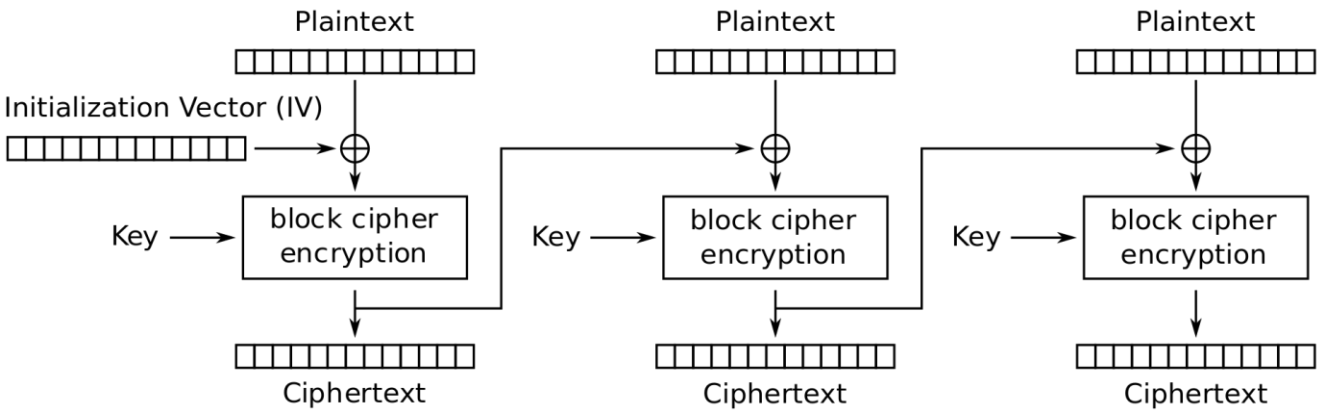
- Alternative techniques developed to increase the security of symmetric block encryption for large sequences
- Overcomes the weaknesses of ECB
- Consequently…different Block cipher modes were designed

- **Electronic Code Book (ECB) Mode**
- Cipher Block Chaining (CBC) Mode
- Cipher Feedback Mode (CFB)
- Output Feedback Mode (OFM)
- Counter mode (CTR)

Cipher Block Chaining Mode

- Electronic Code Book (ECB) Mode
- **Cipher Block Chaining (CBC) Mode**
- Cipher Feedback Mode (CFB)
- Output Feedback Mode (OFM)
- Counter mode (CTR)

- Input to encryption algorithm is XOR of next 64-bits plaintext and preceding 64-bits ciphertext
- Typical applications: General-purpose block-oriented transmission; authentication
- Initialization Vector (IV) must be known by sender/receiver, but secret from attacker

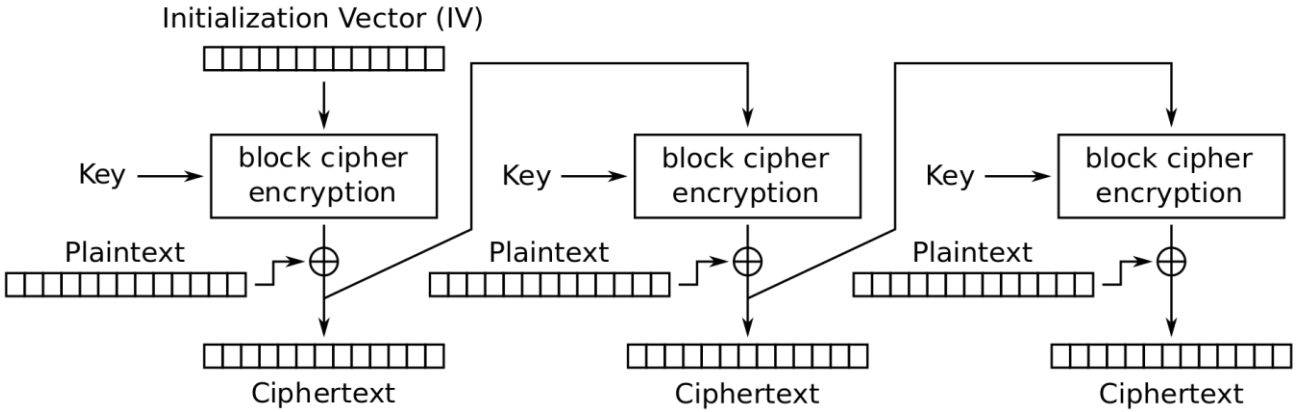


https://sandilands.info/crypto/BlockCipherModesofOperation.html

- Electronic Code Book (ECB) Mode
- Cipher Block Chaining (CBC) Mode
- **Cipher Feedback Mode (CFB)**
- Output Feedback Mode (OFM)
- Counter mode (CTR)

Cipher Feedback Mode

- Converts block cipher into stream cipher
- No need to pad message to integral number of blocks
- Operate in real-time: each character encrypted and transmitted immediately
- Input processed *s* bits at a time
- Preceding ciphertext used as input to cipher to produce pseudo-random output
- XOR output with plaintext to produce ciphertext
- Typical applications: General-purpose stream-oriented transmission; authentication



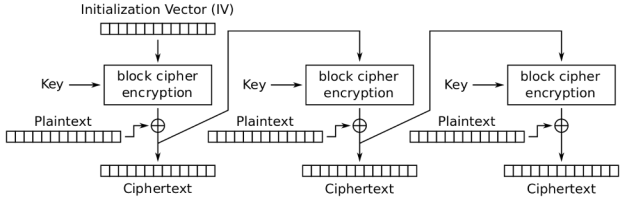
Cipher Feedback (CFB) mode encryption

https://sandilands.info/crypto/BlockCipherModesofOperation.html

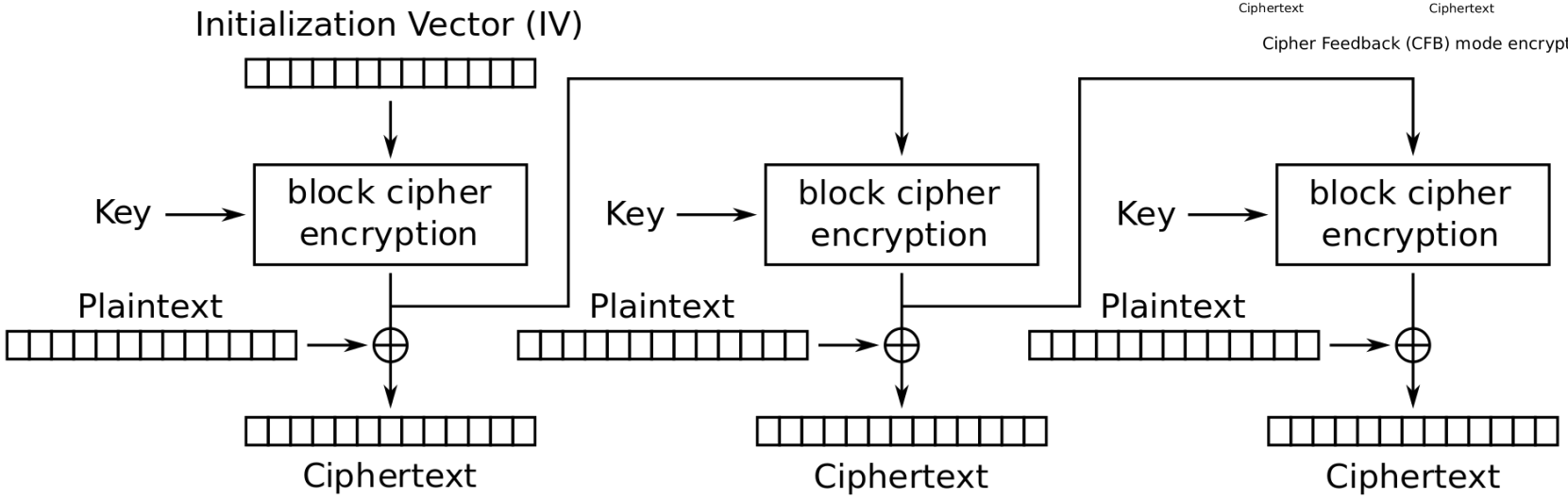
Output Feedback Mode

- Electronic Code Book (ECB) Mode
- Cipher Block Chaining (CBC) Mode
- Cipher Feedback Mode (CFB)
- **Output Feedback Mode (OFM)**
- Counter mode (CTR)

- Converts block cipher into stream cipher
- Similar to CFB, except input to encryption algorithm is preceding encryption output
- Typical applications: stream-oriented transmission over noisy channels (e.g. satellite communications)
- Advantage compared to OFB: bit errors do not propagate
- Disadvantage: more vulnerable to message stream modification attack



Cipher Feedback (CFB) mode encryption

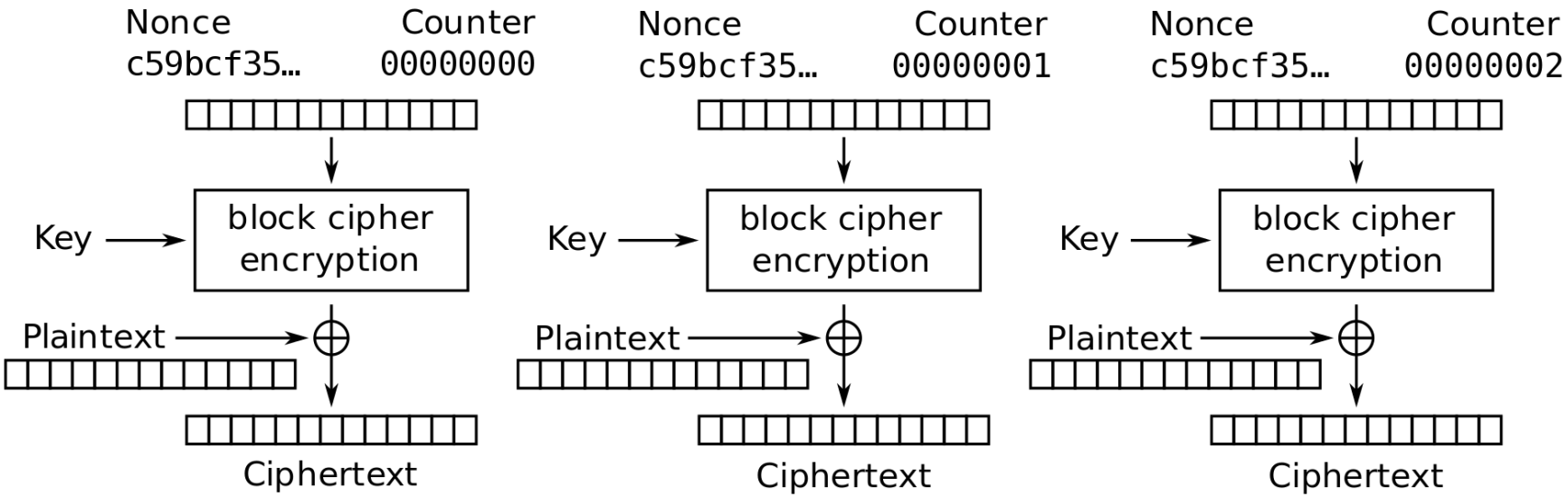


https://sandilands.info/crypto/BlockCipherModesofOperation.html

Counter Mode

- Electronic Code Book (ECB) Mode
- Cipher Block Chaining (CBC) Mode
- Cipher Feedback Mode (CFB)
- Output Feedback Mode (OFM)
- **Counter Mode (CTR)**

- Converts block cipher into stream cipher
- Each block of plaintext XORed with encrypted counter
- Typical applications: General-purpose block-oriented transmission; useful for high speed requirements
- Efficient hardware and software implementations
- Simple and secure



https://sandilands.info/crypto/BlockCipherModesofOperation.html

Block Cipher Modes - Symmetric Encryption

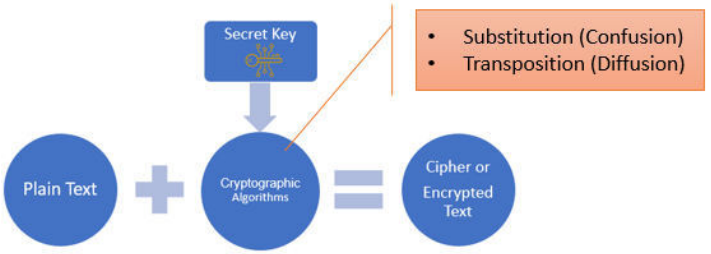
Summary

Mode	Description	Typical Application
Electronic Codebook (ECB)	Each block of 64 plaintext bits is encoded independently using the same key.	•Secure transmission of single values (e.g., an encryption key)
Cipher Block Chaining (CBC)	The input to the encryption algorithm is the XOR of the next 64 bits of plaintext and the preceding 64 bits of ciphertext.	•General-purpose block-oriented transmission •Authentication
Cipher Feedback (CFB)	Input is processed *s* bits at a time. Preceding ciphertext is used as input to the encryption algorithm to produce pseudorandom output, which is XORed with plaintext to produce next unit of ciphertext.	•General-purpose stream-oriented transmission •Authentication
Output Feedback (OFB)	Similar to CFB, except that the input to the encryption algorithm is the preceding DES output.	•Stream-oriented transmission over noisy channel (e.g., satellite communication)
Counter (CTR)	Each block of plaintext is XORed with an encrypted counter. The counter is incremented for each subsequent block.	•General-purpose block-oriented transmission •Useful for high-speed requirements

Attack Strategies on Symmetric Encryption

Brute-force Attacks

- Try all possible keys on some ciphertext until an intelligible translation into plaintext is obtained
- On average half of all possible keys must be tried to achieve success
- Number of Keys are dictated by the key size.



Cryptanalytic Attacks

- Rely on:
  - Nature of the algorithm
  - Some knowledge of the general characteristics of the plaintext
  - Some sample plaintext-ciphertext pairs
- Exploits the characteristics of the algorithm to attempt to deduce a specific plaintext or the key being used
  - If successful, all future and past messages encrypted with that key are compromised

Week No. 4

Cryptography Part-II

Week 4 Topic 1

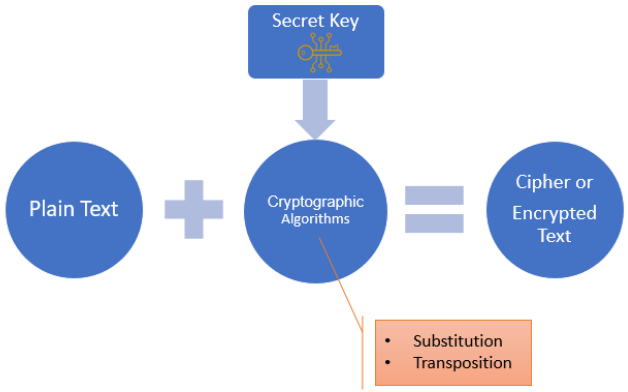
Feistel Network

Symmetric Encryption

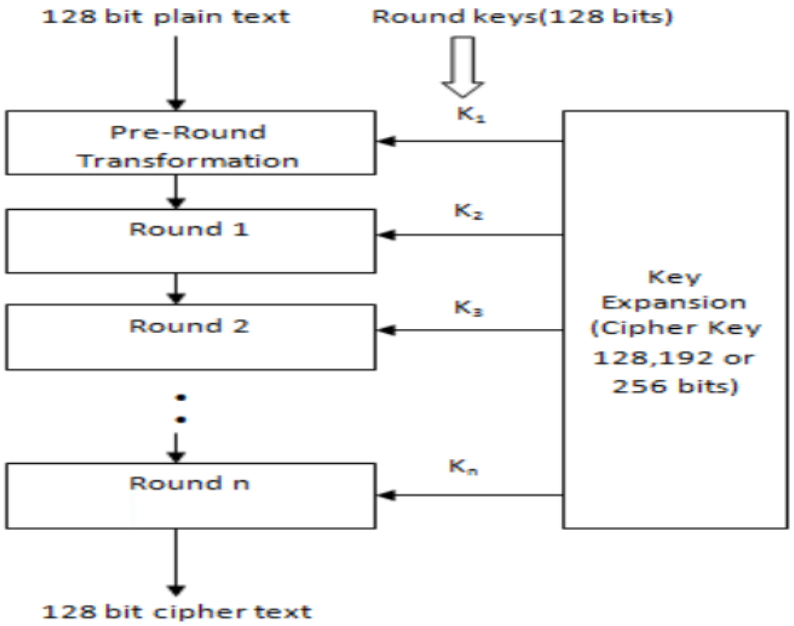
Week 4 Topic 2

Encryption/Decryption Process

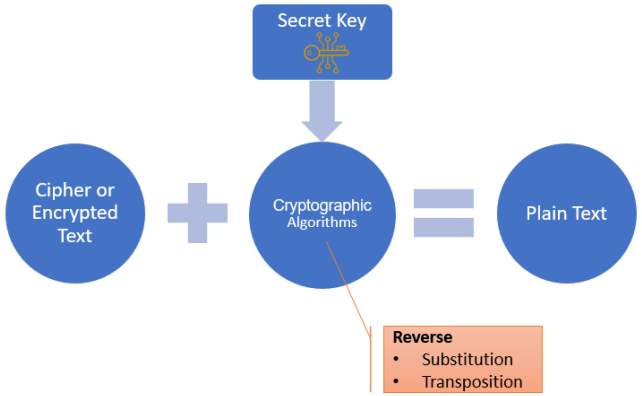
Encryption Process



Feistel network consisting multiple rounds of processing of the plaintext, each round consisting of a "substitution" step followed by a permutation step.



Decryption Process



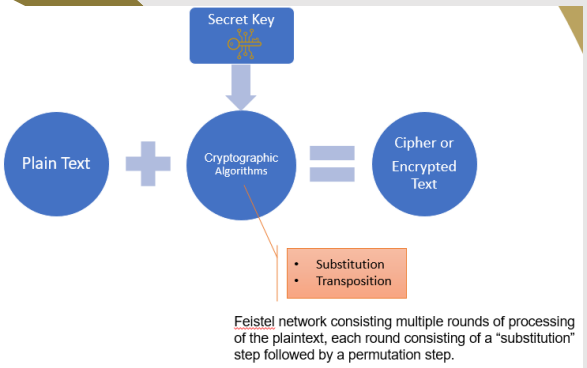
We want to make encryption process hard for attacker to break our algorithm…How?

More rounds, complex substitution and transposition…

But, users with the Key should be able decrypt it **easily**…How?

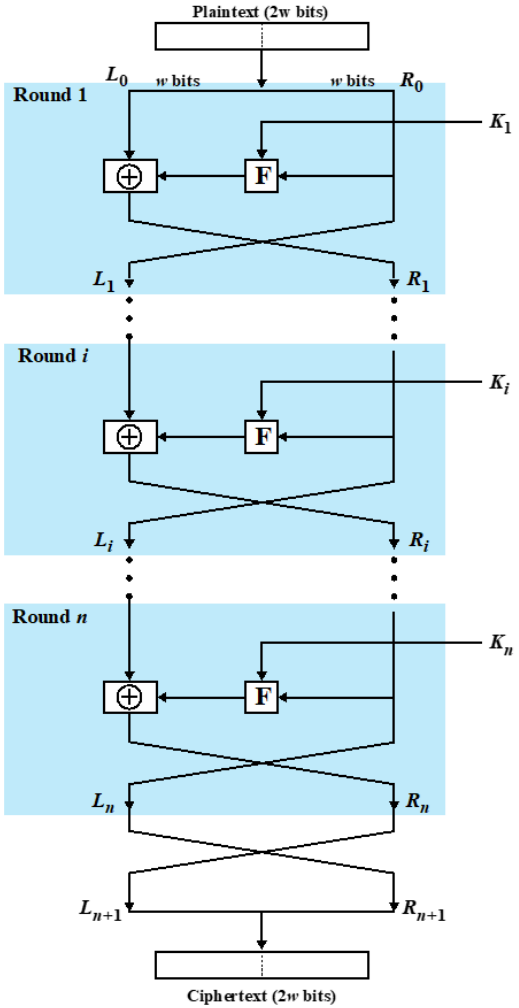
Feistel Network

Feistel Network - Symmetric Encryption



Feistel network consisting multiple rounds of processing of the plaintext, each round consisting of a "substitution" step followed by a permutation step.

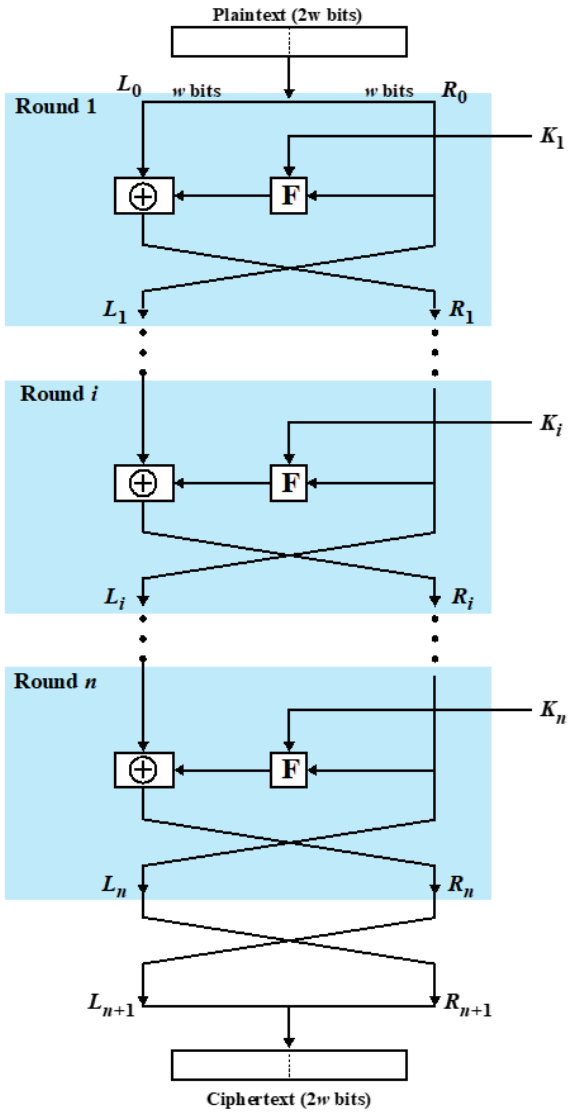
- Many encryption algorithms incorporate a structure first proposed by Horst Feistel of IBM (1973); a **Feistel Network**.
- Feistel structure consisting multiple rounds of processing of the plaintext, each round consisting of a "substitution" step followed by a permutation step.
- Many advance encryption algorithms are designed using this Feistel structure
  - This includes the DES standard.



Feistel Network –

Brief explanation

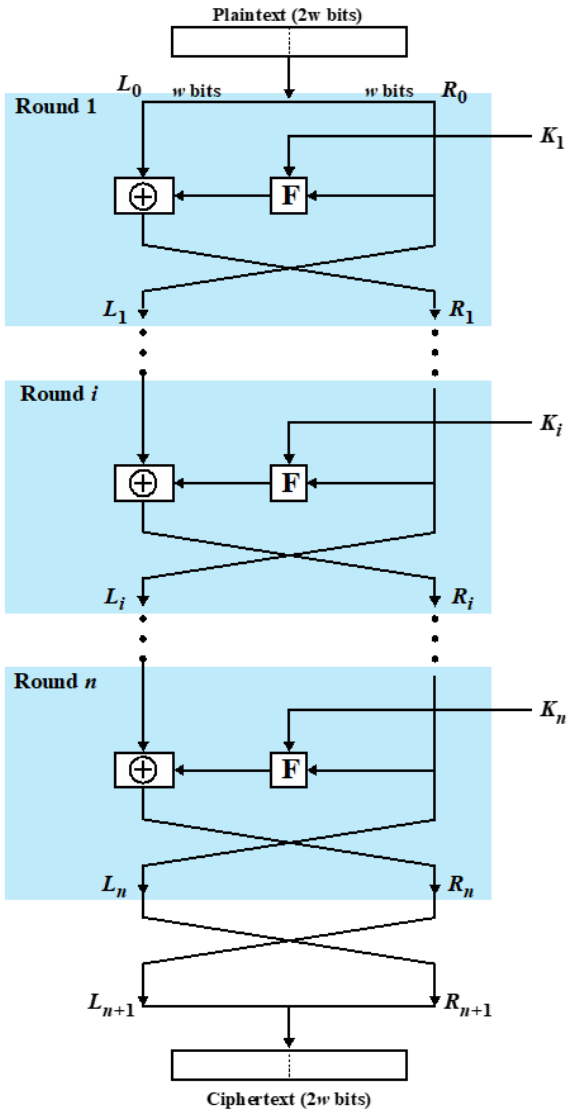
- The inputs to the encryption algorithm are a plaintext block of length 2w bits and a key K .
- The plaintext block is divided into two halves, L^0 and R^0.
- The two halves of the data pass through n rounds of processing and then combine to produce the ciphertext block.
- Each round i has as inputs L^{i-1} and R^{i-1} , derived from the previous round, as well as a subkey K^i, derived from the overall K .
- In general, the subkeys K^i are different from K and from each other and are generated from the key by a subkey generation algorithm.



Feistel Network –

Brief explanation

- All rounds have the same structure. A substitution is performed on the left half of the data.
- This is done by applying a round function F to the right half of the data and then taking the exclusive-OR (XOR) of the output of that function and the left half of the data.
- The round function has the same general structure for each round but is parameterized by the round subkey K^i .
- Following this substitution, a permutation is performed that consists of the interchange of the two halves of the data.



What's happening inside round function "F"?

Users with the Key should be able decrypt it **easily**...How?

Feistel Network

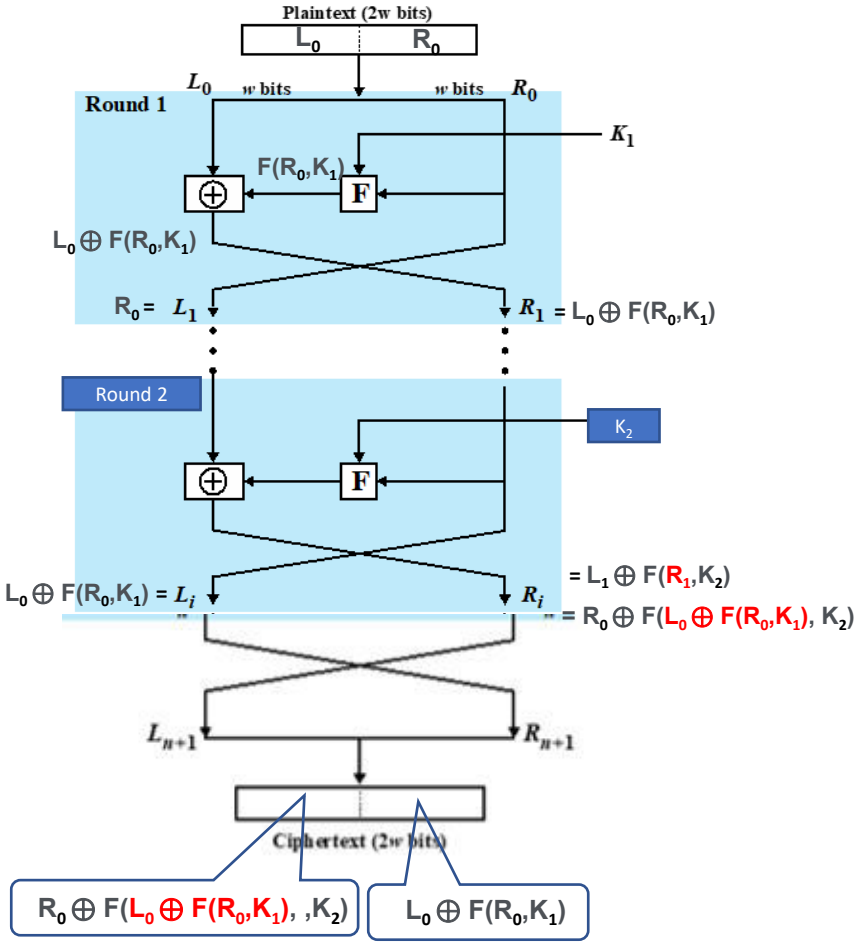
Encryption/Decryption Process

What's happening inside round function "F"?

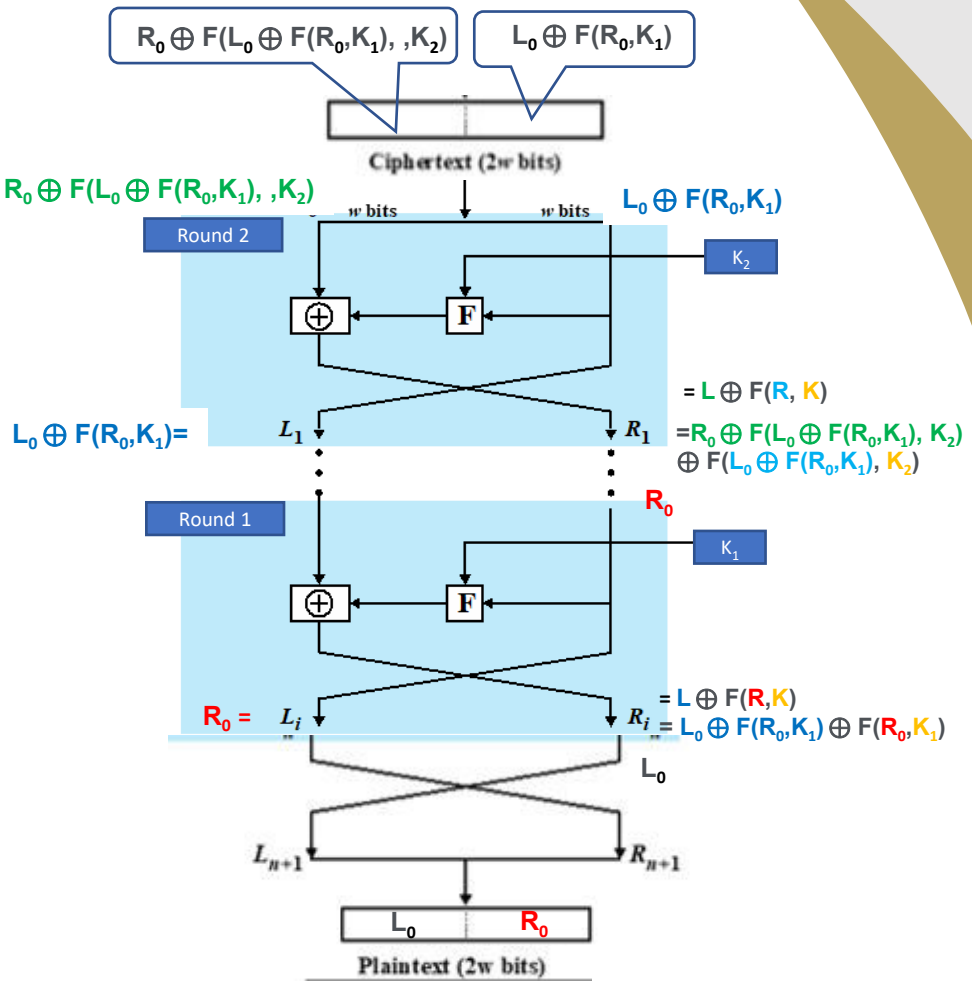
Users with the Key should be able decrypt it **easily**...How?

Feistel Network

Encryption Process



Decryption Process



Week 4 Topic 3

Data Encryption Standard (DES)

Symmetric Encryption Algorithm

Until recently was the most widely used encryption scheme

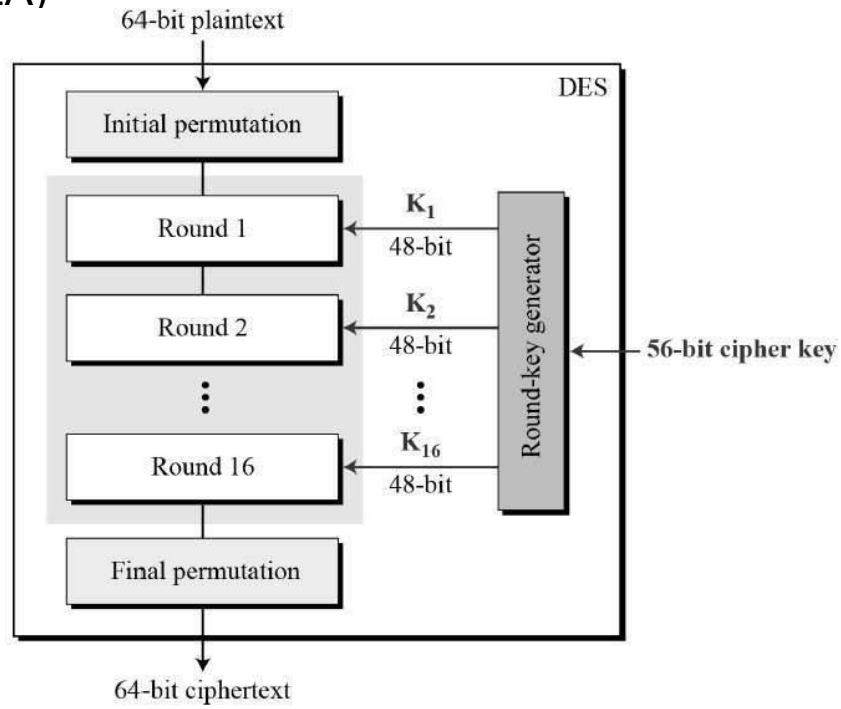
- **Federal Information Processing Standards** FIPS PUB 46
- Referred to as the Data Encryption Algorithm (DEA)

- DES is the most studied encryption algorithm
- DES is a Feistel Cipher.

Working

- **64 bit plaintext block**
- **56 bit key**
- to produce a **64 bit ciphertext block**
- Total**16 rounds**

- Concerns about the use of a 56-bit key
  - Prone to brute-force attack…



https://csrc.nist.gov/csrc/media/publications/fips/46/3/archive/1999-10-25/documents/fips46-3.pdf

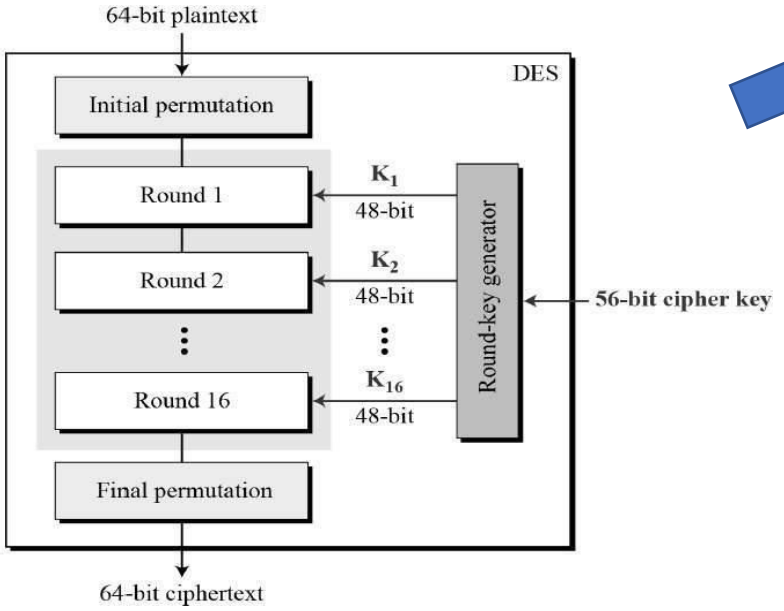
Data Encryption Standard (DES)

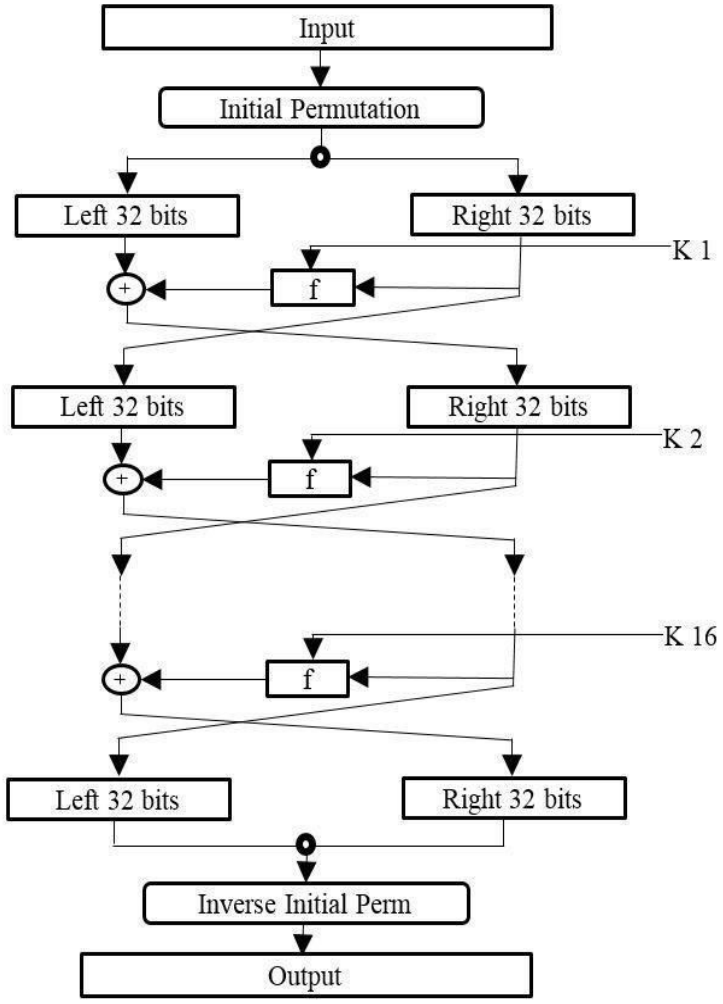
Symmetric Encryption Algorithm

- DES is the most studied encryption algorithm
- DES is a Feistel Cipher.

Working

- **64 bit plaintext block**
- **56 bit key**
- to produce a **64 bit ciphertext block**
- Total**16 rounds**

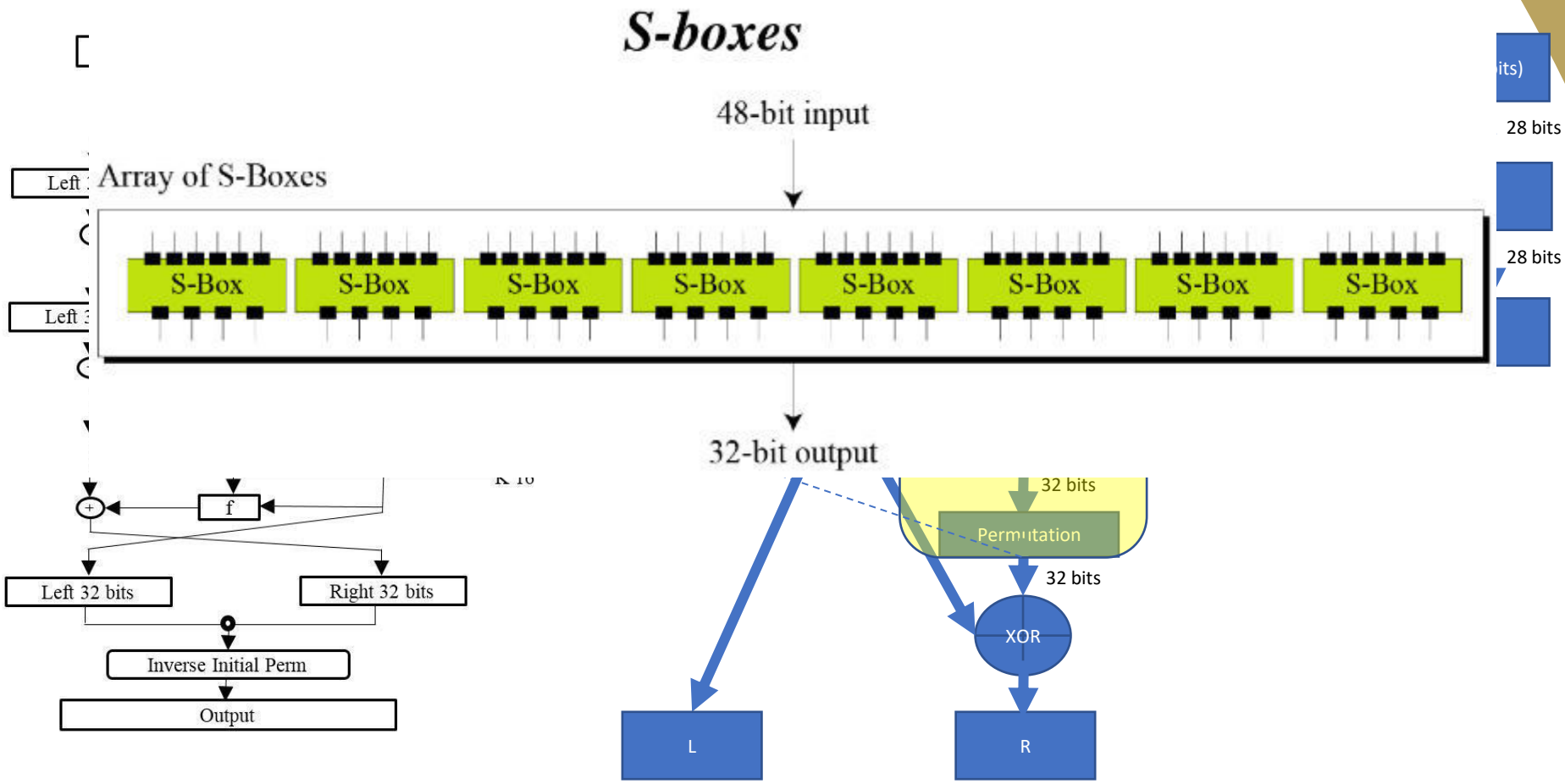




Data Encryption Standard (DES)

What happens in each round?

- 16 Rounds.
- In each round we apply:
  - Expansion Box.
  - Substitution Box.
  - XOR with the round kev.



Data Encryption Standard (DES)

How strong?

Concerns about the use of a 56-bit key

Brute-force attacks

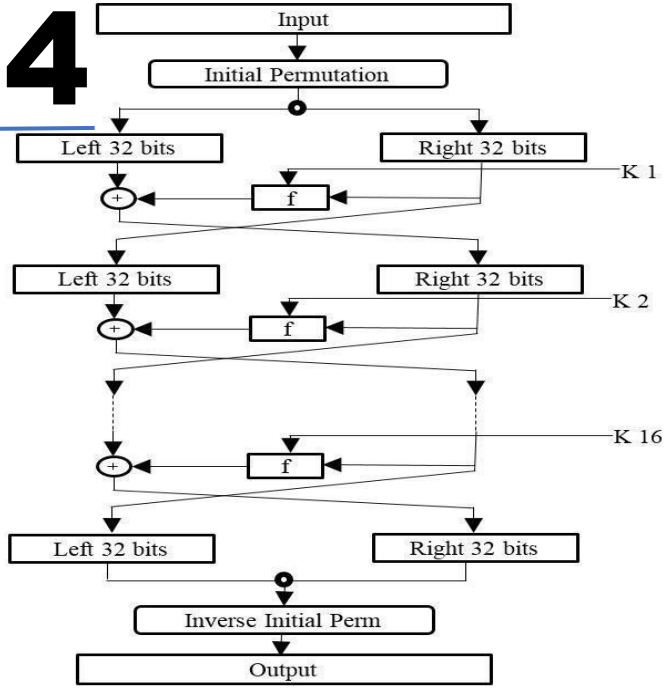
- Try all possible keys on some ciphertext until an intelligible translation into plaintext is obtained
- On average ***half of all possible keys must be tried*** to achieve success
- Number of Keys are dictated by the key size.

Key size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 decryptions/s	Time Required at 10^{13} decryptions/s
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	2^{55} ns = 1.125 years	1 hour

Think…what can you do to make it strong??

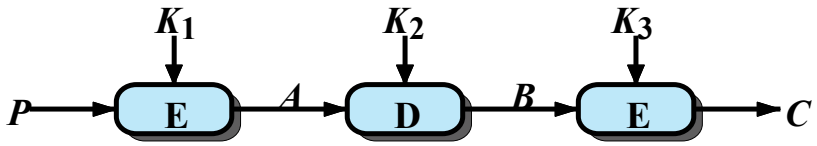
Week 4 Topic 4

Triple DES (3DES)

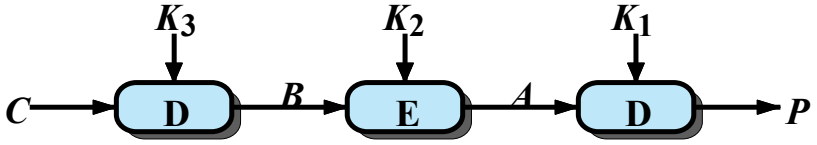


Symmetric Encryption Algorithm

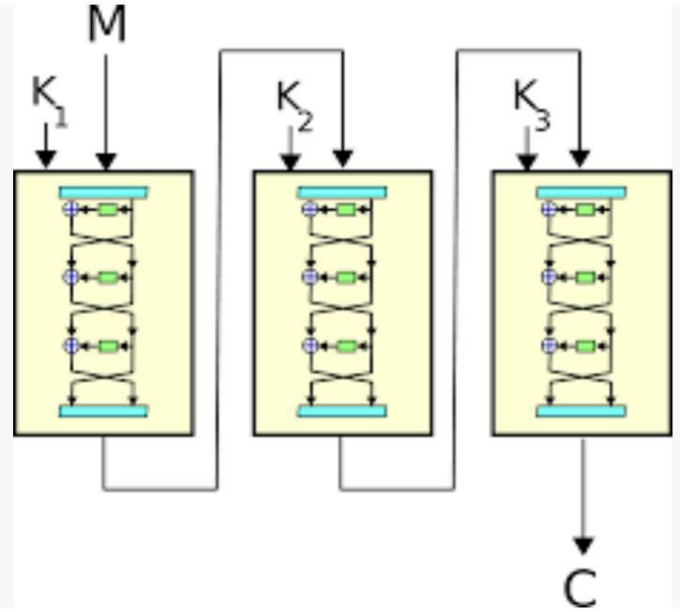
- Designed to address security concerns over DES
  - Original DES soon become prone to brute-force attack
- Need more secure encryption algorithms
- Repeats basic DES algorithm three times using either two or three unique keys
- First standardized for use in financial applications in ANSI standard X9.17 in 1985



(a) Encryption



(b) Decryption



Triple DES (3DES)

Symmetric Encryption Algorithm

Attractions:

- With three distinct keys, 3DES has an effective key length of 168 bits.
- 168-bit key length overcomes the vulnerability to brute-force attack of DES
- Underlying encryption algorithm is the same as in DES

Key size (bits)	Cipher	Number of Alternative Keys	Time Required at 10^9 decryptions/s	Time Required at 10^{13} decryptions/s
56	DES	$2^{56} \approx 7.2 \times 10^{16}$	2^{55} ns = 1.125 years	1 hour
168	Triple DES	$2^{168} \approx 3.7 \times 10^{50}$	2^{167} ns = 5.8×10^{33} years	5.8×10^{29} years

Drawbacks:

- Algorithm is sluggish in software
- Uses a 64-bit block size

Week 4 Topic 5

Advanced Encryption Standard (AES)

Symmetric Encryption Algorithm

NIST National Institute of Standards and Technology

Needed a replacement for 3DES

3DES was not reasonable for long term use

NIST called for proposals for a new AES in 1997

Should have a security strength equal to or better than 3DES

Significantly improved efficiency

Symmetric block cipher

128 bit data and 128/192/256 bit keys

Proposal submissions

In a first round of evaluation, 15 proposed algorithms were accepted.

Second round narrowed the field to 5 algorithms.

Selected Rijndael in November 2001

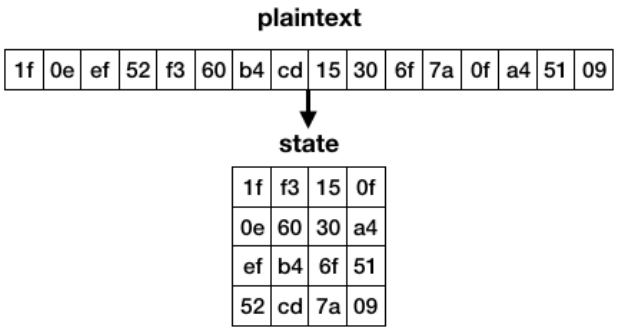
Published as FIPS 197

AES is now widely available in commercial products.

Advanced Encryption Standard (AES)

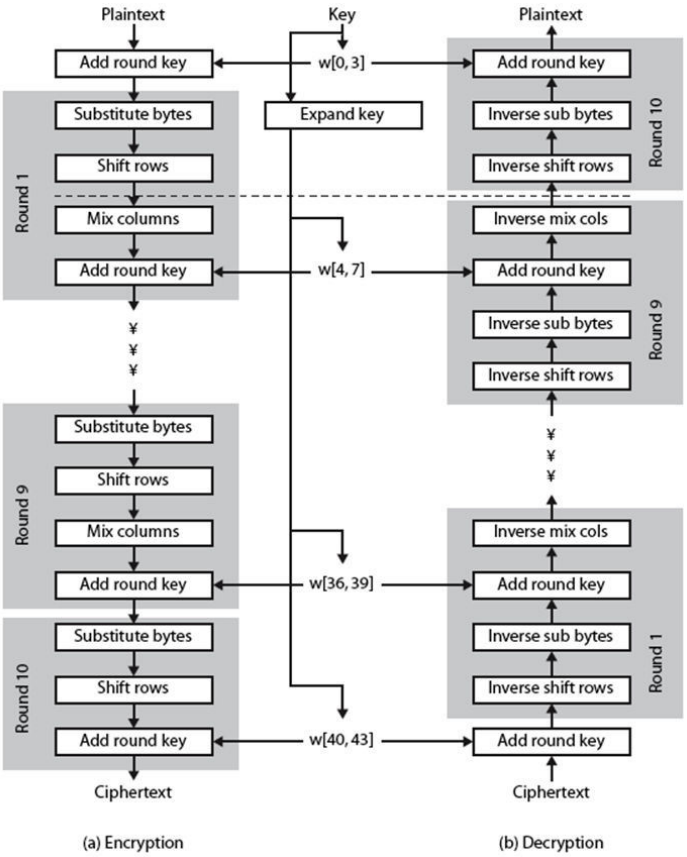
Symmetric Encryption Algorithm

- An **iterative** rather than **Feistel** cipher
  - Processes data as block of 4 columns of 4 bytes
  - Operates on entire data block in every round
- Designed to be:
  - Resistant against known attacks
  - Speed and code compactness on many CPUs
  - Design simplicity
- Data block viewed as 4-by-4 table of bytes
  - Such a table is called the **current state**
- Key is expanded to array of words
- Has 10 rounds in which state the following transformations (called `layers'):
  - BS- byte substitution (1 S-box used on every byte)
  - SR- shift rows (permute bytes between groups/columns)
  - MC- mix columns (uses matrix multiplication in GF(256))
  - ARK- add round key (XOR state with round k
- First and last round are a little different

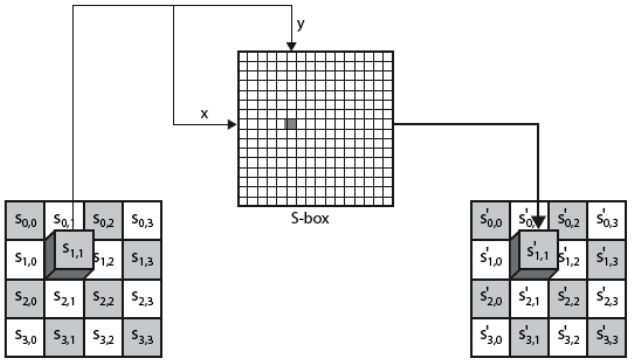


Algorithm	Key length (bits)	Block size (bits)	No of round
AES- 128	128	128	10
AES- 192	192	128	12
AES- 256	256	128	14

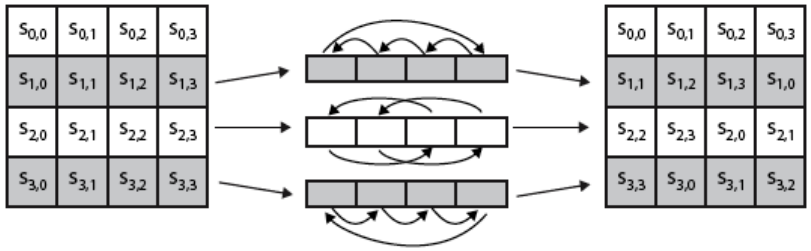
AES Working



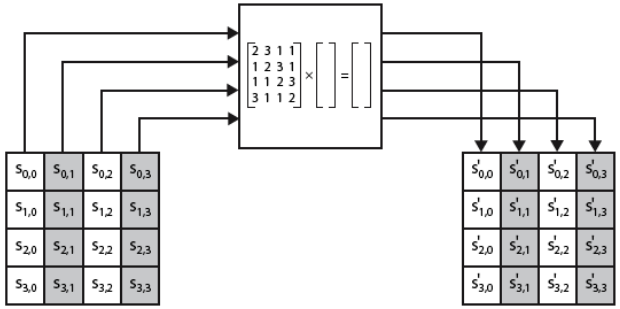
BS



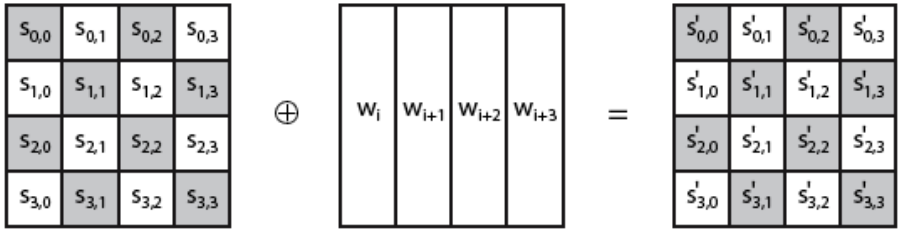
SR



MC

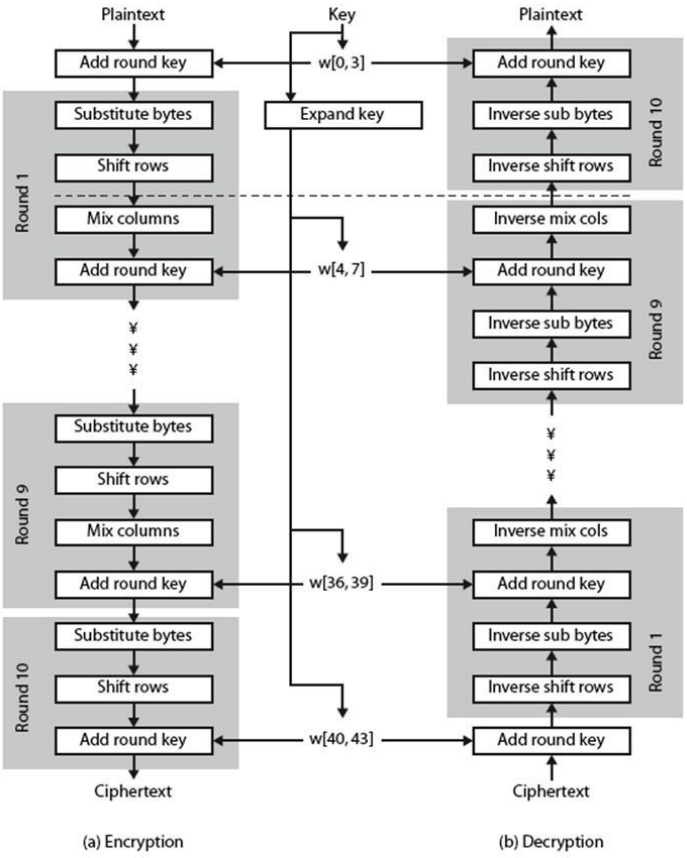


ARK

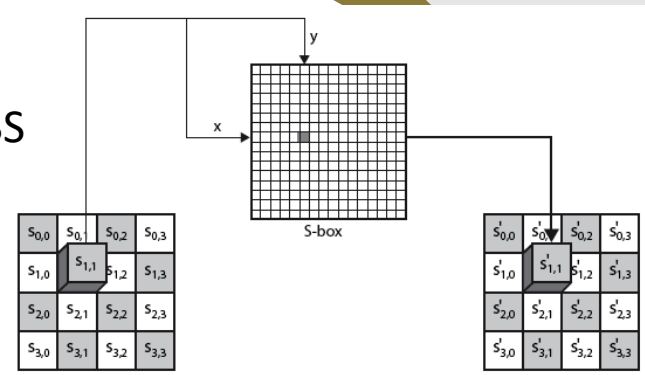


AES Working

Byte Substitution



BS



x \ y	0	1	2	3	4	5	6	7	8	9	a	b	c	d	e	f
0	63	7c	77	7b	f2	6b	6f	c5	30	01	67	2b	fe	d7	ab	76
1	ca	82	c9	7d	fa	59	47	f0	ad	d4	a2	af	9c	a4	72	c0
2	b7	fd	93	26	36	3f	f7	cc	34	a5	e5	f1	71	d8	31	15
3	04	c7	23	c3	18	96	05	9a	07	12	80	e2	eb	27	b2	75
4	09	83	2c	1a	1b	6e	5a	a0	52	3b	d6	b3	29	e3	2f	84
5	53	d1	00	ed	20	fc	b1	5b	6a	cb	be	39	4a	4c	58	cf
6	d0	ef	aa	fb	43	4d	33	85	45	f9	02	7f	50	3c	9f	a8
7	51	a3	40	8f	92	9d	38	f5	bc	b6	da	21	10	ff	f3	d2
8	cd	0c	13	ec	5f	97	44	17	c4	a7	7e	3d	64	5d	19	73
9	60	81	4f	dc	22	2a	90	88	46	ee	b8	14	de	5e	0b	db
a	e0	32	3a	0a	49	06	24	5c	c2	d3	ac	62	91	95	e4	79
b	e7	c8	37	6d	8d	d5	4e	a9	6c	56	f4	ea	65	7a	ae	08
c	ba	78	25	2e	1c	a6	b4	c6	e8	dd	74	1f	4b	bd	8b	8a
d	70	3e	b5	66	48	03	f6	0e	61	35	57	b9	86	c1	1d	9e
e	e1	f8	98	11	69	d9	8e	94	9b	1e	87	e9	ce	55	28	df
f	8c	a1	89	0d	bf	e6	42	68	41	99	2d	0f	b0	54	bb	16

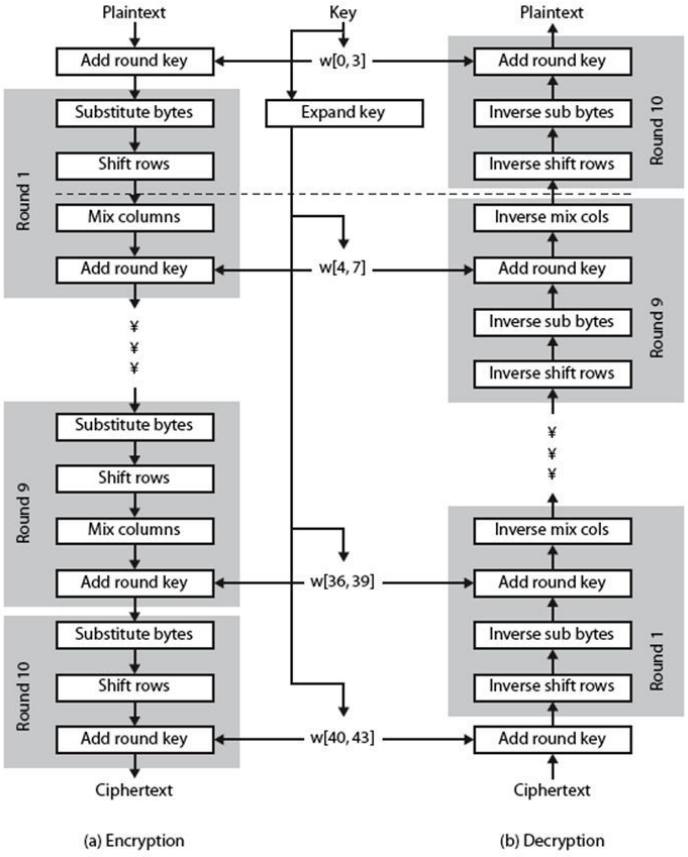
AES S-box

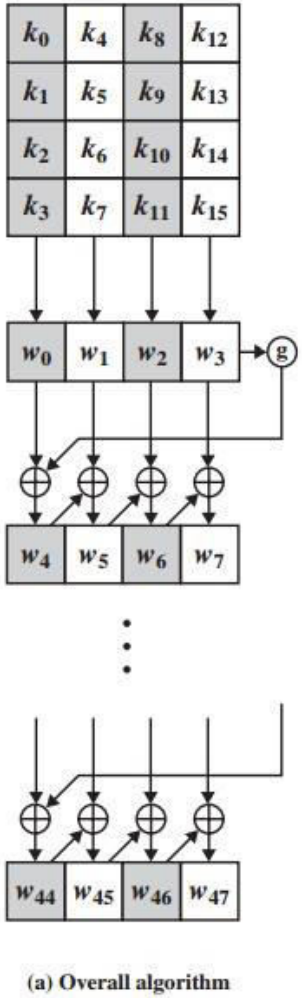
x \ y	0	1	2	3	4	5	6	7	8	9	a	b	c	d	e	f
0	52	09	6a	d5	30	36	a5	38	bf	40	a3	9e	81	f3	d7	fb
1	7c	e3	39	82	9b	2f	ff	87	34	8e	43	44	c4	de	e9	cb
2	54	7b	94	32	a6	c2	23	3d	ee	4c	95	0b	42	fa	c3	4e
3	08	2e	a1	66	28	d9	24	b2	76	5b	a2	49	6d	8b	d1	25
4	72	f8	f6	64	86	68	98	16	d4	a4	5c	cc	5d	65	b6	92
5	6c	70	48	50	fd	ed	b9	da	5e	15	46	57	a7	8d	9d	84
6	90	d8	ab	00	8c	bc	d3	0a	f7	e4	58	05	b8	b3	45	06
7	d0	2c	1e	8f	ca	3f	0f	02	c1	af	bd	03	01	13	8a	6b
8	3a	91	11	41	4f	67	dc	ea	97	f2	cf	ce	f0	b4	e6	73
9	96	ac	74	22	e7	ad	35	85	e2	f9	37	e8	1c	75	df	6e
a	47	f1	1a	71	1d	29	c5	89	6f	b7	62	0e	aa	18	be	1b
b	fc	56	3e	4b	c6	d2	79	20	9a	db	c0	fe	78	cd	5a	f4
c	1f	dd	a8	33	88	07	c7	31	b1	12	10	59	27	80	ec	5f
d	60	51	7f	a9	19	b5	4a	0d	2d	e5	7a	9f	93	c9	9c	ef
e	a0	e0	3b	4d	ae	2a	f5	b0	c8	eb	bb	3c	83	53	99	61
f	17	2b	04	7e	ba	77	d6	26	e1	69	14	63	55	21	0c	7d

AES – Inverse S-box

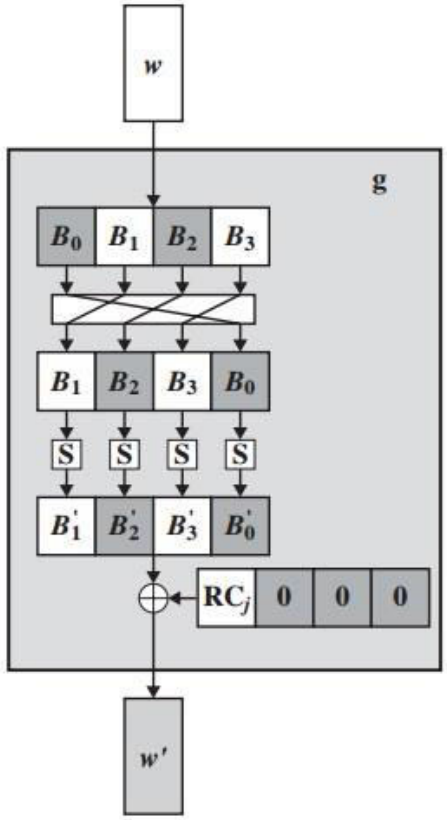
AES Sub-Key Generation

Key Expansion





(a) Overall algorithm



(b) Function g

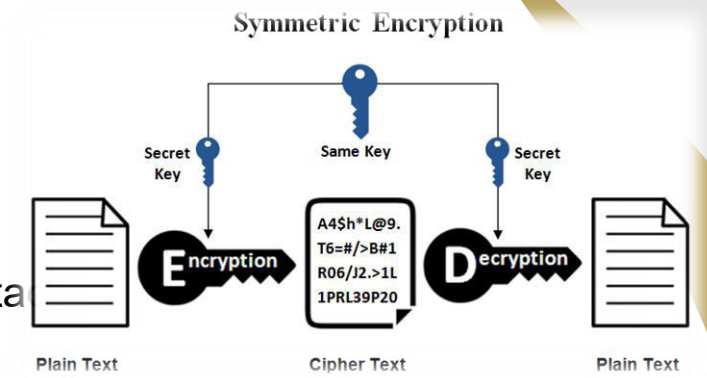
Week 4 Topic 6

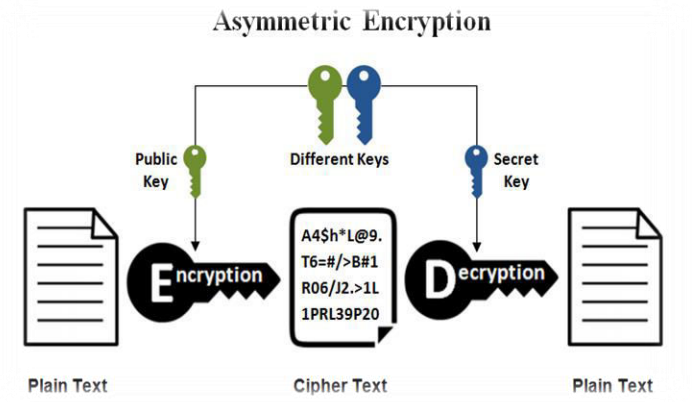
Public-Key Cryptography

Asymmetric Encryption

Why Public-Key?

- Developed to address two major issues:
  - **key distribution** – how to have secure key exchange among communicating parties
  - **digital signatures** – how to verify a message comes inta from the claimed sender
- Public-Key Cryptography was designed to address these concerns
- Public invention due to Whitfield Diffie & Martin Hellman at Stanford Univ. in 1976
  - known earlier in classified community

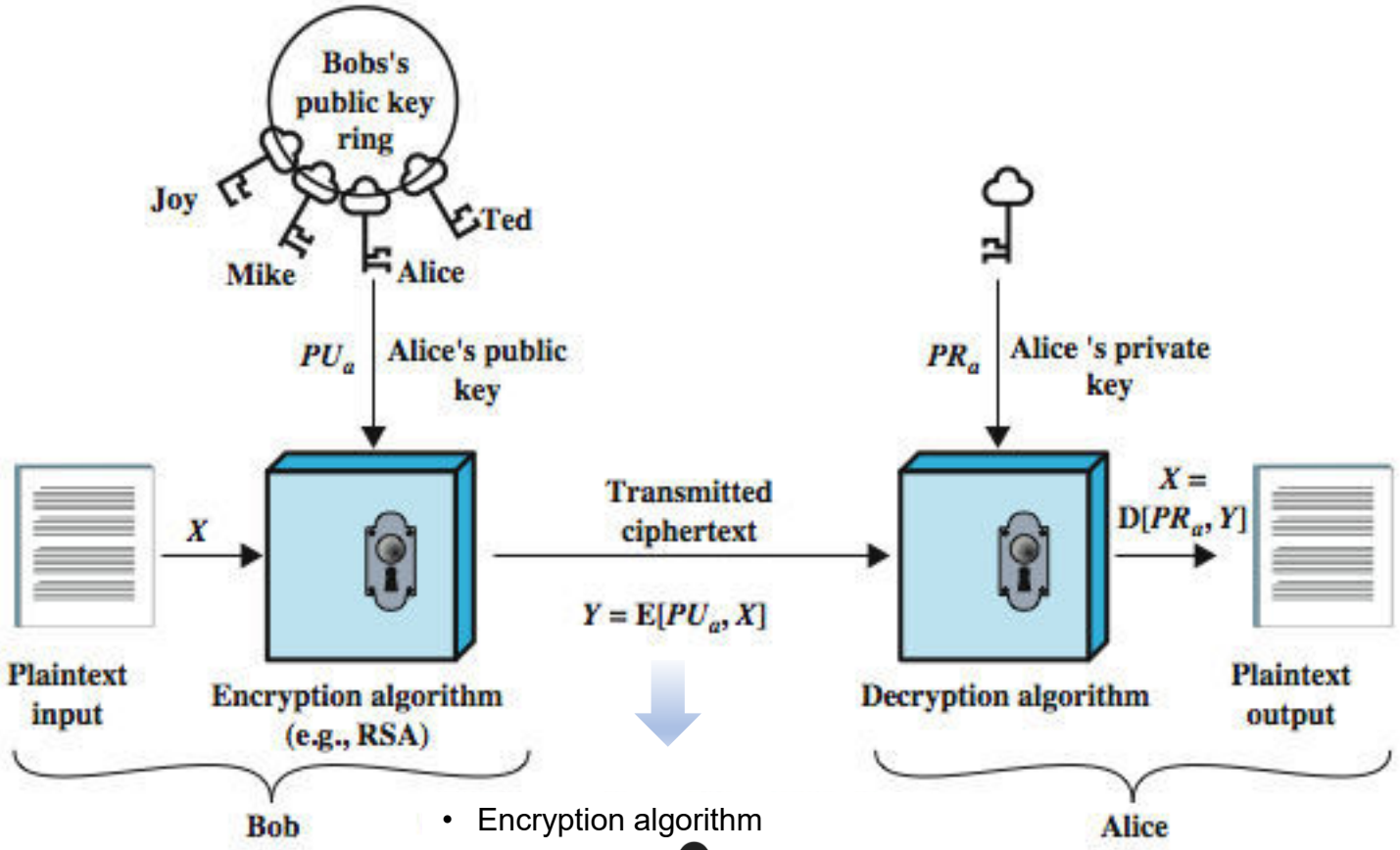




- Probably most significant advancement in the history of cryptography
- Uses two keys – a public & a private key
- Asymmetric since different keys are used for encryption and decryption
- Uses clever application of number theoretic concepts to function
- This is not meant to replace Symmetric Encryption (private key crypto) but rather to complement…

Public-Key Cryptography

How public and private keys are used?



- Encryption algorithm
- Public Key
- Ciphertext

Private Key??
Plaintext??

Public-Key Cryptography

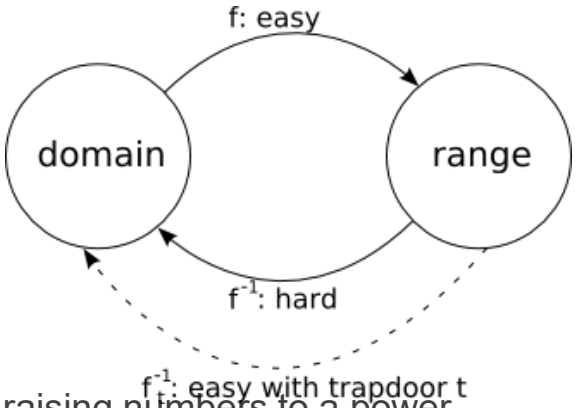
Example of public and private keys

Week 4 Topic 7

One-way Functions

Base for Modern Cryptography

- A **one-way function** is “easy” to compute and “difficult” to reverse.



- The process of **exponentiation** means raising numbers to a power.
- Raising **2** to the power **3**, normally denoted 2^3 just means multiplying **2** by itself **3** times. In other words:
  - 2^3 =(2x2x2)
  - a^x = a x a x a x … x a
- **Modular exponentiation** means computing a^x mod some other number **n**.
  - a^x mod n.
- In other words, given a number **a** and a prime number **n**, the function
  - f(x) = a^x mod n
    is a one-way function

For x=b, we can easily compute $y=f(b)=a^b \bmod n$ But its reverse is :(

For a particular y=c, its difficult to get respective x Such that $c=f(b)=a^x \bmod n$

One-way Functions

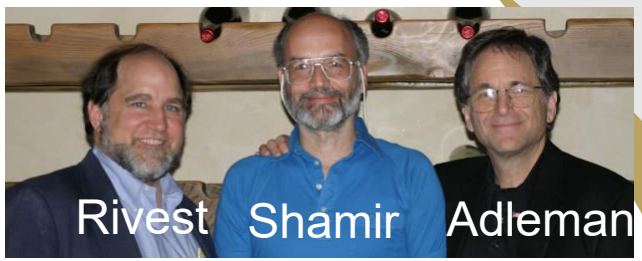
Base for Modern Cryptography

Another Example

- It is easy to take two prime numbers and multiply them together.
- If the numbers are small, we can do this in our heads, on a piece of paper.
- What if numbers get bigger and bigger?
- Multiplication of two **big** prime numbers is **believed** to be a one-way function.
- Check Wikipedia for RSA Numbers
- https://en.wikipedia.org/wiki/RSA_numbers#:~:text=In%20mathematics%2C%20the%20RSA%20numbers,prime%20factors%20of%20each%20number.
- One of the modern asymmetric algorithm RSA is based on this idea

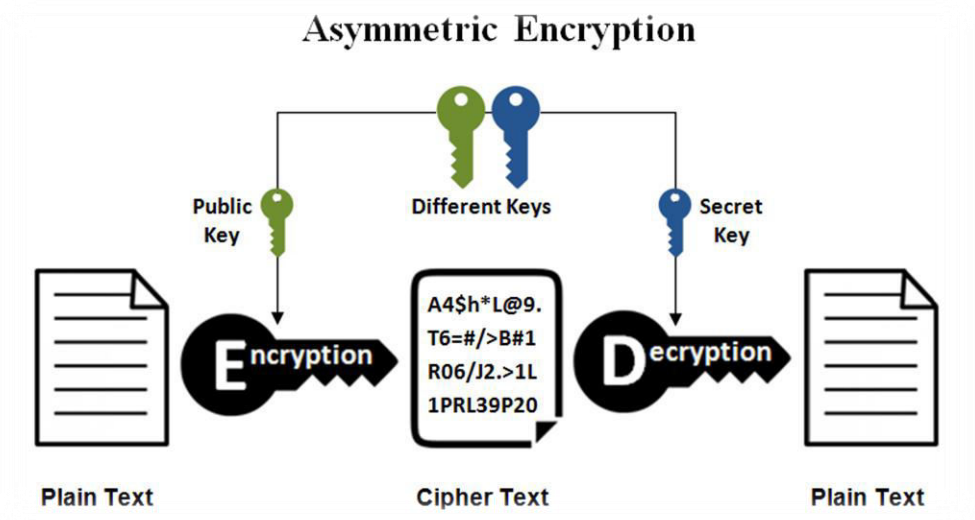
Week 4 Topic 8

RSA Algorithm



Asymmetric Encryption Algorithm

- The **RSA** algorithm was the first practical implementation of public key encryption.
- It is named after the three researchers Ron Rivest, Adi Shamir and Len Adleman



RSA Algorithm

How the public and private keys are selected?

- Let **n** be the product of two large primes **p** and **q** **(i.e. n=pxq)**
  - at least 512 bits.
- Select a special number **e**
  - greater than 1 and less than (**p**-1)(**q**-1). The precise mathematical property that **e** must have is that there must be no numbers that divide neatly into **e** and into (**p**-1)(**q**-1), except for 1.
- Publish the pair of numbers (**n**,**e**)
- Compute the private key **d** from **p**, **q** and **e**
- The private key **d** is computed to be the unique inverse of **e** modulo (**p**-1)(**q**-1).
- In other words, **d** is the unique number less than (**p**-1)(**q**-1) that when multiplied by **e** gives you 1 modulo (**p**-1)(**q**-1).
  - ed = 1 mod (p-1)(q-1)

Public key: (e, n)
Private key: (d, n)

RSA Algorithm

How the message is encrypted and decrypted?

Encryption

Given a message M, $0 < M < n$ $\quad M \in Z_n - \{0\}$

use public key (e, n)

compute $C = M^e \bmod n$ $\quad C \in Z_n - \{0\}$

Decryption

Given a ciphertext C, use private key (d)

Compute $C^d \bmod n = (M^e \bmod n)^d \bmod n = M^{ed} \bmod n = M$

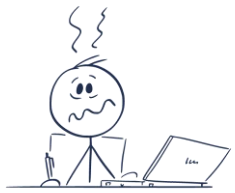
Sender Side

Plaintext: M

Encryption

$C = M^e \bmod (n=pq)$

Ciphertext: C



Receiver Side

Ciphertext: C

Plaintext: $M = C^d \bmod n$

From n, difficult to figure out p,q

From (n,e), difficult to figure d.

From (n,e) and C, difficult to figure out M s.t. $C = M^e$

RSA Algorithm

Can we see the public and private keys?

- Let **n** be the product of two large primes **p** and **q** **(i.e. n=pxq)**
  - at least 512 bits.
- Select a special number **e**
  - greater than 1 and less than (**p**-1)(**q**-1). The precise mathematical property that **e** must have is that there must be no numbers that divide neatly into **e** and into (**p**-1)(**q**-1), except for 1.
- Publish the pair of numbers (**n**,**e**)
- Compute the private key **d** from **p**, **q** and **e**
- The private key **d** is computed to be the unique inverse of **e** modulo (**p**-1)(**q**-1).
- In other words, **d** is the unique number less than (**p**-1)(**q**-1) that when multiplied by **e** gives you 1 modulo (**p**-1)(**q**-1).
  - ed = 1 mod (p-1)(q-1)

Public key: (e, n)
Private key: (d, n)

A Digital Certificate is **an electronic file that is tied to a cryptographic key pair and authenticates the identity of a website, individual, organization, user, device or server**. It is also known as a public key certificate or identity certificate.

https://www.boxentriq.com/code-breaking/hex-to-decimal-converter

Week 4 Topic 9

RSA Algorithm Example

How are the public and private keys generated?

- Assume we have generated the RSA public-private key pair:

- Choose two "big" primes p=11 and q=13
- Compute the number **n** =p*q = 143

- Number **e=?** ∈ **[1,** (p-1)(q-1)**] = [1, 120]**
  - Relative prime with (p-1)(q-1)
- **e=7**

- private exponent ***d*** = ?
  - ed = 1 mod (p-1)(q-1)
- ***d*** =103

Public key: (e, n)
Private key: (d, n)

- Let **n** be the product of two large primes **p** and **q** **(i.e. n=pxq)**
  - at least 512 bits.
- Select a special number **e**
  - greater than 1 and less than (**p**-1)(**q**-1). The precise mathematical property that **e** must have is that there must be no numbers that divide neatly into **e** and into (**p**-1)(**q**-1), except for 1.
- Publish the pair of numbers (**n**,**e**)
- Compute the private key **d** from **p**, **q** and **e**
- The private key **d** is computed to be the unique inverse of **e** modulo (**p**-1)(**q**-1).
- In other words, **d** is the unique number less than (**p**-1)(**q**-1) that when multiplied by **e** gives you 1 modulo (**p**-1)(**q**-1).
  - ed = 1 mod (p-1)(q-1)

Public key: (e, n)
Private key: (d, n)

RSA Algorithm Example

How the message is encrypted and decrypted?

- number **n** say 143
- **e=7**
- ***d*** =103

Public key: (e, n)
Private key: (d, n)

- Let's **encrypt** a secret message ***msg*** = **83**

Encryption
$C = M^e \bmod (n=pq)$

- Let's now try **decryption** of the secret message **C=*8***

Plaintext: $M = C^d \bmod n$

https://cryptobook.nakov.com/asymmetric-key-ciphers/the-rsa-cryptosystem-concepts

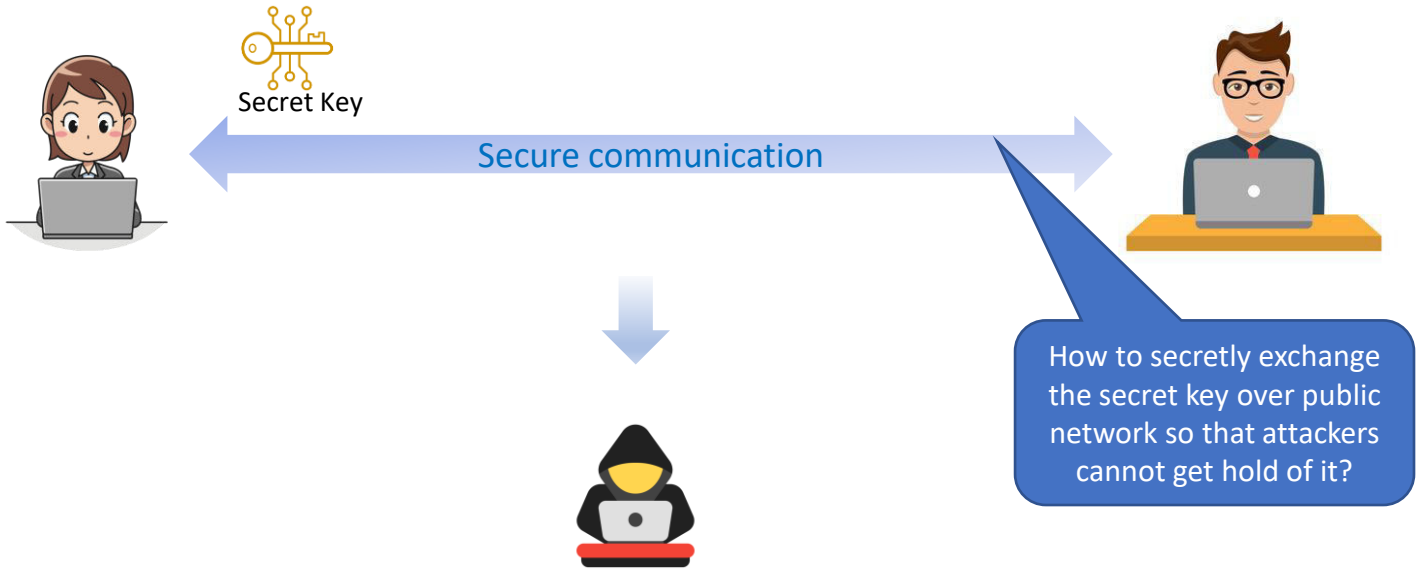
Week 4 Topic 10

Diffie–Hellman Key Exchange Protocol

For Secure Key Exchange

Two major issues with symmetric encryptions algorithms:

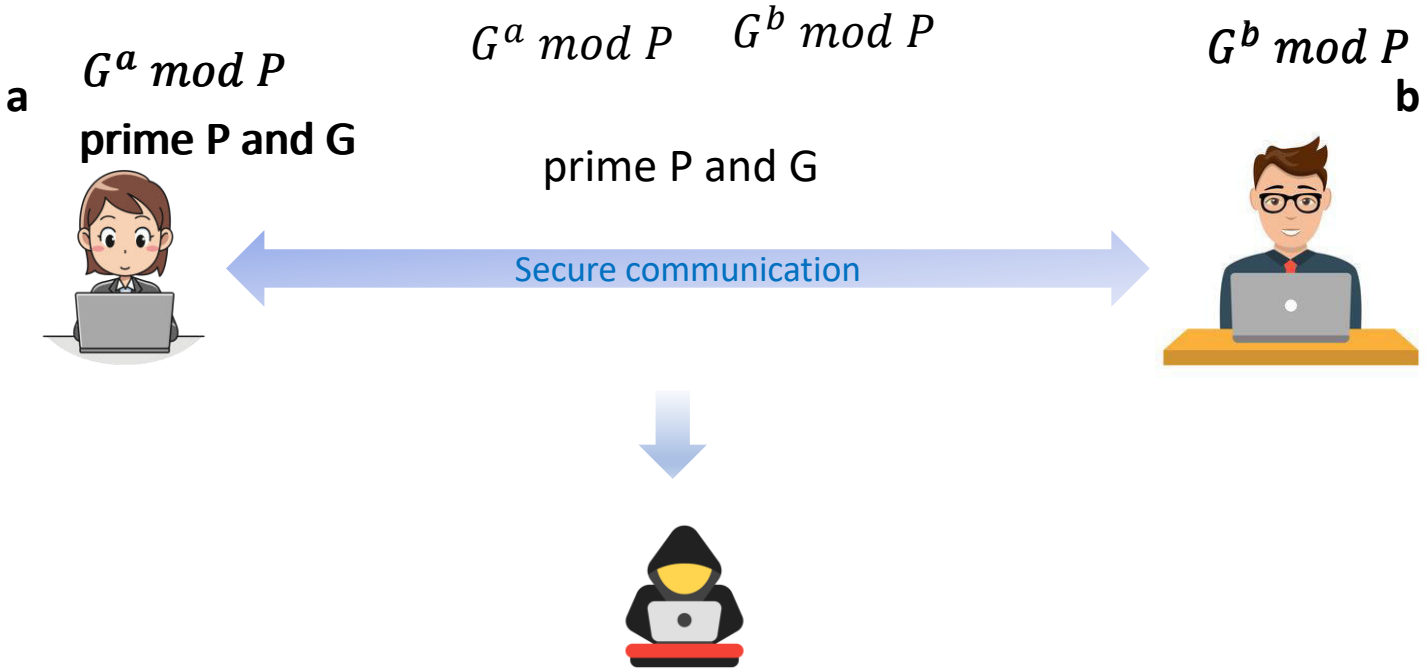
- **key distribution** – how to have secure key exchange among communicating parties
- **digital signatures** – how to verify a message comes intact from the claimed sender



Diffie–Hellman Key Exchange Protocol

How Keys are secretly exchanged?

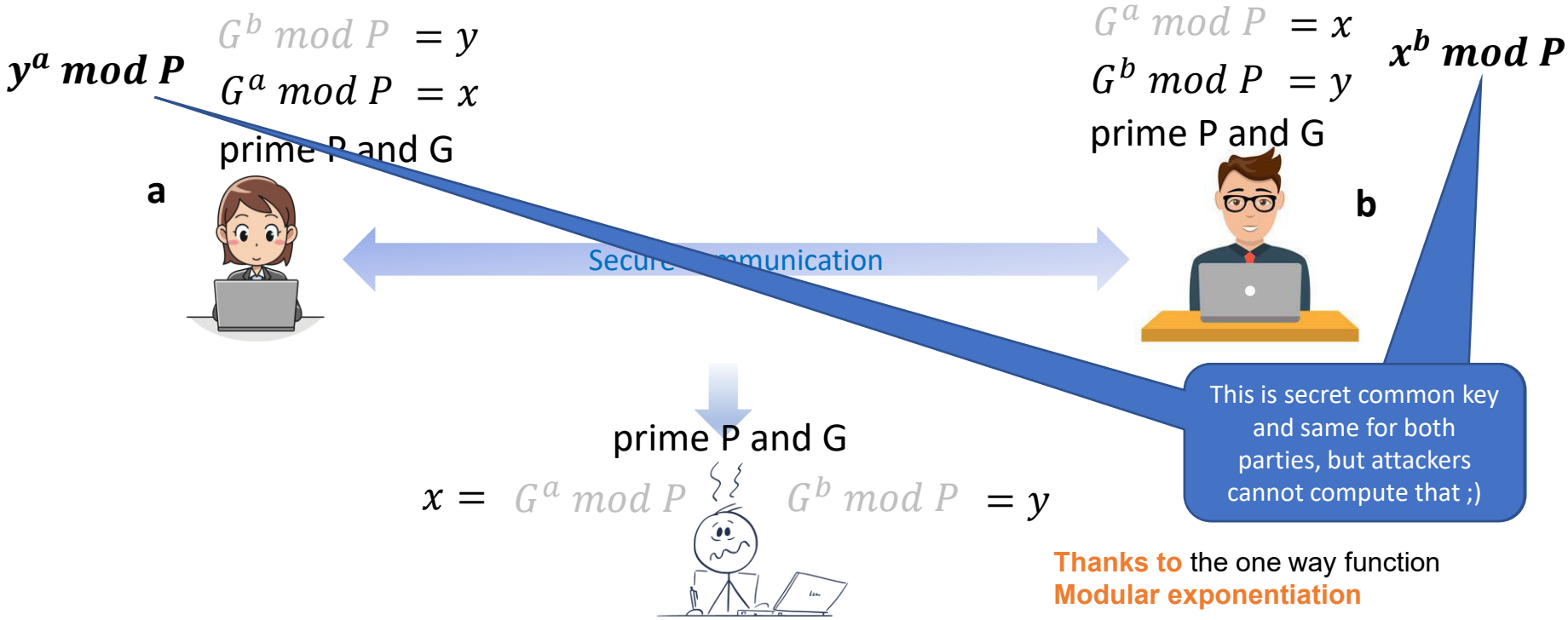
- Lets see, how two users can secretly exchange the key in presence of attacker
- Either party can choose one prime P and G (a primitive root of P) and exchange with the other…attacker can also see that
- Next, each party choose their private values
  - lets say, user-1 choose "**a**" and user-2 choose **"b"**.
- Afterwards, both parties compute a number $G^x \ mod \ P$ and send it to the other
- Finally, both parties can generate the common secret key



Diffie–Hellman Key Exchange Protocol

How Keys are secretly exchanged?

- Lets see, how two users can secretly exchange the key in presence of attacker
- Either party can choose one prime P and G (a primitive root of P) and exchange with the other…attacker can also see that
- Next, each party choose their private values
  - lets say, user-1 choose "**a**" and user-2 choose **"b"**.
- Afterwards, both parties compute a number $G^x \ mod \ P$ and send it to the other
- Finally, both parties can generate the common secret key



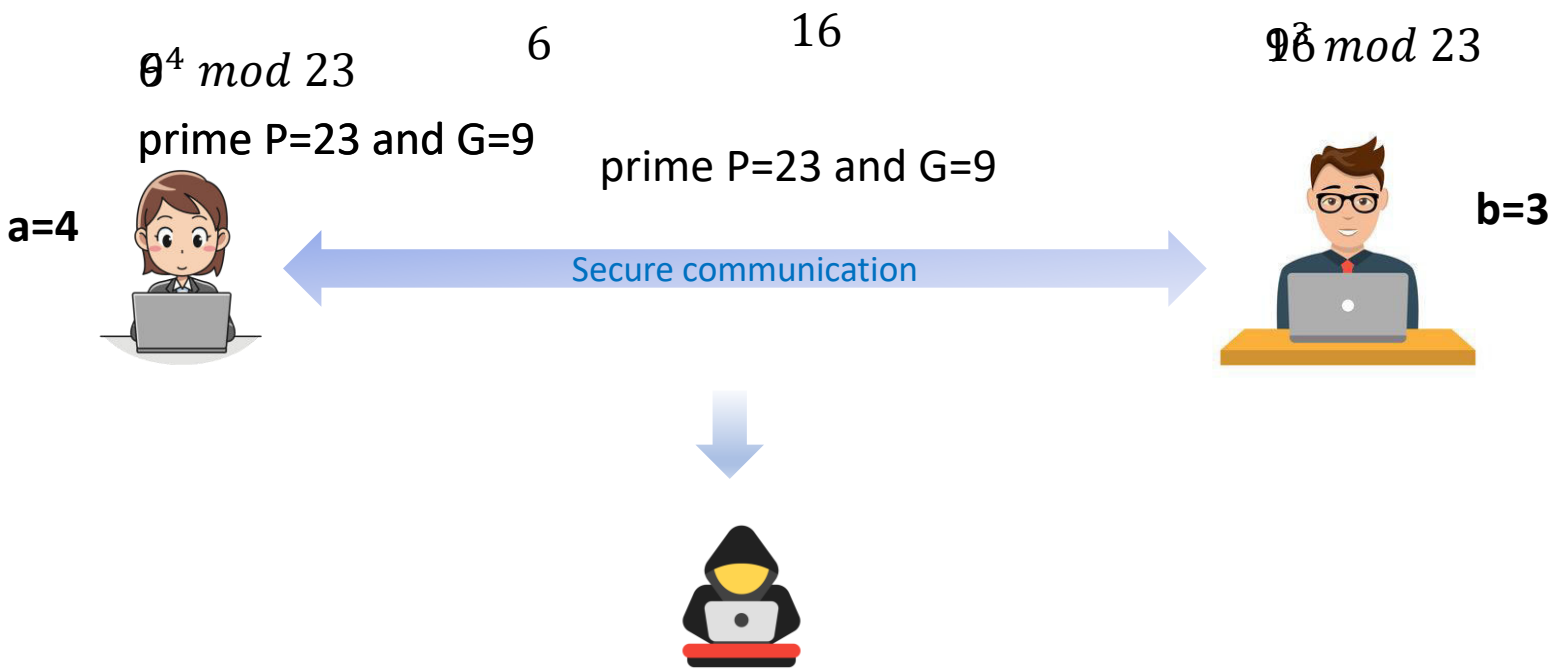
Thanks to the one way function
Modular exponentiation

Week 4 Topic 11

Diffie–Hellman Key Exchange - Example

How Keys are secretly exchanged?

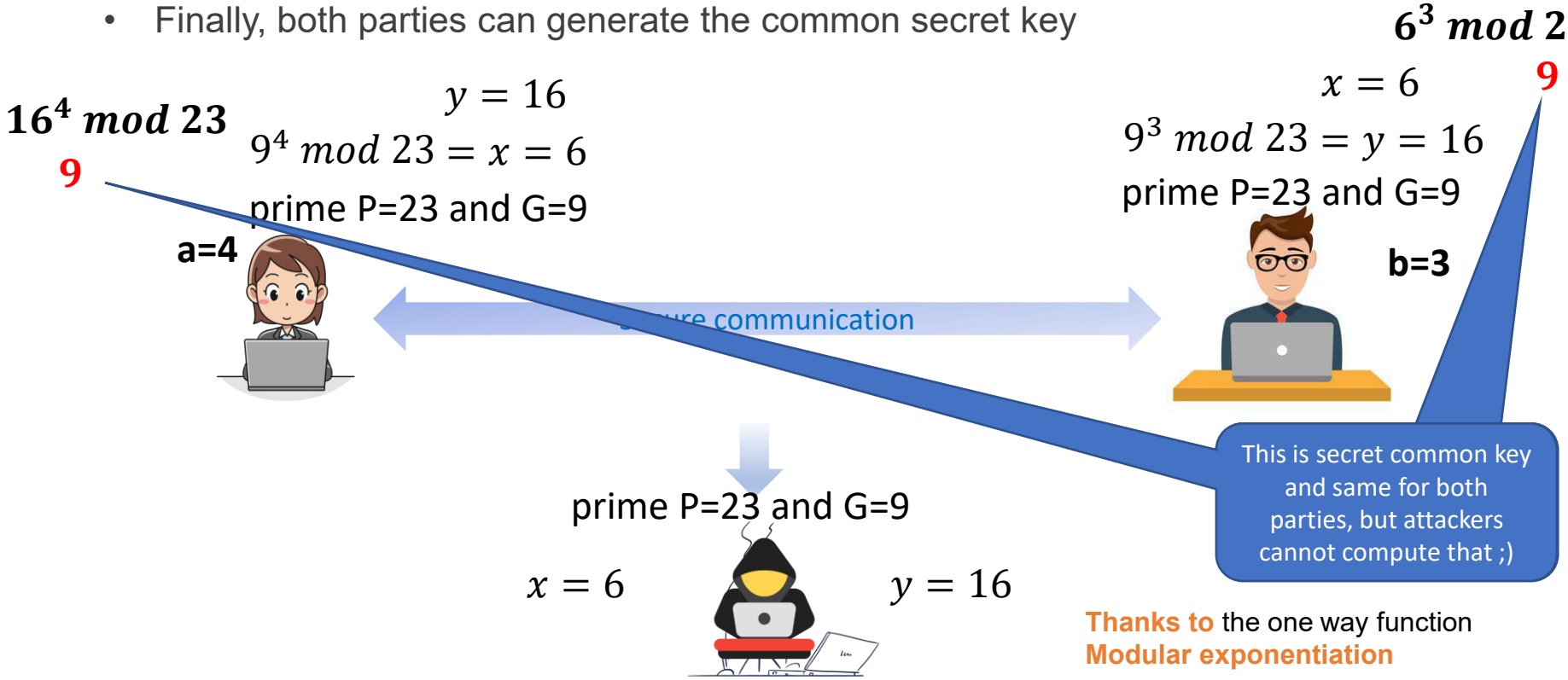
- Lets see, how two users can secretly exchange the key in presence of attacker
- Either party can choose one prime P=23 and G=9 (a primitive root of P) and exchange with the other…attacker can also see that
- Next, each party choose their private values
  - lets say, user-1 choose "**a=4"** and user-2 choose **"b=3"**.
- Afterwards, both parties compute a number $G^x \ mod \ P$ and send it to the other
- Finally, both parties can generate the common secret key



Diffie–Hellman Key Exchange - Example

How Keys are secretly exchanged?

- Lets see, how two users can secretly exchange the key in presence of attacker
- Either party can choose one prime P and G (a primitive root of P) and exchange with the other…attacker can also see that
- Next, each party choose their private values
  - lets say, user-1 choose "**a**" and user-2 choose **"b"**.
- Afterwards, both parties compute a number $G^x \ mod \ P$ and send it to the other
- Finally, both parties can generate the common secret key



Thanks to the one way function
Modular exponentiation

Week 4 Topic 12

Security Issue in the Diffie-Hellman

Can we trust the Diffie-Hellman Algorithm for secure Key exchange?

- Diffie-Hellman Algorithm is safe against sniffing attack…interception

- But what if attacker sits in the middle?

Man in the Middle Attack

Week No. 5

Network Security

Week 5 Topic 1

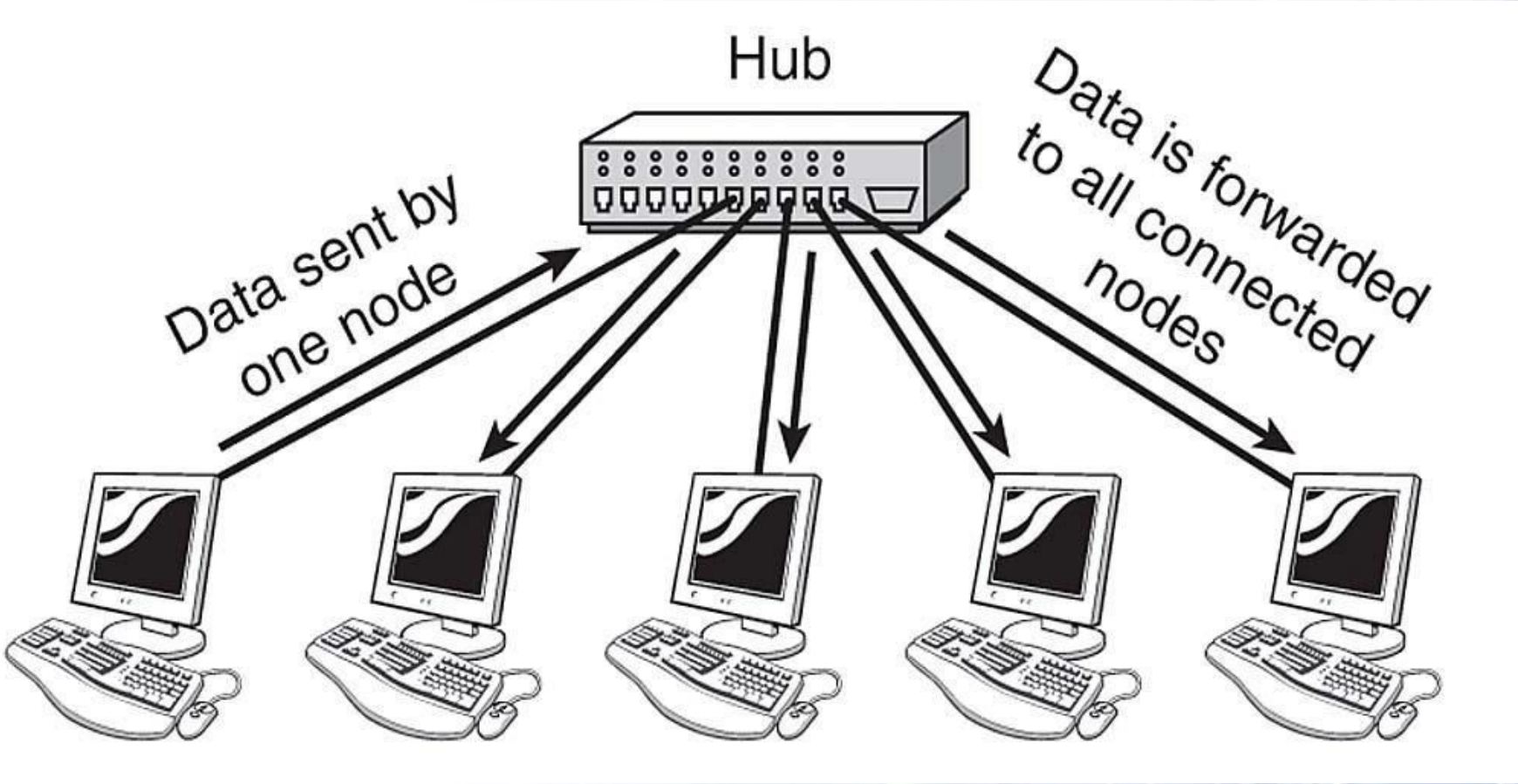
Introduction

- In this topic we will cover the basics of network devices and their functions.
- We will discuss different types of network devices, including routers, switches, firewalls, and more.

Hub

- A network hub is a device that broadcasts data to every computer or Ethernet-based device connected to it.
- Network hubs are best suited for small, simple local area network (LAN) environments.

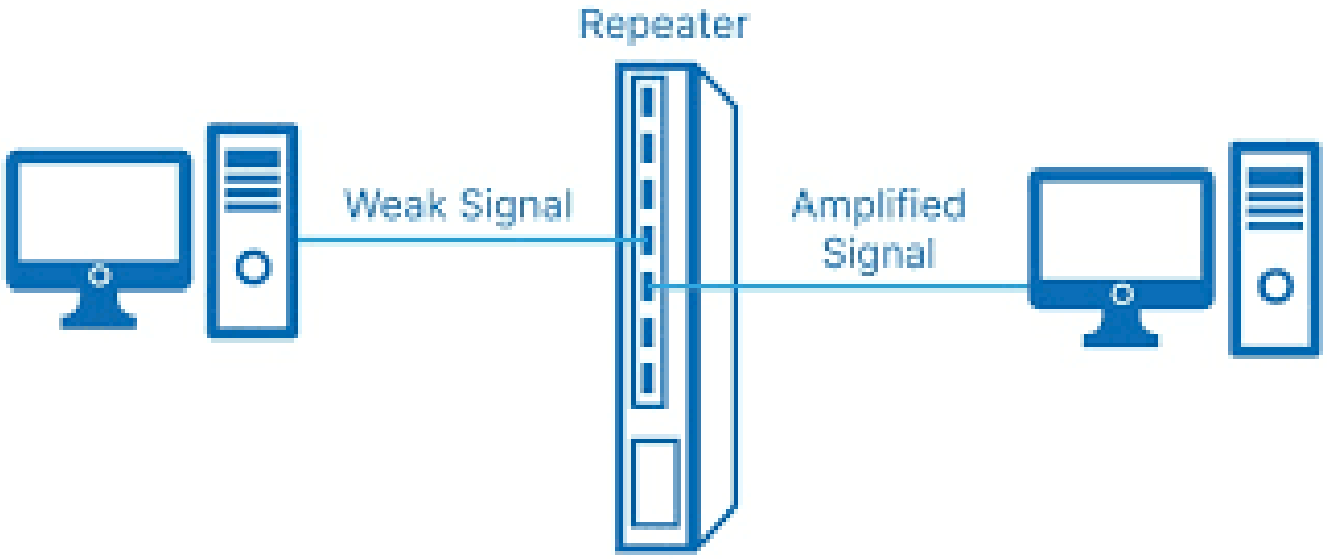
Working of Hub



Repeater

- Repeaters are network devices operating at physical layer of the OSI model that amplify or regenerate an incoming signal before retransmitting it.
- They are incorporated in networks to expand its coverage area. They are also known as signal boosters.

Working of Repeater



Switch

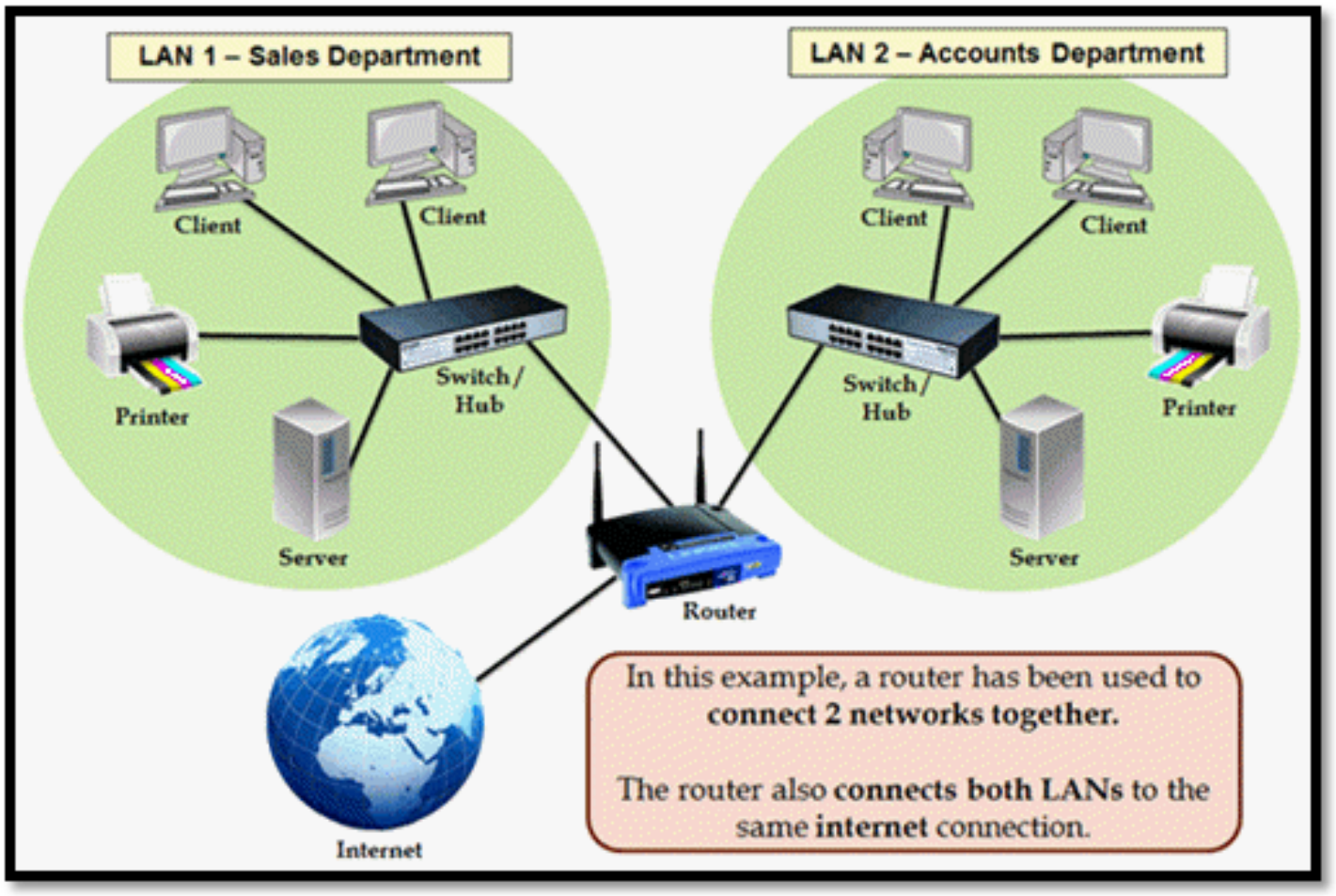
- A switch is a network device that connects devices on a local area network (LAN).
- It operates at the data link layer of the OSI model and uses MAC addresses to direct traffic to the appropriate device.

Switch’s working

Routers

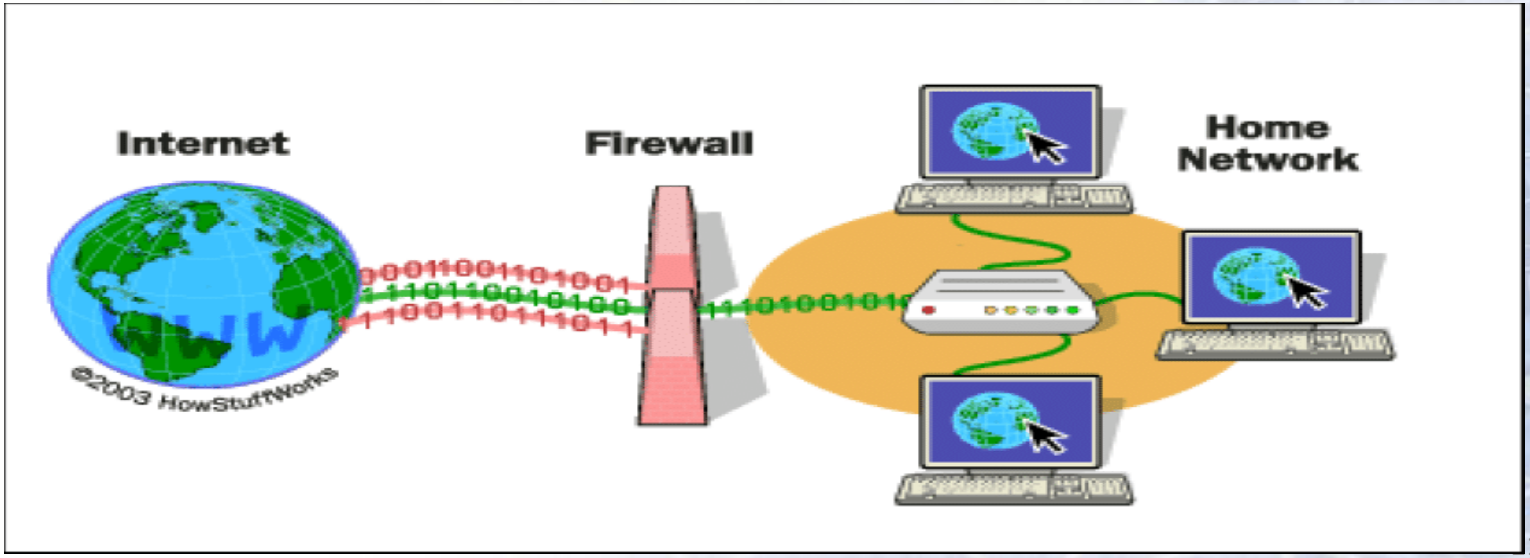
- A router is a network device that connects multiple networks and routes traffic between them.
- It operates at the network layer of the OSI model and uses routing tables to determine the best path for data to travel.

Router's working



Firewalls

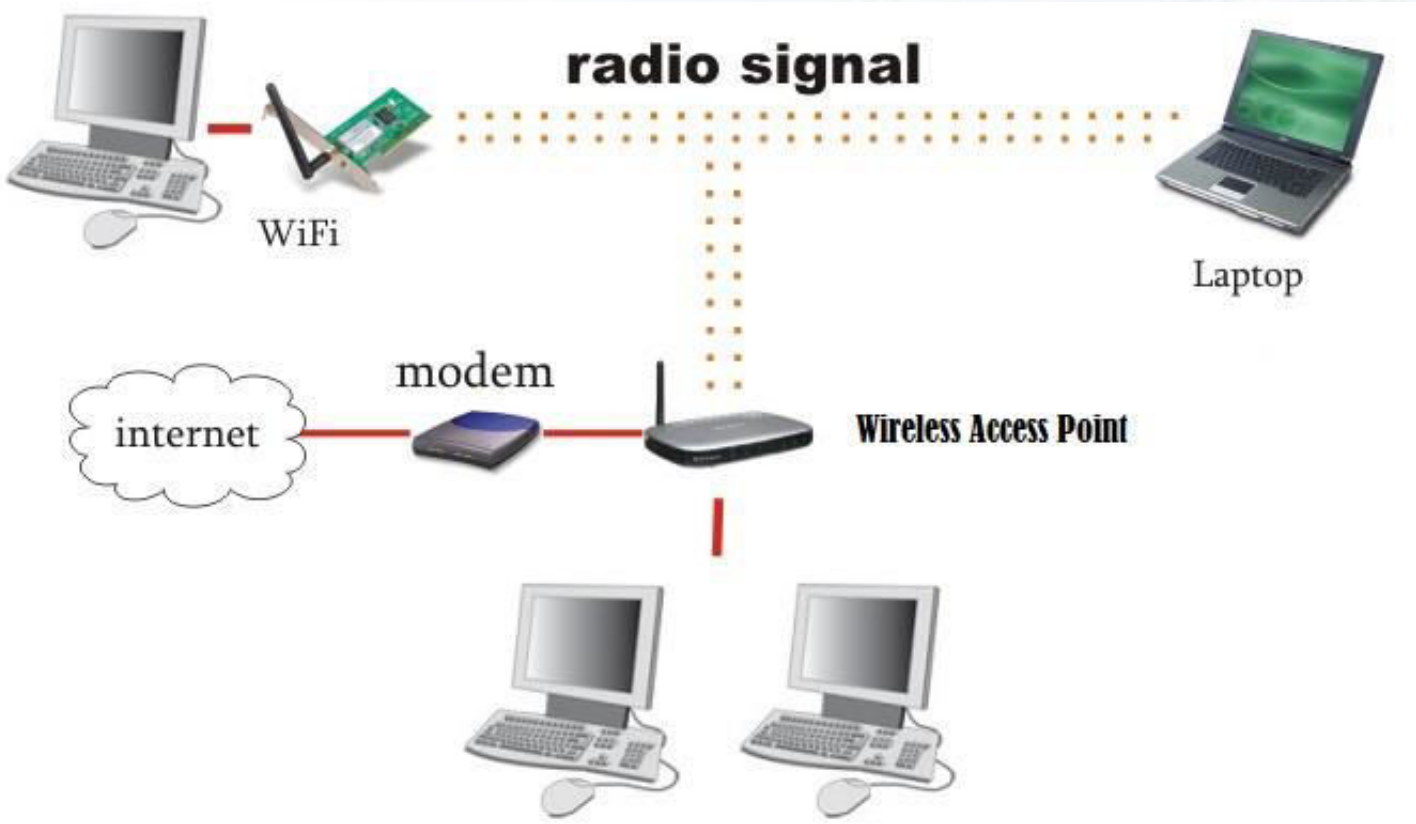
- A firewall is a network security device that monitors and controls incoming and outgoing network traffic.
- It can block unauthorized access to a network and prevent malicious traffic from entering or leaving the network.



Wireless Access Points

- A wireless access point (WAP) is a network device that allows wireless devices to connect to a wired network.
- It provides a wireless signal for devices to connect to and can support multiple wireless devices simultaneously.

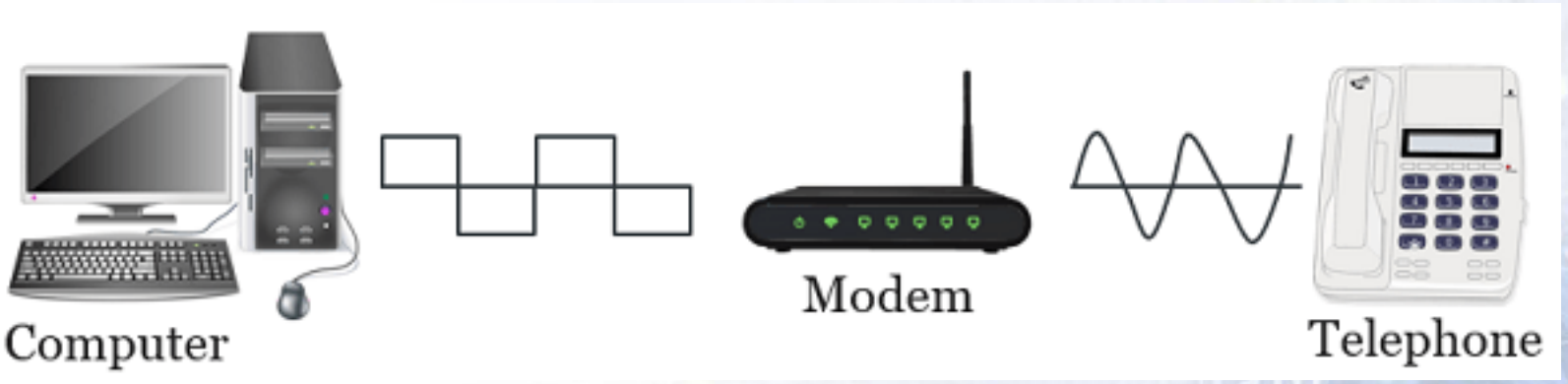
Wireless Access Point's working



Modems

- A modem is a network device that modulates and demodulates signals between a computer and the internet service provider (ISP).
- It converts digital signals from a computer into analog signals that can travel over phone lines or cable lines, and vice versa.

Working of Modem

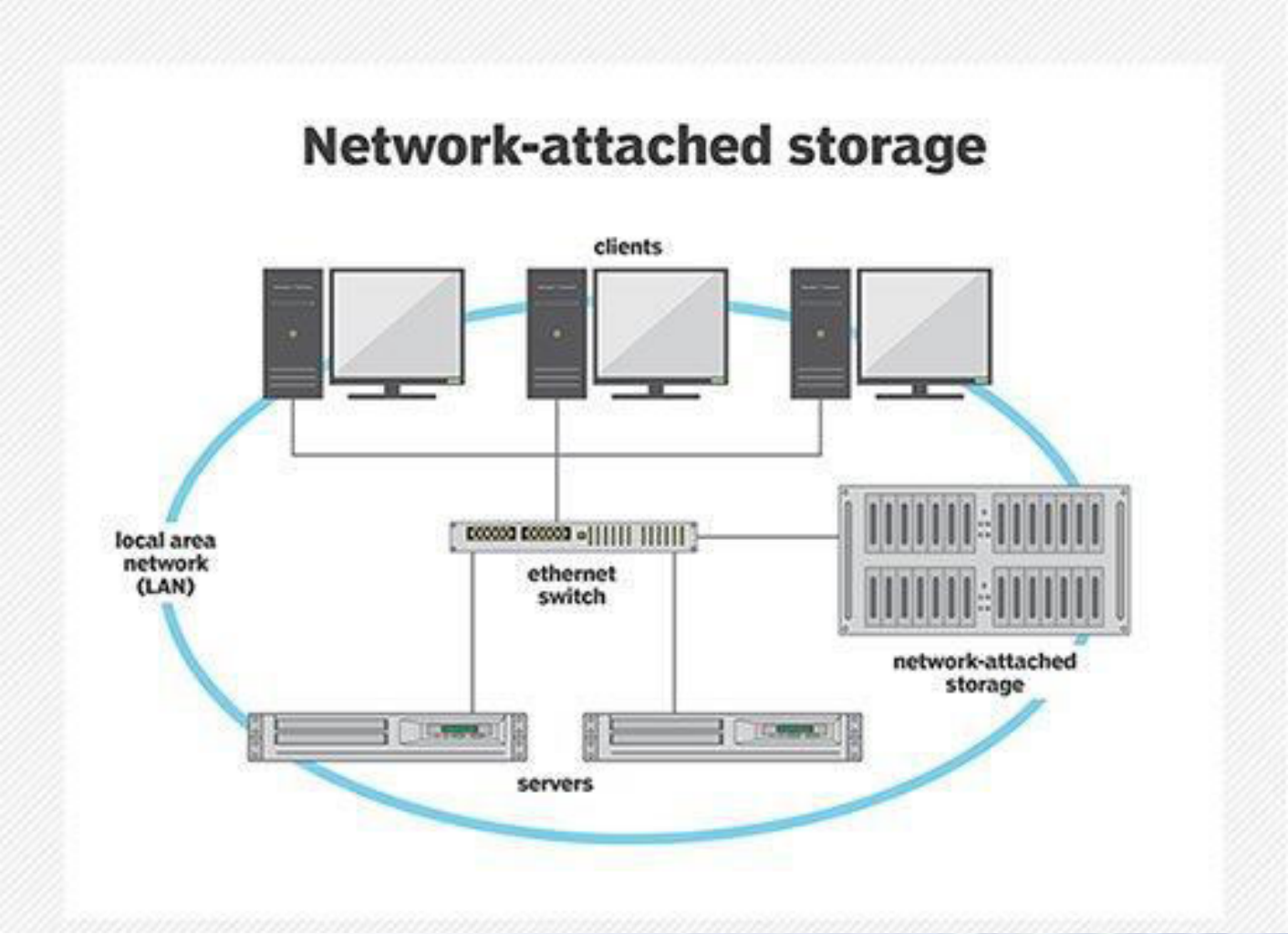


Network Attached Storage (NAS)

- Network Attached Storage (NAS) is a network device that allows multiple devices to share and access files from a central location.

- It can provide data redundancy, backup, and storage capabilities for a network.

Network Attached Storage working



Conclusion

- In conclusion, network devices are essential components of a computer network.
- Understanding the functions and capabilities of each device can help network administrators design, configure, and maintain a secure and efficient network infrastructure.

Week 5 Topic 2

Physical perimeter Security

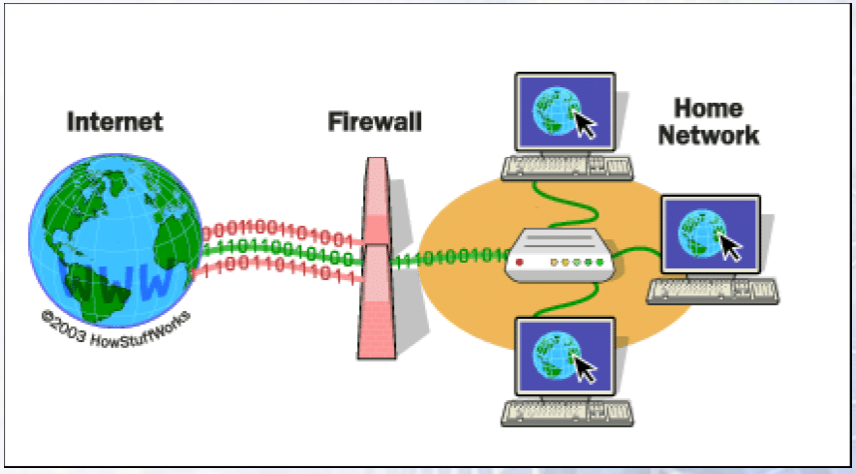
- Physical perimeter security includes measures such as fences, gates, walls, and security cameras.
- These measures restrict access to a physical location and can prevent unauthorized entry.

Logical Perimeter Security

- Logical perimeter security includes measures such as firewalls, intrusion detection systems, and virtual private networks (VPNs).
- These measures control access to a network and can prevent unauthorized access.

Firewalls

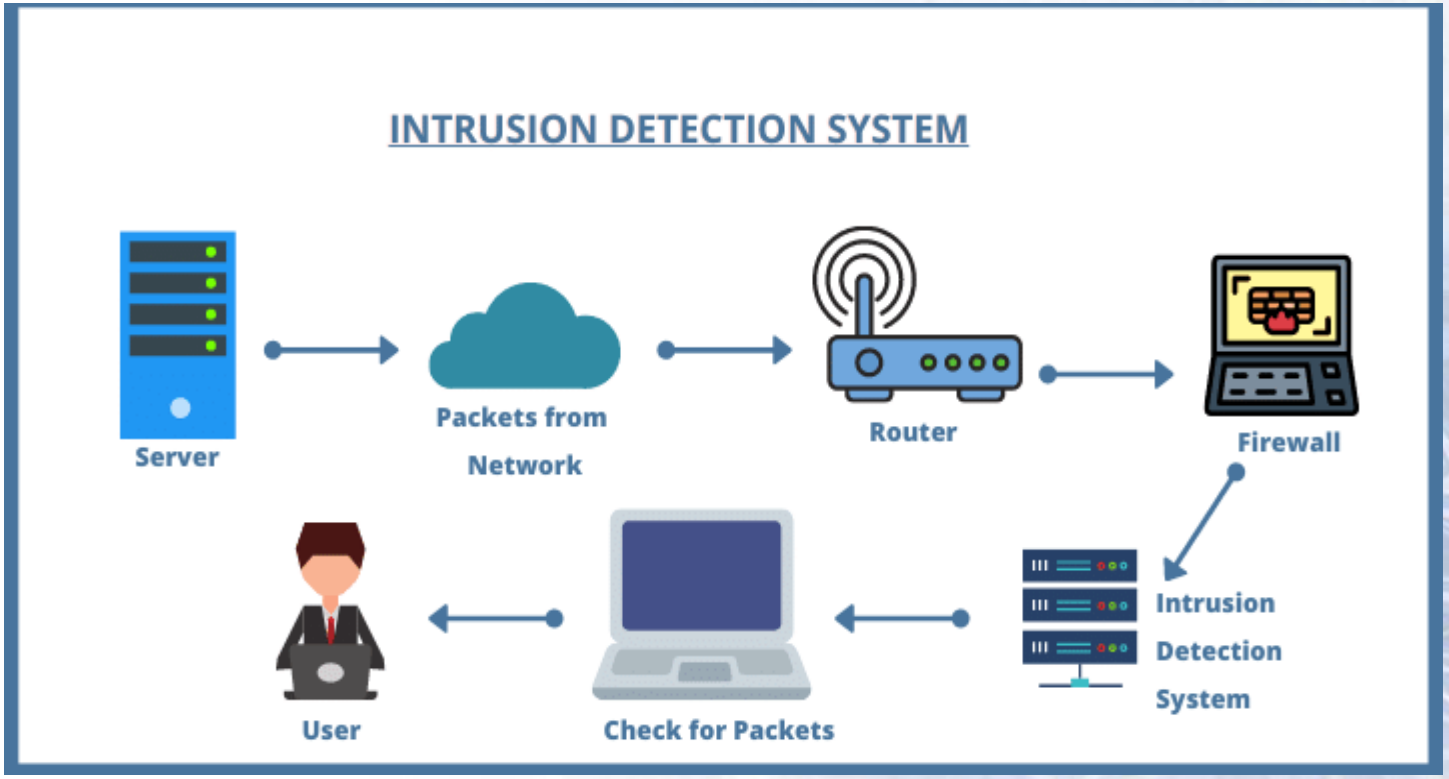
- A firewall is a logical perimeter security device that monitors and controls incoming and outgoing network traffic.
- It can block unauthorized access to a network and prevent malicious traffic from entering or leaving the network.



Intrusion Detection Systems (IDS)

- An intrusion detection system (IDS) is a logical perimeter security device that monitors a network for suspicious activity.
- It can detect and alert network administrators of potential security breaches.

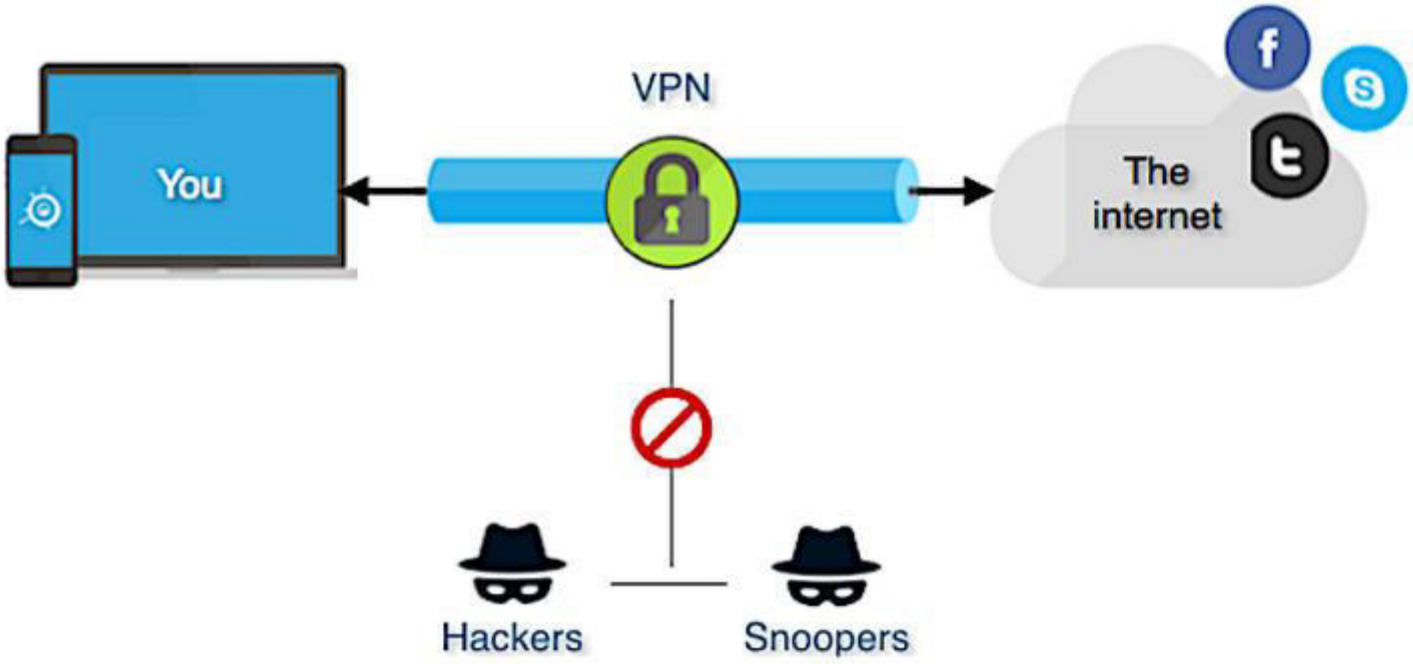
Working of IDS



Virtual Private Networks (VPNs)

- A virtual private network (VPN) is a logical perimeter security measure that allows remote users to securely connect to a network.
- It encrypts traffic between the remote user and the network, providing secure access to network resources.

Working of VPN



Access Control

- Access control is a logical perimeter security measure that restricts access to network resources based on user credentials and permissions.

- It ensures that only authorized users have access to sensitive information.

Conclusion

- In conclusion, perimeter security is a critical component of network security.
- Physical and logical measures can be used to protect a network from unauthorized access and malicious attacks.
- Understanding the various types of perimeter security measures and their functions can help network administrators design, configure, and maintain a secure network infrastructure.

Week 5 Topic 3

What is an intrusion?

- An intrusion is an unauthorized attempt to access, use, or modify a network, system, or device.
- It can occur through various means, including malware, phishing attacks, and brute-force attacks.

Types of Intrusions

There are different types of intrusions, including:

- **External Intrusion**: when an attacker attempts to gain access to a network from outside.
- **Internal Intrusion**: when an attacker gains access to a network from within, such as an employee with malicious intent.
- **Insider Threat**: when an employee or contractor intentionally or unintentionally causes harm to a network.
- **Distributed Denial of Service (DDoS)**: when an attacker floods a network with traffic to disrupt normal operations.

Impact of Intrusions

Intrusions can have severe impacts on a network, including:

- Data theft or loss
- Financial loss
- Reputation damage
- Disruption of operations

Prevention Measures

To prevent intrusions, organizations can implement various measures, including:

- Firewalls and intrusion detection/prevention systems
- Regular software updates and patching
- Strong password policies
- Employee training on phishing and social engineering attacks
- Access control policies

Incident Response

- Despite preventative measures, intrusions can still occur.
- Organizations should have an incident response plan in place to quickly and effectively respond to a security breach.

Conclusion

- In conclusion, intrusions are unauthorized attempts to access, use, or modify a network, system, or device.
- They can have severe impacts on an organization, but prevention measures and incident response plans can help mitigate the risks.

Week 5 Topic 4

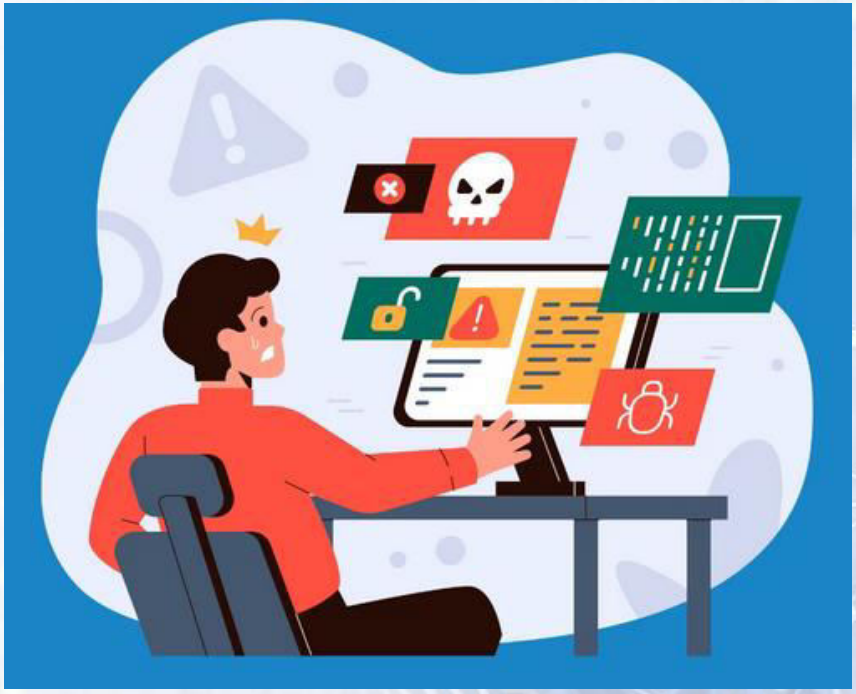
Introduction

- In this topic we will cover some common examples of intrusions.
- We will discuss the types of attacks used in each example and the impact on the affected network.

Examples of Intrusion

Malware Infection

- Malware is a type of software designed to harm a computer system or network.
- Examples of malware include viruses, worms, and Trojan horses.
- A malware infection can result in stolen data, financial loss, and network downtime.

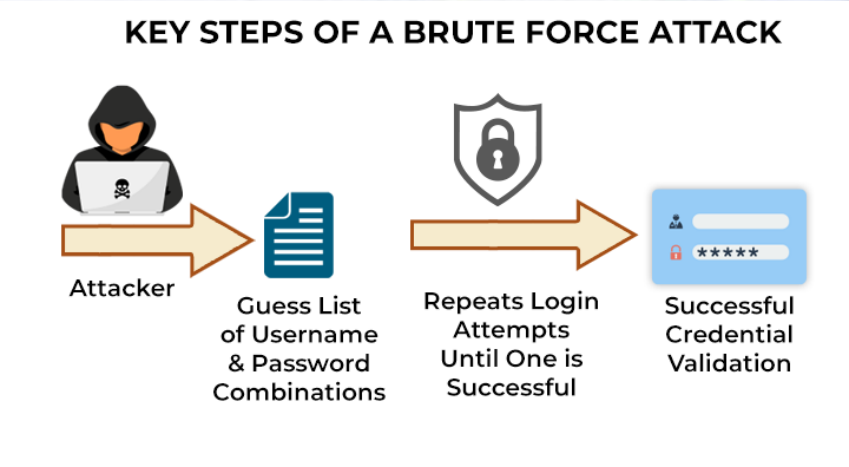


Phishing Attacks

- Phishing attacks are attempts to trick individuals into revealing sensitive information.
- Attackers often use email or social media to deceive victims into clicking a malicious link or providing personal information.
- A successful phishing attack can result in stolen login credentials or sensitive data.

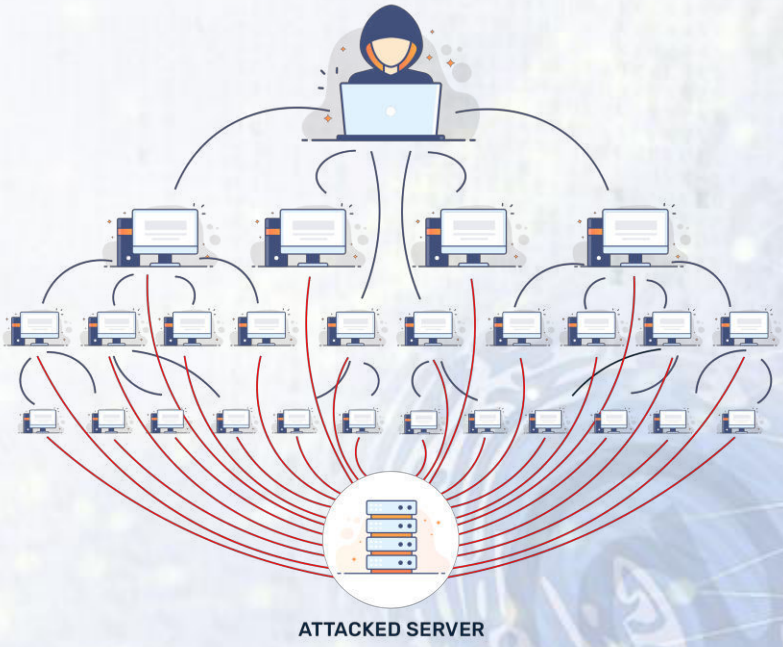
Brute-Force Attacks

- A brute-force attack is an attempt to gain unauthorized access to a system or network by guessing passwords.
- Attackers use automated tools to try multiple password combinations until they find the correct one.
- A successful brute-force attack can result in unauthorized access to sensitive data.



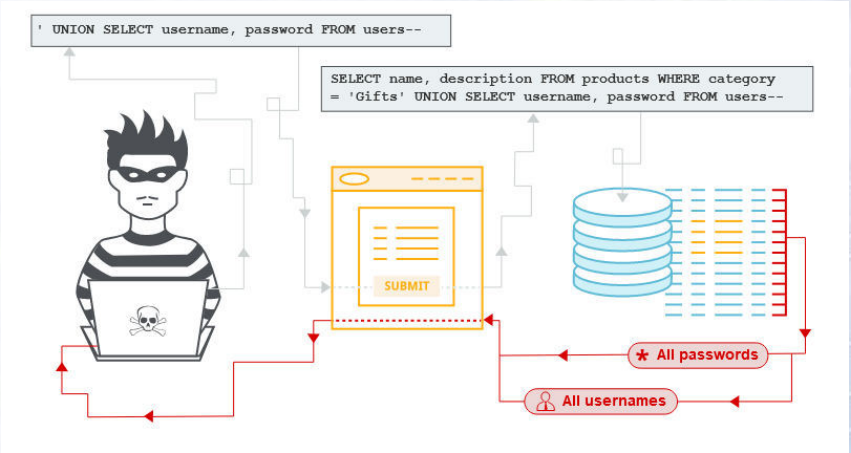
Distributed Denial of Service (DDoS)

- A DDoS attack is an attempt to disrupt normal network operations by overwhelming the network with traffic.
- Attackers use a botnet, a group of compromised devices, to flood the network with traffic.
- A successful DDoS attack can result in network downtime and financial loss.



SQL Injection

- An SQL injection is an attack that targets the database of a web application.
- Attackers input malicious SQL code into a web form to access or modify sensitive information stored in the database.
- A successful SQL injection can result in unauthorized access to sensitive data.



Conclusion

- In conclusion, there are various examples of intrusions that can impact a network.
- Attackers use different types of attacks, including malware infections, phishing attacks, brute-force attacks, DDoS attacks, and SQL injections.
- Organizations must implement strong security measures, such as firewalls, intrusion detection systems, and access control policies, to prevent and mitigate the impact of intrusions.

Week 5 Topic 5

Intruder Behavior

- In this topic we will cover intruder behavior and how it can impact a network.
- We will discuss the different types of intruders and their motivations for attacking a network.

Types of Intruders

There are different types of intruders, including:

Script Kiddies: inexperienced attackers who use pre-written scripts to launch attacks.

- **Hacktivists**: attackers who target a network to promote a political or social cause.
- **Insiders**: employees or contractors who intentionally or unintentionally cause harm to a network.
- **Cybercriminals**: attackers who target a network for financial gain.
- **Nation-state Actors**: attackers who are sponsored by a government to gain access to sensitive information.

Motivations for Intruder Behavior

Intruders may have various motivations for attacking a network, including:

- Financial gain
- Political or social reasons
- Espionage
- Personal challenge
- Revenge

Intruder Methods

Intruders use various methods to gain access to a network, including:

- Exploiting vulnerabilities in software or hardware
- Social engineering, such as phishing attacks
- Brute-force attacks
- Distributed denial of service (DDoS) attacks
- Insider threats

Impact of Intruder Behavior

Intruder behavior can have severe impacts on a network, including:

- Data loss or theft
- Financial loss
- Reputation damage
- Disruption of operations
- Legal consequences

Prevention and Mitigation

To prevent and mitigate the impact of intruder behavior, organizations can implement various measures, including:

- Strong passwords and access control policies
- Regular software updates and patching
- Employee training on social engineering attacks
- Firewalls and intrusion detection/prevention systems
- Incident response plans

Conclusion

- In conclusion, intruder behavior can have severe impacts on a network, and there are different types of intruders with varying motivations for attacking a network.
- Organizations must implement strong security measures to prevent and mitigate the impact of intruder behavior, including strong passwords, access control policies, regular software updates, employee training, and incident response plans.

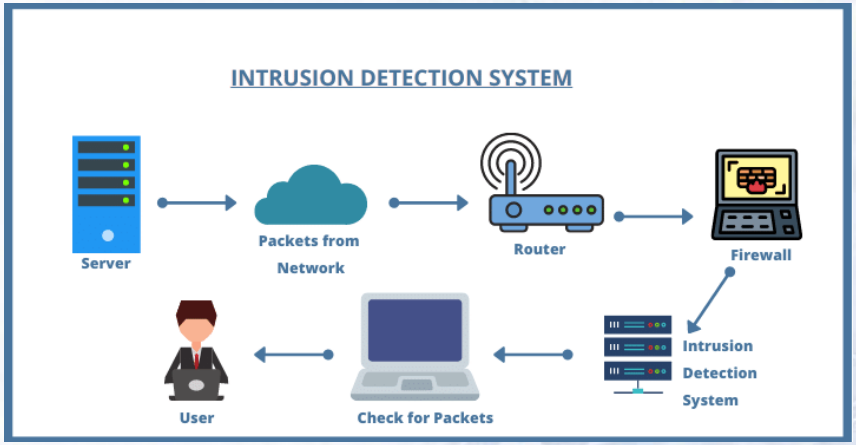
Week 5 Topic 6

Intrusion Detection System (IDS)

- In this topic we will cover Intrusion Detection System (IDS) and its importance in network security.
- We will discuss the types of IDS and how they work to detect intrusions.

What is an IDS?

- An IDS is a security tool designed to detect and alert on malicious activity on a network.
- IDS can detect unauthorized access, malware infections, phishing attacks, and other types of intrusions.



Types of IDS

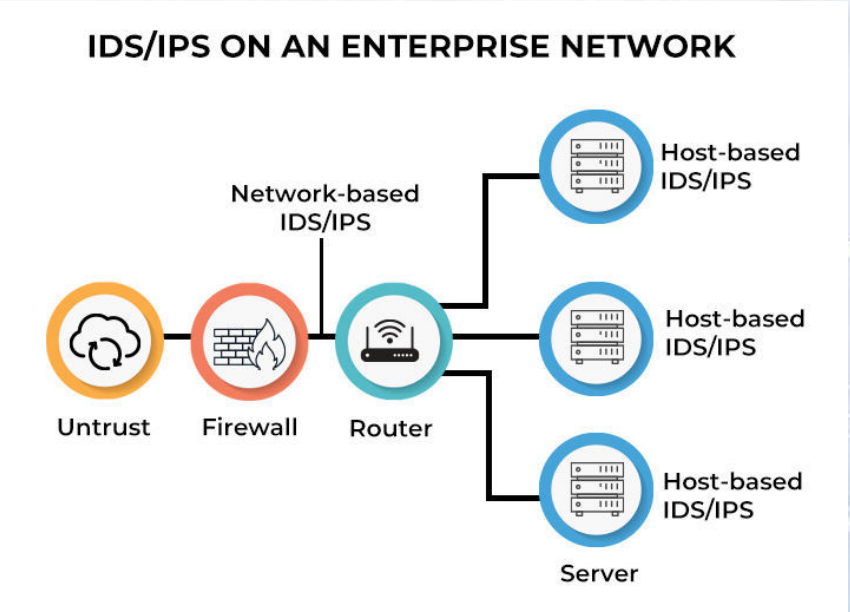
There are two types of IDS:

- **Network-based IDS (NIDS):** These monitor network traffic for suspicious activity, such as unusual traffic patterns or known attack signatures.

- **Host-based IDS (HIDS):** These monitor activity on individual devices, such as servers or workstations, to detect unauthorized access or system-level attacks.

How IDS Works?

- IDS works by comparing network traffic or system activity against known attack signatures, behavior patterns, or other indicators of compromise (IoCs).
- IDS can detect intrusions by analyzing packet headers and payloads, system logs, and other data sources.
- IDS alerts security teams or generates automated responses, such as blocking traffic or quarantining affected devices.



Benefits of IDS

IDS provides several benefits, including:

- Early detection and alerting of intrusions, reducing the impact of an attack.
- Faster incident response by identifying the affected devices and the scope of the attack.
- Improved visibility into network traffic and activity, allowing security teams to identify vulnerabilities and potential attack vectors.

Limitations of IDS

IDS has some limitations, including:

- IDS may generate false positives or false negatives, leading to unnecessary alerts or missed intrusions.
- IDS requires maintenance and updates to stay current with the latest attack signatures and IoCs.
- IDS may not detect new or unknown attack vectors.

Conclusion

- In conclusion, IDS is an important tool in network security that can detect and alert on intrusions, reducing the impact of an attack.
- Organizations must choose the right type of IDS, NIDS or HIDS, based on their network architecture and security needs.
- IDS has limitations, and organizations must implement complementary security measures, such as firewalls, access control, and endpoint security, to achieve a comprehensive security posture.

Week 5 Topic 7

IDS Analysis Approaches

- In this topic we will cover IDS analysis approaches and how they can be used to detect and respond to network intrusions.
- We will discuss the different types of IDS analysis approaches and how they work.

Types of IDS Analysis Approaches

There are three main types of IDS analysis approaches:

- Signature-based analysis
- Anomaly-based analysis
- Hybrid analysis

1- Signature-based Analysis

- Signature-based analysis compares network traffic against known attack signatures or patterns.
- IDS with signature-based analysis can identify known attacks with high accuracy but may miss new or unknown attacks.
- Signature-based analysis requires regular updates to stay current with new attack signatures.

2- Anomaly-based Analysis

- Anomaly-based analysis detects deviations from normal network traffic or user behavior.

- IDS with anomaly-based analysis can identify new or unknown attacks but may generate more false positives than signature-based analysis.

- Anomaly-based analysis requires a baseline of normal network traffic or user behavior to be established and updated regularly.

3- Hybrid Analysis

- Hybrid analysis combines signature-based and anomaly-based analysis to achieve a more comprehensive detection capability.

- IDS with hybrid analysis can identify known and unknown attacks with fewer false positives but require more resources to operate effectively.

IDS Analysis Approaches in Action

IDS analysis approaches can be applied to detect various types of network intrusions, including:

- Malware infections
- Unauthorized access attempts
- Data exfiltration
- Denial of service attacks

Conclusion

- In conclusion, IDS analysis approaches are essential for detecting and responding to network intrusions effectively.
- Organizations must choose the right type of IDS analysis approach based on their network architecture and security needs.
- IDS analysis approaches require regular maintenance, updates, and baseline establishment to operate effectively.

Week 5 Topic 8

Host-Based IDS

- In this topic we will cover Host-Based Intrusion Detection System (HIDS) and its importance in host-level security.
- We will discuss how HIDS works and its benefits and limitations.

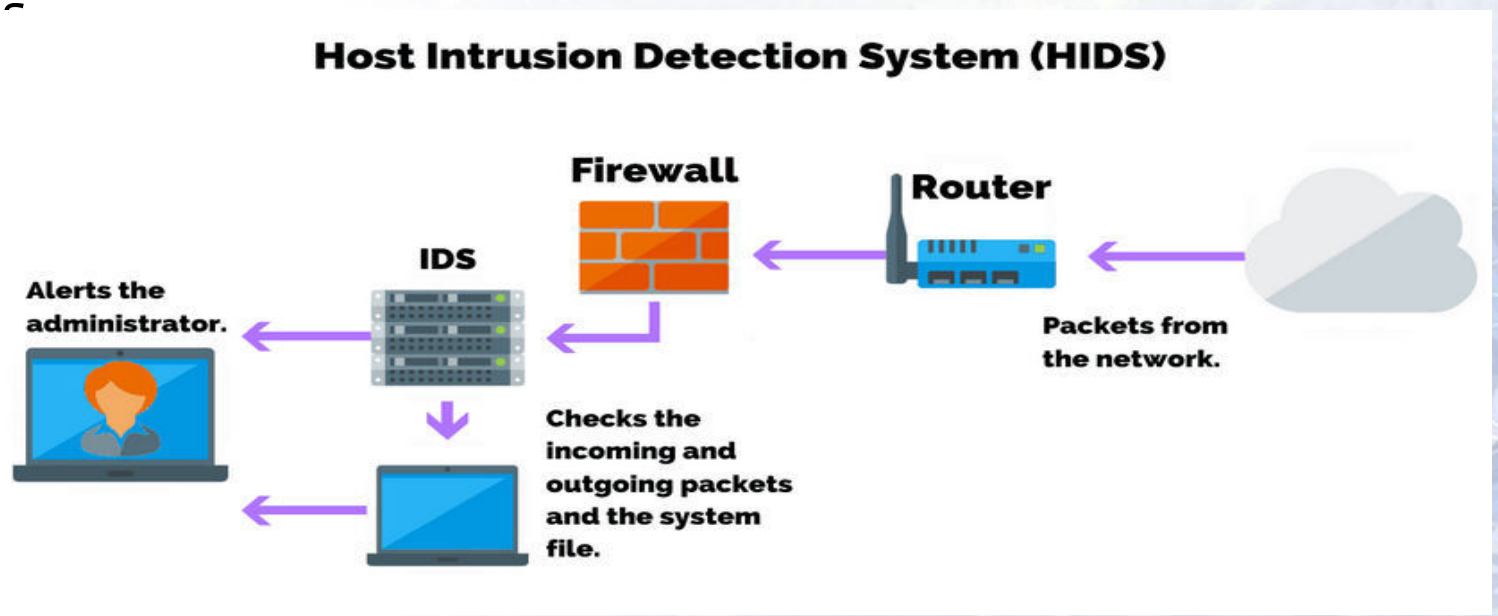
What is HIDS?

- HIDS is an intrusion detection system that monitors activity on individual devices, such as servers or workstations, to detect unauthorized access or system-level attacks.

- HIDS can detect malicious activity that network-based IDS (NIDS) may not capture, such as file modifications or process-level attacks.

How HIDS Works?

- HIDS works by collecting and analyzing system activity logs, file integrity, and system performance metrics to identify suspicious activity.
- HIDS can detect unauthorized access attempts, malware infections, and other types of host-level attacks.
- HIDS alerts security teams or generates automated responses, such as terminating malicious processes or isolating affected device



Benefits of HIDS

HIDS provides several benefits, including:

- Granular visibility into host-level activity, allowing for faster incident response and reducing the impact of an attack.
- Detecting threats that may evade NIDS, such as fileless malware or process-level attacks.
- Enhancing compliance by monitoring and reporting on system-level activity.

Limitations of HIDS

HIDS has some limitations, including:

- HIDS can generate a high number of alerts, leading to alert fatigue and missed intrusions.
- HIDS requires maintenance and updates to stay current with the latest attack patterns and IoCs.
- HIDS may not detect sophisticated or zero-day attacks.

HIDS Deployment

HIDS can be deployed in several ways, including:

- **Agent-based:** HIDS agent installed on each monitored device.
- **Agentless:** HIDS uses system logs and network packets for analysis.
- **Hybrid:** HIDS uses a combination of agent-based and agentless approaches.

Conclusion

- In conclusion, HIDS is an essential tool in host-level security that can detect and alert on intrusions, reducing the impact of an attack.
- Organizations must choose the right type of HIDS deployment based on their network architecture and security needs.
- HIDS has limitations, and organizations must implement complementary security measures, such as firewalls, access control, and endpoint security, to achieve a comprehensive security posture.

Week 5 Topic 9

Network-Based IDS

- Network-based Intrusion Detection Systems (NIDS) are security tools that monitor and analyze network traffic to detect suspicious activity or malicious attacks.

- NIDS is one of the most important security measures in modern-day networks.

- NIDS provides a higher level of security by detecting and alerting the network administrator of potential threats.

Types of NIDS

- **Signature-based NIDS:** Uses a pre-defined database of known attack patterns, and alerts when a network packet matches a signature in the database.

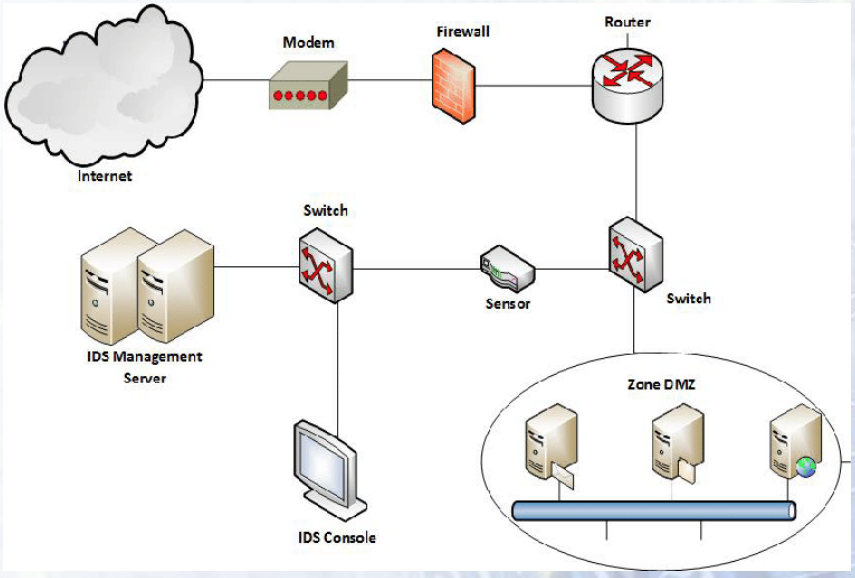
- **Anomaly-based NIDS**: Analyzes the network traffic for abnormal behavior or traffic patterns, and alerts the administrator when such activity is detected.

- **Hybrid NIDS**: Combines both signature-based and anomaly-based detection methods to provide a more comprehensive approach to intrusion detection.

NIDS Architecture

NIDS architecture includes the following components:

- **Network Taps**: Collect and route network traffic to the NIDS for analysis.
- **Sensors**: Monitor network traffic and analyze packets for malicious activity.
- **Console**: Provides the interface for administrators to configure and manage the NIDS, and review alerts and logs.



NIDS Deployment

NIDS can be deployed in two ways: passive or active.

- **Passive deployment**: Does not alter the network traffic or packets, and only analyzes network traffic.

- **Active deployment**: Alters network traffic or packets, such as dropping or modifying packets, to prevent malicious activity.

Advantages of NIDS

- Provides real-time monitoring of network traffic.
- Detects and alerts the administrator of potential threats, allowing for timely action to be taken.
- Can be deployed on a variety of network architectures and sizes.
- Can be configured to monitor specific types of traffic, such as web traffic or email traffic.

Disadvantages of NIDS

- **False positives**: Alerts generated by NIDS may not always indicate a genuine threat, which can lead to unnecessary investigations.
- **Limited visibility**: NIDS can only monitor network traffic, and may not be able to detect attacks on endpoints or applications.
- **Performance impact**: NIDS can impact network performance, especially if the network traffic is high.

Conclusion

- NIDS is an important tool for network security, providing real-time monitoring and alerting of potential threats.
- NIDS architecture includes sensors, network taps, and a console for management and configuration.
- NIDS can be deployed passively or actively, with advantages and disadvantages for each deployment method.

Week 5 Topic 10

WIPS - Wireless IPS

- Wireless Intrusion Prevention Systems (WIPS) are security tools that detect and prevent unauthorized access to wireless networks.
- WIPS is a crucial security measure for modern-day wireless networks.
- WIPS provides a higher level of security by detecting and preventing potential threats to wireless networks.

Types of WIPS

- **Overlay WIPS:** A separate wireless sensor network is deployed to monitor and secure the wireless network.

- **Integrated WIPS:** The WIPS functionality is integrated into the wireless access points (APs) themselves.

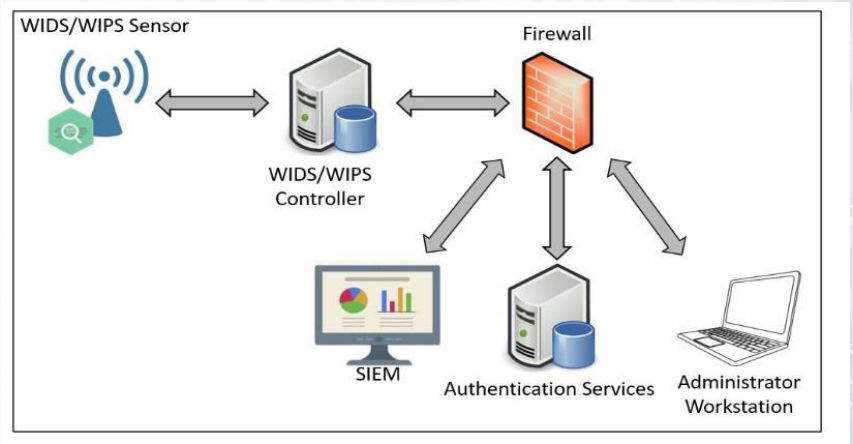
WIPS Architecture

WIPS architecture includes the following components:

- **Access Points:** Provide wireless connectivity to devices and also monitor for suspicious activity.

- **Sensors:** Detect wireless attacks or suspicious behavior and notify the access points to take appropriate action.

- **Management Console:** Provides the interface for administrators to configure and manage the WIPS, and review alerts and logs.



WIPS Deployment

- WIPS can be deployed in two ways: standalone or integrated.
- Standalone deployment: A separate sensor network is deployed to monitor wireless traffic and detect attacks.
- Integrated deployment: WIPS functionality is integrated into wireless APs themselves, reducing the need for additional hardware.

Advantages of WIPS

- Provides real-time monitoring of wireless traffic.
- Detects and prevents potential threats to the wireless network, including rogue APs and unauthorized access attempts.
- Can be configured to monitor and protect specific types of wireless traffic, such as voice or data.
- Supports compliance with regulatory requirements, such as PCI-DSS.

Disadvantages of WIPS

- **False positives**: Alerts generated by WIPS may not always indicate a genuine threat, which can lead to unnecessary investigations.
- **Limited visibility**: WIPS can only monitor wireless traffic, and may not be able to detect attacks on wired networks or applications.
- **Performance impact**: WIPS can impact wireless performance, especially if the wireless network traffic is high.

Conclusion

- WIPS is a crucial tool for wireless network security, providing real-time monitoring and prevention of potential threats.
- WIPS architecture includes access points, sensors, and a management console for configuration and management.
- WIPS can be deployed standalone or integrated, with advantages and disadvantages for each deployment method.

Week 5 Topic 11

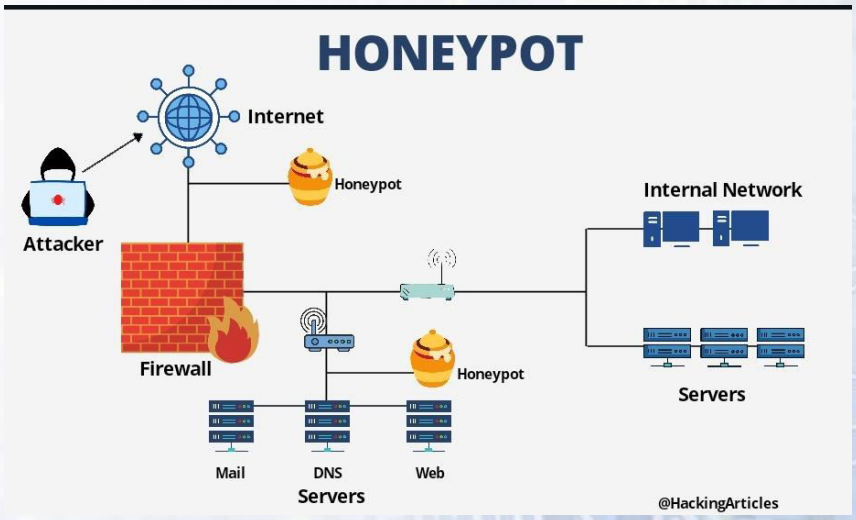
Honeypots

- Honeypots are a type of security tool that simulate vulnerable systems or applications to attract attackers and gather information about their techniques and motives.
- Honeypots are a crucial tool for modern-day cybersecurity.
- Honeypots can provide valuable insights into attacker behavior and help improve overall security posture.

Types of Honeypots

- **Production honeypots:** Real systems or applications that are deployed to gather information about attackers.

- **Research honeypots:** Simulated systems or applications that are deployed in a controlled environment to gather research data about attacker behavior.



Advantages of Honeypots

- Provides early warning of potential attacks, allowing for quick detection and response.
- Can gather valuable intelligence about attacker techniques, tactics, and motives.
- Helps identify vulnerabilities in systems or applications that can be remediated to improve overall security posture.
- Can divert attackers away from real systems and applications, reducing the risk of successful attacks.

Disadvantages of Honeypots

- **False positives**: Honeypots can generate false alarms, which can lead to unnecessary investigations and waste of resources.
- **Security risks**: Honeypots can be compromised by attackers, potentially exposing sensitive information or systems.
- **Maintenance overhead**: Honeypots require regular maintenance and updates, which can be resource-intensive.

Honeypot Deployment Strategies

- **Low interaction honeypots**: Simulate only the most basic functionality of a system or application, providing limited interaction with attackers.

- **Medium interaction honeypots**: Simulate more functionality of a system or application, allowing attackers to interact with them more fully.

- **High interaction honeypots**: Provide a full simulation of a real system or application, allowing attackers to interact with it as if it were real.

Honeypot Tools

Examples of honeypot tools include:

- **KFSensor**: A Windows-based honeypot that simulates vulnerable services and applications.
- **Honeyd**: A customizable honeypot that can simulate multiple operating systems and services.
- **Cowrie**: A high-interaction honeypot that simulates a full SSH environment.

Conclusion

- Honeypots are a crucial tool for modern-day cybersecurity, providing valuable insights into attacker behavior and improving overall security posture.
- Honeypots can be deployed in different ways, with advantages and disadvantages for each deployment strategy.
- Honeypot tools, such as KFSensor, Honeyd, and Cowrie, are available as open-source solutions or as part of commercial cybersecurity solutions.

Week No. 6

Vulnerability Assessment

Week 6 Topic 1

Vulnerability Mangement & Assessment

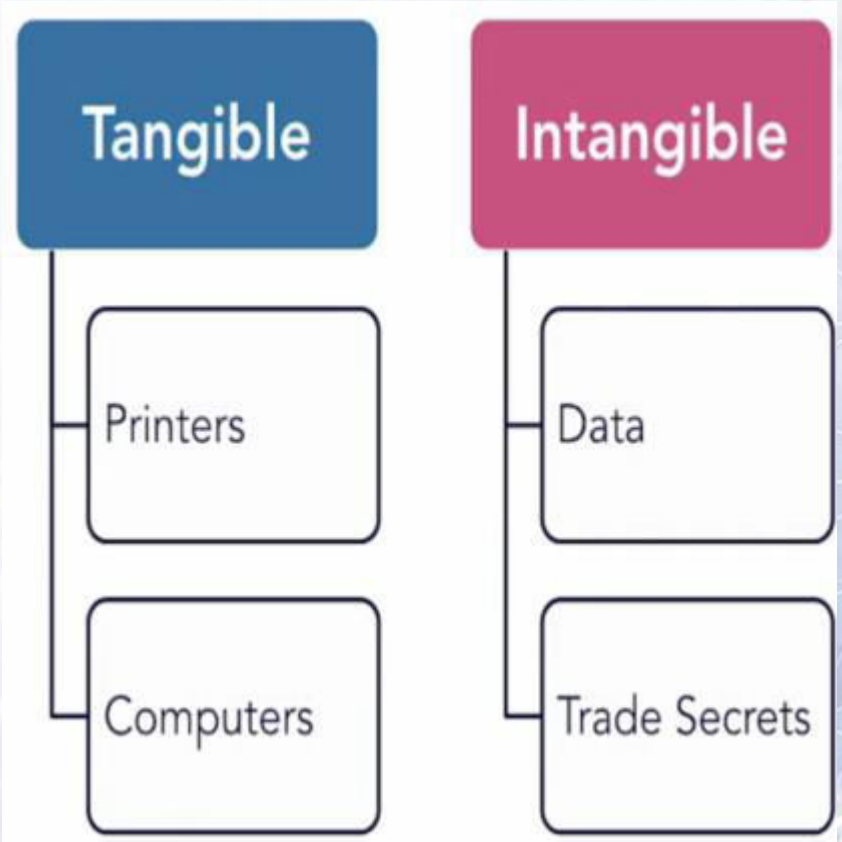
- **Vulnerability assessment:**
- is the process of identifying and evaluating security vulnerabilities in a system or network.
- involves running scans and tests to discover vulnerabilities
- analyzing the results to determine the severity and potential impact of each vulnerability.

- **Vulnerability management:**
- process of addressing and mitigating vulnerabilities that have been identified through the vulnerability assessment.
- includes prioritizing vulnerabilities based on severity and potential impact, developing a plan to address them, and implementing the necessary fixes or patches.
- remediated through patching and configuration of security settings.

Terms

- Assets
- Risks
- Threats
- Vulnerabilites

Assets



RISK

- Risk refers to the potential harm or damage that can be caused by a cyber attack or security breach.
- Includes bussiness disruption, financial loss.

Threat

- Anything that can exploit a vulnerability
- obtain , damge or destroy an asset

What is a vulnerability ?

- **vulnerability**

refers to a weakness or flaw in a system, application, or network

exploited by attackers to gain unauthorized access, steal data, disrupt operations

Vulnerabilities can be caused by software bugs, configuration errors, design flaws, or unpatched systems that leave systems exposed to potential attacks.

Examples of common vulnerabilities:

- Weak or easily guessable passwords
- Unpatched software vulnerabilities
- Misconfigured settings
- Malware infections

- A vulnerability assessment uses automated network security scanning tools.

Vulnerability scanners

- Common vulnerability scanners ?
  - OpenVAS
  - Nessus
  - Qualys
  - Rapid7
  - Nmap

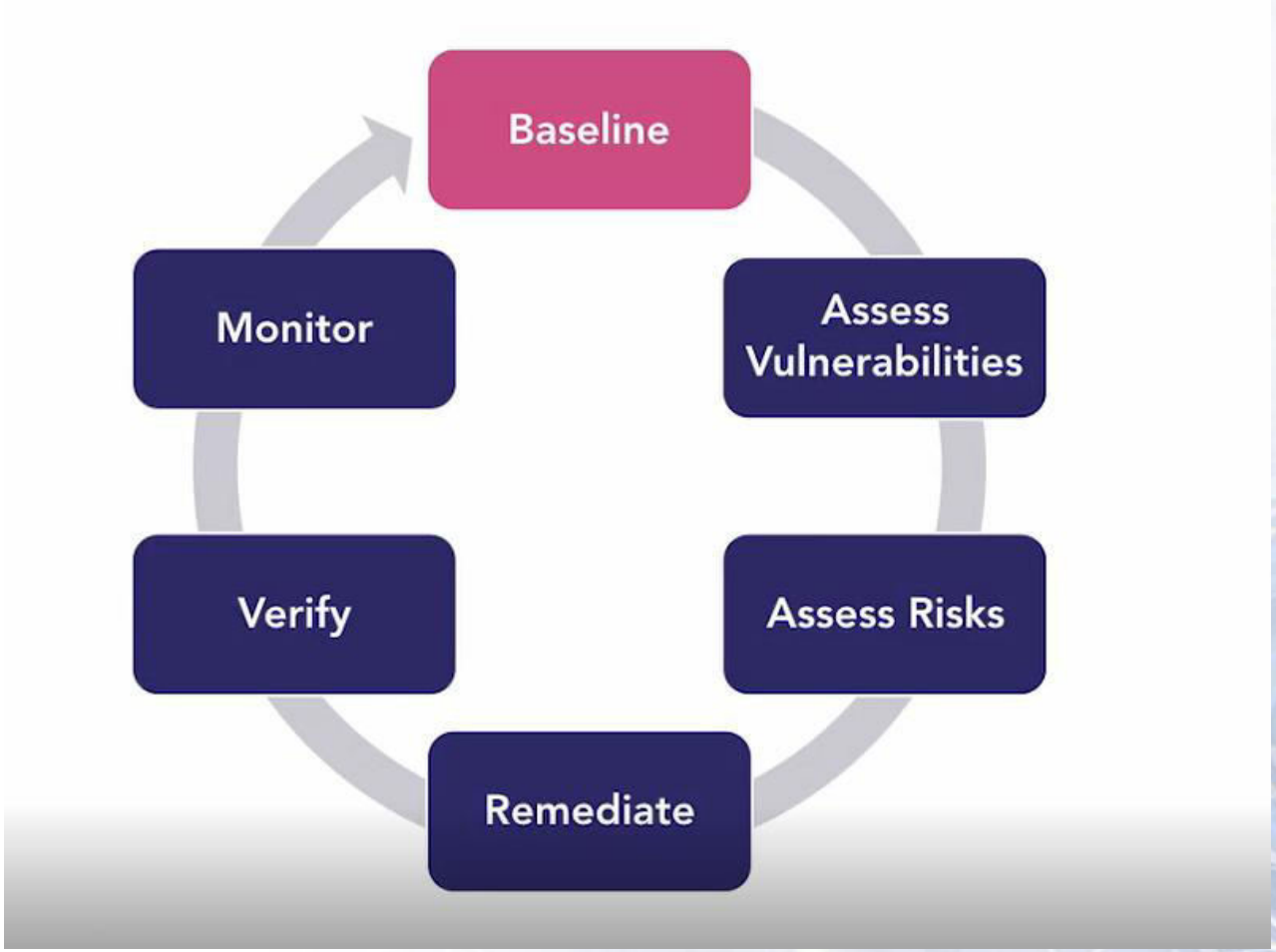
END

Week 6 Topic 2

Vulnerability management life cycle

- Threats exist, as well as vulnerabilities.
- You can’t control the threats.
- You can reduce the vulnerabilities

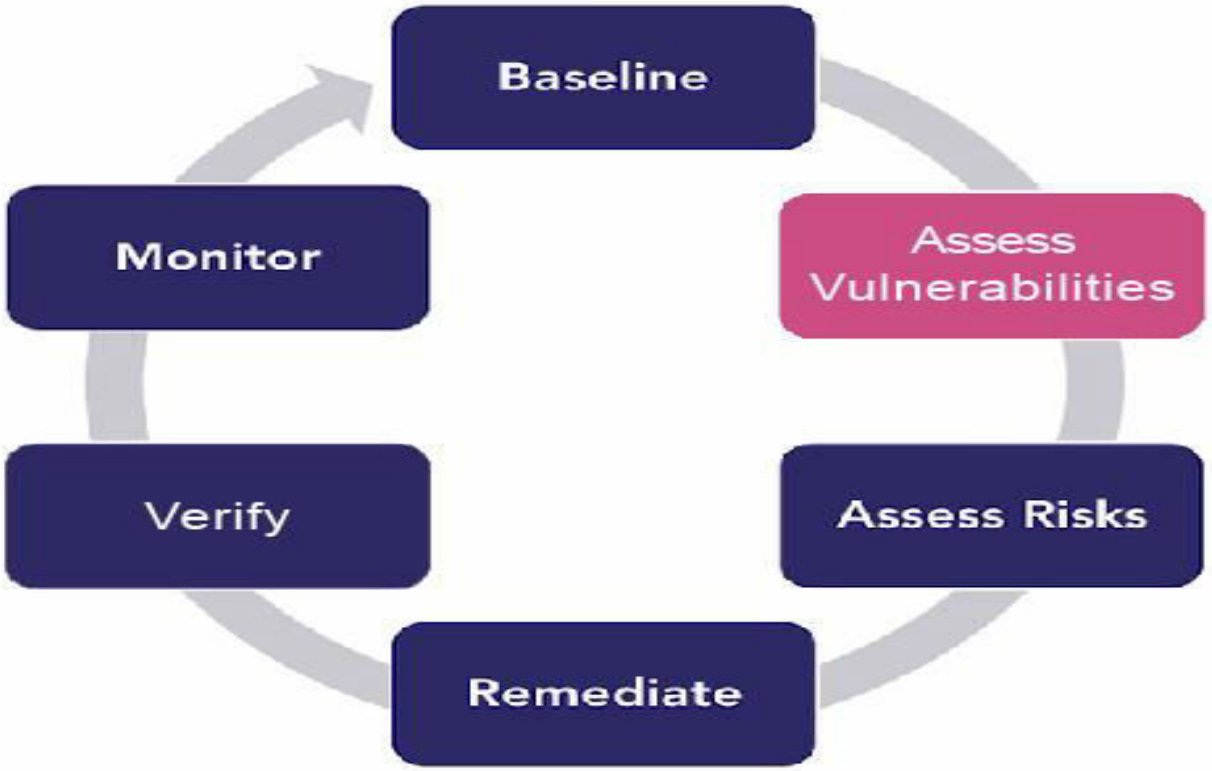
Vulnerability management life cycle



Vulnerability management life cycle

Initial Assessment:

- Identify assets, define risk and possible business impact
- Helps answer the question: “Why are we doing this?”
- Understanding the overall impact of a cyber attack will inspire everyone to be more vested in mitigating vulnerabilities

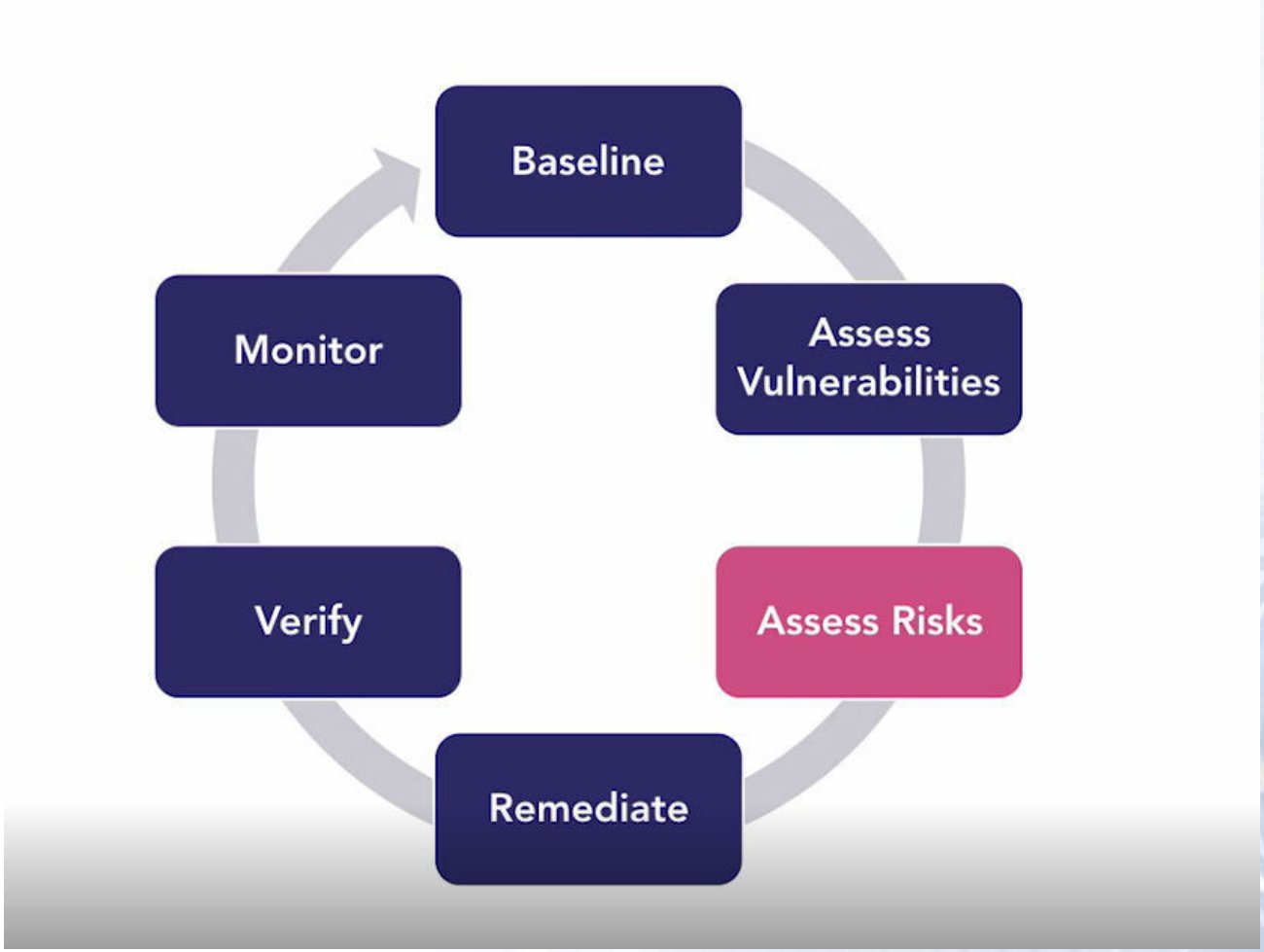


Vulnerability management life cycle

- **Plan:**

- **Check for compliance requirements**
- **Determine the best time to perform the scan**
- **Decide on what tools to use**
  -Port Scan, network scans, or web application scans
- **Run the automated scan**
- **Generate report**

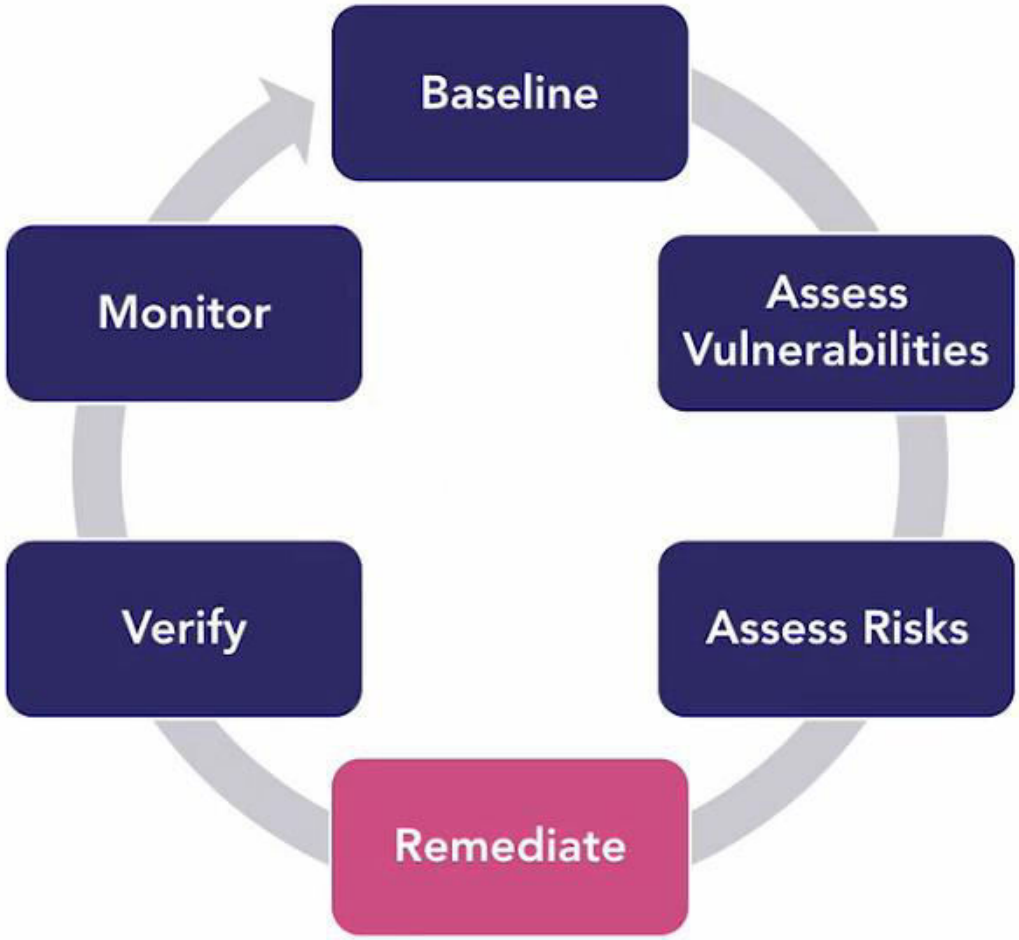
Vulnerability management life cycle



Vulnerability management life cycle

- **Detailed description, discovery date ,what was affected**
  - OS, application, network, or mobile device
- **Common Vulnerabilities and exposures(CVE) score**
- **Prioritize according to the risk level**
- **Determine a time to reassess the vulnerability**

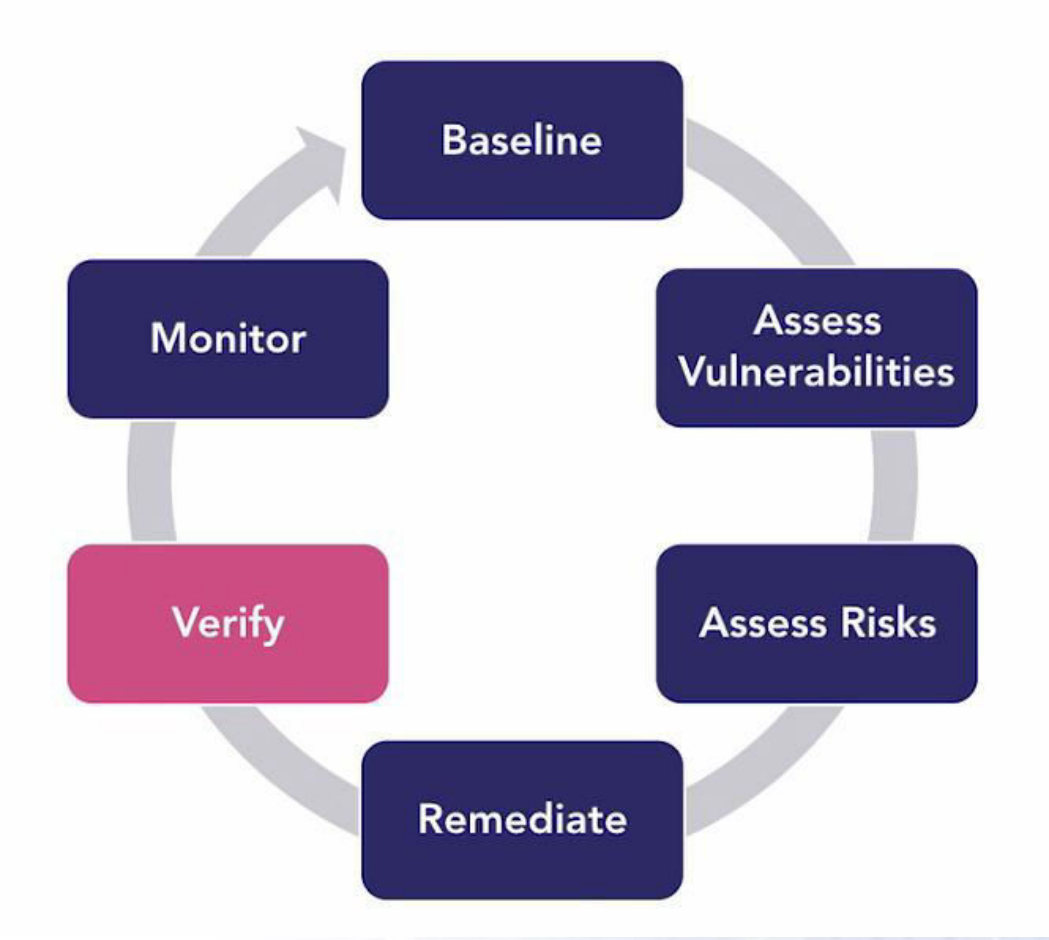
Vulnerability management life cycle



Vulnerability management life cycle

- **Remediate**
- Take steps to correct system integrity
- Research the best way to mitigate the vulnerability
  - Research vulnerabilities
  - Evaluate fixes and remediation method
  - Test the patches and fixes
  - Apply patches/fixes
  - Monitor results

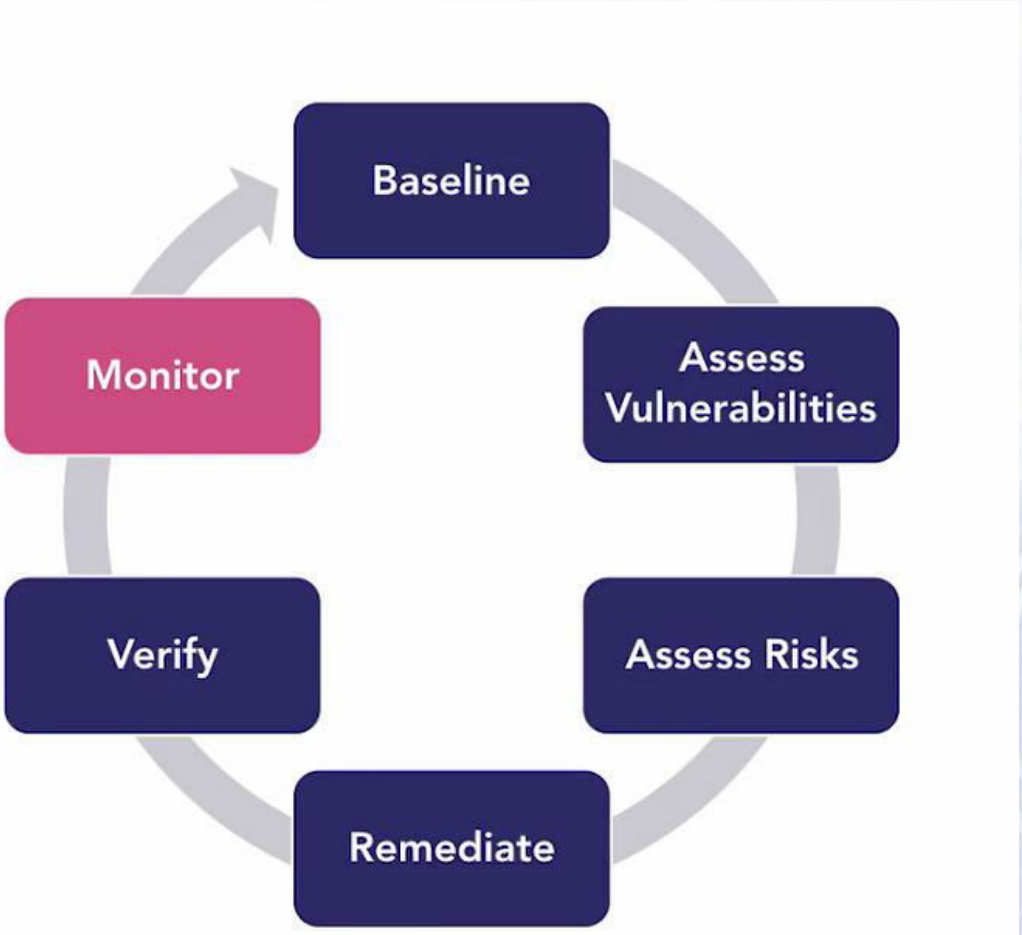
Vulnerability management life cycle



Vulnerability management life cycle

- **Retest and verify:**
- Retest and verify that you successfully corrected the problem
- This involves rescanning the system and comparing the results

Vulnerability management life cycle



Vulnerability management life cycle

- Vulnerability management life cycle
  A continuous best practice process to protect your organization and data

Week 6 Topic 3

Why Is A VM Program Required ?

- What is a patch ?

  "A **patch** is a piece of software designed to update a computer program or its supporting data, to fix or improve it. This includes fixing **security** vulnerabilities and other bugs"

- What is patch management ?

  Patch management is an area of systems management that involves acquiring, testing, and installing multiple patches (code changes) to an administered computer system.

https://en.wikipedia.org/wiki/Patch_(computing)

Why Is A VM Program Required ?

- Patch management tasks :

  Maintaining current knowledge of available patches, deciding what patches are appropriate for particular systems, ensuring that patches are installed.

  properly, testing systems after installation, and documenting all associated procedures, such as specific configs required.

http://searchenterprisedesktop.techtarget.com/definition/patch-management

Why Is A VM Program Required ?

Risk of not patching:

- By not applying a patch you might be leaving the door open for a malware attack

- Defects in clients like web browsers, email programs, image viewers, instant messaging software, and media players may allow malicious websites, etc. to infect or compromise your computer.

A VM program addresses timely management of patching to ensure that vulnerabilities are not present for hackers to exploit.

Week 6 Topic 4

An Exploit

- What is an exploit ?

  Program or some code that takes advantage of a security hole (i.e. a vulnerability) in an application or system, so that an attacker can use it for their benefit.

Types of An Exploit ?

- **Remote exploit:**

  A *remote exploit* works over a network and exploits the security vulnerability without any prior access to the vulnerable system.

  For example, an attacker compromises a web server on a corporate network, the attacker can then use the compromised web server to attack other systems on the network

- **Local exploit:**

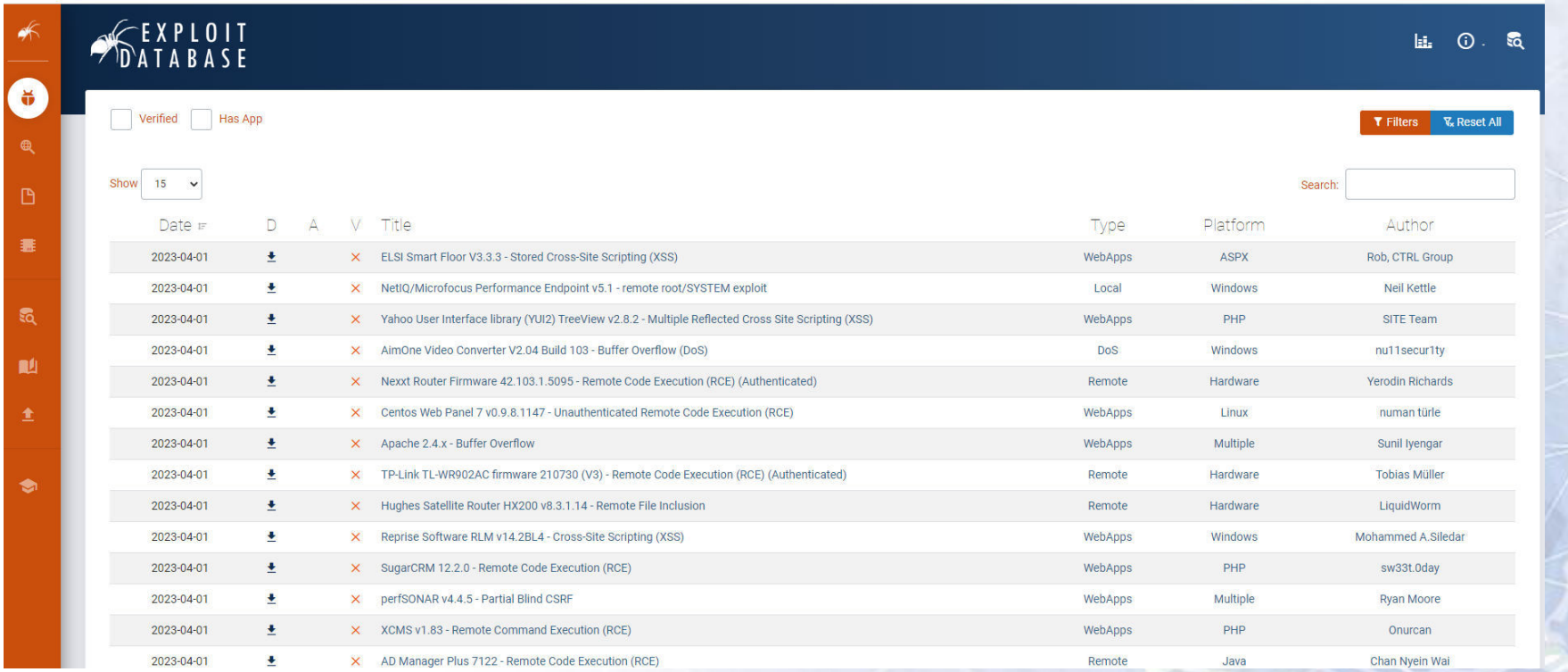
  A *local exploit* requires prior access to the vulnerable system and usually increases the privileges of the person running the exploit past those granted by the system administrator.

https://en.wikipedia.org/wiki/Exploit_(computer_security)

What Is An Exploit ?

- **Exploit database:**

The Exploit Database is a CVE compliant archive of public exploits and corresponding vulnerable software, developed for use by penetration testers and vulnerability researchers.



https://www.exploit-db.com/

What Is An Exploit ?

- **Zero-day exploit:**

A zero day vulnerability refers to a hole in software that is unknown to the vendor. This security hole is then exploited by hackers before the vendor becomes aware and hurries to fix

Week 6 Topic 5

Security Breach Case Study 1: Home Dept 2014

- 56 million payment cards compromised
- Early September 2014

- **Sequence of events:**
  - The attackers were able to gain access to one of Home Depot's vendor environments by using a third-party vendor's login credentials.
  - Then they exploited a zero-day vulnerability in Windows, which allowed them to rotate from the vendor-specific environment to the Home Depot corporate environment.

Security Breach Case Study 1: Home Dept 2014

- Once they were in the Home Depot network, they were able install memory scraping malware on over 7,500 self-checkout POS terminals (Smith, 2014).

- This malware was able to grab 56 million credit and debit cards. The malware was also able to capture 53 million email addresses (Winter, 2014).

- The stolen payment cards were used to put up for sale and bought by carders. The stolen email addresses were helpful in putting together large phishing campaigns

Security Breach Case Study 1: Home Dept 2014

- Home Depot didn't have secure configuration of the software or hardware on the POS terminals.
- There was no proof of regularly scheduled vulnerability scanning of the POS environment.
- They didn't have proper network separation between the Home Depot corporate network and the POS network.

- **Overall:**

Several controls missing, vendor management of IDs and access management missing, and monitoring of the network was missing

https://www.sans.org/reading-room/whitepapers/breaches/case-study-home-depot-data-breach-36367

Week 6 Topic 6

Security Breach Case Study 2: Anthem

- Health Insurer Anthem
- Affected 78.8 million individuals

http://www.bankinfosecurity.com/new-in-depth-analysis-anthem-breach-a-9627

Security Breach Case Study 2: Anthem

- **Sequence of events:**
  - Data breach began on Feb. 18, 2014, when a user within one of Anthem's subsidiaries opened a phishing email containing malicious content.
  - Opening the email launched the download of malicious files to the user's computer and allowed hackers to gain remote access to that computer and dozens of other systems within the Anthem enterprise, including Anthem's data warehouse.
  - Starting with the initial remote access, the attacker was able to move laterally across Anthem systems and escalate privileges, gaining increasingly greater ability to access information and make changes in the environment

Security Breach Case Study 2: Anthem

- **Sequence of events:**

- The attacker utilized at least 50 accounts and compromised at least 90 systems within the Anthem enterprise environment including, eventually, the company's enterprise data warehouse.

- A system that stores a large amount of consumer personally identifiable information.

- Queries to that data warehouse resulted in access to an exfiltration of approximately 78.8 m unique user records.

http://www.bankinfosecurity.com/new-in-depth-analysis-anthem-breach-a-9627

Security Breach Case Study 2: Anthem

- **Vulnerabilities:**
  - Exploitable vulnerabilities were found in anthem network
  - User security awareness training conducted to prevent phishing and social engineering

http://www.bankinfosecurity.com/new-in-depth-analysis-anthem-breach-a-9627

Security Breach Case Study 2: Anthem

- **Remediation measures:**
  - Implemented two-factor authentication on all remote access tools, deployed a privileged account management solution and added enhanced logging resources to its security event and incident management solutions
  - Further, the company conducted a complete reset of passwords for all privileged users, suspended all remote access pending implementation of two-factor authentication and created new Network Admin IDs

Week 6 Topic 7

VM Challenges & Pitfalls

- **Challenges:**
  - Internal expertise on VM tool
  - Not enough support from IT teams
  - Vulnerability patching causing application failure
  - Management support

- **Internal expertise on VM tool:**
  - Not too much expertise required
  - Monitor traffic pattern
  - Train staff if possible
  - Patch small portions of the network first

VM Challenges & Pitfalls

- **Not enough support from IT teams:**
  - Create reports and share among IT management
  - Highlight and educate risks to IT management and board

- **Patching causing application failure:**
  - In test environment create work around or compensating controls
  - Test the compensating controls
  - Document the compensating controls

- **Not enough management support:**
  - Share reports with management highlighting recent incidents
  - Share industry-specific or geographically relevant breach reports
  - Create awareness

Week 6 Topic 8

Vulnerability scanners

- Vulnerability scanners are automated tools used to identify, assess, and report security vulnerabilities

- Vulnerabilities or weakness exist in many different places:

software, operating systems, networks and even people

- There are many choices today for assessment tools
- Some are free, some online and some are subscription-based

Types of vulnerability scanners

- There are two types of vulnerability scanners:

- **Network-based scanners:** These scanners scan an organization's network to identify vulnerabilities in network devices such as routers, switches, and firewalls.

- **Host-based scanners:** These scanners are installed on individual systems or servers to identify vulnerabilities in the underlying operating system, applications, and services.

Vulnerability scanners

Provide comprehensive view of their potential attack surface

- identify vulnerabilities
- Prioritize remediation efforts
- Improve security posture
- Save time and resources

Different Examples of Vulnerability scanners

OpenVAS

HACKER TARGET

SCANNERS TOOLS RESEARCH SERVICES ABOUT PRICING LOG IN

The OpenVAS scanner is a comprehensive vulnerability assessment system that can detect security issues in all manner of servers and network devices. Use this hosted version of the OpenVAS software to effortlessly test your Internet infrastructure.

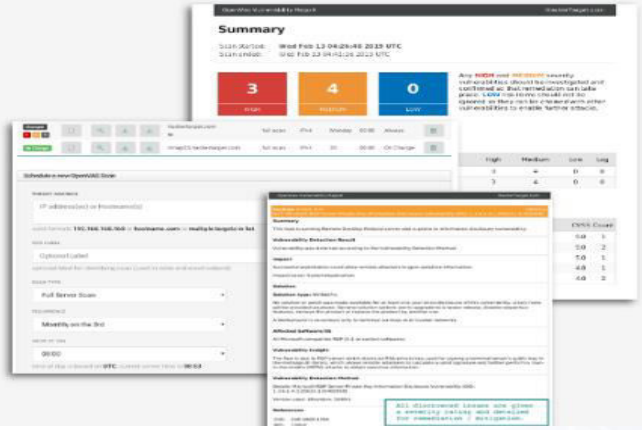
Results are delivered to your email address for analysis, allowing you to start re-mediating any risks your systems face from external threats.

Sample Reports

Launch OpenVAS Vulnerability Scan

Login for access to OpenVAS Vulnerability Scanning

Detect vulnerabilities in servers, networks and web sites



MEMBERSHIP BENEFITS

- Find **security vulnerabilities** in any Internet facing system
- **Detailed reporting** for risk assessment and re-mediation
- **Vulnerability Alerts** on detected change in scheduled report
- **Custom scan options;** Network/Server, Web, WordPress and Joomla Scans
- Access to **27 Vulnerability Scanners** and **OSINT** Tools
- **Trusted** Open Source Tools

VIEW PLANS USE CASES

https://www.greenbone.net/en/testnow/

Vega helps you find and fix cross-site scripting (XSS), SQL injection, and more.

Vega is a free and open source web security scanner and web security testing platform to test the security of web applications. Vega can help you find and validate SQL Injection, Cross-Site Scripting (XSS), inadvertently disclosed sensitive information, and other vulnerabilities. It is written in Java, GUI based, and runs on Linux, OS X, and Windows.

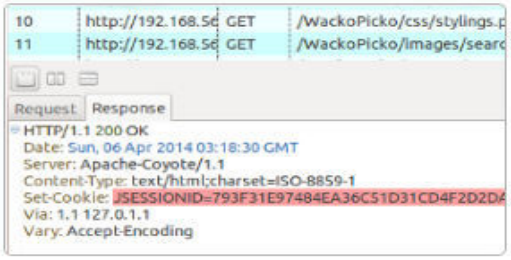
Vega can help you find vulnerabilities such as: reflected cross-site scripting, stored cross-site scripting, blind SQL injection, remote file include, shell injection, and others. Vega also probes for TLS / SSL security settings and identifies opportunities for improving the security of your TLS servers.

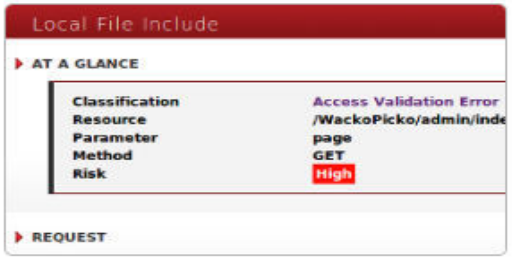
Vega includes an automated scanner for quick tests and an intercepting proxy for tactical inspection. The Vega scanner finds XSS (cross-site scripting), SQL injection, and other vulnerabilities. Vega can be extended using a powerful API in the language of the web: Javascript.

Vega was developed by Subgraph in Montreal.

DOWNLOAD

Automated, Manual, and Hybrid Security Testing





Automated Scanner

Vega includes a website crawler powering its automated scanner. Vega can automatically log into websites when supplied with user credentials.

Intercepting Proxy

Vega can be used to observe and interact with communication between clients and servers, and will perform SSL interception for HTTP websites.

Proxy Scanner

The Vega proxy can also be configured to run attack modules while the user is browsing the target site through it. This allows for semi-automated, user-driven security testing to ensure maximum

Summary

This document reports on the results of an automatic security scan. The report first summarises the results found. Then, for each host, the report describes every issue found. Please consider the advice given in each description, in order to rectify the issue.

It only lists hosts that produced issues.

All dates are displayed using the timezone "Coordinated Universal Time", which is abbreviated "UTC".

Scan started: **Mon Dec 7 12:51:47 2015 UTC**
Scan ended:
Task: testasp.vulnweb.com

Vulnerability Summary

HIGH	MEDIUM	LOW
2	8	0

Any **HIGH** and **MEDIUM** risk vulnerabilities should be investigated and confirmed so that remediation can take place. **LOW** risk items should not be ignored as they can be stepping stones to High risk attacks.

Host Summary

Host	Start	End	High	Medium	Low	Log	False Positive
87.230.29.167	Dec 7, 12:51:52	(not finished)	2	8	0	23	0
Total: 1			2	8	0	23	0

Results per Host

Host 87.230.29.167

Scanning of this host started at: Mon Dec 7 12:51:52 2015 UTC
Number of results: 33

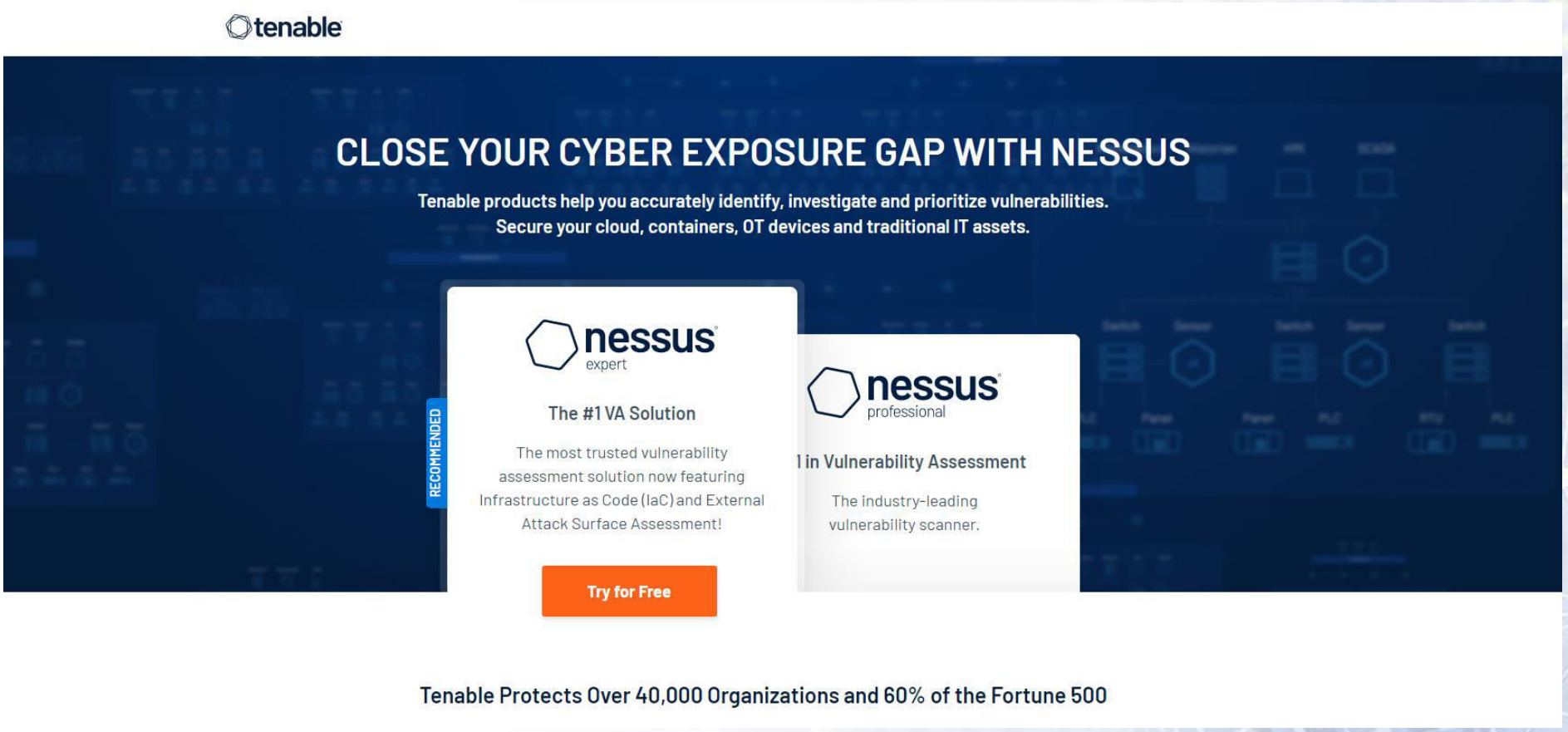
Port Summary for Host 87.230.29.167

Service (Port)	Threat Level
80/tcp	High
139/tcp	Log
3389/tcp	Medium

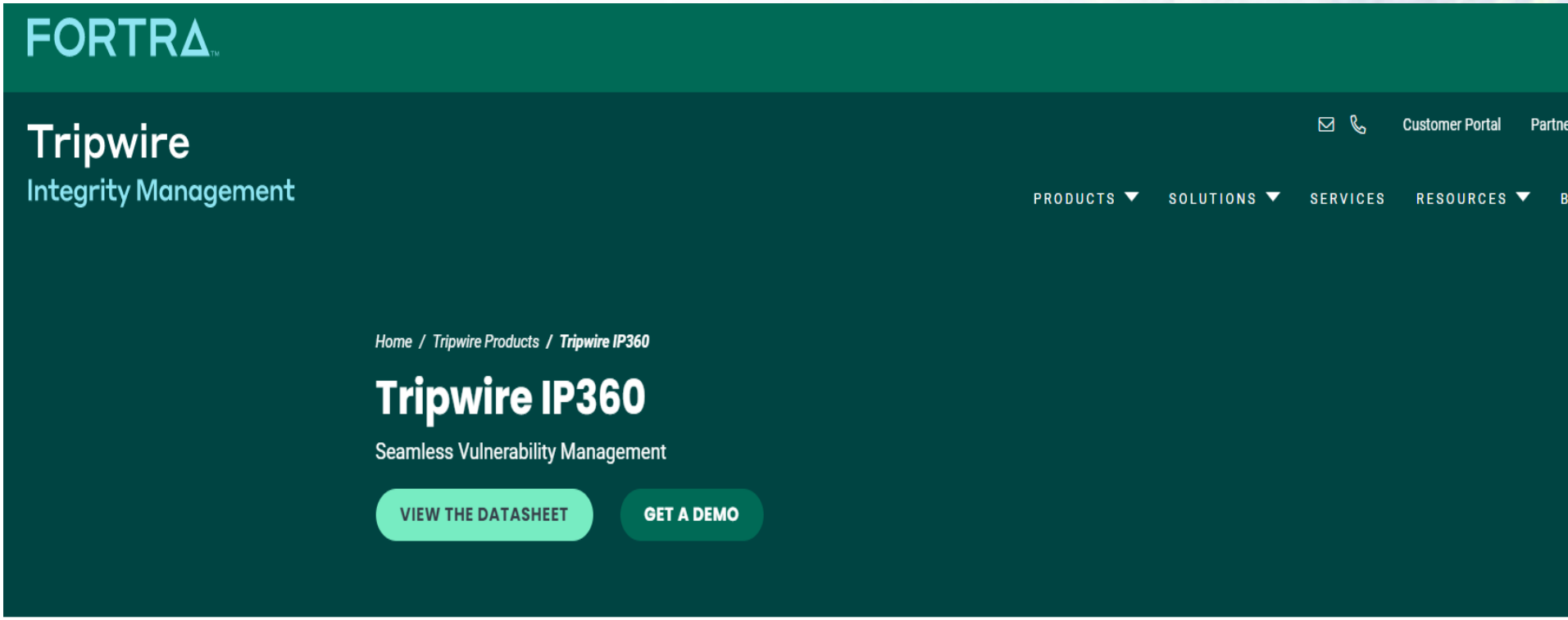
https://hackertarget.com/sample-vulnerability-report/sample-openvas-report.pdf

https://hackertarget.com/sample-vulnerability-report/metasploitable-2.0-openvas.pdf

Tenable


tenable
CLOSE YOUR CYBER EXPOSURE GAP WITH NESSUS
Tenable products help you accurately identify, investigate and prioritize vulnerabilities.
Secure your cloud, containers, OT devices and traditional IT assets.
RECOMMENDED
nessus expert
The #1 VA Solution
The most trusted vulnerability assessment solution now featuring Infrastructure as Code (IaC) and External Attack Surface Assessment!
Try for Free
nessus professional
l in Vulnerability Assessment
The industry-leading vulnerability scanner.
Tenable Protects Over 40,000 Organizations and 60% of the Fortune 500

Tripwire



Nobody needs more unnecessary alerts. Ready for prioritized risk scoring that focuses on what really matters?

Major Banking Institution Case Study

This multinational banking institution has been around for over 100 years, dedicated to helping a customer base of over 20 million people in countries all over the world.

In order to serve such a large customer base and keep financial services at competitive rates, they've taken advantage of the latest in cloud technology to reduce the operating costs of their IT infrastructure and outward-facing services—from online banking apps to mortgage calculators. In doing so, they've migrated many of these customer-facing services to operate in all of the major cloud platforms, including Microsoft Azure, Google Cloud and soon Amazon Web Services. It's a challenge for organizations adopting cloud infrastructure to properly secure those environments due to the elasticity and short lifespan of servers, as well as the ever-growing presence of containers.

INDUSTRY: Banking and Financial Services

HEADCOUNT: 90,000

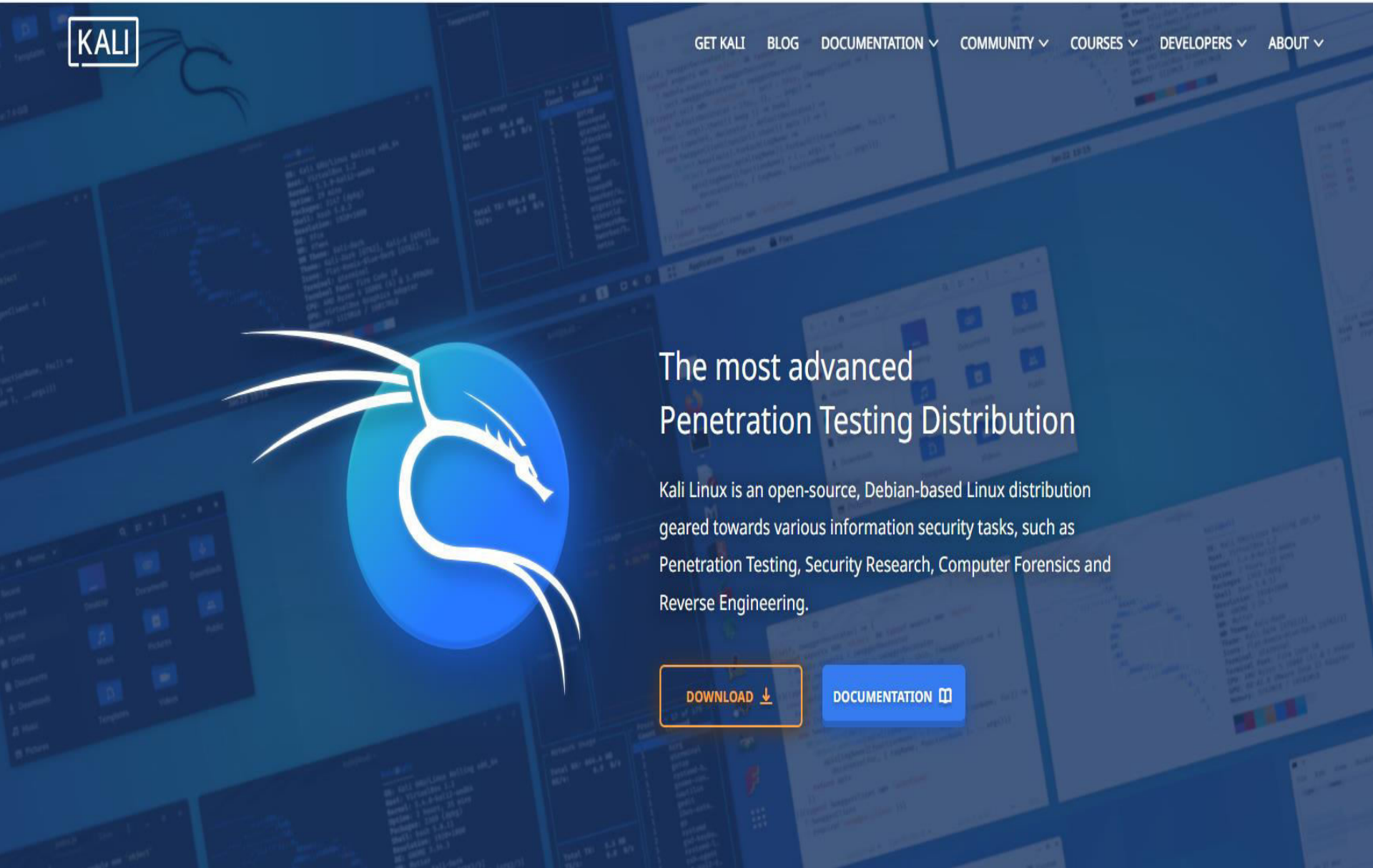
CUSTOMER SINCE: 2000

SOLUTIONS:

- Tripwire Enterprise
- Tripwire IP360

> Over the past 18 years, this multinational bank has kept their trust in Tripwire. They've relied on our promises to deliver the solutions that protect both their enterprise and the millions of customers that drive their success.

KALI Linux


KALI
GET KALI
BLOG
DOCUMENTATION
COMMUNITY
COURSES
DEVELOPERS
ABOUT
The most advanced
Penetration Testing Distribution
Kali Linux is an open-source, Debian-based Linux distribution geared towards various information security tasks, such as Penetration Testing, Security Research, Computer Forensics and Reverse Engineering.
DOWNLOAD
DOCUMENTATION

Try Nessus Expert Free for 7 Days

Nessus® is the most comprehensive vulnerability assessment tool on the market today. Nessus Expert will help automate the vulnerability assessment process for the modern attack surface, save time on your compliance cycles and allow you to engage your IT team.

	Nessus Expert 7-Day Trial	Nessus Expert Purchase
Designed For	Consultants, Pen Testers, Developers and SMB's wanting to evaluate Nessus Expert	Consultants, Pen Testers, Developers and SMB's to use for their security practice
Real-Time Vulnerability Updates	✓	✓
Vulnerability Scanning	✓	✓
External Attack Surface Scanning	✓	✓
Scan Cloud Infrastructure	✓	✓
Unlimited Scans	✓	✓
Number of IPs Per Scanner	32	Unlimited
Web Application Scanning	✓	✓

Register

Please register to evaluate Nessus. An activation code will be emailed to the address you provide.

First Name **Last Name**

Business Email

Details regarding your trial will be sent to this email.

Phone

Title

Company Name

Company Size (Employees)

Qualys Cloud Platform.

The revolutionary architecture that powers Qualys' IT, security, and compliance cloud apps.

Watch video

QUALYS CLOUD PLATFORM

Cloud Platform - Free Trial

FREE SERVICES

60-Day Remote Endpoint Protection

Global AssetView

Community Edition

SSL Labs

CertView

CloudView

BrowserCheck

Everything visible, everything secure.

Qualys Cloud Platform gives you a continuous, always-on assessment of

SONICWALL

PRODUCTS SOLUTIONS PARTNERS SUPPORT CONTACT SALES

SONICWALL PHISHING QUIZ

Over 90% of today's data breaches start with a phishing attack. Can you spot when you're being phished?

Test your ability to identify fraudulent emails and see how susceptible you really are to social engineering and phishing scams.
The SonicWall Phishing Quiz uses real examples from some of the most common phishing email attacks. Take the test and reveal your Phishing IQ today.

TAKE THE QUIZ

https://www.sonicwall.com/phishing-iq-test/#

SONICWALL

PRODUCTS SOLUTIONS PARTNERS SUPPORT CONTACT SALES

Back

Question: 1/10

01 02 03 04 05 06 07 08 09 10

You've received a pricing inquiry!

PHISHING LEGITIMATE

Re: Inquiry.

From: June Zhang support@bpricessearcher.shop

To: rizqwan cs205@vu.edu.pk

From: June Zhang support@bpricessearcher.shop

To: rizqwan cs205@vu.edu.pk

Subject: Re: Inquiry.

Hello, Nice to meet you, Pls kindly study our quotation form below and input the required prices.

Waiting for your reply so as to proceed to send our officiail order.

June Zhang,

Sales Manager

Quotation.xlsx (174.60K)

DOWNLOAD

SONICWALL

PRODUCTS SOLUTIONS PARTNERS SUPPORT CONTACT SALES

GOOD JOB, RIZQWAN!

You answered 6/10 questions correctly

Email Me My Results

Email Address →

By submitting this form, you agree to receive the SonicWall Newsletter and accept our Terms of Use and acknowledge our Privacy Statement. You can unsubscribe at any time from the Preference Center.

Question Summary:

Answered Incorrectly

1. You've Received A Pricing Inquiry!

You Said: Legitimate

LEARN WHY

Answered Correctly

2. Failed DHL Delivery

You Said: Phishing

LEARN WHY

Answered Correctly

3. It's Time To Update Your Office 365 Password

You Said: Phishing

LEARN WHY

Answered Incorrectly

4. Confirm Your Account With Doodle

You Said: Phishing

LEARN WHY

Answered Correctly

5. You're Invited To Join A Webcast!

You Said: Legitimate

LEARN WHY

Answered Correctly

6. Current Procurement Information For Sonicwall INC.

You Said: Phishing

LEARN WHY

Answered Incorrectly

7. 2: Qa-Partnership | 7:4

You Said: Legitimate

LEARN WHY

Answered Correctly

8. Microsoft Subscription Expiry

You Said: Phishing

LEARN WHY

Answered Correctly

9. Bill 22427 From Steven Murphy Electrical Contractors Pty Ltd Is Due

You Said: Legitimate

LEARN WHY

Answered Incorrectly

10. Your Credit Card Payment Is Due On Aug 7

You Said: Phishing

LEARN WHY

Incorrect

This is actually a phishing email. Be cautious about hyperlinks and attachments you open from emails – they may direct you to malicious websites designed to get you to share sensitive information.

Re: Inquiry.

From: June Zhang support@bpricessearcher.shop

To: rizqwan cs205@vu.edu.pk

From: June Zhang support@bpricessearcher.shop

To: rizqwan cs205@vu.edu.pk

Subject: Re: Inquiry.

Hello, Nice to meet you Pls kindly study our quotation form below and input the required prices.

Waiting for your reply so as to proceed to send our officiail order.

June Zhang,

Sales Manager

- -

Quotation.xlsx (174.60K)

DOWNLOAD

PREVIEW

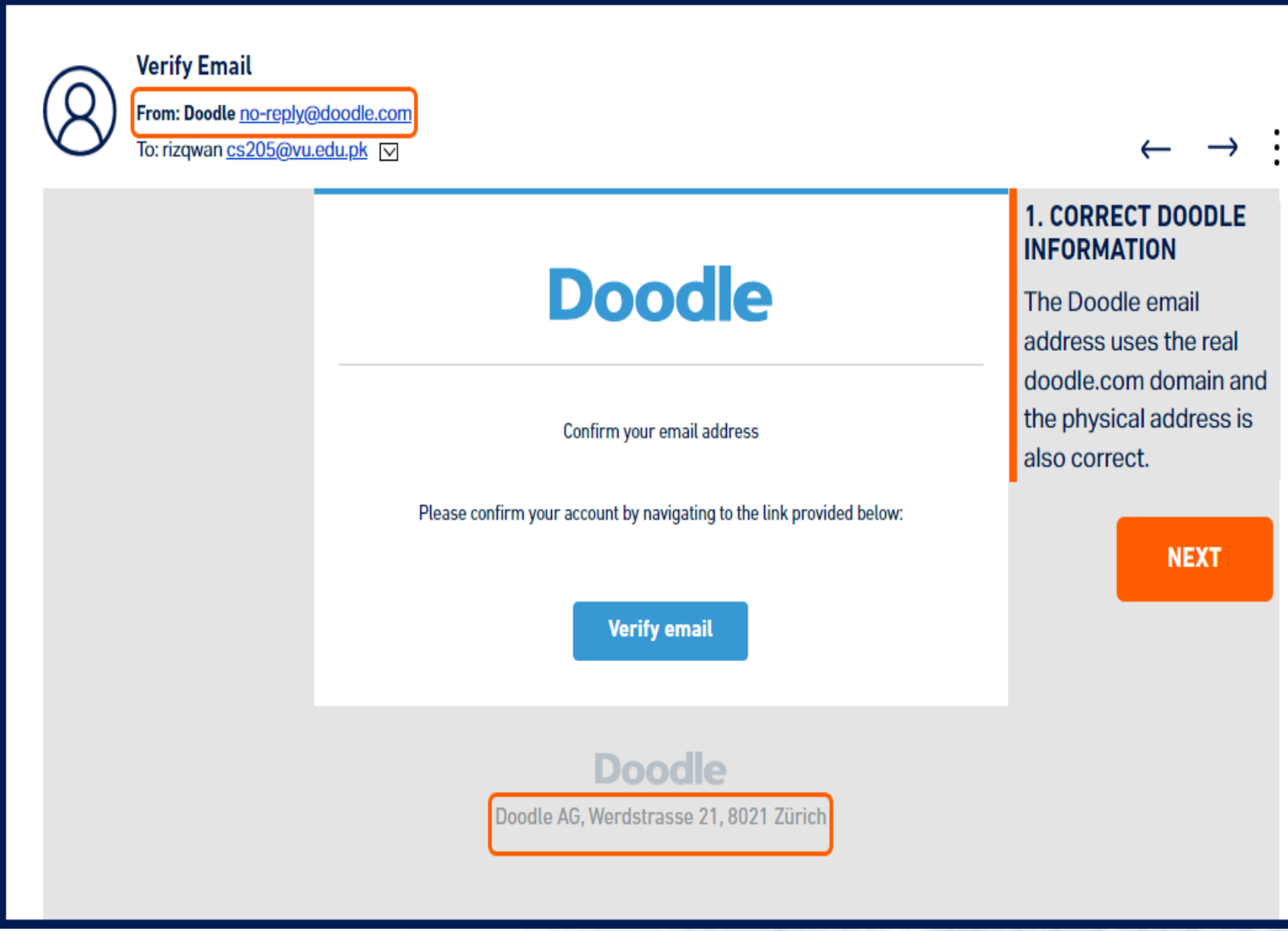
1. MISSPELLED WORDS

While it is not unusual for a real email to have some spelling errors, this particular email has too many misspelled words and grammatical errors for a professional email.

NEXT

Incorrect

This is a legitimate Doodle email communication.



- Vulnerability scanners typically work by scanning systems, applications, and network devices for known vulnerabilities and misconfigurations, using a database of known vulnerabilities and attack vectors.

Week 6 Topic 9

SECURITY HARDENING – MANUAL & AUTOMATED WORK

- **Step 1:** Scan an IT asset using Qualys compliance scan, NESSUS compliance scan, or CIS CAT PRO Tool.
- Acquire report of failed controls

- **Step 2:** Apply the failed controls using AD (for Windows) or manually for other systems & devices.

- **Step 3:** Use the automated feature of Qualys compliance scan, Nessus compliance scan or CIS CAT Pro Tool to verify that applied controls are in place.
- Compare the ‘before’ and ‘after’ report

SECURITY HARDENING – MANUAL & AUTOMATED WORK

- **Step 4:** manually verify if any discrepancy is found (control should be in place but not being validated by the tool)

- **Step 5:** For any system or device for which the Qualys compliance scan, Nessus compliance scan, or CIS CAT Pro Tool scan cannot be performed, conduct the validation of control implementation manually

SECURITY HARDENING – MANUAL & AUTOMATED WORK

- Use sampling where necessary during manual validation work to reduce workload
- For example, 15-20 % of assets may be checked at random
- Or 15-20% of controls may be checked on an asset

END

Week 6 Topic 10

(Security Content Automation Protocol)

- **SCAP** was developed by the **National Institute of Standards and Technology (NIST)** in collaboration with various government agencies and industry partners
- To create a consistent language and format for discussing secuirty issues

SCAP Components

- Common Weakness Enumeration (CWE)
- Common vulnerabilities and exposures (CVE)
- Common Configuration Enumeration (CCE)
- Common Platform Enumeration (CPE)
- Common vulnerability scoring system (CVSS)

Common Weakness Enumeration (CWE)

- CVE is a community-developed list of software and hardware weakness types.
- It serves as a measuring stick for security tools, and as a baseline for weakness identification, mitigation, and prevention efforts.
- https://cwe.mitre.org/index.html

Common Weakness Enumeration

A Community-Developed List of Software & Hardware Weakness Types

Top HW CWE | Top 25

ID Lookup: Go

Home | About | CWE List | Scoring | Mapping Guidance | Community | News | Search

CWE™ is a community-developed list of software and hardware weakness types. It serves as a common language, a measuring stick for security tools, and as a baseline for weakness identification, mitigation, and prevention efforts.

CWE List Quick Access

Search CWE

ENHANCED BY Google

View CWE

- by Software Development
- by Hardware Design
- by Research Concepts
- by Other Criteria

Total Weaknesses: 933

Viewing Customized CWE information

The CWE Team, in collaboration with the CWE/CAPEC User Experience Working Group (UEWG), has updated how users can view Weaknesses to display only those weakness details that are most relevant to them, as noted below. This update replaces the often-overlooked dropdown menu with four new filter options that better reflect the needs of our audience.

These content viewing options are available at the top of each CWE Weakness. Please review the hover text below for a description of each content filter.

Conceptual Operational Mapping Friendly Complete

Community Engagement

Hardware CWE Special Interest Group	Join HW CWE SIG
ICS/OT Special Interest Group	Join ICS/OT SIG
REST API Working Group	Join REST API WG
User Experience Working Group	Join UE WG
CWE/CAPEC Board	Read meeting minutes

CWE News

News Hardware Weaknesses Added to CWE List 3 Years Ago Today

News "CWE-CAPEC ICS/OT SIG" Booth at *S4x23*

News CWE Version 4.10 Now Available

Blog Community Actively Working to Enhance CWE's ICS/OT Coverage

Podcast "Using CWE/CAPEC in Education"

More >>

Please see our Guidelines for New Content Suggestions
For other ways to get involved, contact us

Page Last Updated: February 24, 2023

Activate Windows
Go to Settings to activate Windows.

MITRE

Use of the Common Weakness Enumeration (CWE) and the associated references from this website are subject to the Terms of Use. CWE is sponsored by the U.S. Department of Homeland Security (DHS) Cybersecurity and Infrastructure Security Agency (CISA) and managed by the Homeland Security Systems Engineering and Development Institute (HSSEDI) which is operated by The MITRE Corporation (MITRE). Copyright © 2006–2023, The MITRE Corporation. CWE, CWSS, CWRAF, and the CWE logo are trademarks of The MITRE Corporation.

HSSEDI

Common vulnerabilities and exposures (CVE)

- CVE Provides detailed information on known vulnerabilities
- is used to identify and classify vulnerabilities that may impact a software and hardware products.

Common Configuration Enumeration (CCE)

- Common Configuration Enumeration (CCE) is a standardized method of identifying and describing security-relevant system configuration settings.
- CCE is maintained by the National Institute of Standards and Technology (NIST) .
- Security teams evaluate the security posture of their systems, identify misconfigured settings that may increase their risk.
- https://cce.mitre.org/lists/cce_list.html

Common Configuration Enumeration
Unique Identifiers for Common System Configuration Issues

CCE Website is in "Archive" status – read the announcement

About CCE
Documents
FAQs
CCE List
References
Editorial Policies
CCE in Use
CCE Community
CCE Working Group
Discussion Archive
News & Events
Calendar
Search the Site

CCE List – Archive

IMPORTANT: The CCE List is now hosted at http://nvd.nist.gov/cce/index.cfm.

Version – CCE 5 (Archive)

The Common Configuration Enumeration (CCE) List is posted below. In Version 5 CCE-IDs are assigned according to "platform groups." The CCE List is available for download in two formats: the canonical Microsoft Excel spreadsheet format, and an alternative XML format. Spreadsheets are available in a single combined file and by individual platform group. XML is only available for the single combined file, containing CCE entries for all platform groups.

Please note that the spreadsheets are the canonical format. In the case of any discrepancy between the XML and the spreadsheets, the spreadsheets should be preferred. Also, the format of the XML itself is version 0.2 of that encoding, and is subject to change.

IMPORTANT: Activity on the CCE effort has been suspended, and the CCE Web site has been moved to "Archive" status. Read the complete message on the homepage.

Release Details

The current release of CCE is 5.20130214 (CCE Version 5, updated on February 14, 2013). A ChangeLog is available that details the changes since the last release, 5.20120521.

Total CCEs: 12,163

DOWNLOADS (XML format)	DATE UPDATED
CCE v5 - All Platform Groups-COMBINED FILE (11.5 MB)	February 14, 2013

DOWNLOADS (MS Excel format)	DATE UPDATED
CCE v5 - All Platform Groups-COMBINED FILE (5398 KB)	February 14, 2013
CCE v5 - AIX 5.3 (226 KB)	May 6, 2009
CCE v5 - Apache HTTP 1.3 (47 KB)	February 14, 2013
CCE v5 - Apache HTTP 2.0 (97 KB)	February 14, 2013
CCE v5 - Apache HTTP 2.2 (123 KB)	February 14, 2013
CCE v5 - Apache Tomcat 4 (71 KB)	February 14, 2013
CCE v5 - Apache Tomcat 5 (48 KB)	February 14, 2013
CCE v5 - Apache Tomcat 6 (47 KB)	February 14, 2013
CCE v5 - HP-UX 11.23 (202 KB)	May 6, 2009
CCE v5 - Internet Explorer 7 (260 KB)	March 14, 2012
CCE v5 - Internet Explorer 8 (906 KB)	September 26, 2010

CCE List
About CCE Entries
CCE Entry Creation Process
Use Cases
References
Editorial Policies

Activate Windows
Go to Settings to activate Windows.

Common Platform Enumeration (CPE)

- **CPE** is a standardized method of describing and identifying software systems, applications, and operating systems using a unique identifier format.
- provides a structured and uniform way of describing the attributes of a software product, such as the vendor name, product name, version number, and edition.

- https://nvd.nist.gov/products/cpe

Common Platform Enumeration (CPE)

- consists of three components separated by colons:
- The first component identifies the vendor name,
- The second component identifies the product name, and
- The third component identifies the version number.
- For example, the CPE string for Windows 10 would be:
- cpe:/o:microsoft:windows_10
- This format is used by various security tools, such as vulnerability scanners, to identify and match software products with known vulnerabilities or other security issues.

- https://nvd.nist.gov/products/cpe

NOTICE

In September 2023, the NVD plans to retire all legacy data feeds while guiding any remaining data feed users to updated application-programming interfaces (APIs). APIs have many benefits over data feeds and have been the proven and preferred approach to web-based automation for over a decade. For additional information on the NVD API, please visit the developers pages. Click here for more information on the NVD timeline.

Official Common Platform Enumeration (CPE) Dictionary

CPE is a structured naming scheme for information technology systems, software, and packages. Based upon the generic syntax for Uniform Resource Identifiers (URI), CPE includes a formal name format, a method for checking names against a system, and a description format for binding text and tests to a name.

Below is the current official version of the CPE Product Dictionary. The dictionary provides an agreed upon list of official CPE names. The dictionary is provided in XML format and is available to the general public. Please check back frequently as the CPE Product Dictionary will continue to grow to include all past, present and future product releases. The CPE Dictionary is updated nightly when modifications or new names are added.

As of December 2009, The National Vulnerability Database is now accepting contributions to the Official CPE Dictionary. Organizations interested in submitting CPE Names should contact the NVD CPE team at cpe_dictionary@nist.gov for help with the processing of their submission.

The CPE Dictionary hosted and maintained at NIST may be used by nongovernmental organizations on a voluntary basis and is not subject to copyright in the United States. Attribution would, however, be appreciated by NIST.

Common vulnerability scoring system (CVSS)

- CVSS is a standardized method of assessing and scoring the severity of cyber security vulnerabilities.
- prioritize and manage vulnerabilities based on their potential impact.

Exploitability Matrix:

- Access Vector
- Attack Complexity
- Privileges Required
- User Interaction

National Vulnerability Database (NVD)

- NVD is the largest publicly available source of vulnerability intelligence by National Institute of Standards and Technology (NIST)
- Vulnerabilities in the NVD are called Common Vulnerabilities and Exposures (CVE).
- https://nvd.nist.gov/

Week 6 Topic 11

Common Vulnerabilities and Exposures

- Common Vulnerabilities and Exposures (CVE) is a standardized list of publicly known cyber security vulnerabilities and exposures.

- Each CVE entry includes a unique identifier, a description of the vulnerability, the affected software or hardware, and a score based on the Common Vulnerability Scoring System (CVSS).

- The score is derived from a set of metrics using the (CVSS)
- The CVE feeds into the National Vulnerabilities Database(NVD)

https://cve.mitre.org/

https://www.cvedetails.com/vulnerabilities-by-types.php

https://www.cvedetails.com/vulnerability-list/opsqli-1/sql-injection.html

TOTAL CVE Records: 198864

NOTICE: Transition to the all-new CVE website at WWW.CVE.ORG and CVE Record Format JSON are underway.

NOTICE: Changes are coming to CVE List Content Downloads in 2023.

The mission of the CVE® Program is to identify, define, and catalog publicly disclosed cybersecurity vulnerabilities.

CVE News

News has moved to the new CVE website.

Go to new News page >>

CVE Podcast

Podcasts have moved to the new CVE website.

Go to new Podcast page >>

CVE Blog

Blogs are moving to the new CVE website.

Go to new Blogs page >>

Become a CNA

CVE Numbering Authorities, or "CNAs," are essential to the CVE Program's success and every CVE Record is added to the CVE List by a CNA.

Join today!

- Business benefits
- No fee or contract
- Few requirements
- Easy to join

Go to new CVE website

Learn How to Become a CNA >>>

Watch CNA Onboarding Videos >>

Newest CVE Records

Tweets from @CVEnew

CVE
@CVEnew · 2h

CVE-2023-0665 HashiCorp Vault's PKI mount issuer endpoints did not correctly authorize access to remove an issuer or modify issuer metadata, potentially resulting in denial of service of the PKI mount. This bug did not affect public or private key... cve.mitre.org/cgi-bin/cvenam...

Follow @CVEnew >>

Page Last Updated or Reviewed: July 22, 2022

Use of the CVE® List and the associated references from this website are subject to the terms of use. CVE is sponsored by the U.S. Department of Homeland Security (DHS) Cybersecurity and Infrastructure Security Agency (CISA). Copyright © 1999-2023, The MITRE Corporation. CVE and the CVE logo are registered trademarks of The MITRE Corporation.

Switch to https://
Home

Browse :
Vendors
Products
Vulnerabilities By Date
Vulnerabilities By Type

Reports :
CVSS Score Report
CVSS Score Distribution

Search :
Vendor Search
Product Search
Version Search
Vulnerability Search
By Microsoft References

Top 50 :
Vendors
Vendor Cvss Scores
Products
Product Cvss Scores
Versions

Other :
Microsoft Bulletins
Bugtraq Entries
CWE Definitions
About & Contact
Feedback
CVE Help
FAQ
Articles

External Links :
NVD Website
CWE Web Site

View CVE :
Go
(e.g.: CVE-2009-1234 or 2010-1234 or 20101234)

View BID :
Go
(e.g.: 12345)

Search By Microsoft Reference ID:
Go

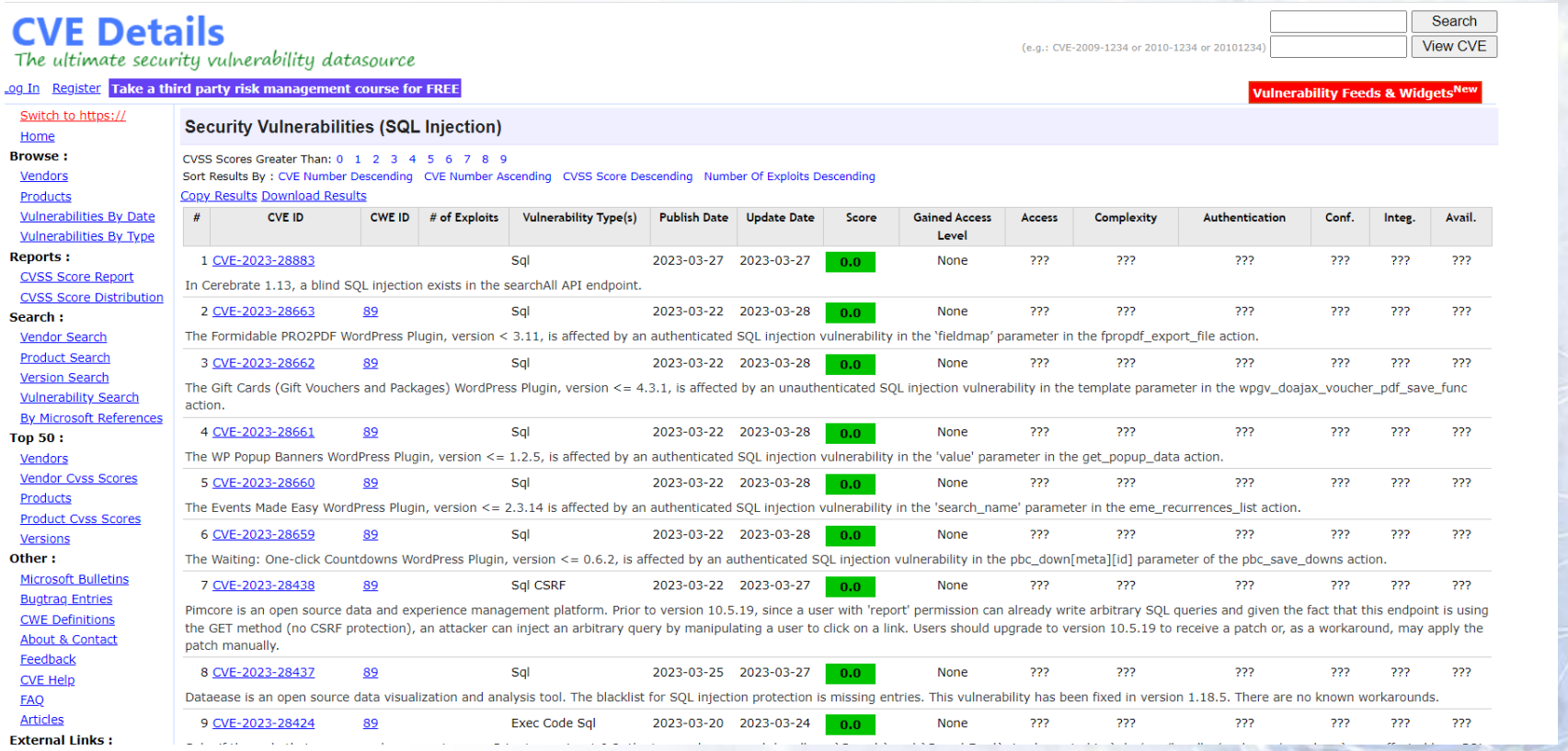
Browse Vulnerabilities By Date

Year	# of Vulnerabilities												
1999	894	January	February	March	April	May	June	July	August	September	October	November	December
2000	1020	January	February	March	April	May	June	July	August	September	October	November	December
2001	1677	January	February	March	April	May	June	July	August	September	October	November	December
2002	2156	January	February	March	April	May	June	July	August	September	October	November	December
2003	1527	January	February	March	April	May	June	July	August	September	October	November	December
2004	2451	January	February	March	April	May	June	July	August	September	October	November	December
2005	4935	January	February	March	April	May	June	July	August	September	October	November	December
2006	6610	January	February	March	April	May	June	July	August	September	October	November	December
2007	6520	January	February	March	April	May	June	July	August	September	October	November	December
2008	5632	January	February	March	April	May	June	July	August	September	October	November	December
2009	5736	January	February	March	April	May	June	July	August	September	October	November	December
2010	4653	January	February	March	April	May	June	July	August	September	October	November	December
2011	4155	January	February	March	April	May	June	July	August	September	October	November	December
2012	5297	January	February	March	April	May	June	July	August	September	October	November	December
2013	5191	January	February	March	April	May	June	July	August	September	October	November	December
2014	7939	January	February	March	April	May	June	July	August	September	October	November	December
2015	6504	January	February	March	April	May	June	July	August	September	October	November	December
2016	6454	January	February	March	April	May	June	July	August	September	October	November	December
2017	14714	January	February	March	April	May	June	July	August	September	October	November	December
2018	16557	January	February	March	April	May	June	July	August	September	October	November	December
2019	17344	January	February	March	April	May	June	July	August	September	October	November	December
2020	18325	January	February	March	April	May	June	July	August	September	October	November	December
2021	20171	January	February	March	April	May	June	July	August	September	October	November	December
2022	25227	January	February	March	April	May	June	July	August	September	October	November	December
2023	7057	January	February	March									

Warning : Vulnerabilities with publish dates before 1999 are not included in this table and chart. (Because there are not many of them and they make the page look bad; and they may not be actually published in those years.)

Vulnerabilities By Year

Common Vulnerabilities and Exposures



CVE Details

The ultimate security vulnerability datasource

(e.g.: CVE-2009-1234 or 2010-1234 or 20101234) Search View CVE

og In Register Take a third party risk management course for FREE

Vulnerability Feeds & Widgets New

Switch to https://
Home
Browse :
Vendors
Products
Vulnerabilities By Date
Vulnerabilities By Type
Reports :
CVSS Score Report
CVSS Score Distribution
Search :
Vendor Search
Product Search
Version Search
Vulnerability Search
By Microsoft References
Top 50 :
Vendors
Vendor Cvss Scores
Products
Product Cvss Scores
Versions
Other :
Microsoft Bulletins
Bugtraq Entries
CWE Definitions
About & Contact
Feedback
CVE Help
FAQ
Articles
External Links :

Security Vulnerabilities (SQL Injection)

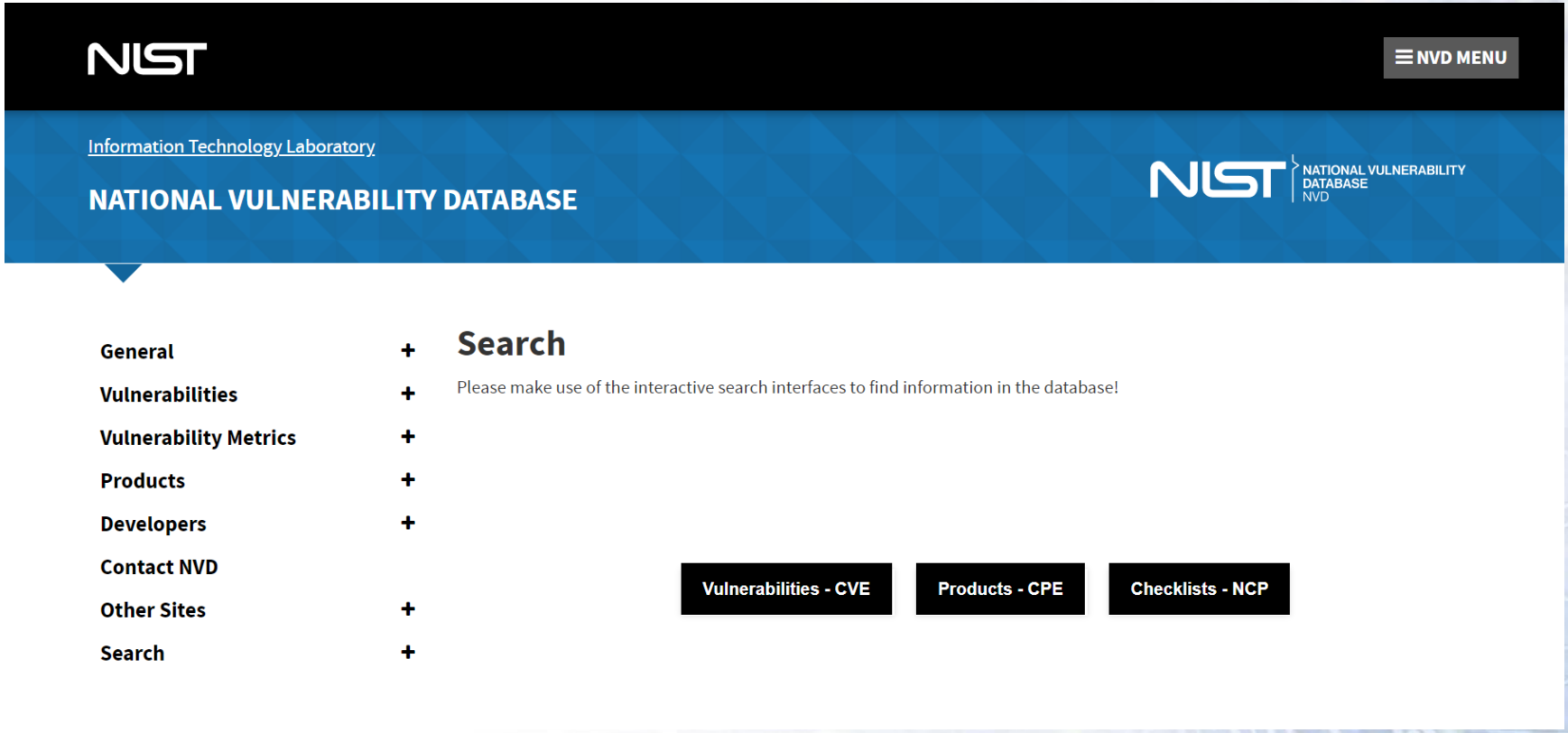
CVSS Scores Greater Than: 0 1 2 3 4 5 6 7 8 9

Sort Results By : CVE Number Descending CVE Number Ascending CVSS Score Descending Number Of Exploits Descending

Copy Results Download Results

#	CVE ID	CWE ID	# of Exploits	Vulnerability Type(s)	Publish Date	Update Date	Score	Gained Access Level	Access	Complexity	Authentication	Conf.	Integ.	Avail.
1	CVE-2023-28883			Sql	2023-03-27	2023-03-27	0.0	None	???	???	???	???	???	???
In Cerebrate 1.13, a blind SQL injection exists in the searchAll API endpoint.														
2	CVE-2023-28663	89		Sql	2023-03-22	2023-03-28	0.0	None	???	???	???	???	???	???
The Formidable PRO2PDF WordPress Plugin, version < 3.11, is affected by an authenticated SQL injection vulnerability in the 'fieldmap' parameter in the fpropdf_export_file action.														
3	CVE-2023-28662	89		Sql	2023-03-22	2023-03-28	0.0	None	???	???	???	???	???	???
The Gift Cards (Gift Vouchers and Packages) WordPress Plugin, version <= 4.3.1, is affected by an unauthenticated SQL injection vulnerability in the template parameter in the wpgv_doajax_voucher_pdf_save_func action.														
4	CVE-2023-28661	89		Sql	2023-03-22	2023-03-28	0.0	None	???	???	???	???	???	???
The WP Popup Banners WordPress Plugin, version <= 1.2.5, is affected by an authenticated SQL injection vulnerability in the 'value' parameter in the get_popup_data action.														
5	CVE-2023-28660	89		Sql	2023-03-22	2023-03-28	0.0	None	???	???	???	???	???	???
The Events Made Easy WordPress Plugin, version <= 2.3.14 is affected by an authenticated SQL injection vulnerability in the 'search_name' parameter in the eme_recurrences_list action.														
6	CVE-2023-28659	89		Sql	2023-03-22	2023-03-28	0.0	None	???	???	???	???	???	???
The Waiting: One-click Countdowns WordPress Plugin, version <= 0.6.2, is affected by an authenticated SQL injection vulnerability in the pbc_down[meta][id] parameter of the pbc_save_downs action.														
7	CVE-2023-28438	89		Sql CSRF	2023-03-22	2023-03-27	0.0	None	???	???	???	???	???	???
Pimcore is an open source data and experience management platform. Prior to version 10.5.19, since a user with 'report' permission can already write arbitrary SQL queries and given the fact that this endpoint is using the GET method (no CSRF protection), an attacker can inject an arbitrary query by manipulating a user to click on a link. Users should upgrade to version 10.5.19 to receive a patch or, as a workaround, may apply the patch manually.														
8	CVE-2023-28437	89		Sql	2023-03-25	2023-03-27	0.0	None	???	???	???	???	???	???
Dataease is an open source data visualization and analysis tool. The blacklist for SQL injection protection is missing entries. This vulnerability has been fixed in version 1.18.5. There are no known workarounds.														
9	CVE-2023-28424	89		Exec Code Sql	2023-03-20	2023-03-24	0.0	None	???	???	???	???	???	???

Common Vulnerabilities and Expore



https://nvd.nist.gov/search

Common Vulnerabilities and Exposures

NIST

NVD MENU

Information Technology Laboratory

NATIONAL VULNERABILITY DATABASE

NIST NATIONAL VULNERABILITY DATABASE NVD

- General +
- Vulnerabilities +
- Vulnerability Metrics +
- Products +
- Developers +
- Contact NVD
- Other Sites +
- Search +

Understanding Vulnerability Detail Pages

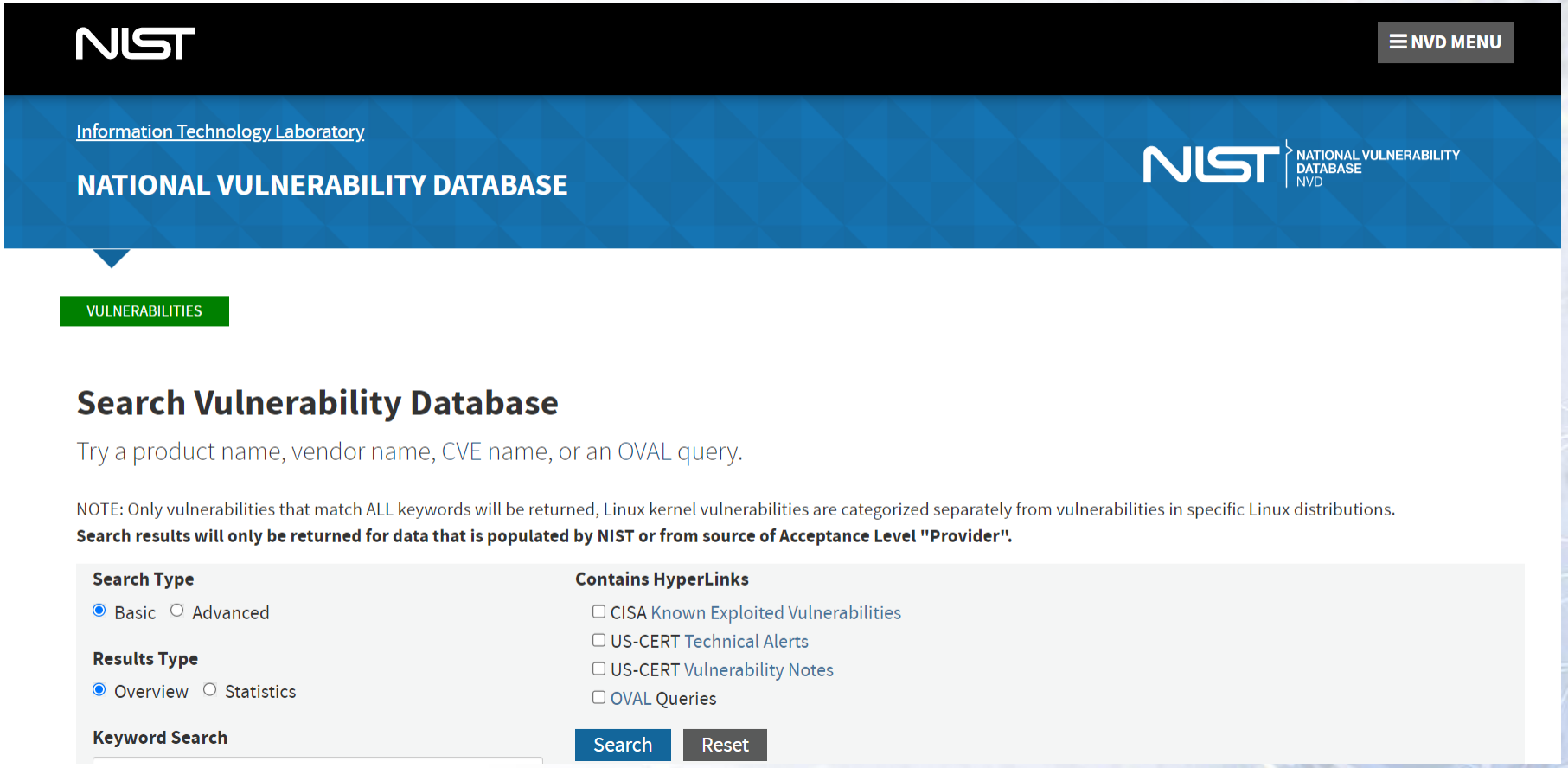
Vulnerability Statuses

Vulnerabilities

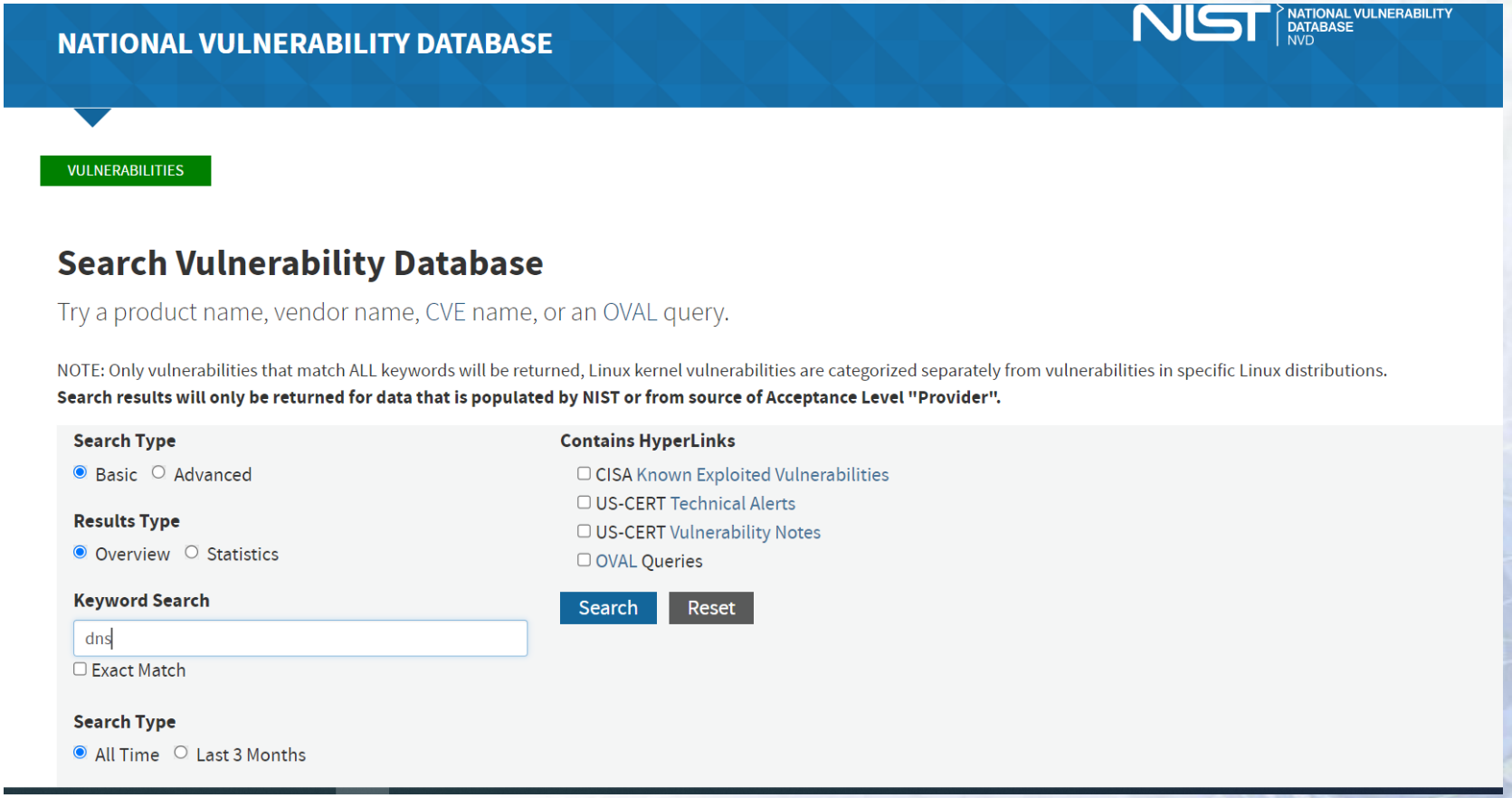
All vulnerabilities in the NVD have been assigned a CVE identifier and thus, abide by the definition below.

CVE defines a vulnerability as:

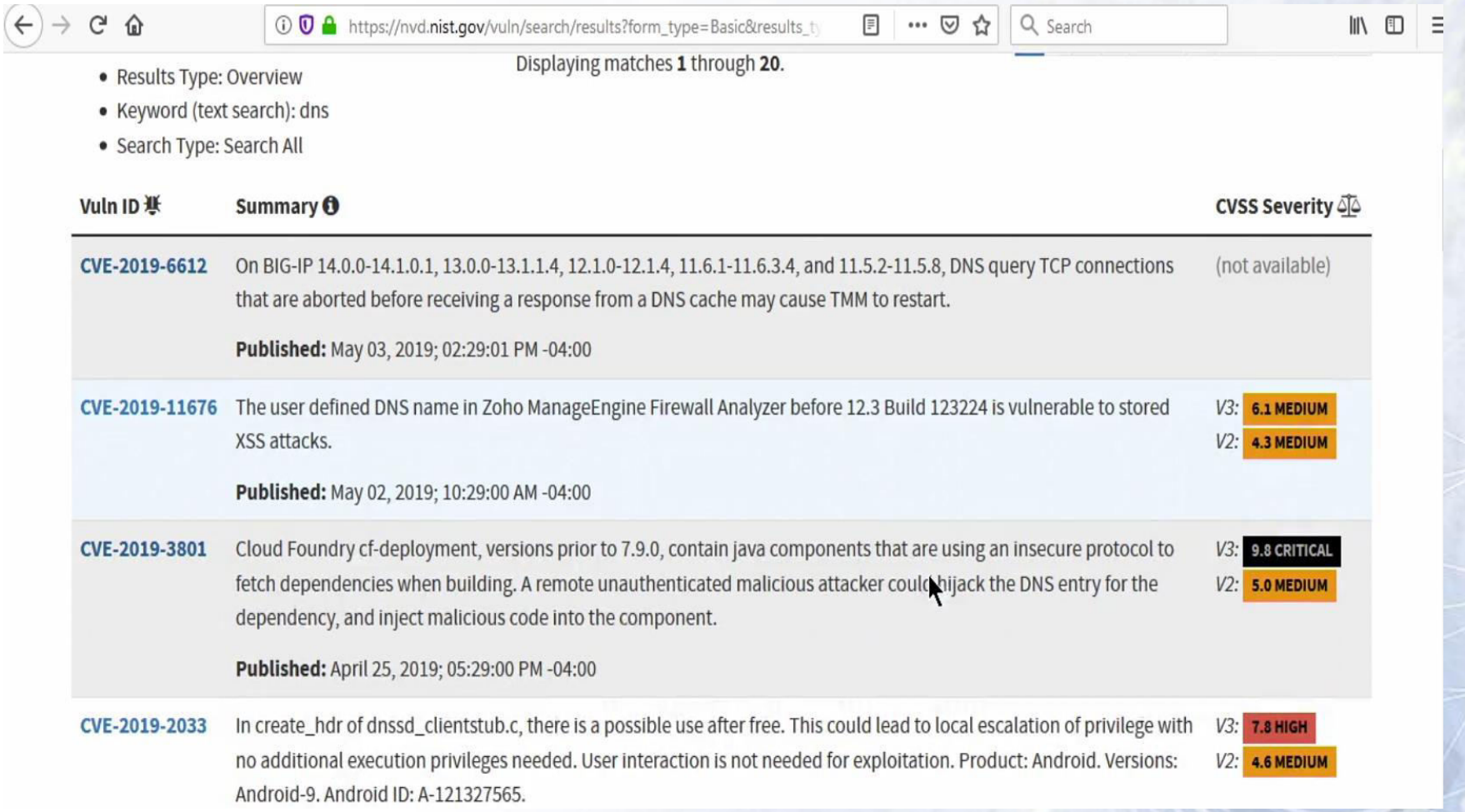
Common Vulnerabilities and Exposures



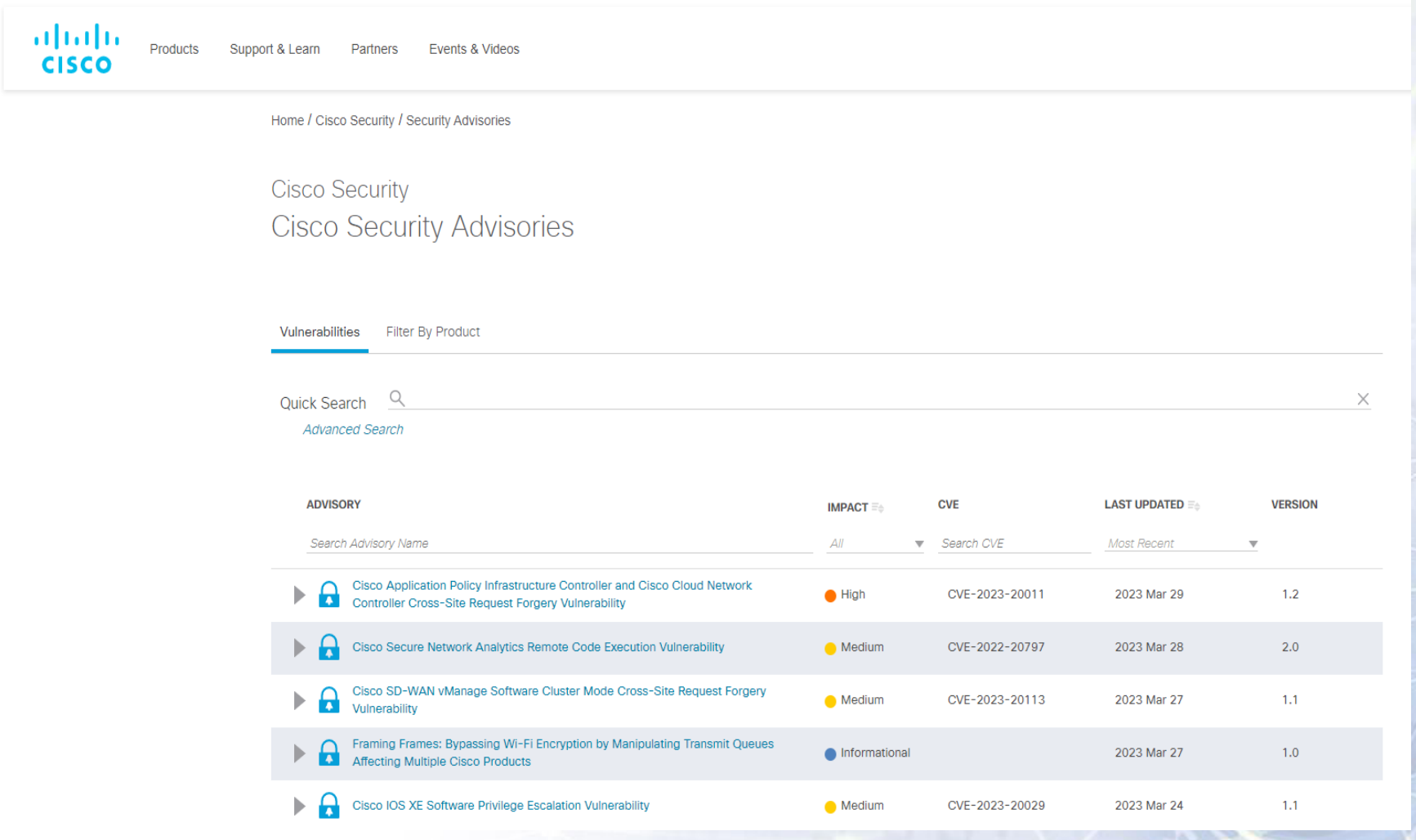
Common Vulnerabilities and Exposures



Common Vulnerabilities and Expore

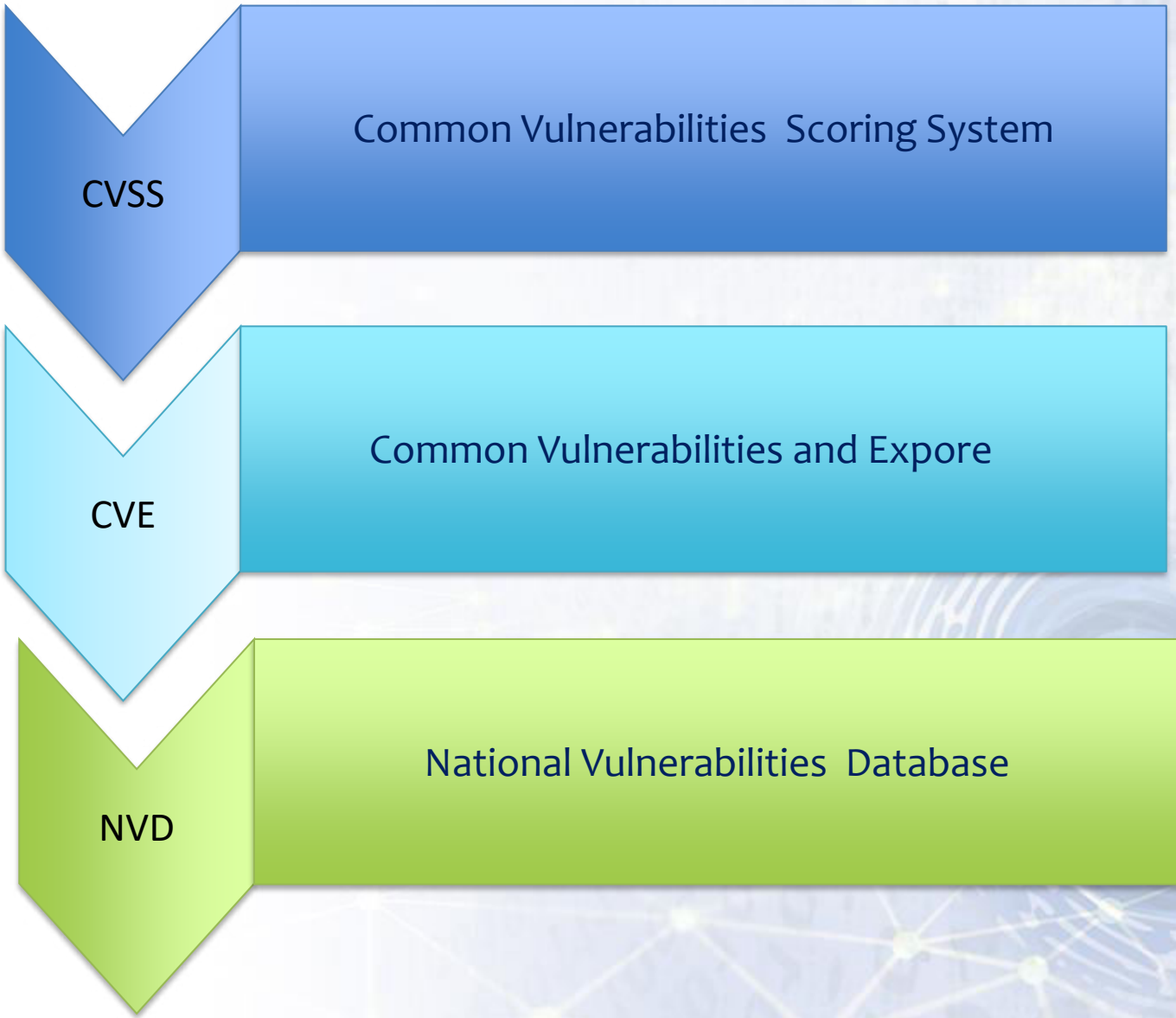


Common Vulnerabilities and Exposures



https://sec.cloudapps.cisco.com/security/center/publicationListing.x

Common Vulnerabilities and Exposures



Week 6 Topic 12

Common Vulnerabilities and Scoring System

- Industry standard that rates the severity of vulnerabilities
- Used in Common Vulnerabilities and Exposures (CVE) listings to aid in prioritizing vulnerabilities
- Based on a set of metrics that determines the overall score

TABLE F-2: ASSESSMENT SCALE – VULNERABILITY SEVERITY

Qualitative Values	Semi-Quantitative Values		Description
Very High	96-100	10	The vulnerability is exposed and exploitable, and its exploitation could result in severe impacts. Relevant security control or other remediation is not implemented and not planned; or no security measure can be identified to remediate the vulnerability.
High	80-95	8	The vulnerability is of high concern, based on the exposure of the vulnerability and ease of exploitation and/or on the severity of impacts that could result from its exploitation. Relevant security control or other remediation is planned but not implemented; compensating controls are in place and at least minimally effective.
Moderate	21-79	5	The vulnerability is of moderate concern, based on the exposure of the vulnerability and ease of exploitation and/or on the severity of impacts that could result from its exploitation. Relevant security control or other remediation is partially implemented and somewhat effective.
Low	5-20	2	The vulnerability is of minor concern, but effectiveness of remediation could be improved. Relevant security control or other remediation is fully implemented and somewhat effective.
Very Low	0-4	0	The vulnerability is not of concern. Relevant security control or other remediation is fully implemented, assessed, and effective.

CVSS severity factors

- **Attack vector:** the attacker needs to be authenticated or whether the attack can be launched remotely.
- **Attack complexity:** the attack requires special knowledge or tools
- **Privileges required:** an attacker would need administrative access or user-level access.
- **Impact on confidentiality, integrity, and availability:** potential impact of the vulnerability on the confidentiality, integrity, and availability of systems and data.
- CVSS uses a scoring system ranging from 0 to 10, with higher scores indicating more severe vulnerabilities.

CVSS Score Qualitative Rating:

Score	Rating
0.0	None
0.1 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10.0	Critical

https://www.first.org/cvss/v3.1/examples

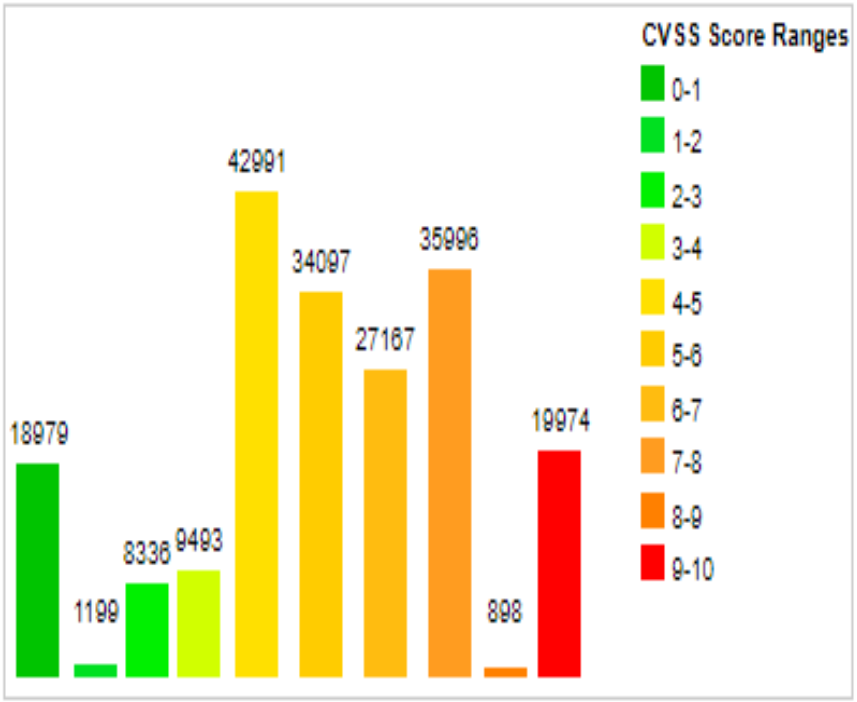
https://nvd.nist.gov/vuln-metrics/cvss

Current CVSS Score Distribution For All Vulnerabilities

Distribution of all vulnerabilities by CVSS Scores

CVSS Score	Number Of Vulnerabilities	Percentage
0-1	18979	9.50
1-2	1199	0.60
2-3	8336	4.20
3-4	9493	4.80
4-5	42991	21.60
5-6	34097	17.10
6-7	27167	13.60
7-8	35996	18.10
8-9	898	0.50
9-10	19974	10.00
Total	199130	

Vulnerability Distribution By CVSS Scores



Common Vulnerabilities and Scoring System

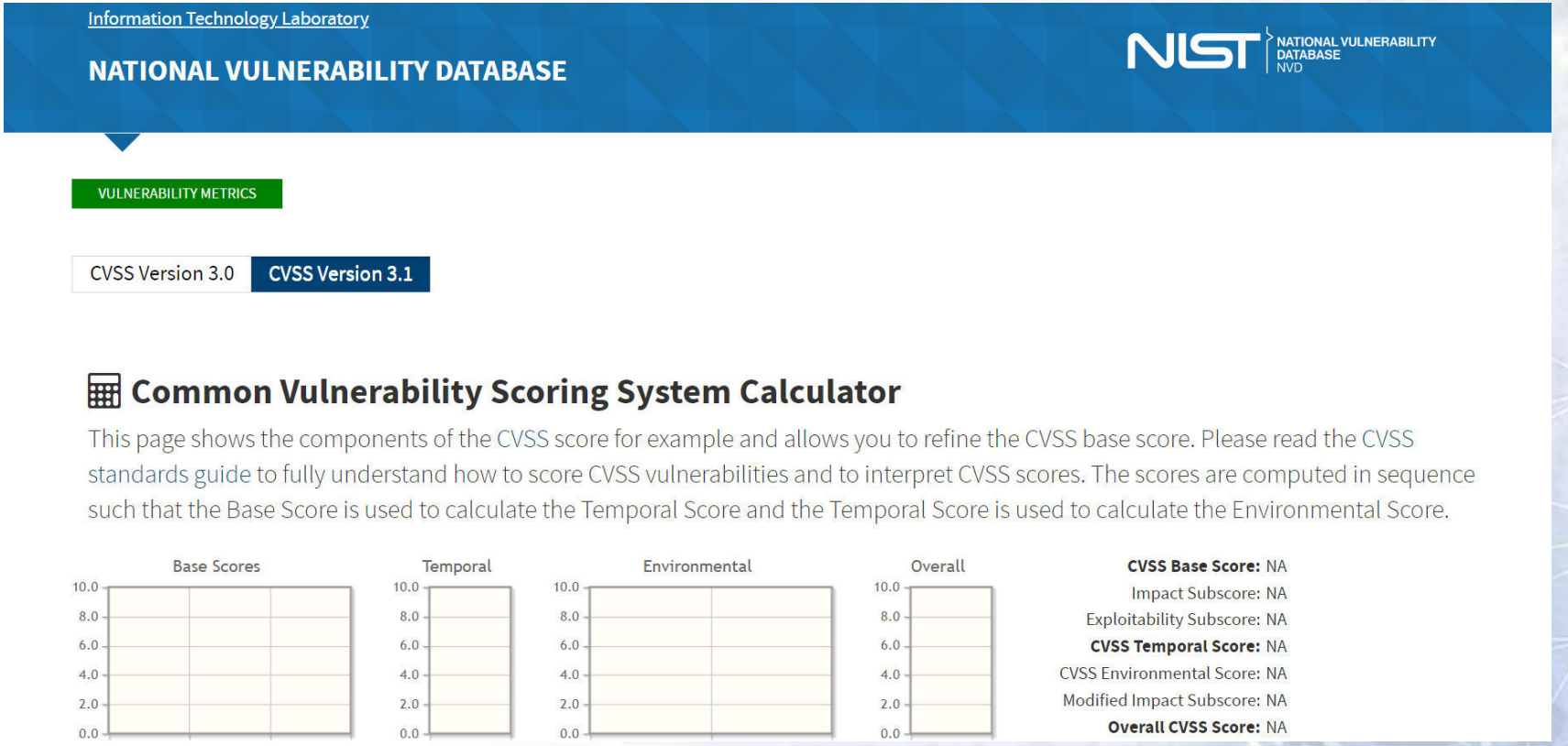
Impact Metrics:

- What impact will this have if the threat is able to exploit the vulnerability?
- Will it be a violation of confidentiality, integrity, or availability

Temporal Metrics:

- The Current state of the exploit

Common Vulnerabilities and Scoring System



https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator

Common Vulnerabilities and Scoring System

Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N)	Adjacent Network (AV:A)	Local (AV:L)	Physical (AV:P)

Attack Complexity (AC)*

Low (AC:L)	High (AC:H)

Privileges Required (PR)*

None (PR:N)	**Low (PR:L)**	High (PR:H)

User Interaction (UI)*

None (UI:N)	**Required (UI:R)**

Scope (S)*

Unchanged (S:U)	**Changed (S:C)**

Impact Metrics

Confidentiality Impact (C)*

None (C:N)	Low (C:L)	**High (C:H)**

Integrity Impact (I)*

None (I:N)	Low (I:L)	**High (I:H)**

Availability Impact (A)*

None (A:N)	Low (A:L)	High (A:H)

Common Vulnerabilities and Scoring System

* - All base metrics are required to generate a base score.

Temporal Score Metrics

Exploit Code Maturity (E)

Not Defined (E:X)	Unproven that exploit exists (E:U)	**Proof of concept code (E:P)**	Functional exploit exists (E:F)	High (E:H)

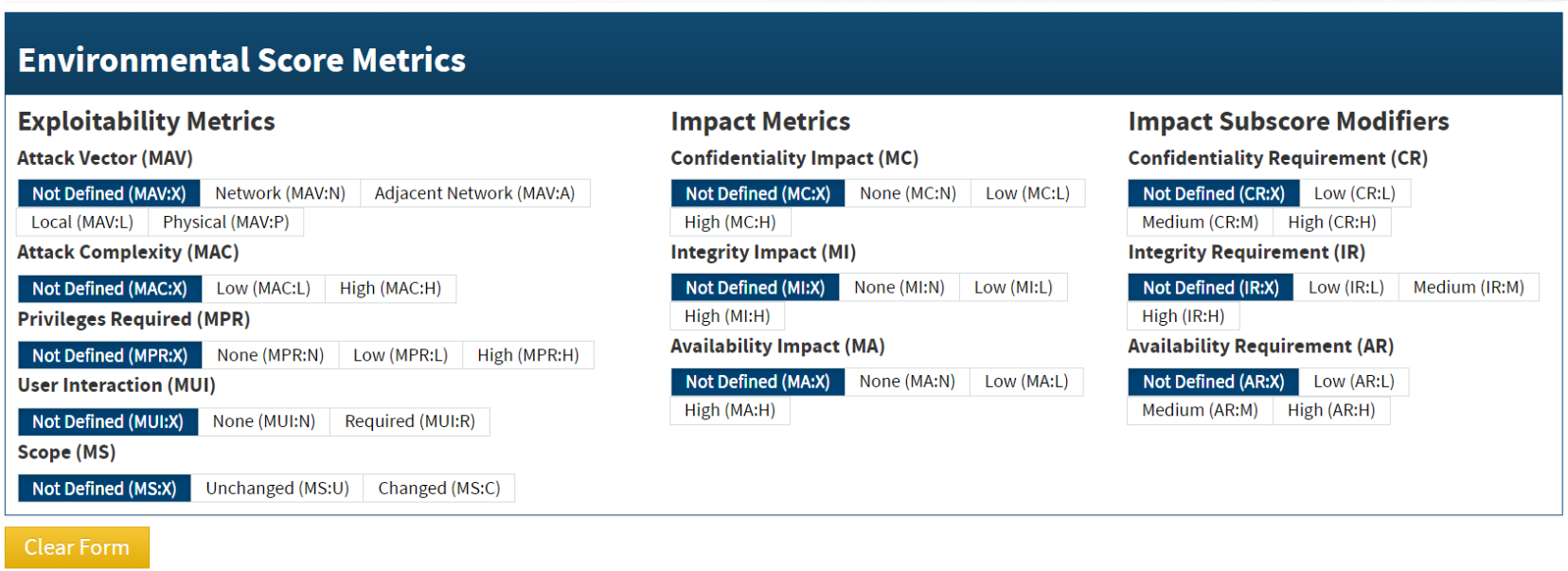
Remediation Level (RL)

Not Defined (RL:X)	Official fix (RL:O)	Temporary fix (RL:T)	**Workaround (RL:W)**	Unavailable (RL:U)

Report Confidence (RC)

Not Defined (RC:X)	Unknown (RC:U)	Reasonable (RC:R)	**Confirmed (RC:C)**

Common Vulnerabilities and Scoring System

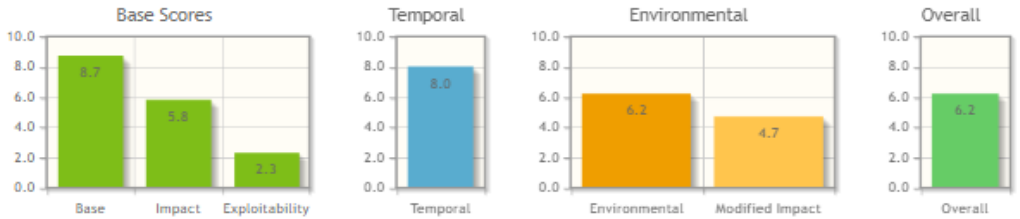


VULNERABILITY METRICS

CVSS Version 3.0 **CVSS Version 3.1**

Common Vulnerability Scoring System Calculator

This page shows the components of the CVSS score for example and allows you to refine the CVSS base score. Please read the CVSS standards guide to fully understand how to score CVSS vulnerabilities and to interpret CVSS scores. The scores are computed in sequence such that the Base Score is used to calculate the Temporal Score and the Temporal Score is used to calculate the Environmental Score.



CVSS Base Score: 8.7
Impact Subscore: 5.8
Exploitability Subscore: 2.3
CVSS Temporal Score: 8.0
CVSS Environmental Score: 6.2
Modified Impact Subscore: 4.7
Overall CVSS Score: 6.2

Show Equations

CVSS v3.1 Vector

AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:N/E:P/RL:W/RC:X/CR:M/IR:X/AR:M/MAV:L/MAC:X/MPR:L/MUI:R/MS:X/MC:X/MI:L/MA:X

Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) | Adjacent Network (AV:A) | Local (AV:L) | Physical (AV:P)

Attack Complexity (AC)*

Low (AC:L) | High (AC:H)

Privileges Required (PR)*

None (PR:N) | **Low (PR:L)** | High (PR:H)

User Interaction (UI)*

None (UI:N) | **Required (UI:R)**

Scope (S)*

Unchanged (S:U) | **Changed (S:C)**

Impact Metrics

Confidentiality Impact (C)*

None (C:N) | Low (C:L) | **High (C:H)**

Integrity Impact (I)*

None (I:N) | Low (I:L) | **High (I:H)**

Availability Impact (A)*

None (A:N) | Low (A:L) | High (A:H)

What Is CVE & Vulnerability Database ?

Impact

CVSS Severity (version 3.0):

CVSS v3 Base Score: 9.8 Critical
Vector: CVSS:3.0/AV:N/AC:L/I
(legend)
Impact Score: 5.9
Exploitability Score: 3.9

CVSS Version 3 Metrics:

Attack Vector (AV): Network
Attack Complexity (AC): Low
Privileges Required (PR): None
User Interaction (UI): None
Scope (S): Unchanged
Confidentiality (C): High
Integrity (I): High
Availability (A): High

What Is CVE & Vulnerability Database ?

CVSS Severity (version 2.0):

CVSS v2 Base Score: 7.5 HIGH
Vector: (AV:N/AC:L/Au:N/C:P/I:P/A:P) (legend)
Impact Subscore: 6.4
Exploitability Subscore: 10.0

CVSS Version 2 Metrics:

Access Vector: Network exploitable
Access Complexity: Low
Authentication: Not required to exploit
Impact Type: Allows unauthorized disclosure of information; Allows unauthorized modification; Allows disruption of service

Week 6 Topic 13

Nessus Introduction

- Nessus dates back to 1998
- Nessus moved to closed source commercial product in 2005
- The most trusted and gold standard vulnerability assessment solution
- Most widely deployed security standard

- Nessus Essential is limited to scanning only 16 IP addresses

Nessus | Tenable®
tenable
Downloads Blog Contact Login Global
Cyber Exposure Products Solutions Research Services Company Partners
Free Trial
Buy Now
THE NESSUS FAMILY
Nessus is trusted by more than 27,000 organizations worldwide as one of the most widely deployed security technologies on the planet - and the gold standard for vulnerability assessment.
nessus Essentials
FREE DOWNLOAD
Scan 16 IPs
✓ Use anywhere
✓ Free training and guidance
✓ Support via Tenable Community
Ideal for: Educators, students and individuals starting their careers in Cyber Security
nessus Professional
7-DAY FREE TRIAL
Scan 32 IPs
✓ Use anywhere, try for 7 days
✓ Configuration Assessment
✓ Live Results
✓ Custom Reporting
✓ Support via Tenable Community
Ideal for: Consultants, Pen Testers and
nessus Professional
SUBSCRIPTION
Scan Unlimited IPs
✓ Unlimited assessments
✓ Use anywhere, annual subscription
✓ Configuration assessment
✓ Live Results
✓ Custom Reporting
✓ Email and Community Support

1

Outdated Protocols

SSL is no longer a secure protocol!

2

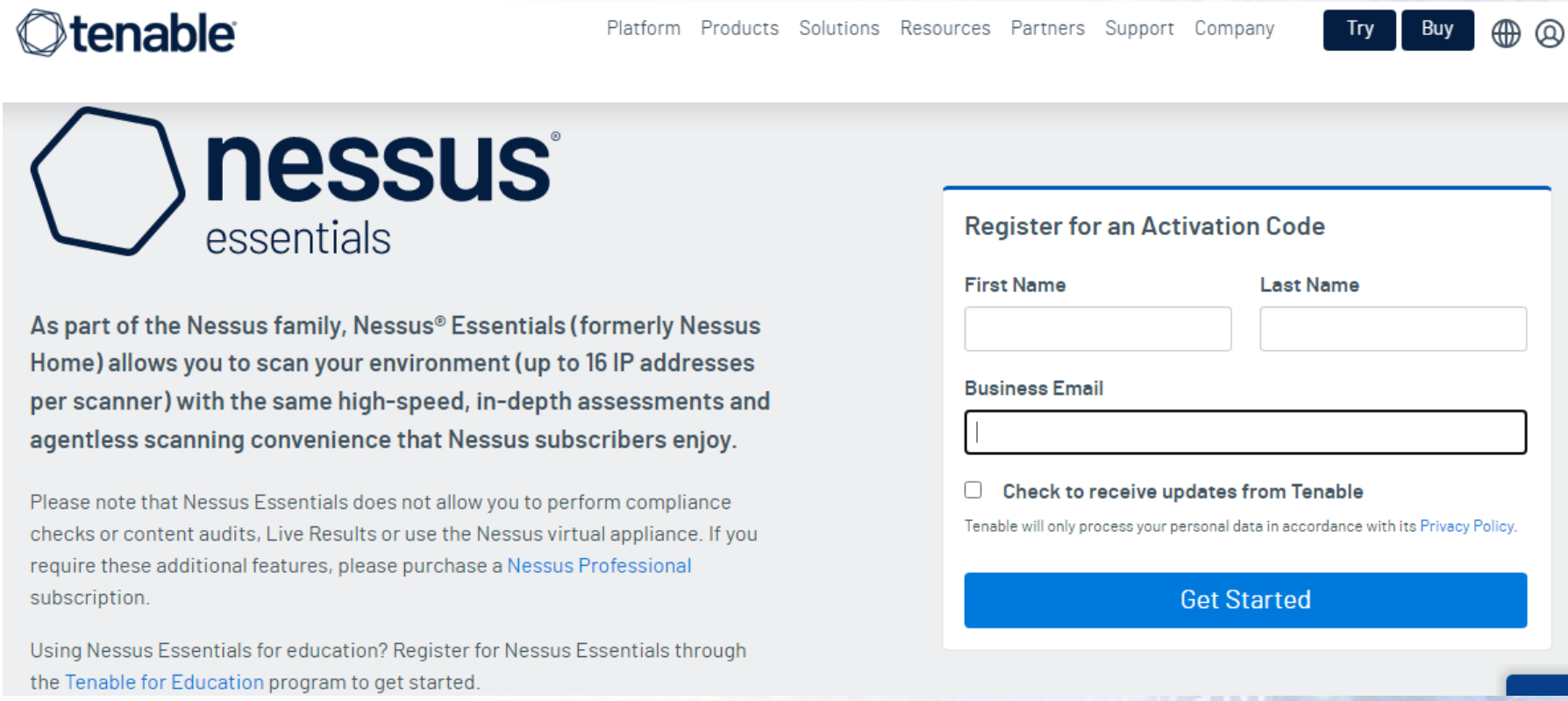
Insecure Cipher Suites

Only support strong encryption!

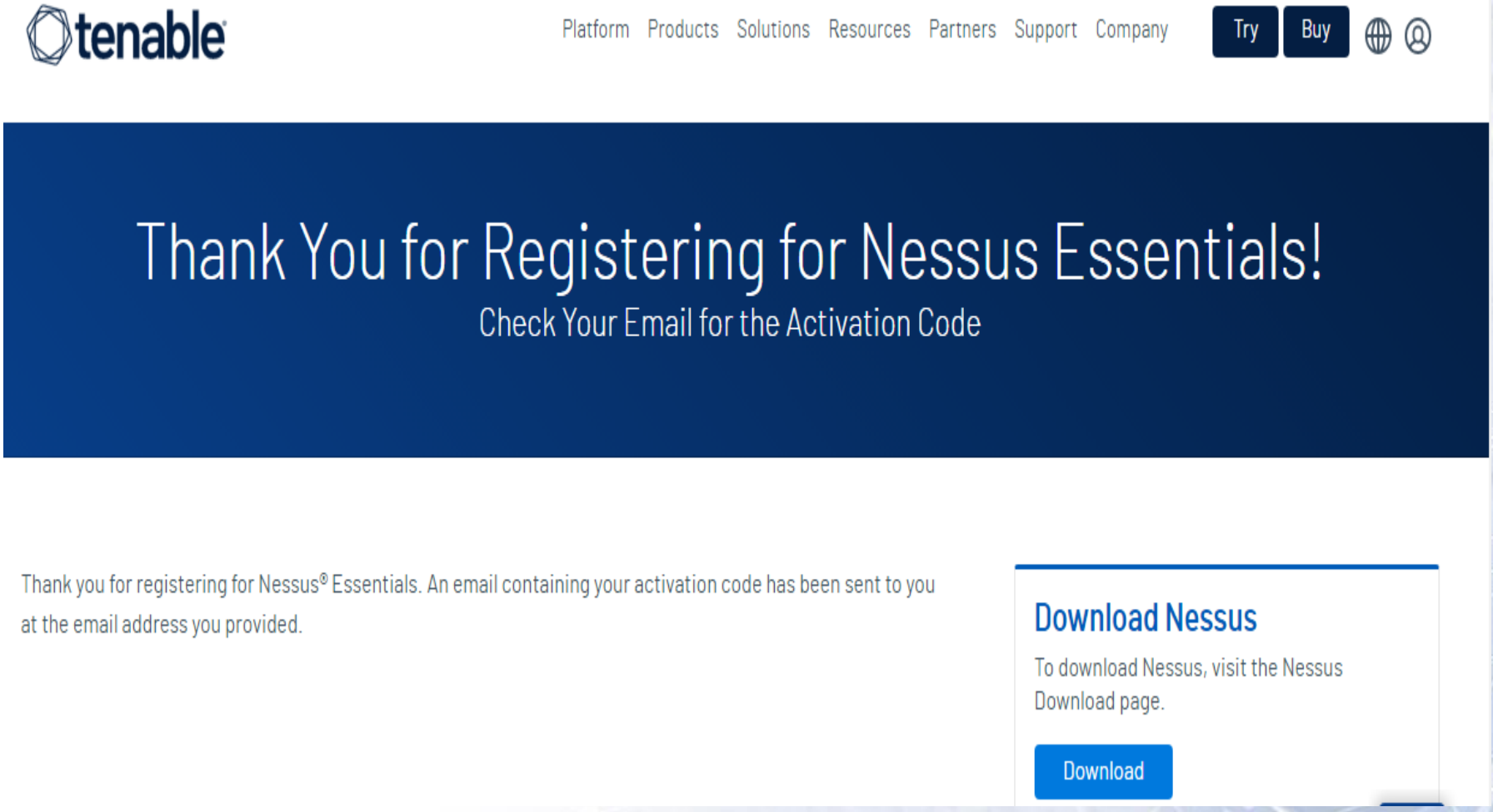
3

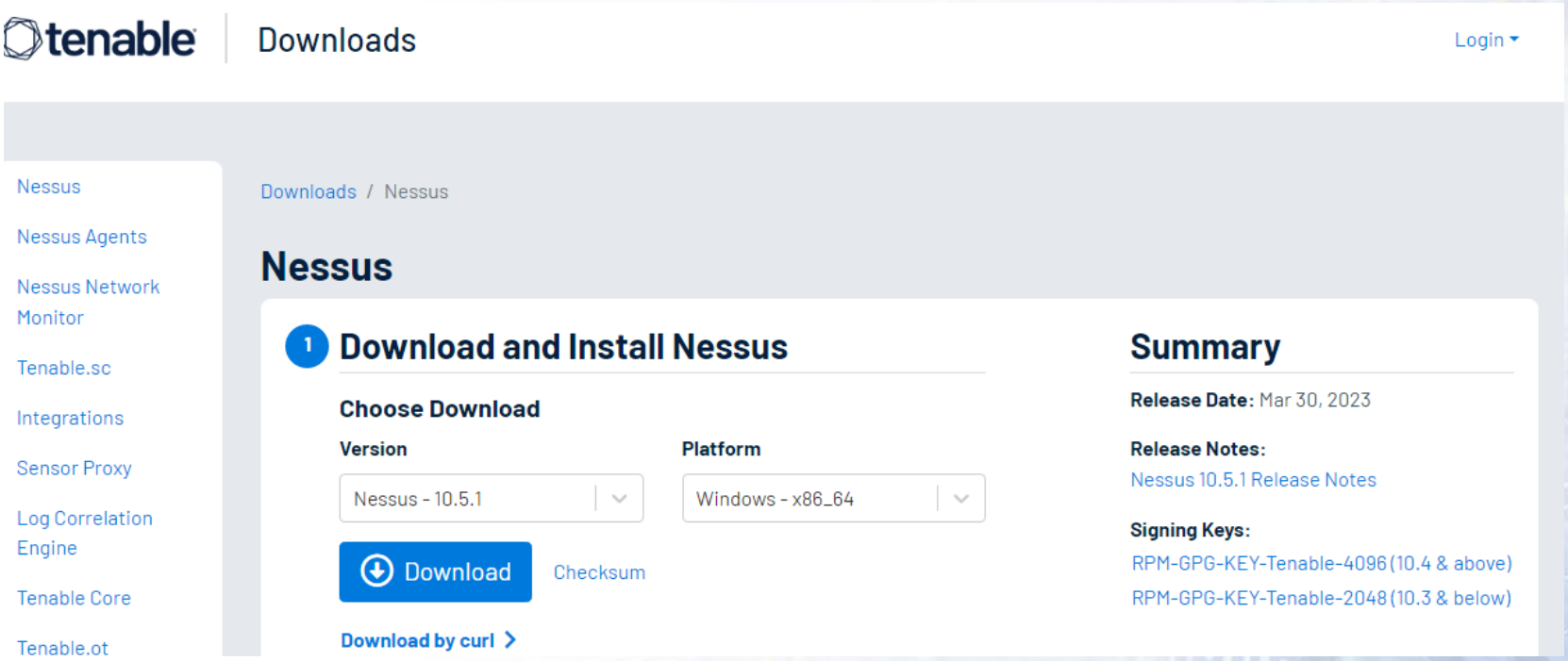
Certificate Issues

Watch for expired, self-signed, or invalid certificates.

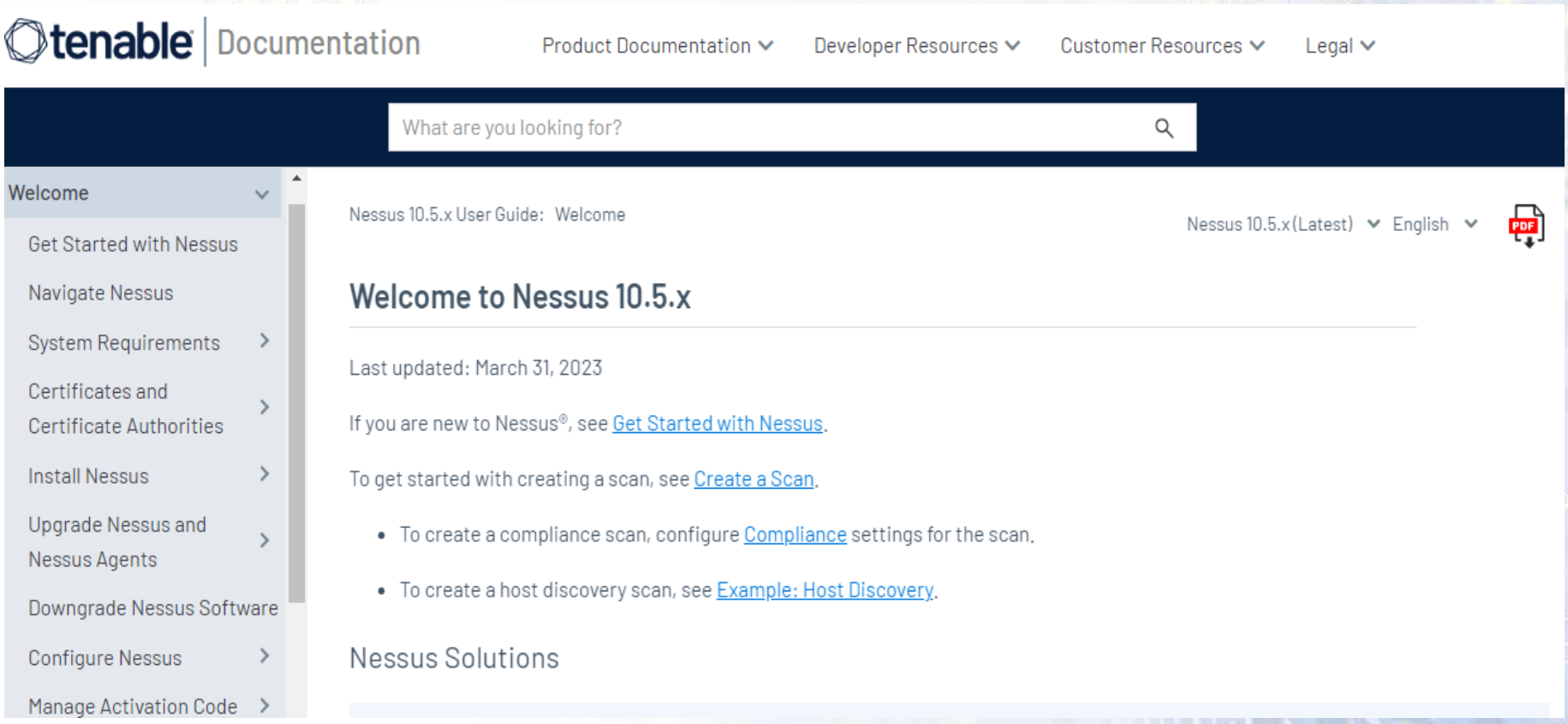


https://www.tenable.com/products/nessus/nessus-essentials?action=register


tenable
Platform Products Solutions Resources Partners Support Company
Try Buy
Thank You for Registering for Nessus Essentials!
Check Your Email for the Activation Code
Thank you for registering for Nessus® Essentials. An email containing your activation code has been sent to you at the email address you provided.
Download Nessus
To download Nessus, visit the Nessus Download page.
Download

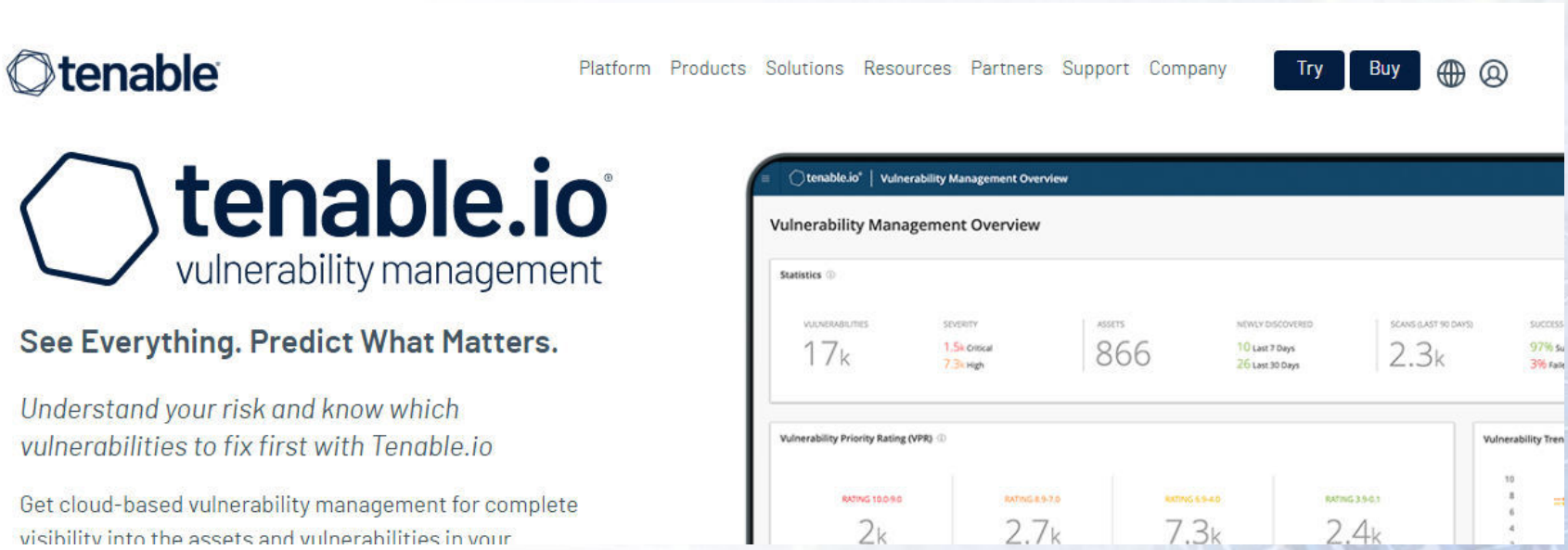


https://www.tenable.com/downloads/nessus?loginAttempted=true

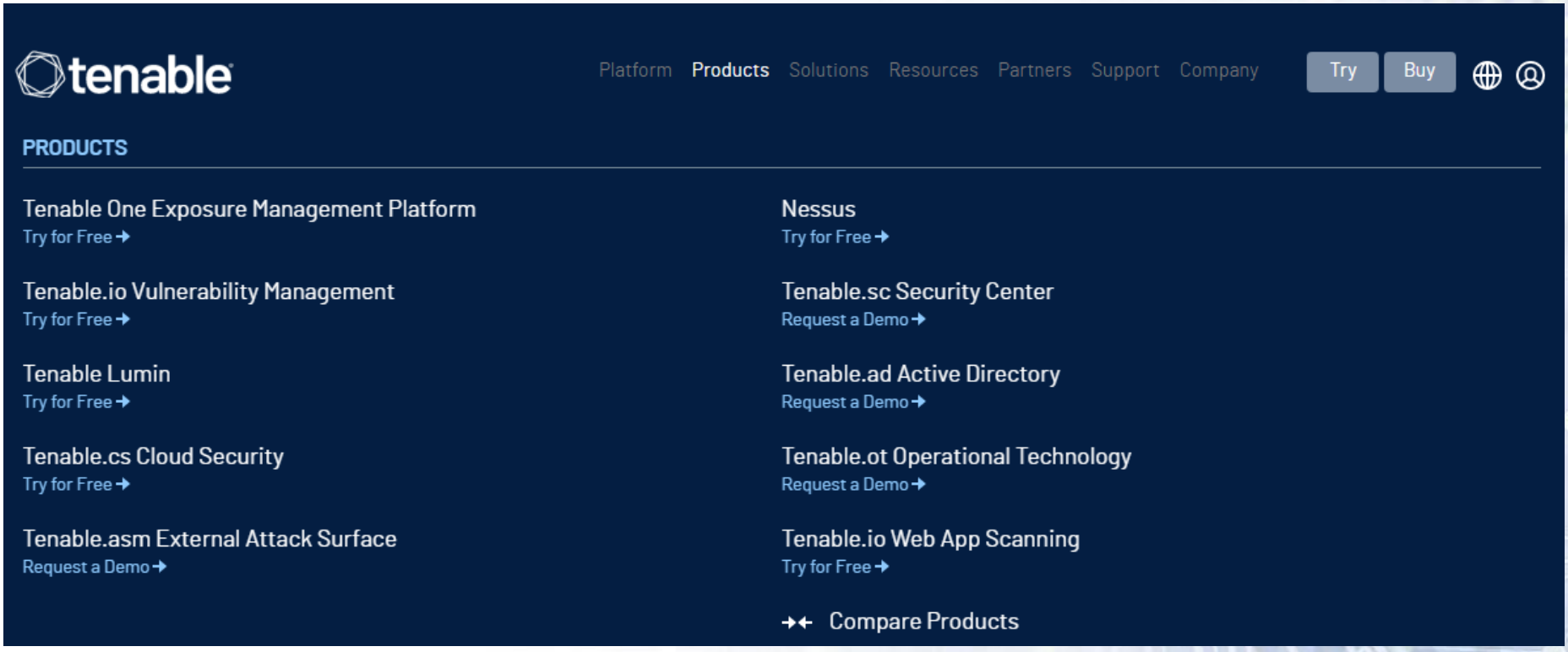


https://docs.tenable.com/nessus/Content/GettingStarted.htm

Cloud based service

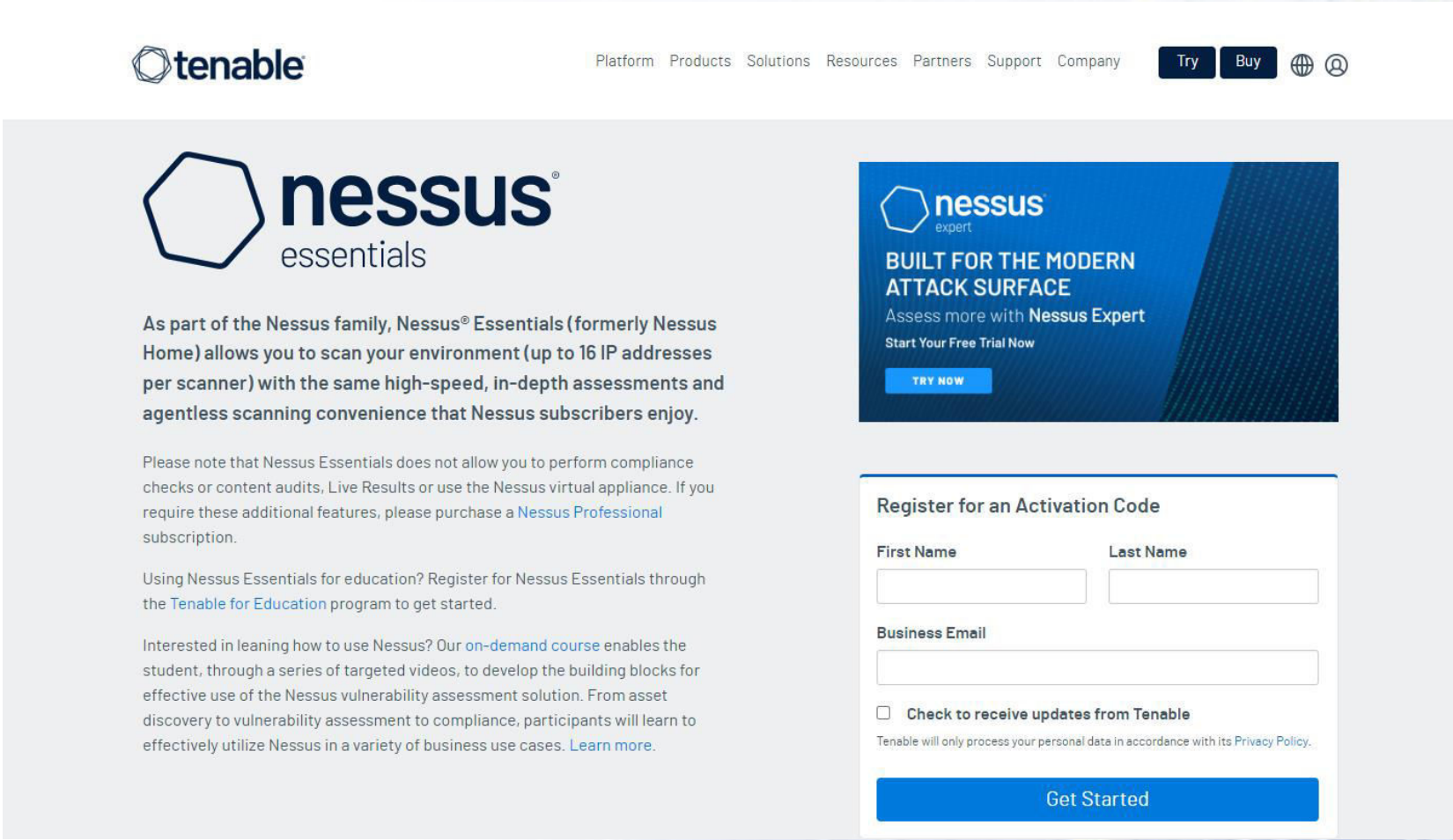


CLOSE YOUR CYBER EXPOSURE GAP WITH NESSUS
Tenable products help you accurately identify, investigate and prioritize vulnerabilities.
Secure your cloud, containers, OT devices and traditional IT assets.
RECOMMENDED
nessus expert
The #1 VA Solution
The most trusted vulnerability assessment solution now featuring Infrastructure as Code (IaC) and External Attack Surface Assessment!
Try for Free
nessus professional
l in Vulnerability Assessment
The industry-leading vulnerability scanner.

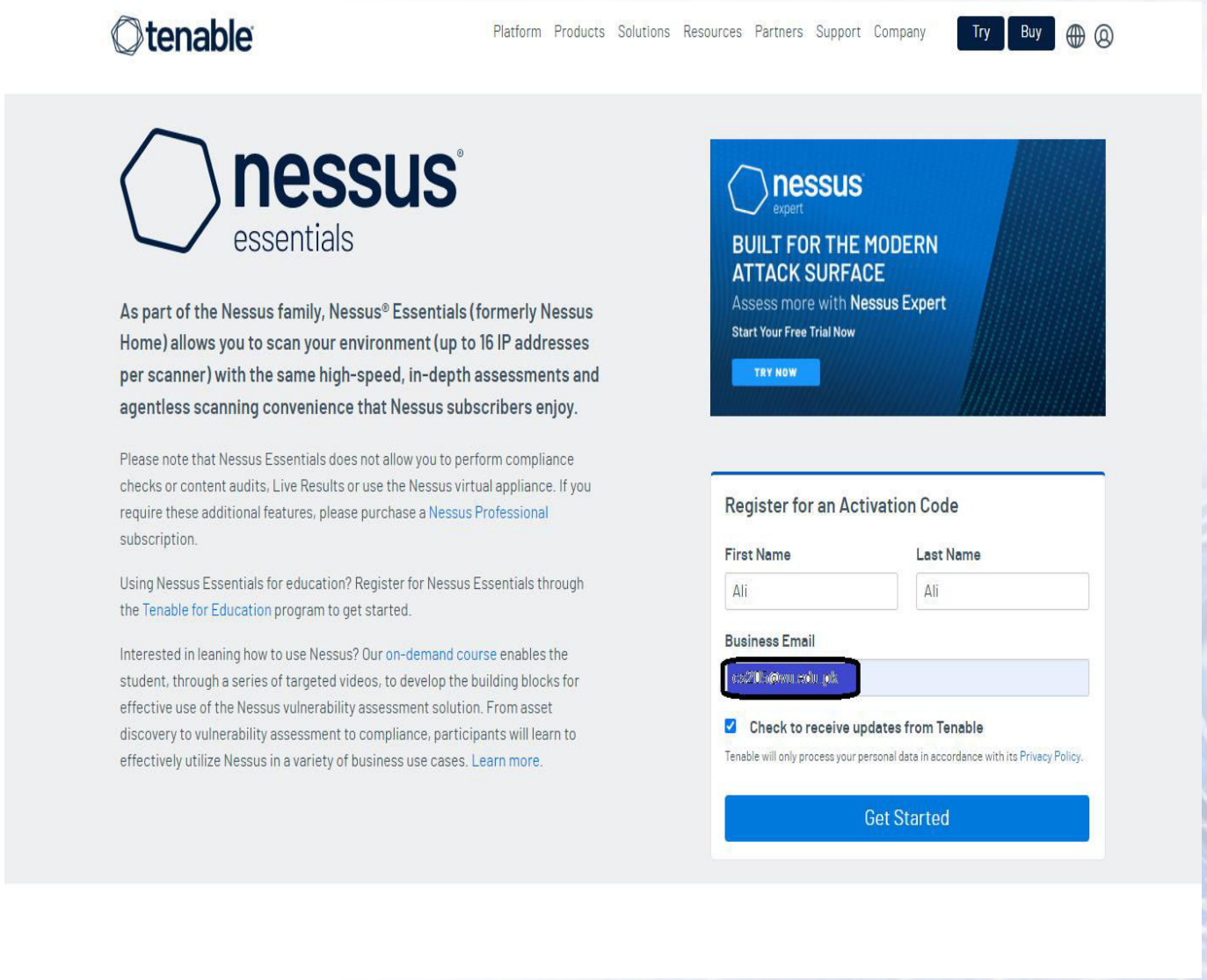

tenable
Platform
Products
Solutions
Resources
Partners
Support
Company
Try
Buy
PRODUCTS
Tenable One Exposure Management Platform
Try for Free
Tenable.io Vulnerability Management
Try for Free
Tenable Lumin
Try for Free
Tenable.cs Cloud Security
Try for Free
Tenable.asm External Attack Surface
Request a Demo
Nessus
Try for Free
Tenable.sc Security Center
Request a Demo
Tenable.ad Active Directory
Request a Demo
Tenable.ot Operational Technology
Request a Demo
Tenable.io Web App Scanning
Try for Free
Compare Products

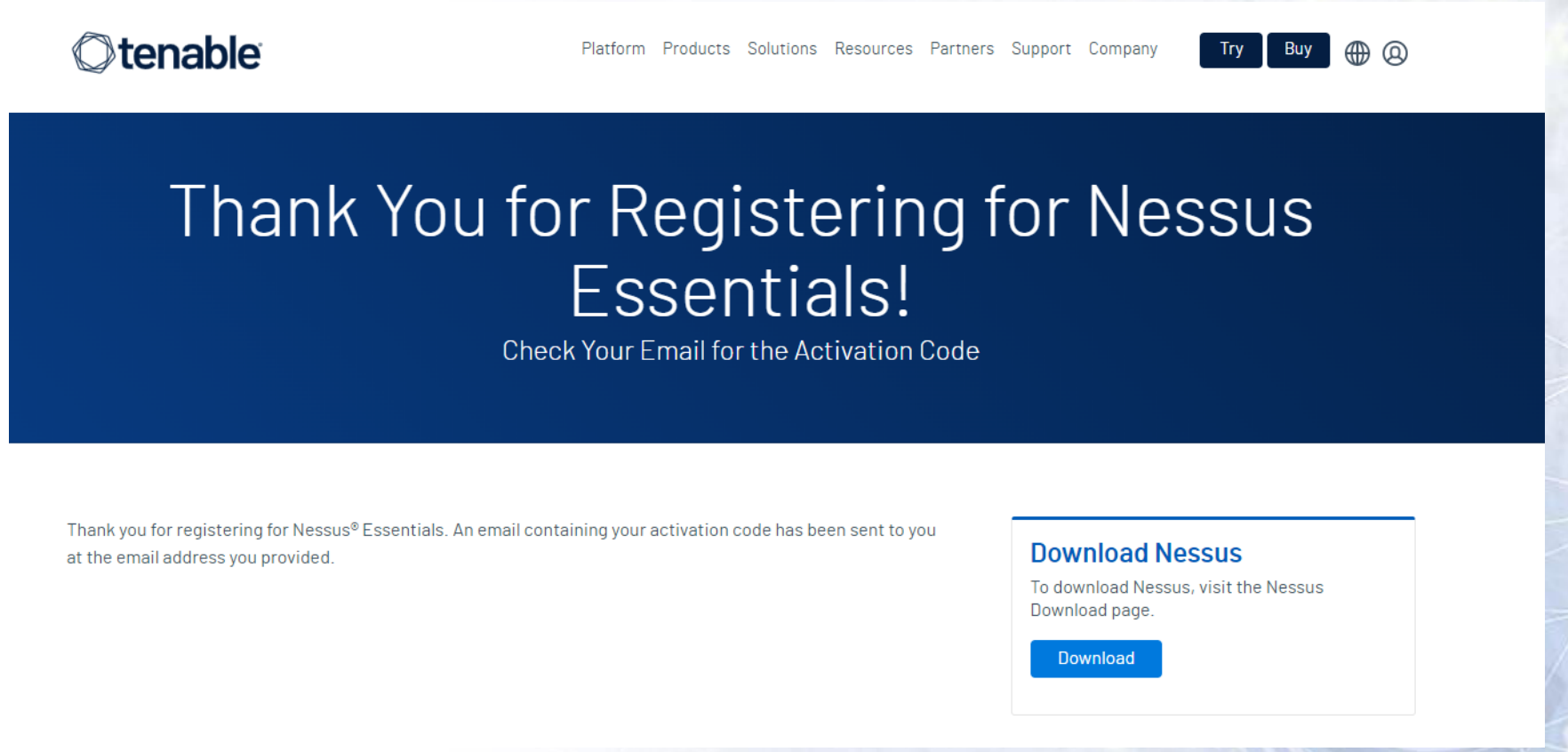
Week 6 Topic 14

Nessus Download and Installation



https://www.tenable.com/products/nessus/nessus-essentials


tenable
Platform Products Solutions Resources Partners Support Company
Try Buy
nessus essentials
As part of the Nessus family, Nessus® Essentials (formerly Nessus Home) allows you to scan your environment (up to 16 IP addresses per scanner) with the same high-speed, in-depth assessments and agentless scanning convenience that Nessus subscribers enjoy.
Please note that Nessus Essentials does not allow you to perform compliance checks or content audits, Live Results or use the Nessus virtual appliance. If you require these additional features, please purchase a Nessus Professional subscription.
Using Nessus Essentials for education? Register for Nessus Essentials through the Tenable for Education program to get started.
Interested in leaning how to use Nessus? Our on-demand course enables the student, through a series of targeted videos, to develop the building blocks for effective use of the Nessus vulnerability assessment solution. From asset discovery to vulnerability assessment to compliance, participants will learn to effectively utilize Nessus in a variety of business use cases. Learn more.
nessus expert
BUILT FOR THE MODERN ATTACK SURFACE
Assess more with Nessus Expert
Start Your Free Trial Now
TRY NOW
Register for an Activation Code
First Name
Ali
Last Name
Ali
Business Email
Check to receive updates from Tenable
Tenable will only process your personal data in accordance with its Privacy Policy.
Get Started


tenable
Platform Products Solutions Resources Partners Support Company
Try Buy
Thank You for Registering for Nessus Essentials!
Check Your Email for the Activation Code
Thank you for registering for Nessus® Essentials. An email containing your activation code has been sent to you at the email address you provided.
Download Nessus
To download Nessus, visit the Nessus Download page.
Download

Welcome To Nessus Essentials

Welcome to Nessus Essentials and congratulations on taking action to secure your network! We offer the latest plugins for vulnerability scanning today, helping you identify more vulnerabilities and keep your network protected.

If you're looking for more advanced capabilities, such as live results and configuration checks – as well as the ability to scan unlimited IPs, check out Nessus Professional. To learn more view the Nessus Professional datasheet.

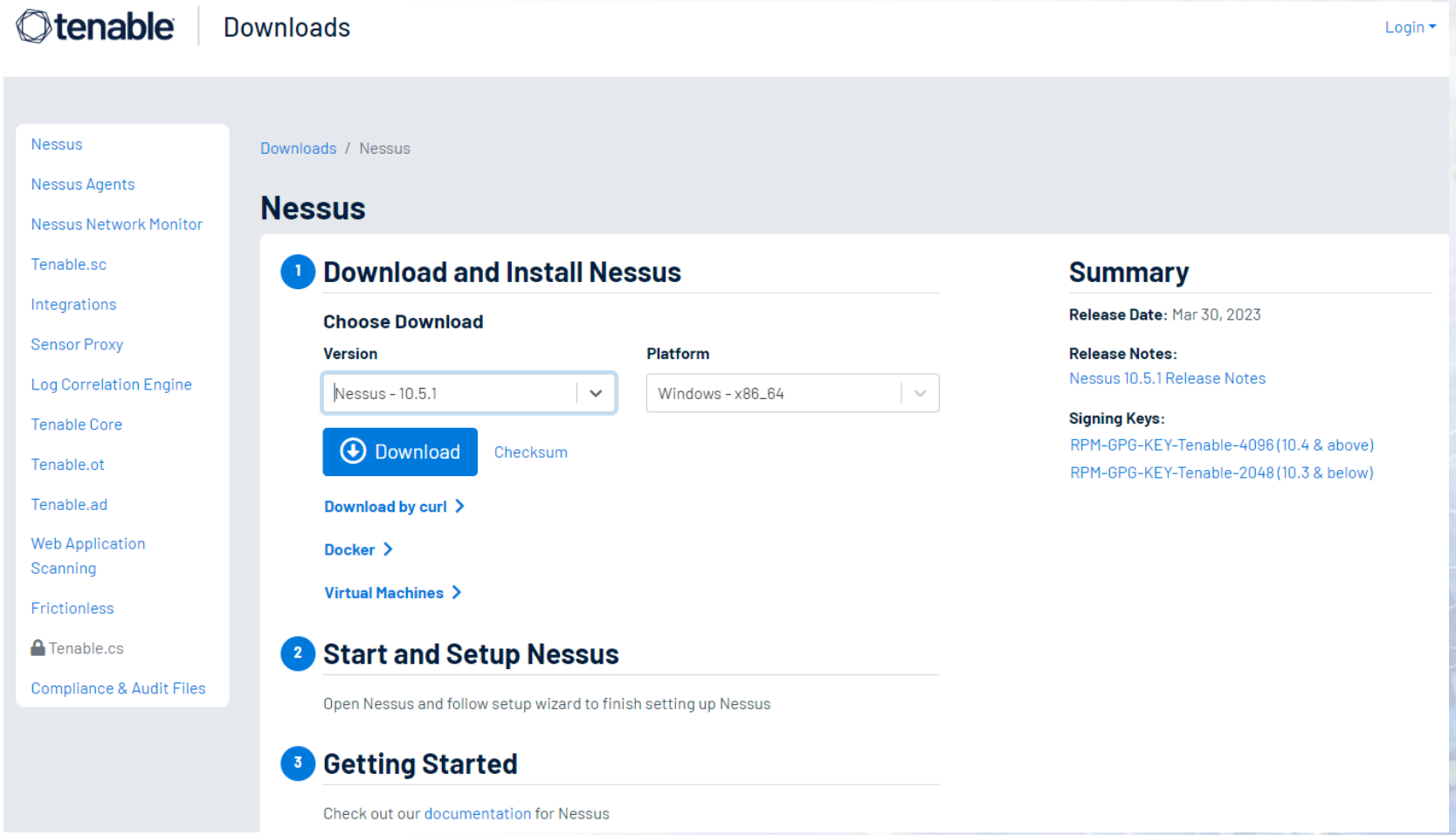
Activating Your Nessus Essentials License
Your activation code for Nessus Essentials is:
QC□U-2'I□-MZ□M-PKR□-48TF

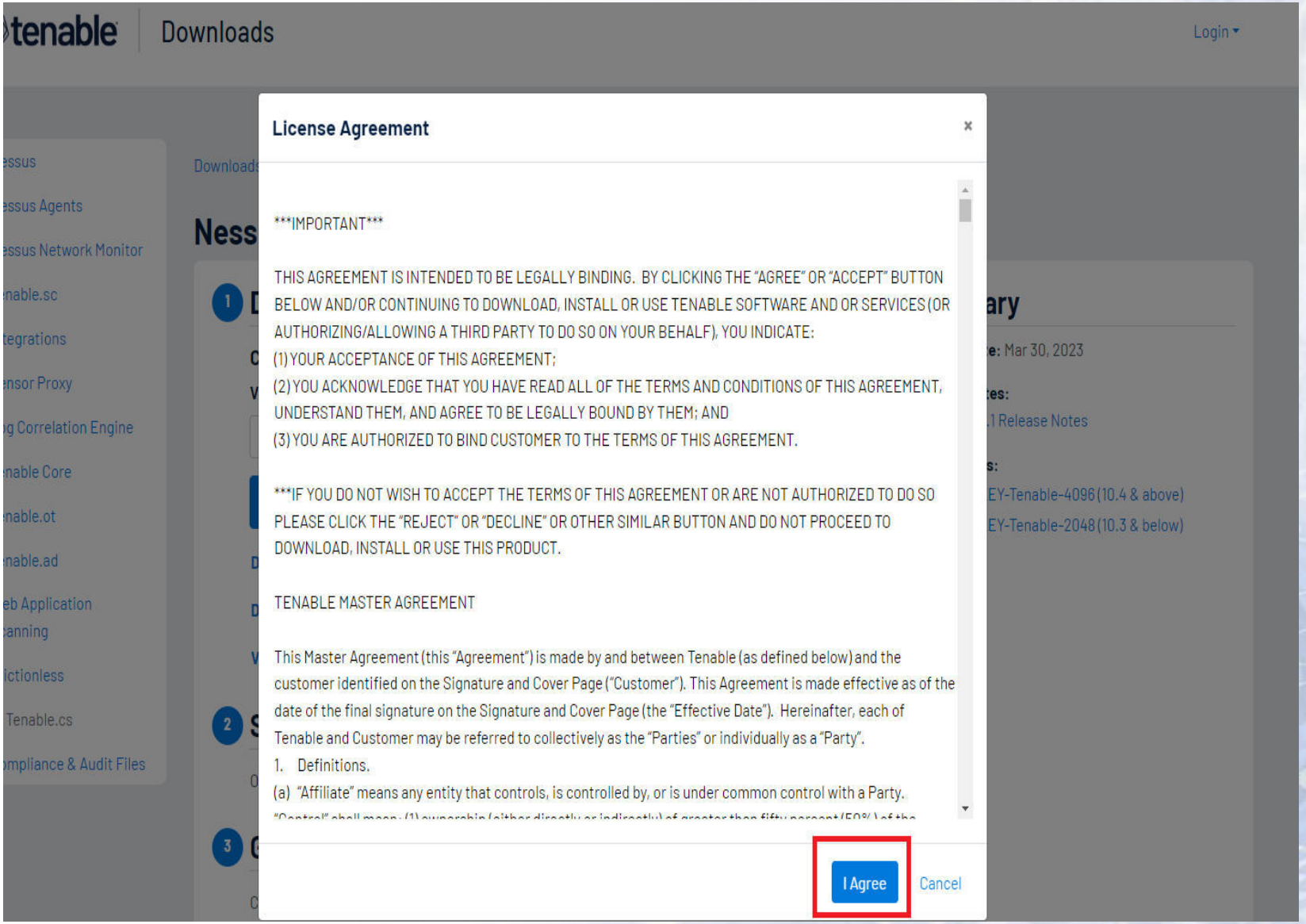
Download Nessus

This is a one-time code. If you uninstall and then reinstall you will need to register the scanner again and receive another activation code.

After initial installation of Nessus you will be prompted to set up and activate your scanner. For further details on activating your subscription review the installation guide.

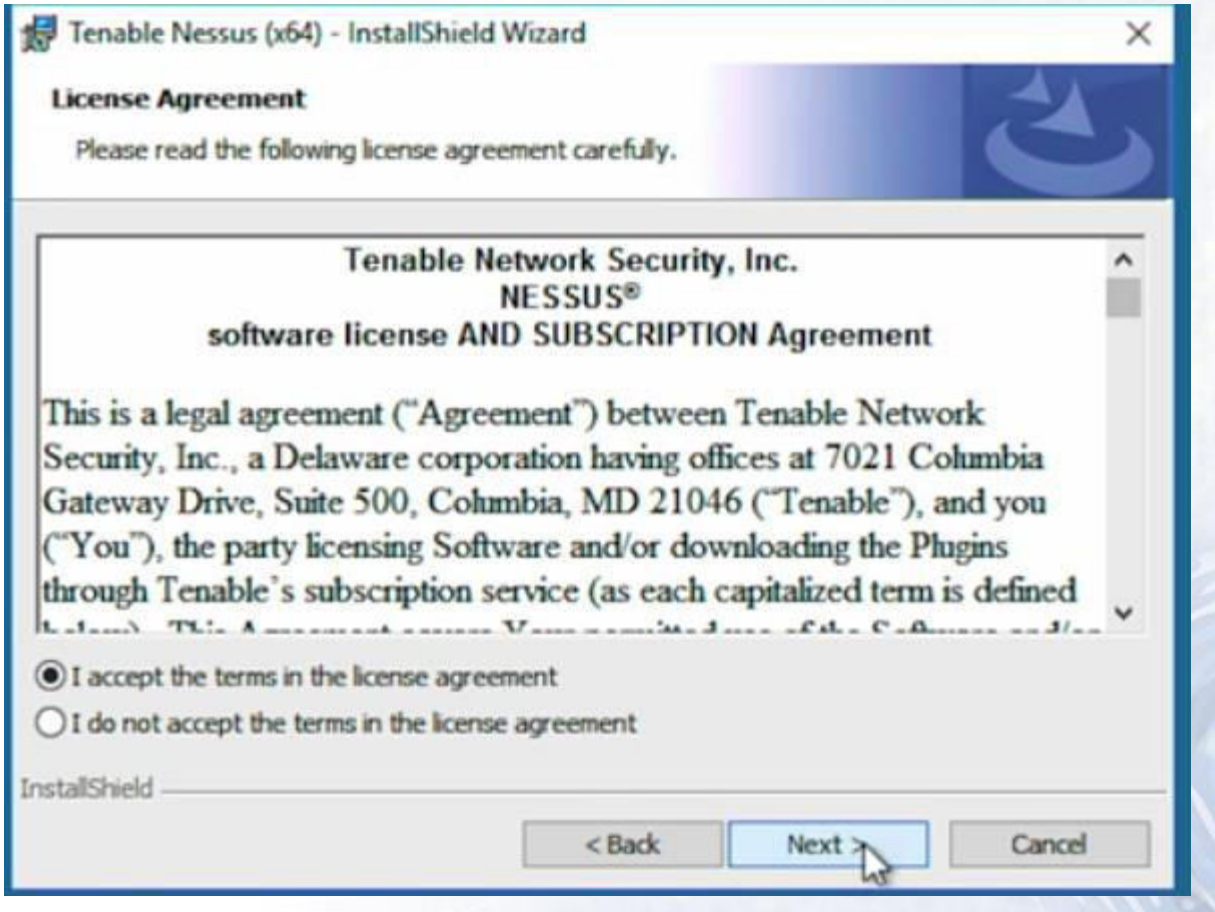
No internet access on your Nessus system?
If your Nessus installation cannot reach the internet directly, please follow the offline registration instructions.

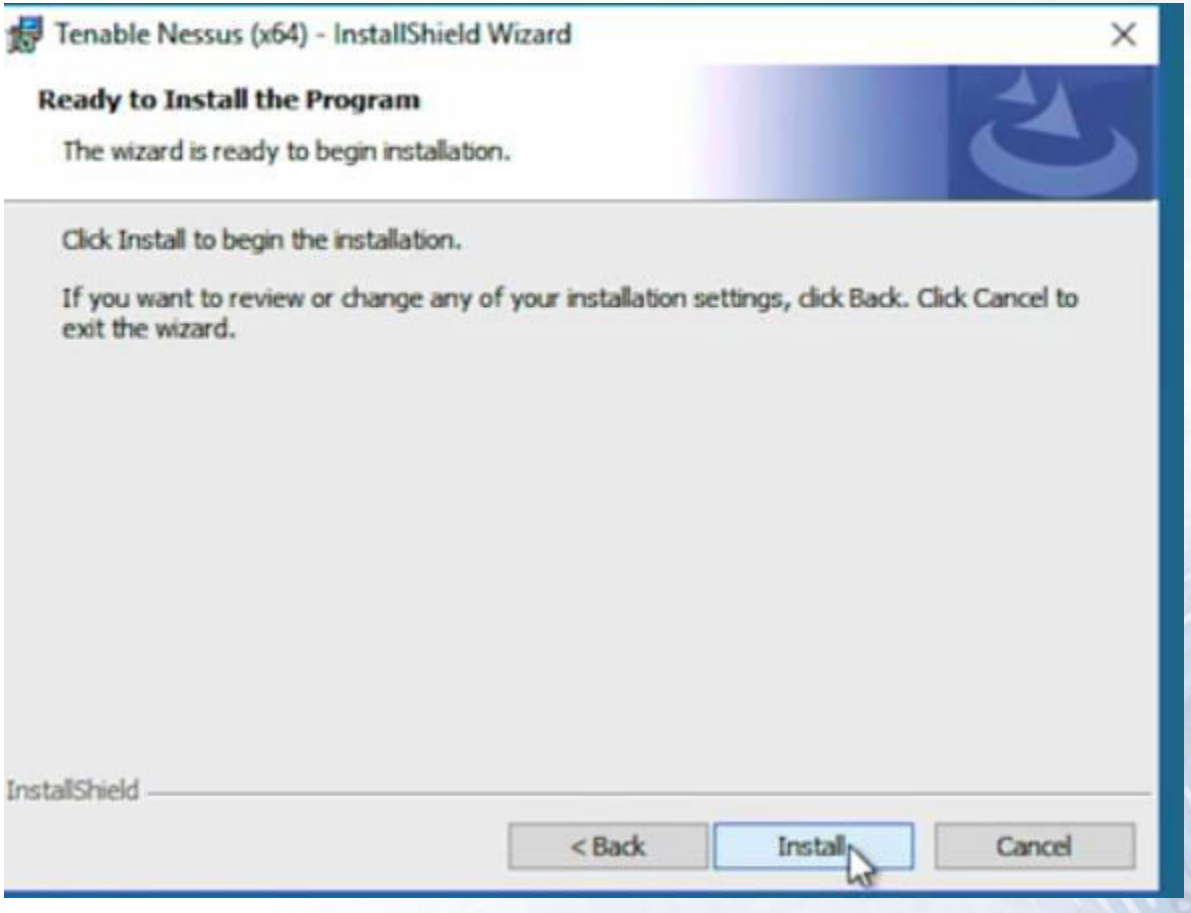

tenable
Downloads
Login
Nessus
Nessus Agents
Nessus Network Monitor
Tenable.sc
Integrations
Sensor Proxy
Log Correlation Engine
Tenable Core
Tenable.ot
Tenable.ad
Web Application Scanning
Frictionless
Tenable.cs
Compliance & Audit Files
Downloads / Nessus
Nessus
1 Download and Install Nessus
Choose Download
Version
Nessus - 10.5.1
Platform
Windows - x86_64
Download
Checksum
Download by curl
Docker
Virtual Machines
2 Start and Setup Nessus
Open Nessus and follow setup wizard to finish setting up Nessus
3 Getting Started
Check out our documentation for Nessus
Summary
Release Date: Mar 30, 2023
Release Notes:
Nessus 10.5.1 Release Notes
Signing Keys:
RPM-GPG-KEY-Tenable-4096 (10.4 & above)
RPM-GPG-KEY-Tenable-2048 (10.3 & below)

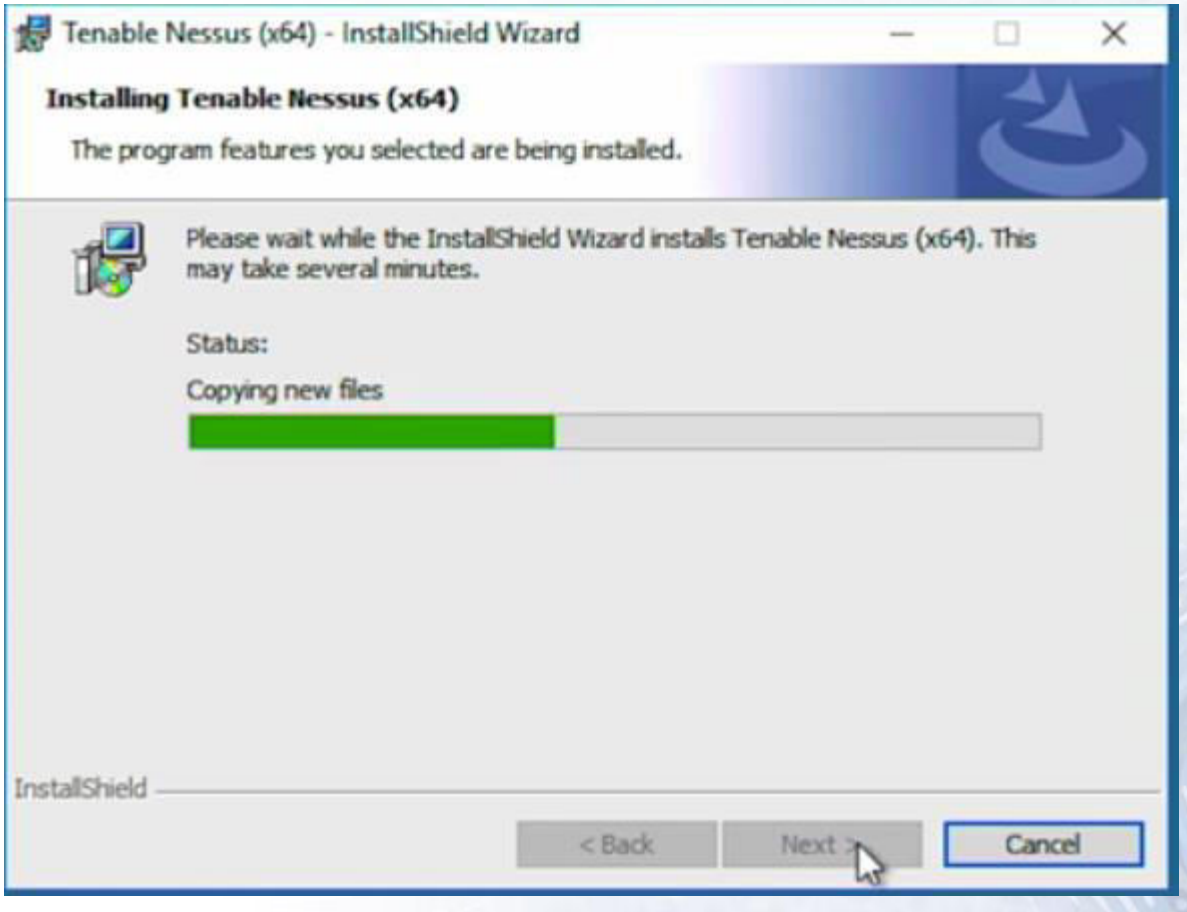

tenable
Downloads
Login
License Agreement
IMPORTANT
THIS AGREEMENT IS INTENDED TO BE LEGALLY BINDING. BY CLICKING THE "AGREE" OR "ACCEPT" BUTTON BELOW AND/OR CONTINUING TO DOWNLOAD, INSTALL OR USE TENABLE SOFTWARE AND OR SERVICES (OR AUTHORIZING/ALLOWING A THIRD PARTY TO DO SO ON YOUR BEHALF), YOU INDICATE:
(1) YOUR ACCEPTANCE OF THIS AGREEMENT;
(2) YOU ACKNOWLEDGE THAT YOU HAVE READ ALL OF THE TERMS AND CONDITIONS OF THIS AGREEMENT, UNDERSTAND THEM, AND AGREE TO BE LEGALLY BOUND BY THEM; AND
(3) YOU ARE AUTHORIZED TO BIND CUSTOMER TO THE TERMS OF THIS AGREEMENT.
***IF YOU DO NOT WISH TO ACCEPT THE TERMS OF THIS AGREEMENT OR ARE NOT AUTHORIZED TO DO SO PLEASE CLICK THE "REJECT" OR "DECLINE" OR OTHER SIMILAR BUTTON AND DO NOT PROCEED TO DOWNLOAD, INSTALL OR USE THIS PRODUCT.
TENABLE MASTER AGREEMENT
This Master Agreement (this "Agreement") is made by and between Tenable (as defined below) and the customer identified on the Signature and Cover Page ("Customer"). This Agreement is made effective as of the date of the final signature on the Signature and Cover Page (the "Effective Date"). Hereinafter, each of Tenable and Customer may be referred to collectively as the "Parties" or individually as a "Party".
1. Definitions.
(a) "Affiliate" means any entity that controls, is controlled by, or is under common control with a Party.
I Agree
Cancel

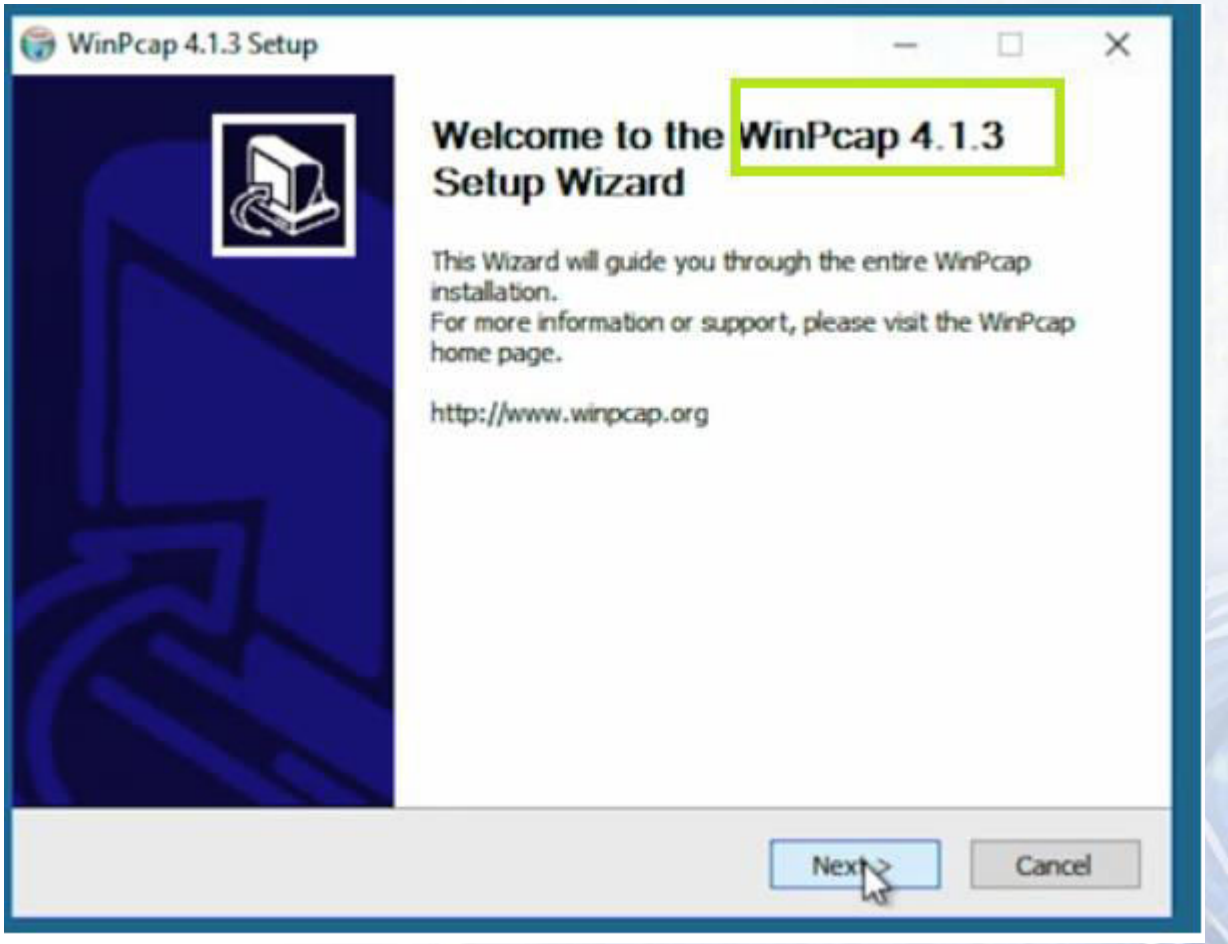
Open File - Security Warning
Do you want to run this file?
Name: ...\Users\Administrator\Downloads\Nessus-8.1.2-x64.msi
Publisher: Tenable Network Security Inc.
Type: Windows Installer Package
From: C:\Users\Administrator\Downloads\Nessus-8.1.2-x64....
Run
Cancel
Always ask before opening this file
While files from the Internet can be useful, this file type can potentially harm your computer. Only run software from publishers you trust.
What's the risk?

Tenable Nessus (x64) - InstallShield Wizard
Welcome to the InstallShield Wizard for Tenable Nessus (x64)
The InstallShield(R) Wizard will install Tenable Nessus (x64) on your computer. To continue, click Next.
WARNING: This program is protected by copyright law and international treaties.
< Back
Next >
Cancel

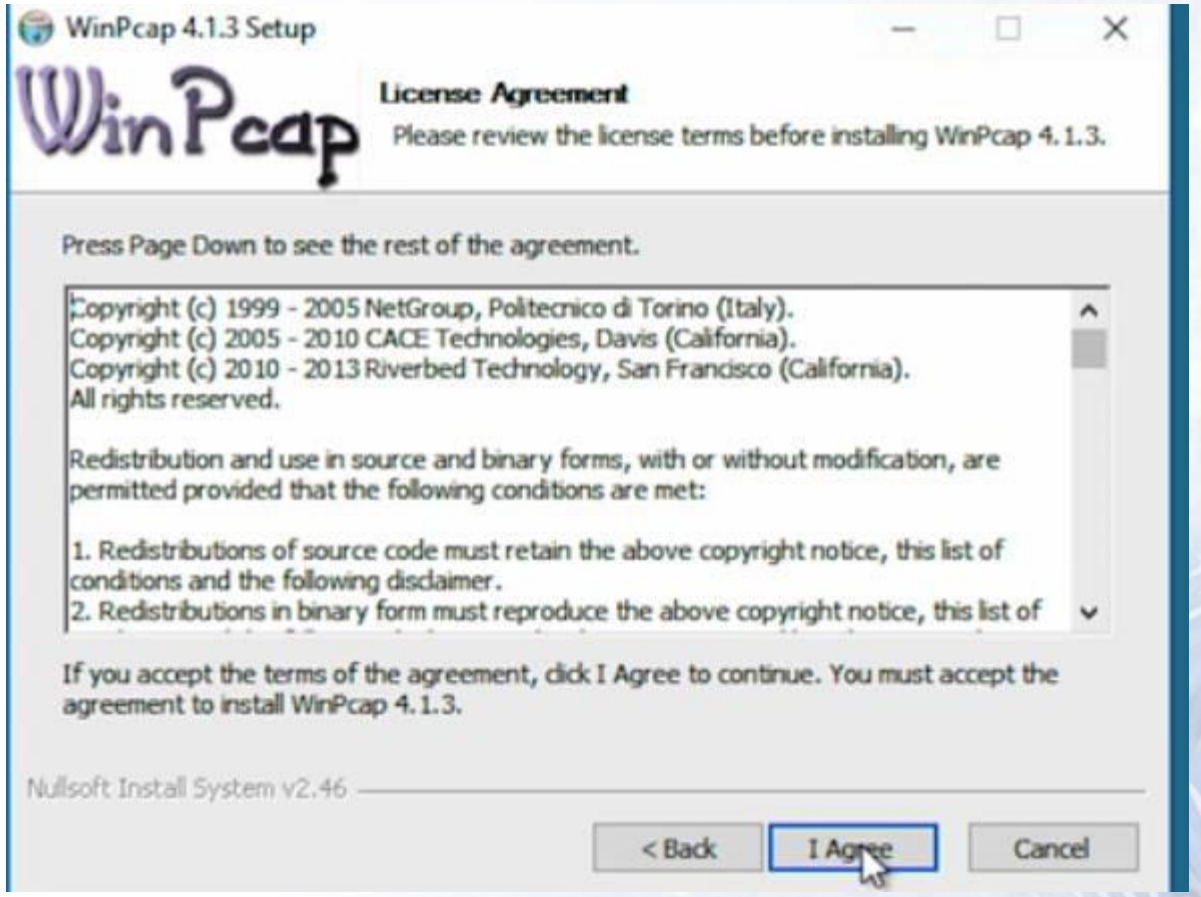

Tenable Nessus (x64) - InstallShield Wizard
License Agreement
Please read the following license agreement carefully.
Tenable Network Security, Inc.
NESSUS®
software license AND SUBSCRIPTION Agreement
This is a legal agreement ("Agreement") between Tenable Network Security, Inc., a Delaware corporation having offices at 7021 Columbia Gateway Drive, Suite 500, Columbia, MD 21046 ("Tenable"), and you ("You"), the party licensing Software and/or downloading the Plugins through Tenable's subscription service (as each capitalized term is defined
I accept the terms in the license agreement
I do not accept the terms in the license agreement
InstallShield
< Back
Next >
Cancel

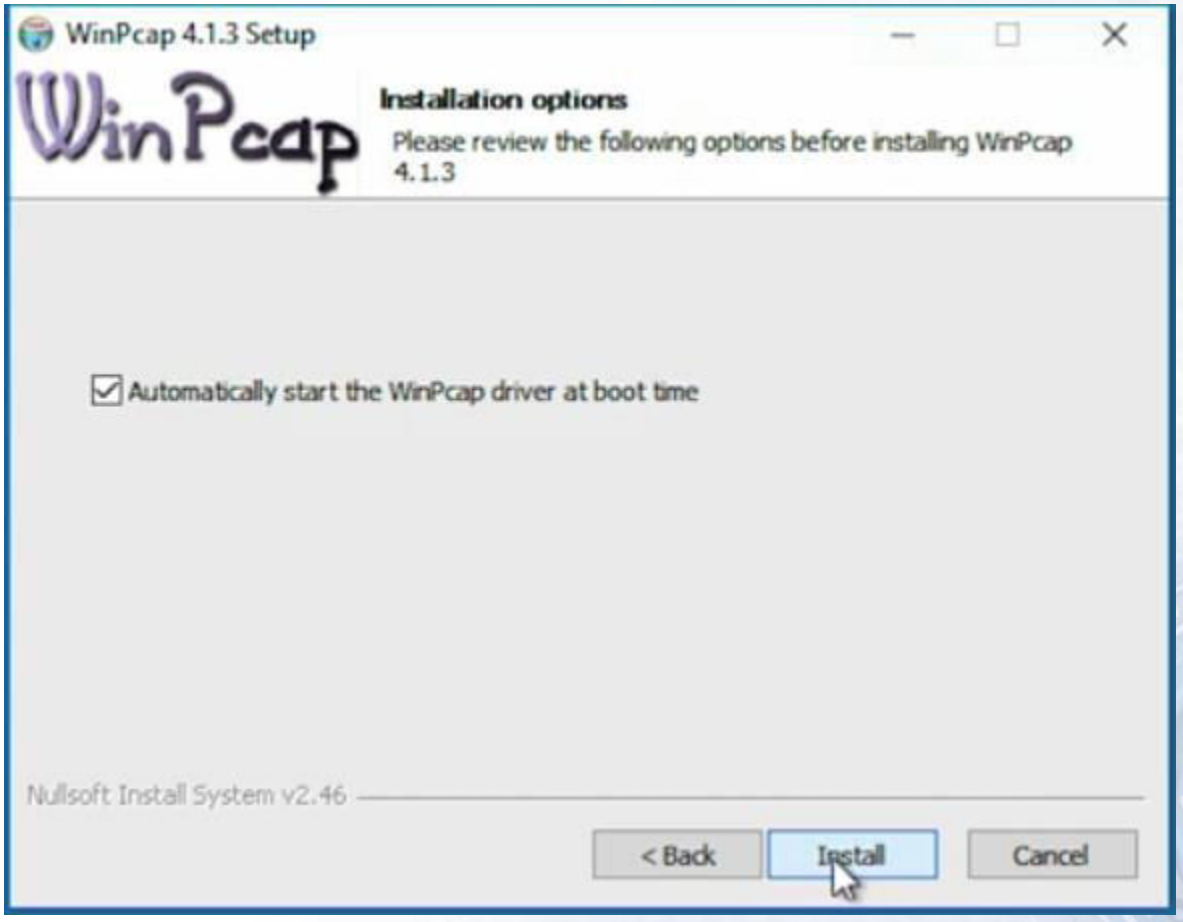

Tenable Nessus (x64) - InstallShield Wizard
Ready to Install the Program
The wizard is ready to begin installation.
Click Install to begin the installation.
If you want to review or change any of your installation settings, click Back. Click Cancel to exit the wizard.
InstallShield
< Back
Install
Cancel


Tenable Nessus (x64) - InstallShield Wizard
Installing Tenable Nessus (x64)
The program features you selected are being installed.
Please wait while the InstallShield Wizard installs Tenable Nessus (x64). This may take several minutes.
Status:
Copying new files
InstallShield
< Back
Next >
Cancel

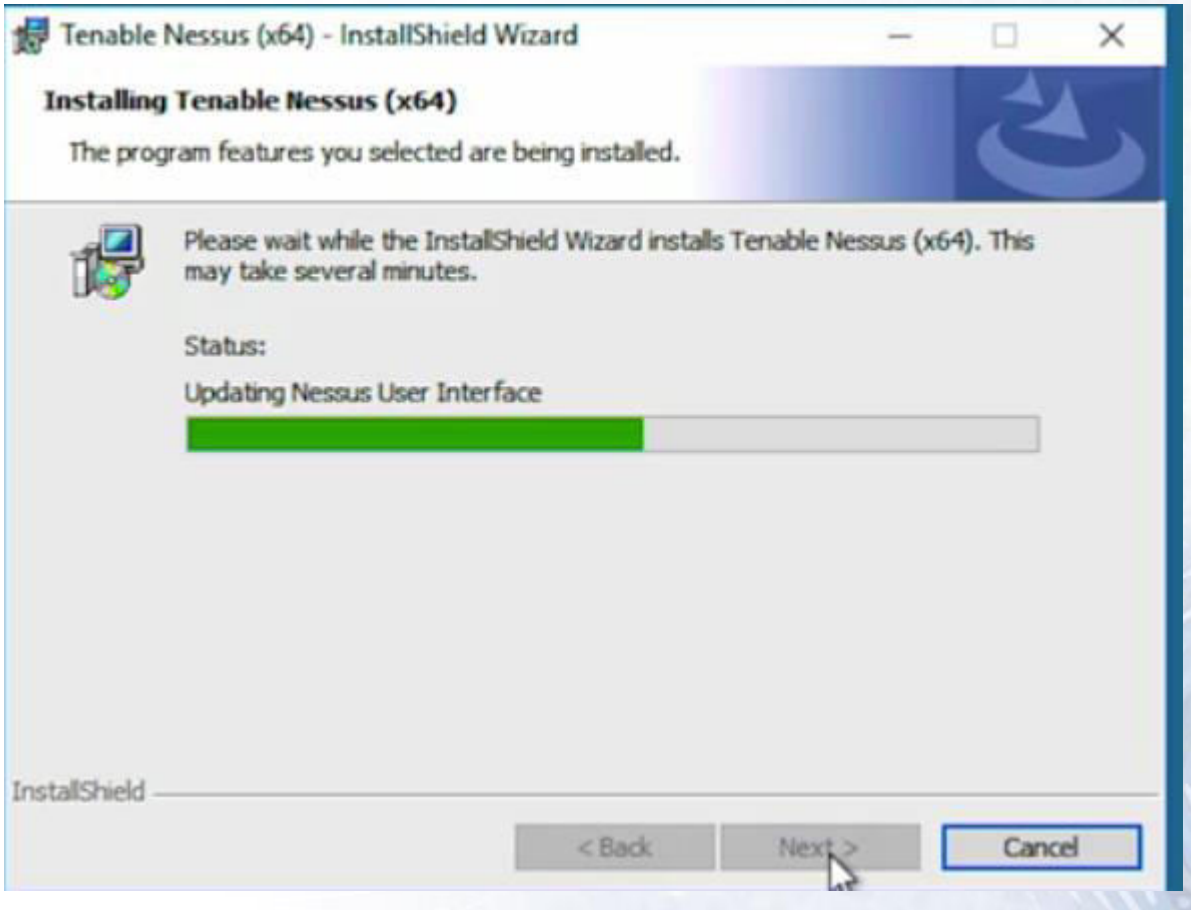

WinPcap 4.1.3 Setup
Welcome to the WinPcap 4.1.3 Setup Wizard
This Wizard will guide you through the entire WinPcap installation.
For more information or support, please visit the WinPcap home page.
http://www.winpcap.org
Next >
Cancel

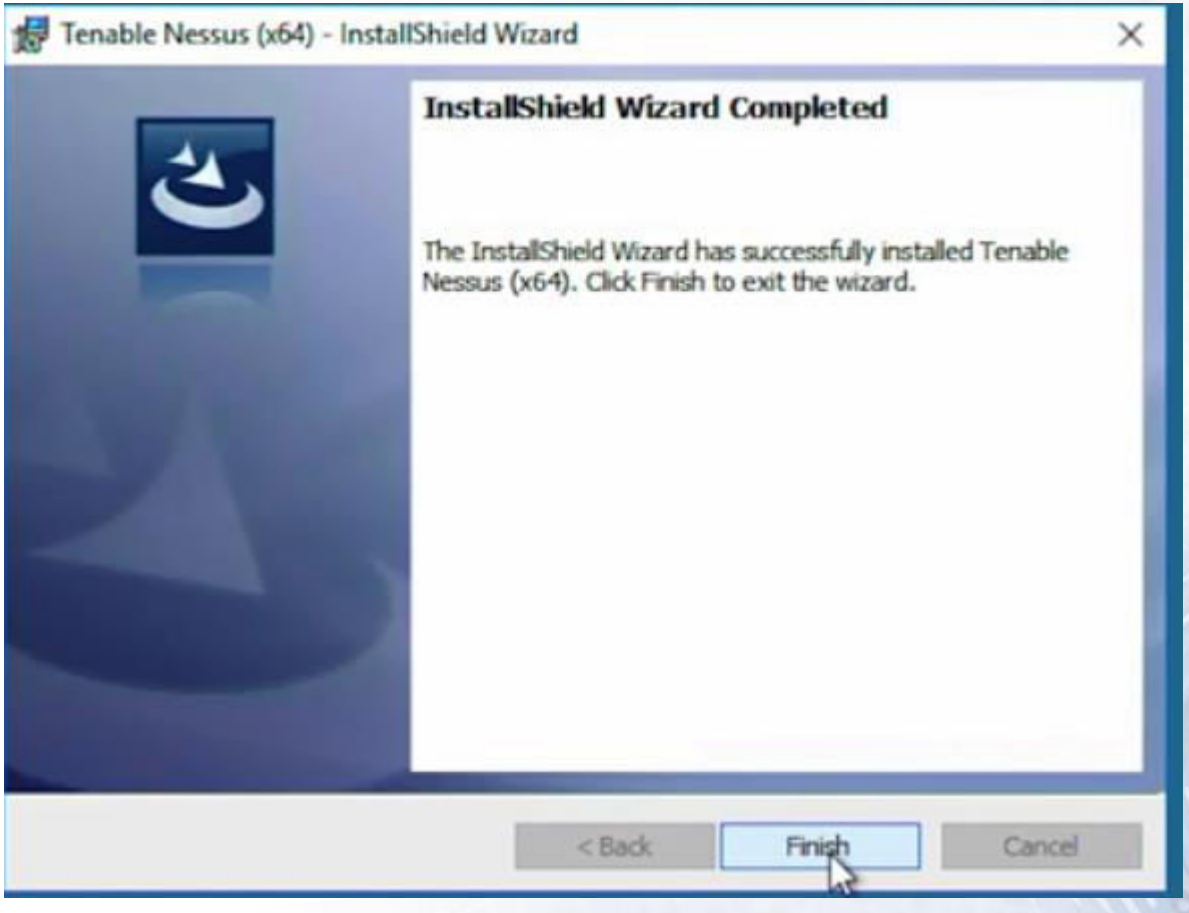
- Nessus installer realize that i don’t have windows packet capture library
- Nessus can’t work on winods without **WinPcap**


WinPcap 4.1.3 Setup
WinPcap
License Agreement
Please review the license terms before installing WinPcap 4.1.3.
Press Page Down to see the rest of the agreement.
Copyright (c) 1999 - 2005 NetGroup, Politecnico di Torino (Italy).
Copyright (c) 2005 - 2010 CACE Technologies, Davis (California).
Copyright (c) 2010 - 2013 Riverbed Technology, San Francisco (California).
All rights reserved.
Redistribution and use in source and binary forms, with or without modification, are permitted provided that the following conditions are met:
1. Redistributions of source code must retain the above copyright notice, this list of conditions and the following disclaimer.
2. Redistributions in binary form must reproduce the above copyright notice, this list of
If you accept the terms of the agreement, click I Agree to continue. You must accept the agreement to install WinPcap 4.1.3.
Nullsoft Install System v2.46
< Back
I Agree
Cancel

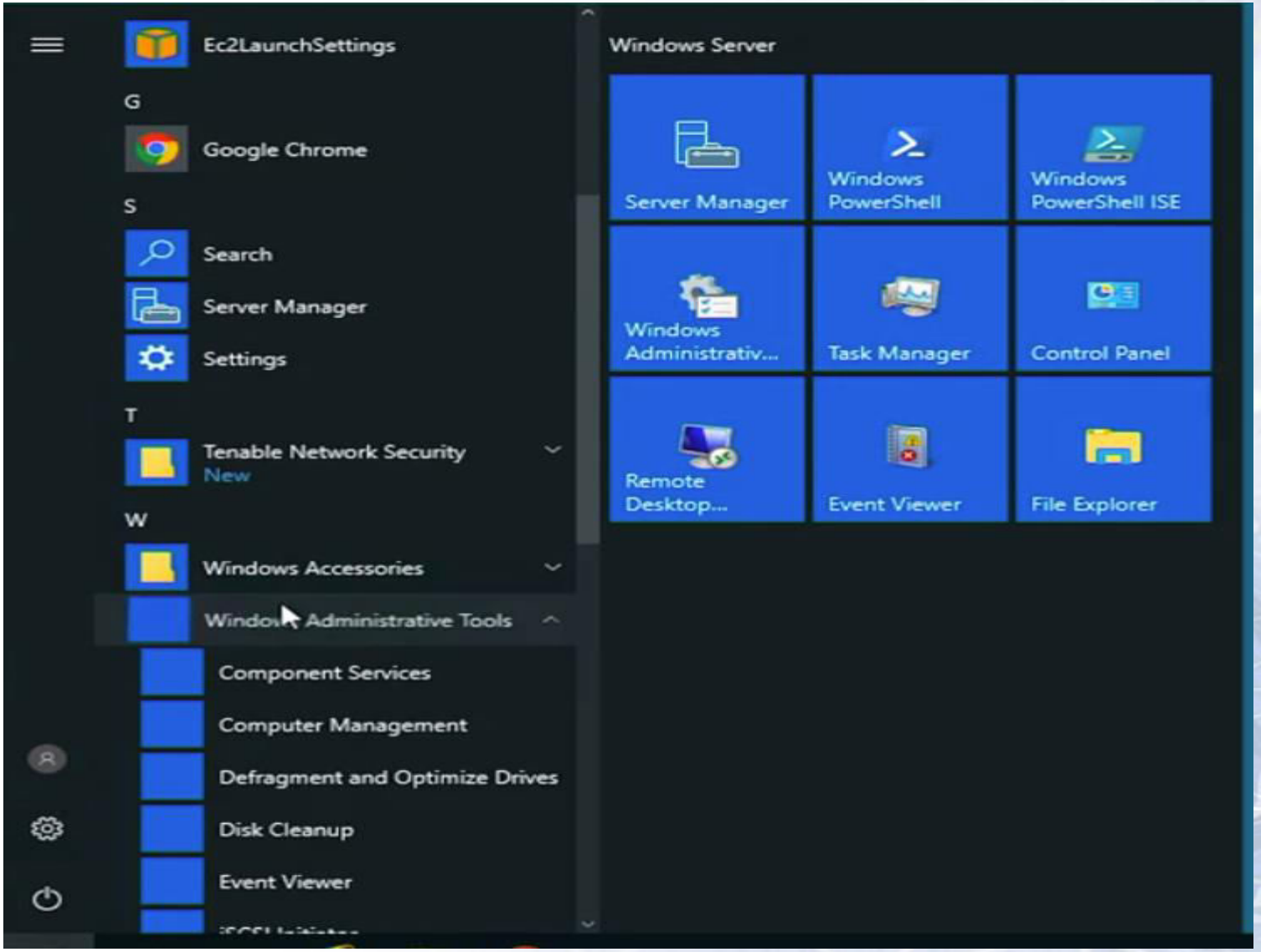

WinPcap 4.1.3 Setup
WinPcap
Installation options
Please review the following options before installing WinPcap 4.1.3
Automatically start the WinPcap driver at boot time
Nullsoft Install System v2.46
< Back
Install
Cancel

WinPcap 4.1.3 Setup
Completing the WinPcap 4.1.3 Setup Wizard
WinPcap 4.1.3 has been installed on your computer.
Click Finish to close this wizard.
< Back
Finish
Cancel

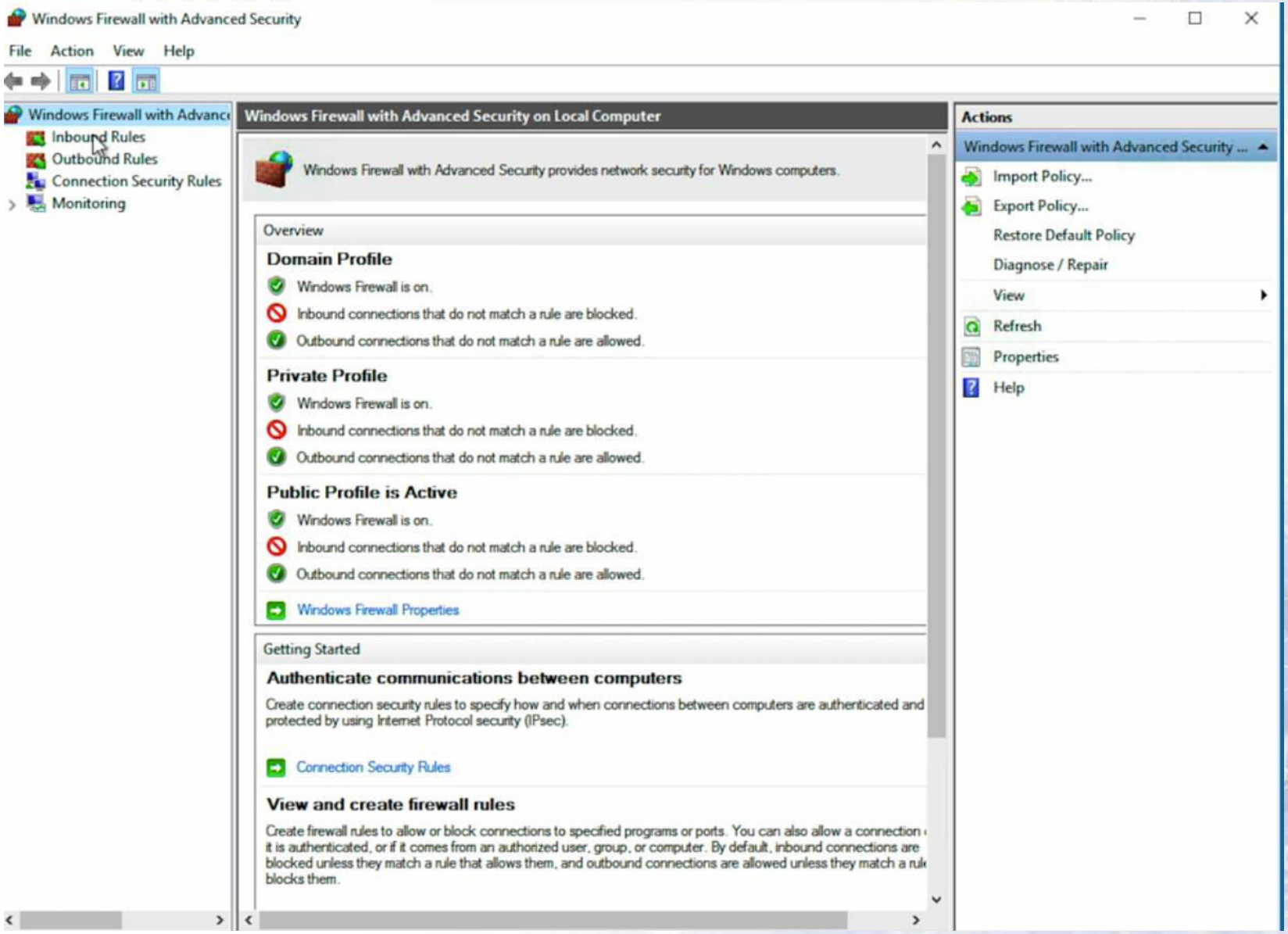

Tenable Nessus (x64) - InstallShield Wizard
Installing Tenable Nessus (x64)
The program features you selected are being installed.
Please wait while the InstallShield Wizard installs Tenable Nessus (x64). This may take several minutes.
Status:
Updating Nessus User Interface
InstallShield
< Back
Next >
Cancel

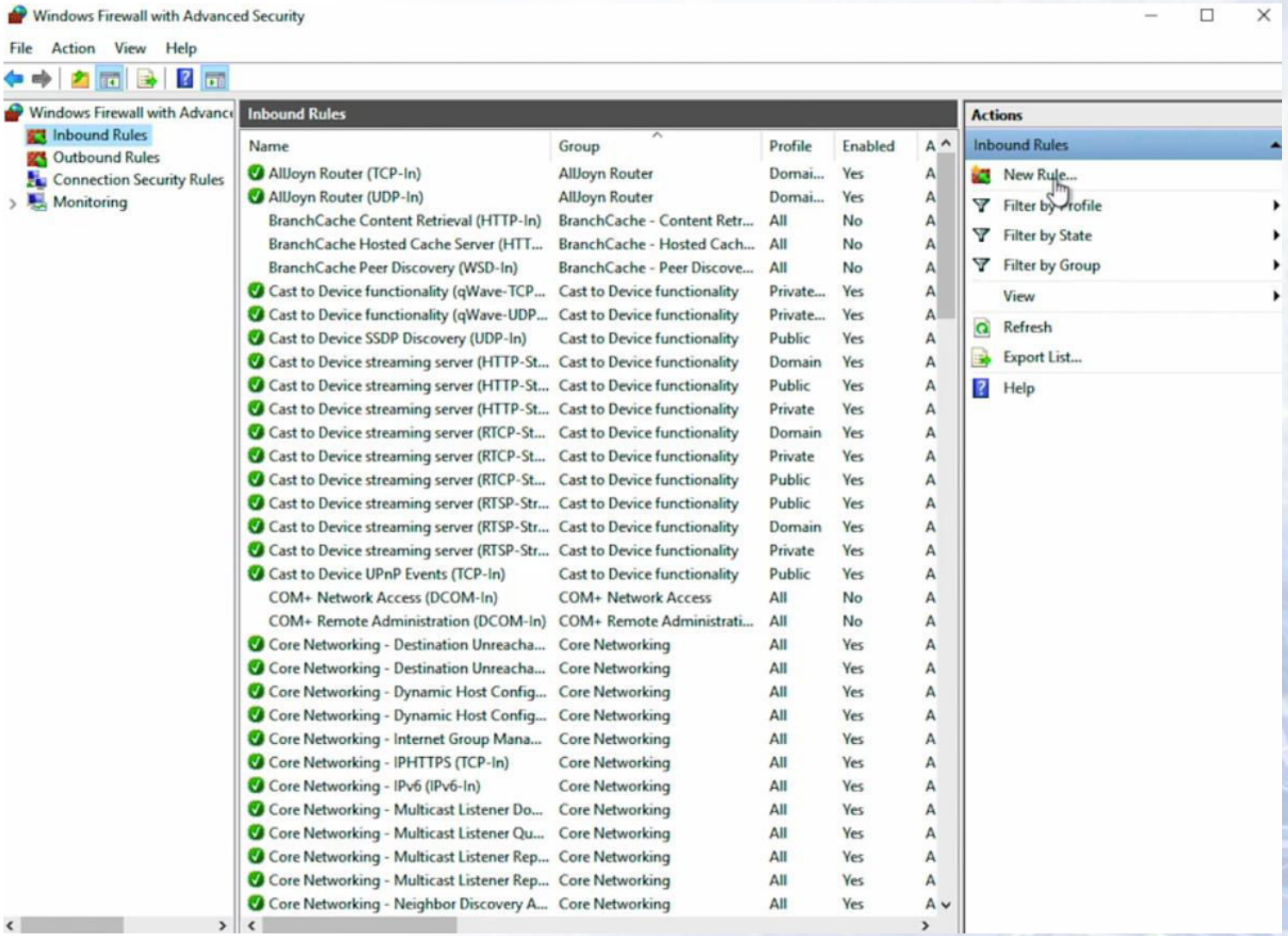

Tenable Nessus (x64) - InstallShield Wizard
InstallShield Wizard Completed
The InstallShield Wizard has successfully installed Tenable Nessus (x64). Click Finish to exit the wizard.
< Back
Finish
Cancel

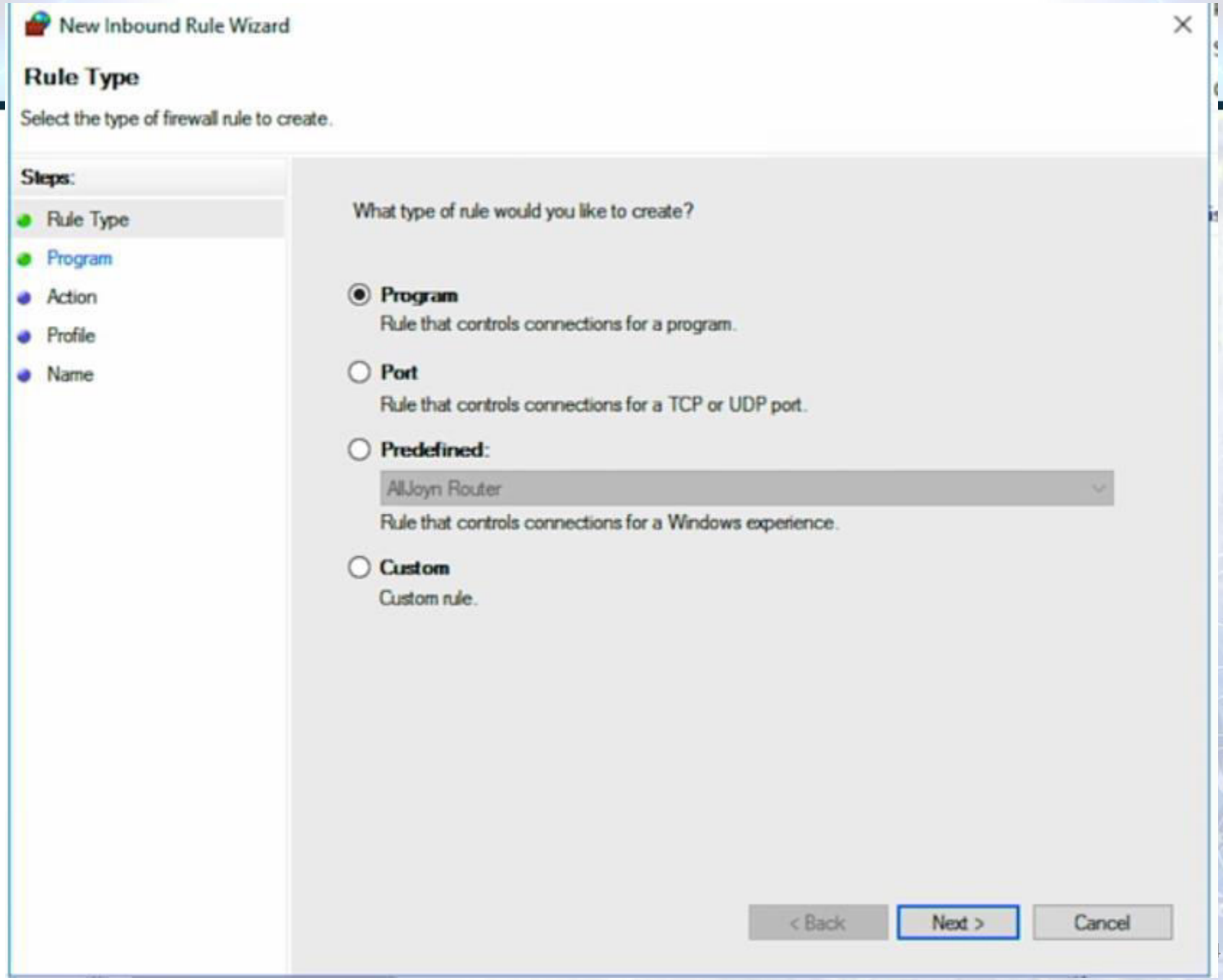
Nessus Manger use TCP port 8834

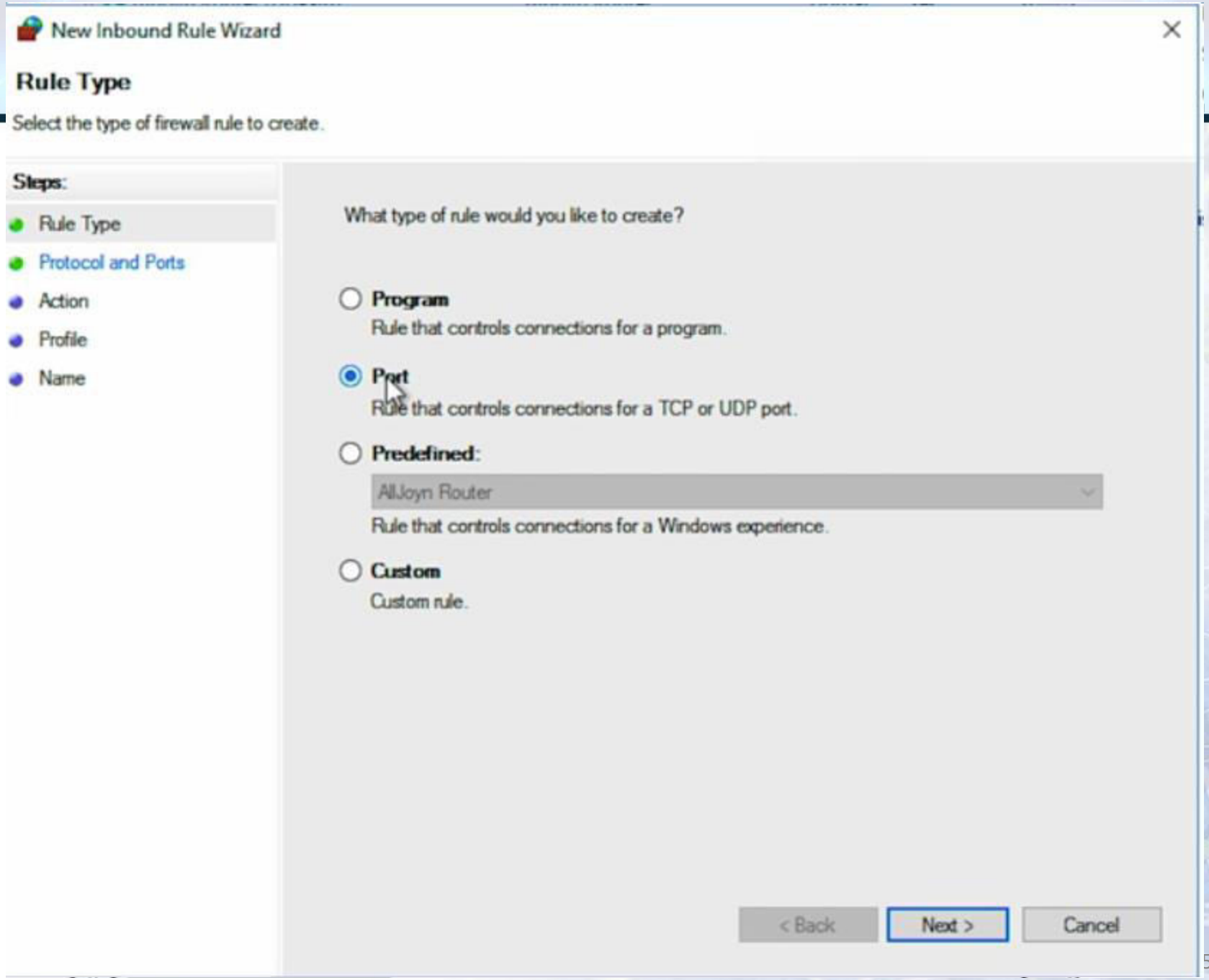

Ec2LaunchSettings
G
Google Chrome
S
Search
Server Manager
Settings
T
Tenable Network Security
New
W
Windows Accessories
Windows Administrative Tools
Component Services
Computer Management
Defragment and Optimize Drives
Disk Cleanup
Event Viewer
Windows Server
Server Manager
Windows PowerShell
Windows PowerShell ISE
Windows Administrativ...
Task Manager
Control Panel
Remote Desktop...
Event Viewer
File Explorer

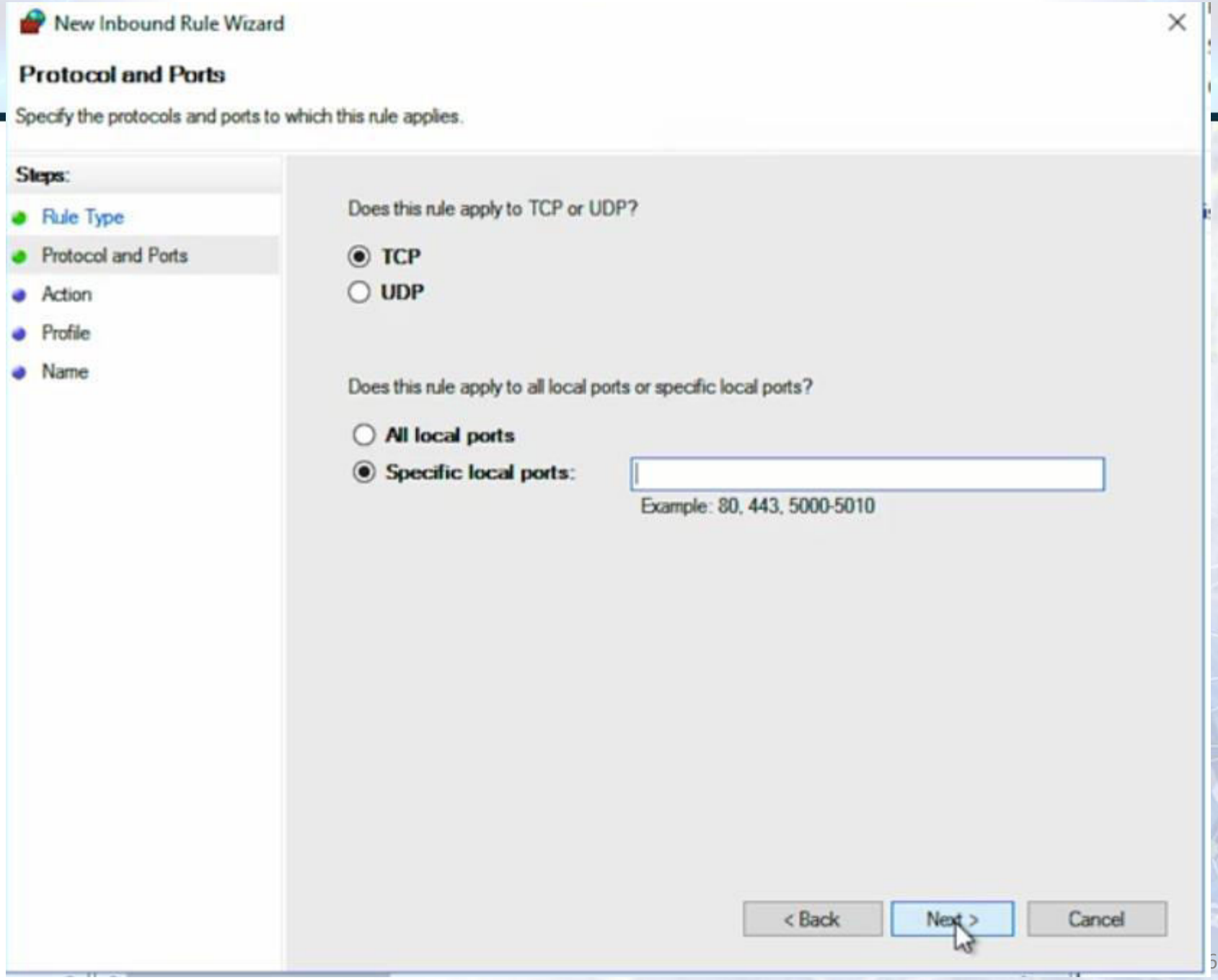
Computer Management
Defragment and Optimize Drives
Disk Cleanup
Event Viewer
iSCSI Initiator
Local Security Policy
Microsoft Azure Services
ODBC Data Sources (32-bit)
ODBC Data Sources (64-bit)
Performance Monitor
Print Management
Resource Monitor
Services
System Configuration
System Information
Task Scheduler
Windows Firewall with Advanced...
Windows Memory Diagnostic
Windows Server
Server Manager
Windows PowerShell
Windows PowerShell ISE
Windows Administrativ...
Task Manager
Control Panel
Remote Desktop...
Event Viewer
File Explorer

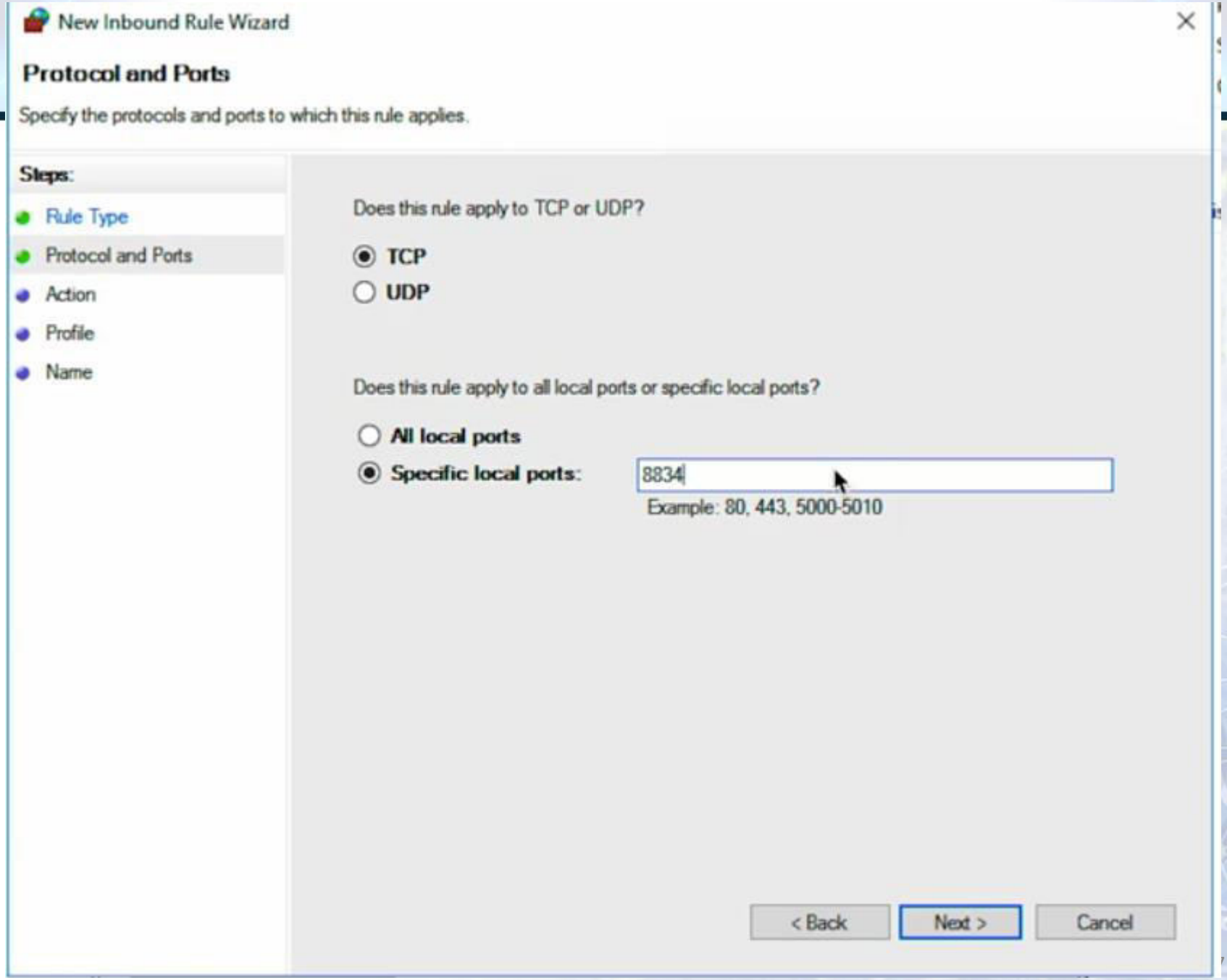

Windows Firewall with Advanced Security
File Action View Help
Windows Firewall with Advanc
Inbound Rules
Outbound Rules
Connection Security Rules
Monitoring
Windows Firewall with Advanced Security on Local Computer
Windows Firewall with Advanced Security provides network security for Windows computers.
Overview
Domain Profile
Windows Firewall is on.
Inbound connections that do not match a rule are blocked.
Outbound connections that do not match a rule are allowed.
Private Profile
Windows Firewall is on.
Inbound connections that do not match a rule are blocked.
Outbound connections that do not match a rule are allowed.
Public Profile is Active
Windows Firewall is on.
Inbound connections that do not match a rule are blocked.
Outbound connections that do not match a rule are allowed.
Windows Firewall Properties
Getting Started
Authenticate communications between computers
Create connection security rules to specify how and when connections between computers are authenticated and protected by using Internet Protocol security (IPsec).
Connection Security Rules
View and create firewall rules
Create firewall rules to allow or block connections to specified programs or ports. You can also allow a connection
it is authenticated, or if it comes from an authorized user, group, or computer. By default, inbound connections are
blocked unless they match a rule that allows them, and outbound connections are allowed unless they match a rul
blocks them.
Actions
Windows Firewall with Advanced Security ...
Import Policy...
Export Policy...
Restore Default Policy
Diagnose / Repair
View
Refresh
Properties
Help

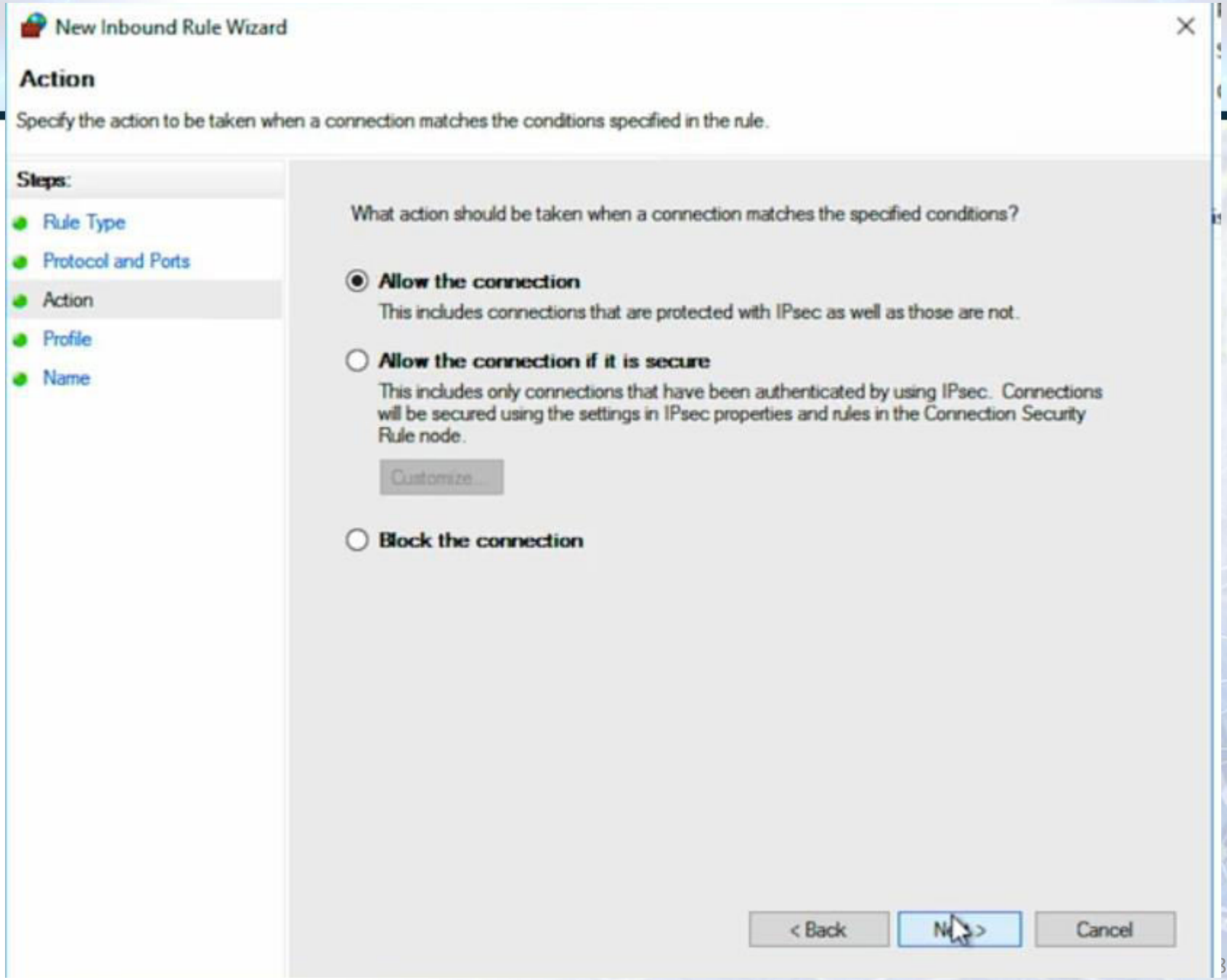

Windows Firewall with Advanced Security
File Action View Help
Windows Firewall with Advanc
Inbound Rules
Outbound Rules
Connection Security Rules
Monitoring
Inbound Rules
Name | Group | Profile | Enabled
AllJoyn Router (TCP-In) | AllJoyn Router | Domai... | Yes
AllJoyn Router (UDP-In) | AllJoyn Router | Domai... | Yes
BranchCache Content Retrieval (HTTP-In) | BranchCache - Content Retr... | All | No
BranchCache Hosted Cache Server (HTT... | BranchCache - Hosted Cach... | All | No
BranchCache Peer Discovery (WSD-In) | BranchCache - Peer Discove... | All | No
Cast to Device functionality (qWave-TCP... | Cast to Device functionality | Private... | Yes
Cast to Device functionality (qWave-UDP... | Cast to Device functionality | Private... | Yes
Cast to Device SSDP Discovery (UDP-In) | Cast to Device functionality | Public | Yes
Cast to Device streaming server (HTTP-St... | Cast to Device functionality | Domain | Yes
Cast to Device streaming server (HTTP-St... | Cast to Device functionality | Public | Yes
Cast to Device streaming server (HTTP-St... | Cast to Device functionality | Private | Yes
Cast to Device streaming server (RTCP-St... | Cast to Device functionality | Domain | Yes
Cast to Device streaming server (RTCP-St... | Cast to Device functionality | Private | Yes
Cast to Device streaming server (RTCP-St... | Cast to Device functionality | Public | Yes
Cast to Device streaming server (RTSP-Str... | Cast to Device functionality | Public | Yes
Cast to Device streaming server (RTSP-Str... | Cast to Device functionality | Domain | Yes
Cast to Device streaming server (RTSP-Str... | Cast to Device functionality | Private | Yes
Cast to Device UPnP Events (TCP-In) | Cast to Device functionality | Public | Yes
COM+ Network Access (DCOM-In) | COM+ Network Access | All | No
COM+ Remote Administration (DCOM-In) | COM+ Remote Administrati... | All | No
Core Networking - Destination Unreacha... | Core Networking | All | Yes
Core Networking - Destination Unreacha... | Core Networking | All | Yes
Core Networking - Dynamic Host Config... | Core Networking | All | Yes
Core Networking - Dynamic Host Config... | Core Networking | All | Yes
Core Networking - Internet Group Mana... | Core Networking | All | Yes
Core Networking - IPHTTPS (TCP-In) | Core Networking | All | Yes
Core Networking - IPv6 (IPv6-In) | Core Networking | All | Yes
Core Networking - Multicast Listener Do... | Core Networking | All | Yes
Core Networking - Multicast Listener Qu... | Core Networking | All | Yes
Core Networking - Multicast Listener Rep... | Core Networking | All | Yes
Core Networking - Multicast Listener Rep... | Core Networking | All | Yes
Core Networking - Neighbor Discovery A... | Core Networking | All | Yes
Actions
Inbound Rules
New Rule...
Filter by Profile
Filter by State
Filter by Group
View
Refresh
Export List...
Help

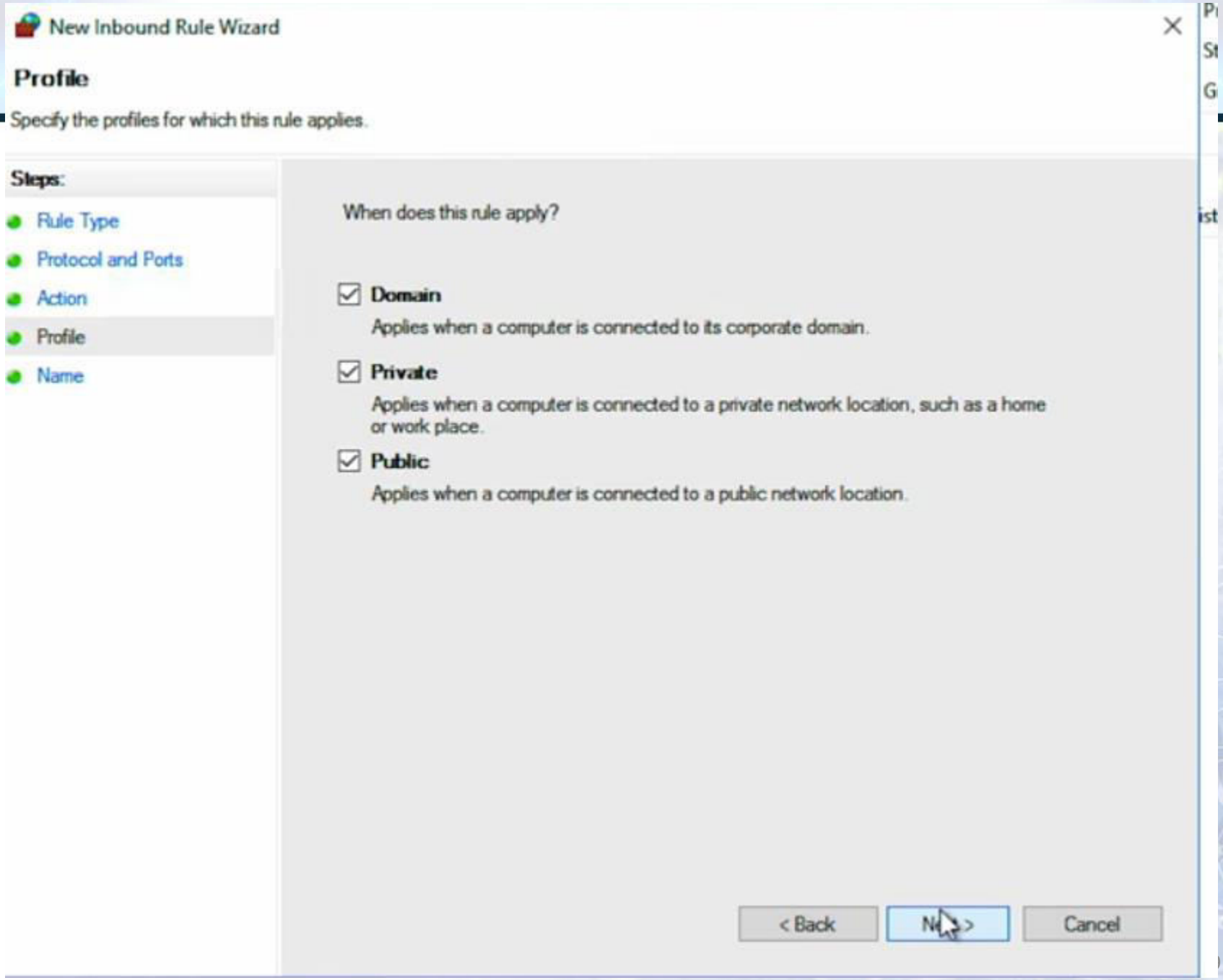

New Inbound Rule Wizard
Rule Type
Select the type of firewall rule to create.
Steps:
Rule Type
Program
Action
Profile
Name
What type of rule would you like to create?
Program
Rule that controls connections for a program.
Port
Rule that controls connections for a TCP or UDP port.
Predefined:
AllJoyn Router
Rule that controls connections for a Windows experience.
Custom
Custom rule.
< Back
Next >
Cancel

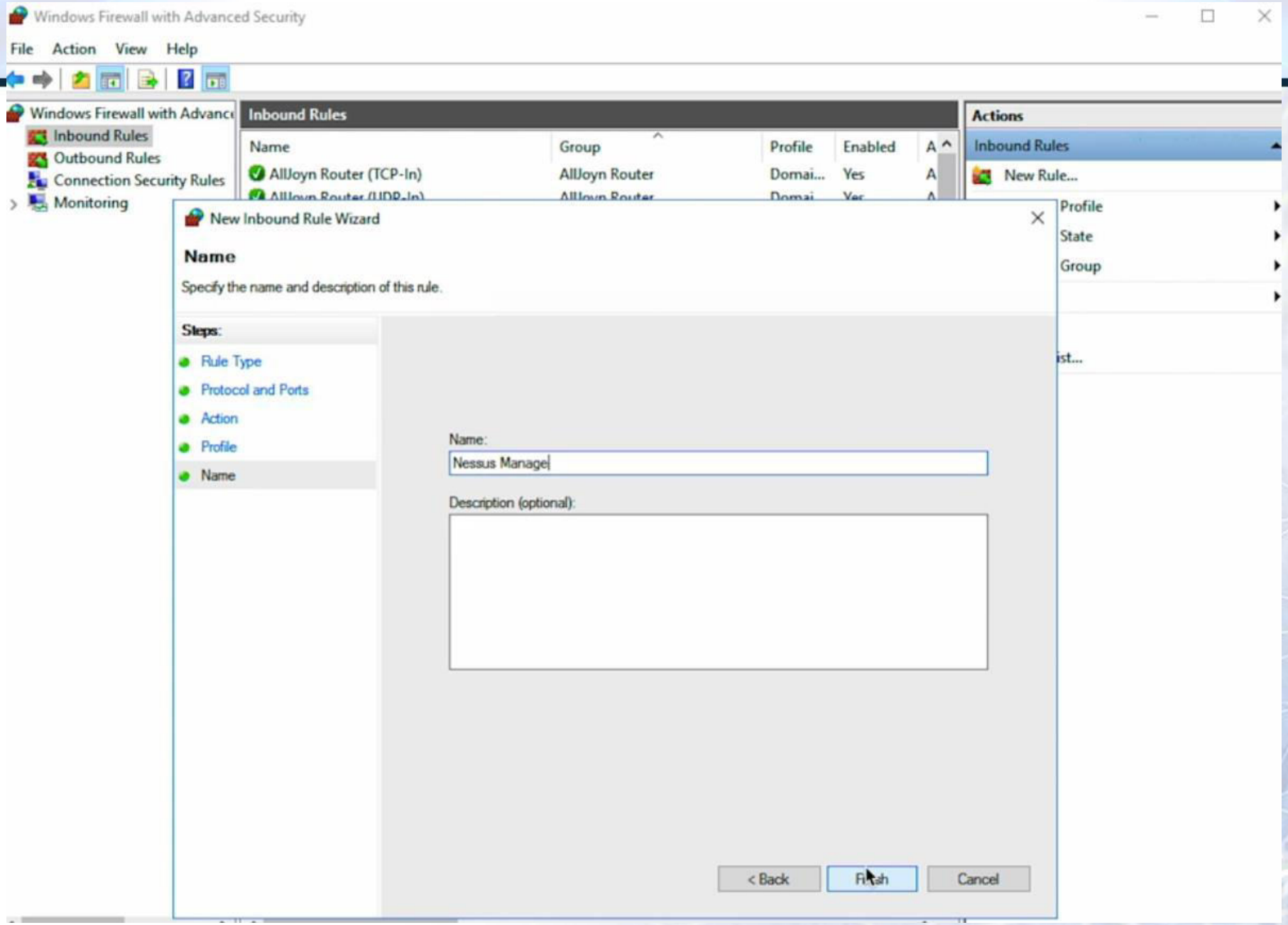

New Inbound Rule Wizard
Rule Type
Select the type of firewall rule to create.
Steps:
Rule Type
Protocol and Ports
Action
Profile
Name
What type of rule would you like to create?
Program
Rule that controls connections for a program.
Port
Rule that controls connections for a TCP or UDP port.
Predefined:
AllJoyn Router
Rule that controls connections for a Windows experience.
Custom
Custom rule.
< Back
Next >
Cancel

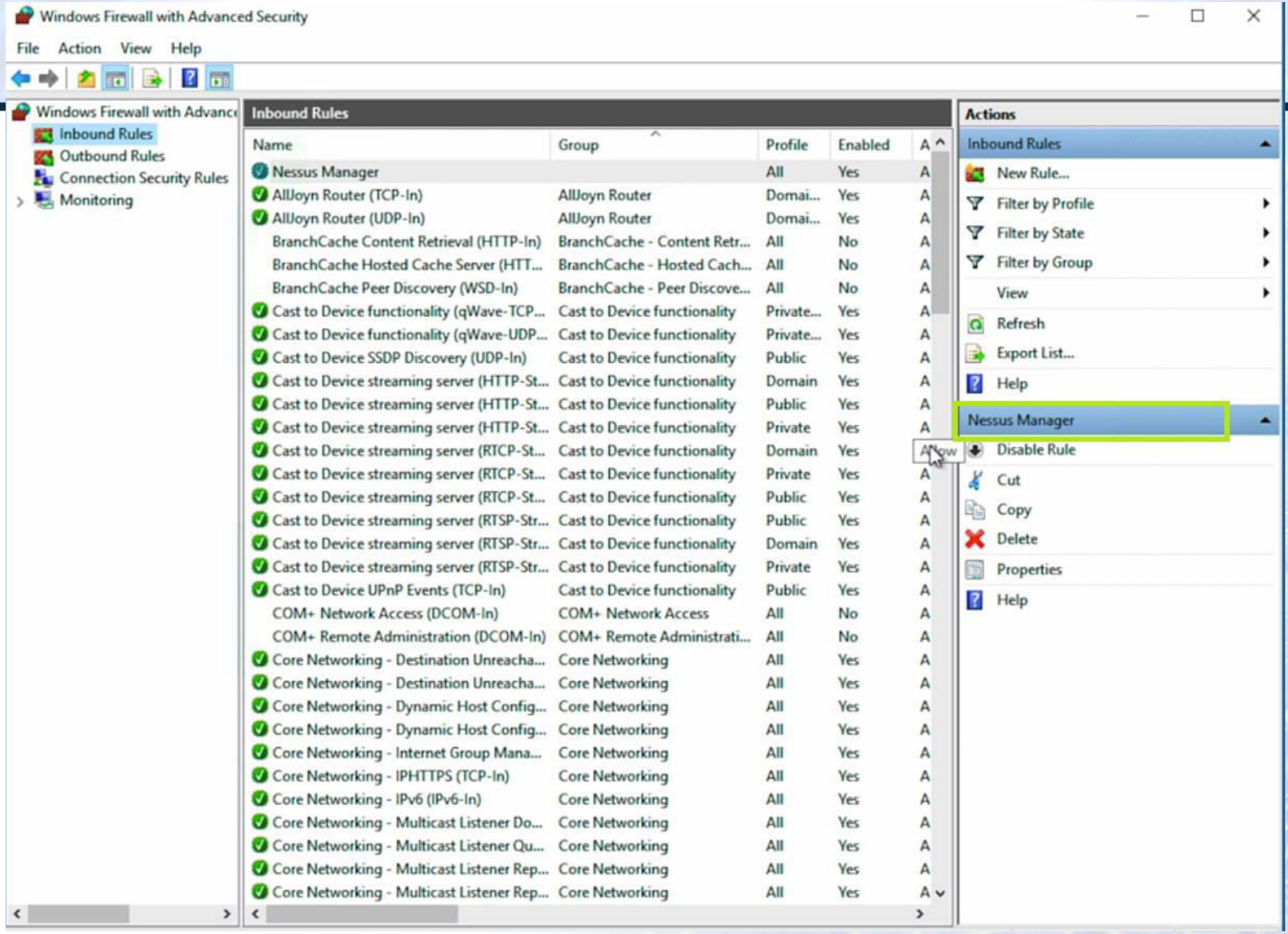

New Inbound Rule Wizard
Protocol and Ports
Specify the protocols and ports to which this rule applies.
Steps:
Rule Type
Protocol and Ports
Action
Profile
Name
Does this rule apply to TCP or UDP?
TCP
UDP
Does this rule apply to all local ports or specific local ports?
All local ports
Specific local ports:
Example: 80, 443, 5000-5010
< Back
Next >
Cancel


New Inbound Rule Wizard
Protocol and Ports
Specify the protocols and ports to which this rule applies.
Steps:
Rule Type
Protocol and Ports
Action
Profile
Name
Does this rule apply to TCP or UDP?
TCP
UDP
Does this rule apply to all local ports or specific local ports?
All local ports
Specific local ports:
8834
Example: 80, 443, 5000-5010
< Back
Next >
Cancel


New Inbound Rule Wizard
Action
Specify the action to be taken when a connection matches the conditions specified in the rule.
Steps:
Rule Type
Protocol and Ports
Action
Profile
Name
What action should be taken when a connection matches the specified conditions?
Allow the connection
This includes connections that are protected with IPsec as well as those are not.
Allow the connection if it is secure
This includes only connections that have been authenticated by using IPsec. Connections will be secured using the settings in IPsec properties and rules in the Connection Security Rule node.
Customize...
Block the connection
< Back
Cancel


New Inbound Rule Wizard
Profile
Specify the profiles for which this rule applies.
Steps:
Rule Type
Protocol and Ports
Action
Profile
Name
When does this rule apply?
Domain
Applies when a computer is connected to its corporate domain.
Private
Applies when a computer is connected to a private network location, such as a home or work place.
Public
Applies when a computer is connected to a public network location.
< Back
Cancel


Windows Firewall with Advanced Security
File Action View Help
Windows Firewall with Advanc
Inbound Rules
Outbound Rules
Connection Security Rules
Monitoring
Inbound Rules
Name Group Profile Enabled
AllJoyn Router (TCP-In) AllJoyn Router Domai... Yes
Actions
Inbound Rules
New Rule...
Profile
State
Group
New Inbound Rule Wizard
Name
Specify the name and description of this rule.
Steps:
Rule Type
Protocol and Ports
Action
Profile
Name
Name:
Nessus Manage
Description (optional):
< Back
Finish
Cancel


Windows Firewall with Advanced Security
File Action View Help
Windows Firewall with Advanc
Inbound Rules
Outbound Rules
Connection Security Rules
Monitoring
Inbound Rules
Name Group Profile Enabled A
Nessus Manager All Yes A
AllJoyn Router (TCP-In) AllJoyn Router Domai... Yes A
AllJoyn Router (UDP-In) AllJoyn Router Domai... Yes A
BranchCache Content Retrieval (HTTP-In) BranchCache - Content Retr... All No A
BranchCache Hosted Cache Server (HTT... BranchCache - Hosted Cach... All No A
BranchCache Peer Discovery (WSD-In) BranchCache - Peer Discove... All No A
Cast to Device functionality (qWave-TCP... Cast to Device functionality Private... Yes A
Cast to Device functionality (qWave-UDP... Cast to Device functionality Private... Yes A
Cast to Device SSDP Discovery (UDP-In) Cast to Device functionality Public Yes A
Cast to Device streaming server (HTTP-St... Cast to Device functionality Domain Yes A
Cast to Device streaming server (HTTP-St... Cast to Device functionality Public Yes A
Cast to Device streaming server (HTTP-St... Cast to Device functionality Private Yes A
Cast to Device streaming server (RTCP-St... Cast to Device functionality Domain Yes A
Cast to Device streaming server (RTCP-St... Cast to Device functionality Private Yes A
Cast to Device streaming server (RTCP-St... Cast to Device functionality Public Yes A
Cast to Device streaming server (RTSP-Str... Cast to Device functionality Public Yes A
Cast to Device streaming server (RTSP-Str... Cast to Device functionality Domain Yes A
Cast to Device streaming server (RTSP-Str... Cast to Device functionality Private Yes A
Cast to Device UPnP Events (TCP-In) Cast to Device functionality Public Yes A
COM+ Network Access (DCOM-In) COM+ Network Access All No A
COM+ Remote Administration (DCOM-In) COM+ Remote Administrati... All No A
Core Networking - Destination Unreacha... Core Networking All Yes A
Core Networking - Destination Unreacha... Core Networking All Yes A
Core Networking - Dynamic Host Config... Core Networking All Yes A
Core Networking - Dynamic Host Config... Core Networking All Yes A
Core Networking - Internet Group Mana... Core Networking All Yes A
Core Networking - IPHTTPS (TCP-In) Core Networking All Yes A
Core Networking - IPv6 (IPv6-In) Core Networking All Yes A
Core Networking - Multicast Listener Do... Core Networking All Yes A
Core Networking - Multicast Listener Qu... Core Networking All Yes A
Core Networking - Multicast Listener Rep... Core Networking All Yes A
Core Networking - Multicast Listener Rep... Core Networking All Yes A
Actions
Inbound Rules
New Rule...
Filter by Profile
Filter by State
Filter by Group
View
Refresh
Export List...
Help
Nessus Manager
Disable Rule
Cut
Copy
Delete
Properties
Help

Week 6 Topic 15

Accessing Nessus

1. First, ensure that the Nessus vulnerability scanner is installed on your system.

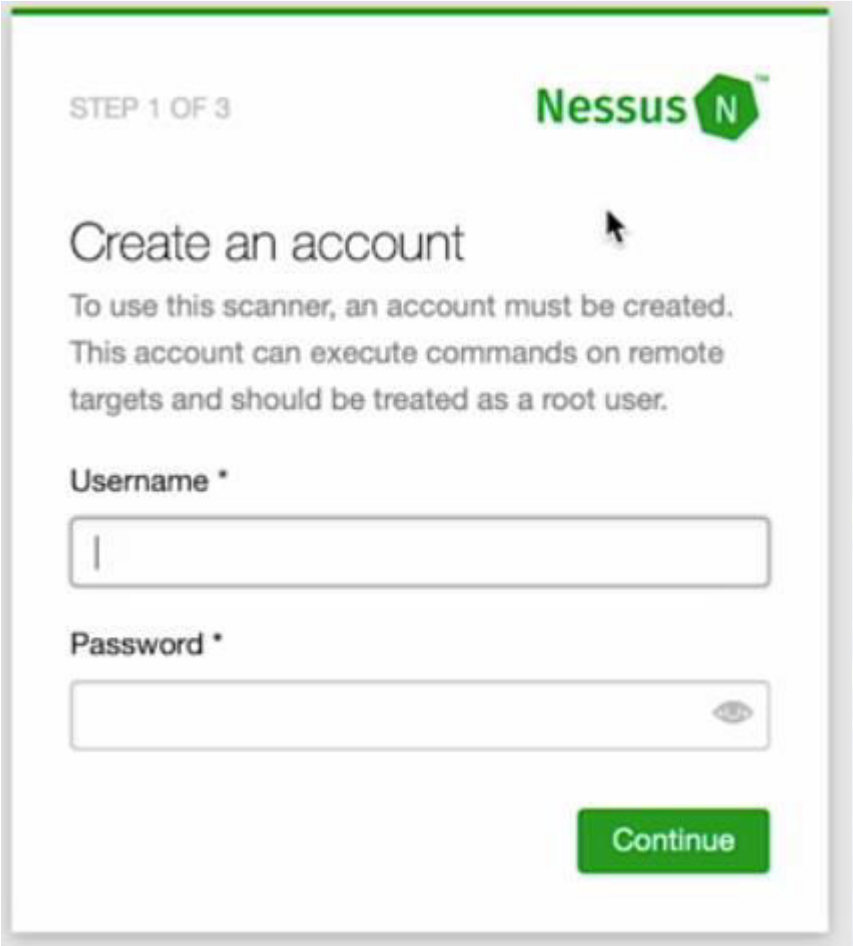
2. Once Nessus is installed, open a web browser (Chrome, Firefox, etc.) on the system you installed Nessus on.

3. In the web browser, navigate to the following URL: https://localhost:8834/ OR https://127.0.0.1:8834/

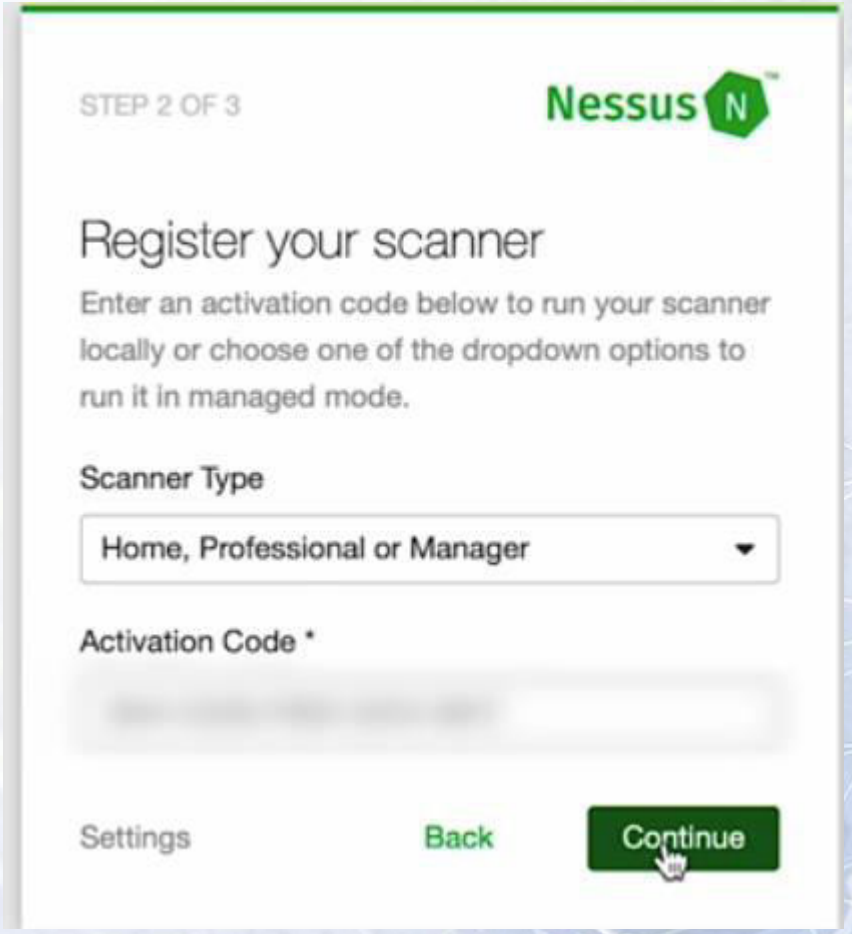
4. If Nessus is running on the same system that you are accessing the web interface from, the Nessus login page should appear in your web browser.

5. Enter your Nessus username and password and click "Login" to access the Nessus web interface.

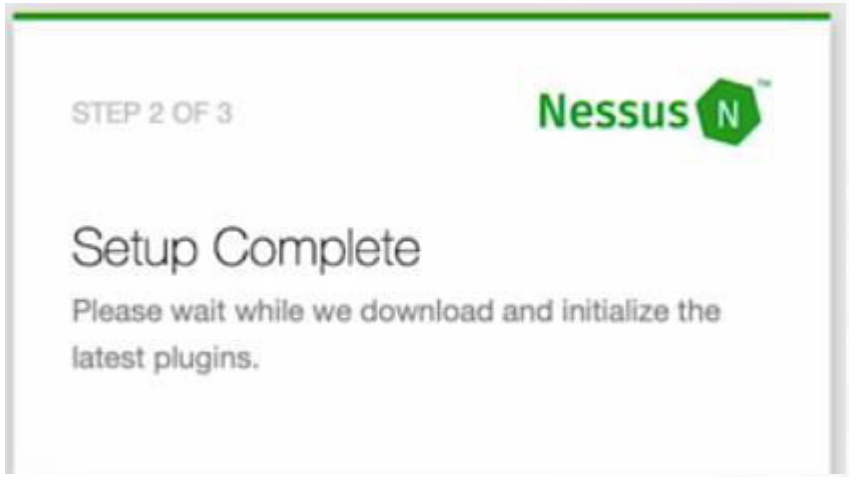
Step 1

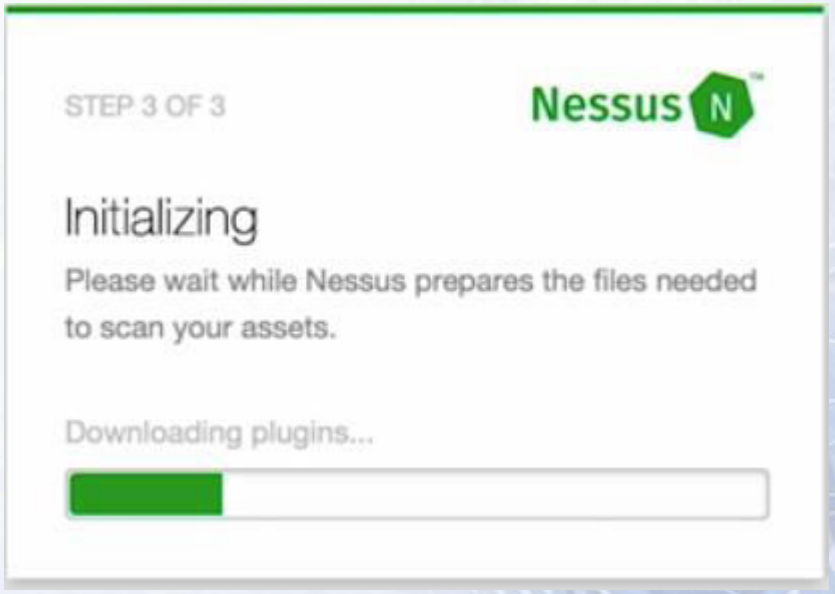

STEP 1 OF 3
Nessus
Create an account
To use this scanner, an account must be created. This account can execute commands on remote targets and should be treated as a root user.
Username *
Password *
Continue

Step 2


STEP 2 OF 3
Nessus
Register your scanner
Enter an activation code below to run your scanner locally or choose one of the dropdown options to run it in managed mode.
Scanner Type
Home, Professional or Manager
Activation Code *
Settings
Back
Continue

Step 3


STEP 2 OF 3
Nessus
Setup Complete
Please wait while we download and initialize the latest plugins.


STEP 3 OF 3
Nessus
Initializing
Please wait while Nessus prepares the files needed to scan your assets.
Downloading plugins...

Week 6 Topic 16

Nessus Features

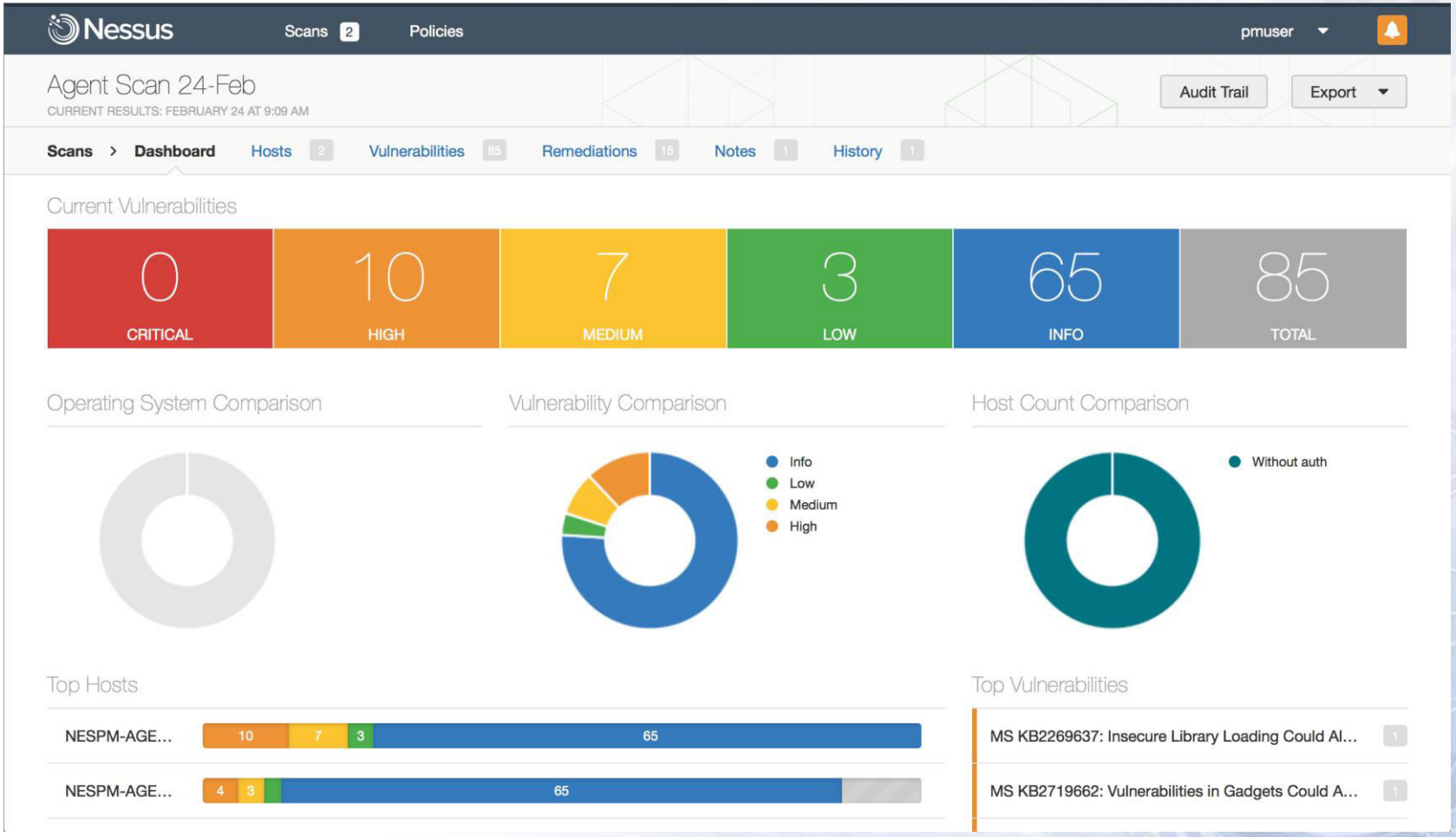
- **Nessus (Reports):**
  - Customize reports to sort by vulnerability or host
  - Create an executive summary or compare scan results
  - Targeted email notifications of scan results

- **Nessus (Scan Types):**
  - Asset discovery
  - Un-credentialed vulnerability discovery
  - Credentialed scanning for system hardening & missing patches

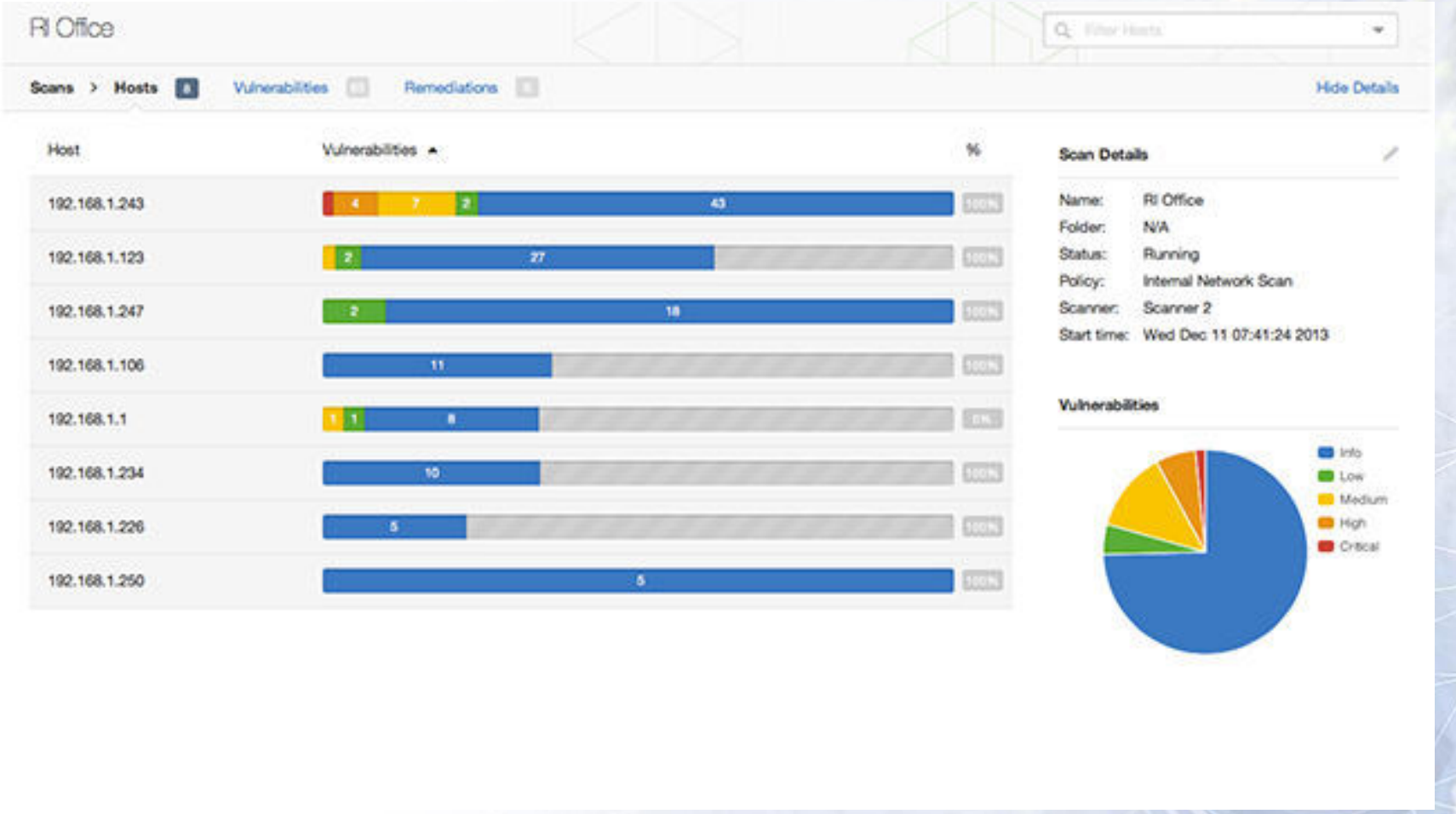
Nessus Features

- **Nessus (Compliance & Config Scans):**
  - Compliance auditing: FFIEC, FISMA, CyberScope, GLBA, HIPAA/ HITECH, NERC, PCI, SCAP, SOX
  - Configuration auditing: CERT, CIS, COBIT/ITIL, DISA STIGs, FDCC, ISO, NIST, NSA
- **Nessus (Risk scores):**
  - Vulnerability ranking based on CVE, five severity levels (Critical, High, Medium, Low, Info), customizable severity levels for recasting of risk

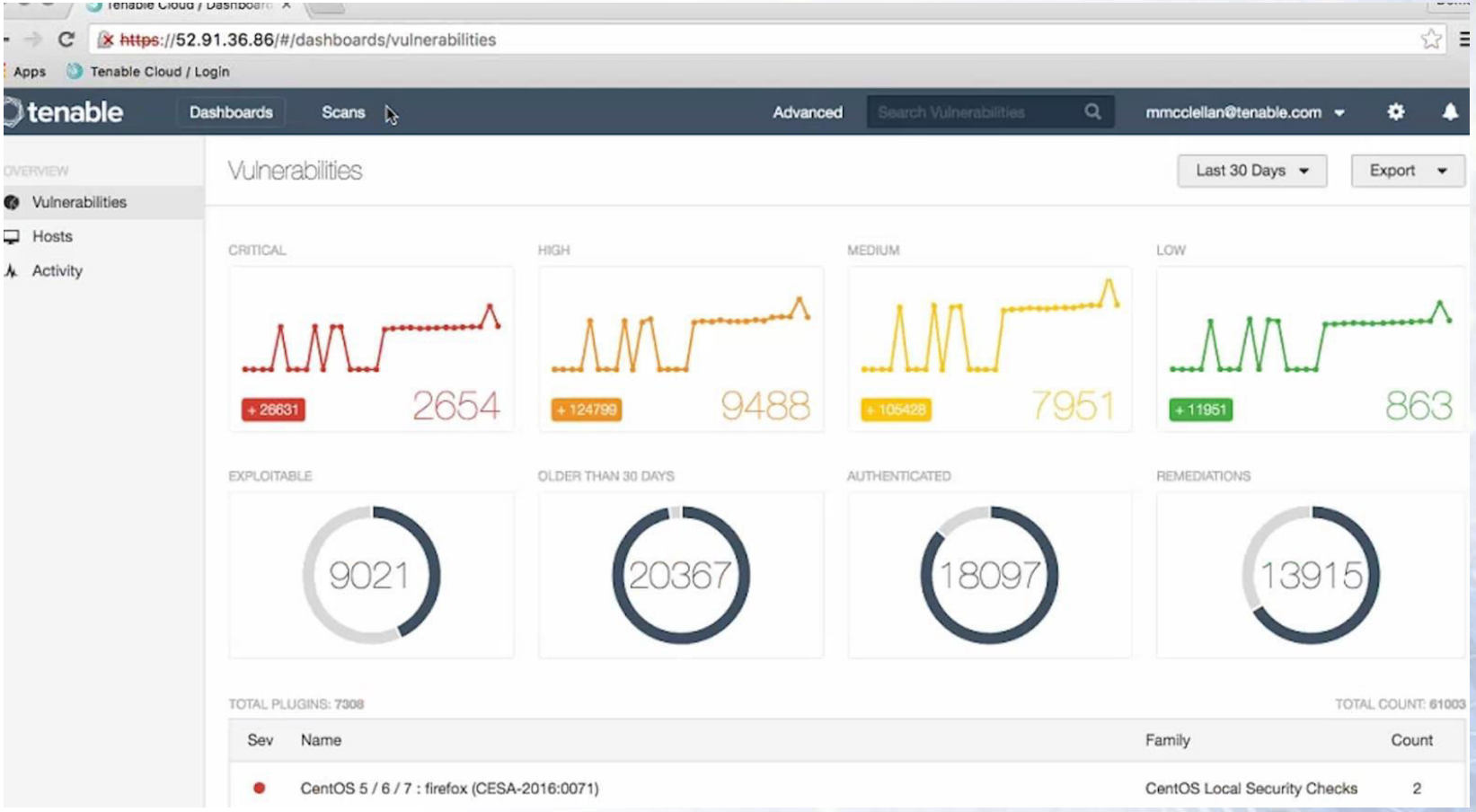
Nessus Features



Nessus Features



Nessus Features



- Nessus is a cost-effective scanner that gets most of the job done for vulnerability scanning
- It has CIS and DISA compliance templates

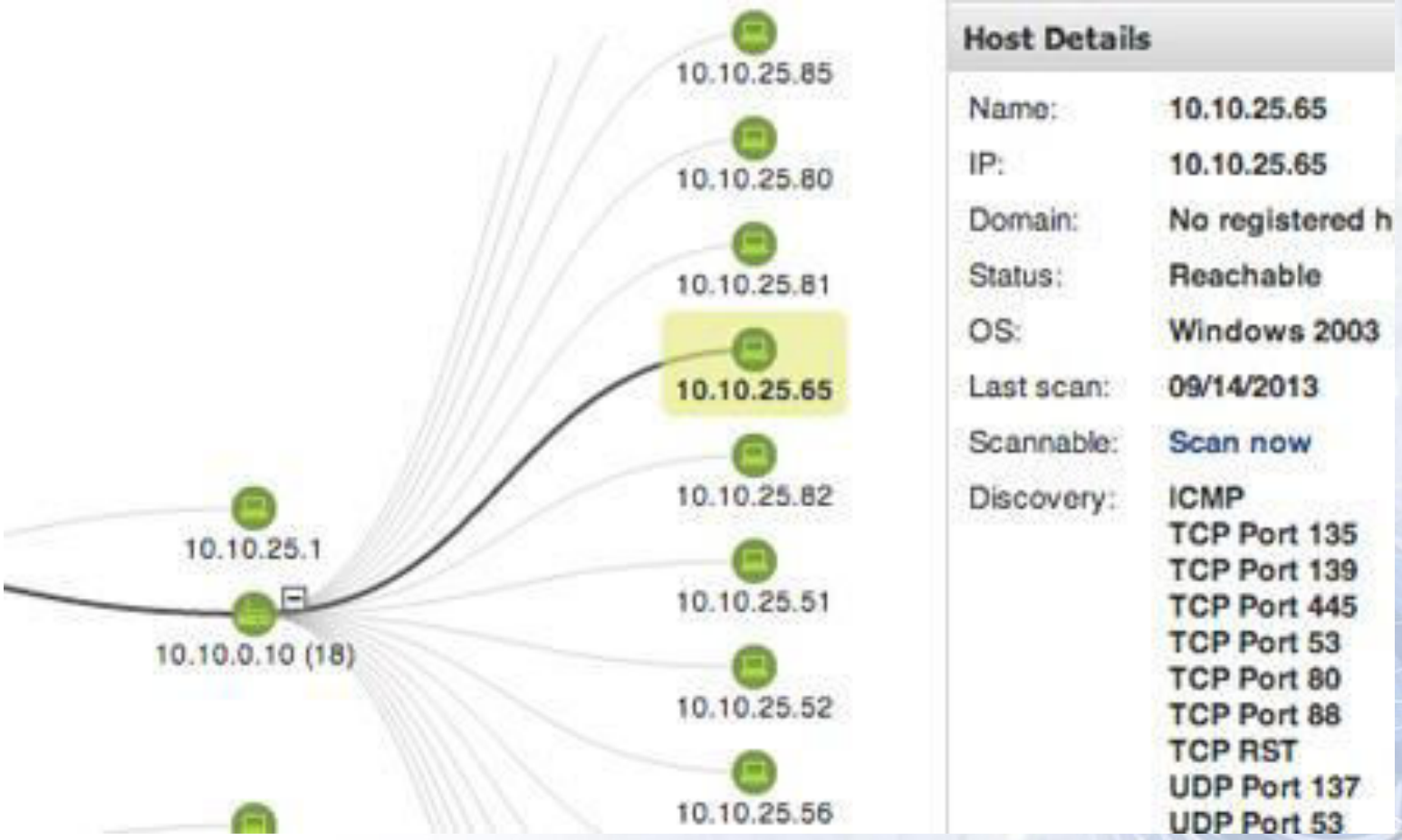
Week 6 Topic 17

Qualys Features

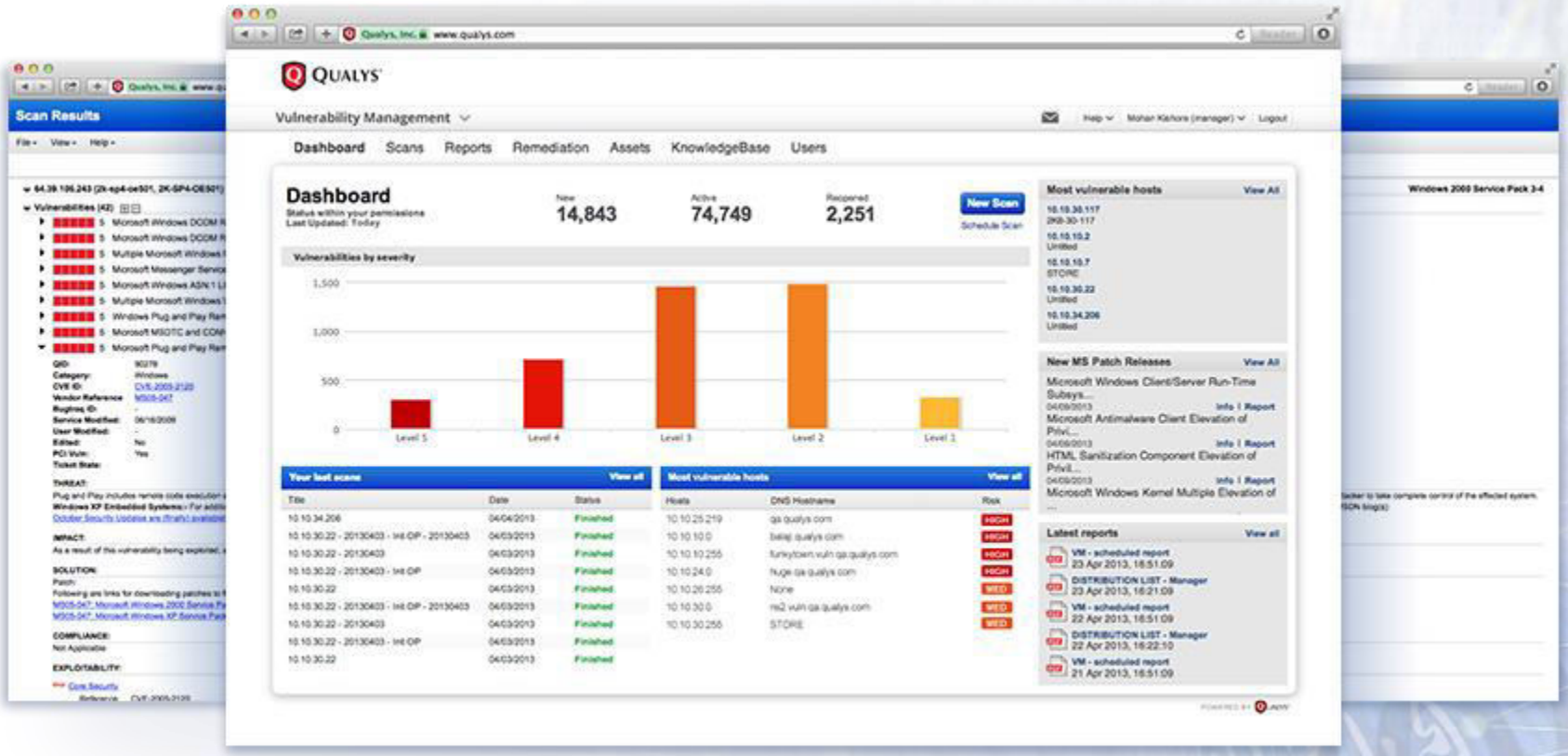
- **Qualys:**
  - Cloud-based service
  - On-premise device
  - Complete suite
  - Scalable and immediate deployment

- **Qualys:**
  - Asset discovery; find and organize hosts
  - Prioritize & manage remediation tickets
  - Continuous monitoring service
  - Policy compliance scanning
  - Qualys Secure Seal for websites

Qualys Features



Qualys Features



Qualys Features

Patch Report

ort Summary

pany: Qualys Training
ed by: Philip Niegos
ed on: 01/10/2014

Report Targets...

Total Patches	Hosts Requiring Patches	Vulnerabilities Addressed
149	14	156

HOSTS

	DNS Name	NetBIOS	OS	Patche...
1.2...	centos5.lab.local		CentOS 5.10	41
1.2...	cisco.lab.local		Cisco IOS 12.2(13)ZH1, EA...	40
1.2...	centos6.lab.local		CentOS 6.4	16
1.2...	windows8_1.lab.local	WINDOWS8...	Windows 8.1 Enterprise	10
1.2...	ws2k8r2.lab.local	WS2K8R2	Windows Server 2008 R2 E...	9
1.2...	winserver2012.lab.lo...	WINSERVE...	Windows Server 2012 Stand...	7
1.2...	vistax64.lab.local	VISTAX64	Windows Vista 64 bit Editio...	6
1.2...	win7x64.lab.local	WIN7X64	Windows 7 Ultimate 64 bit ...	5

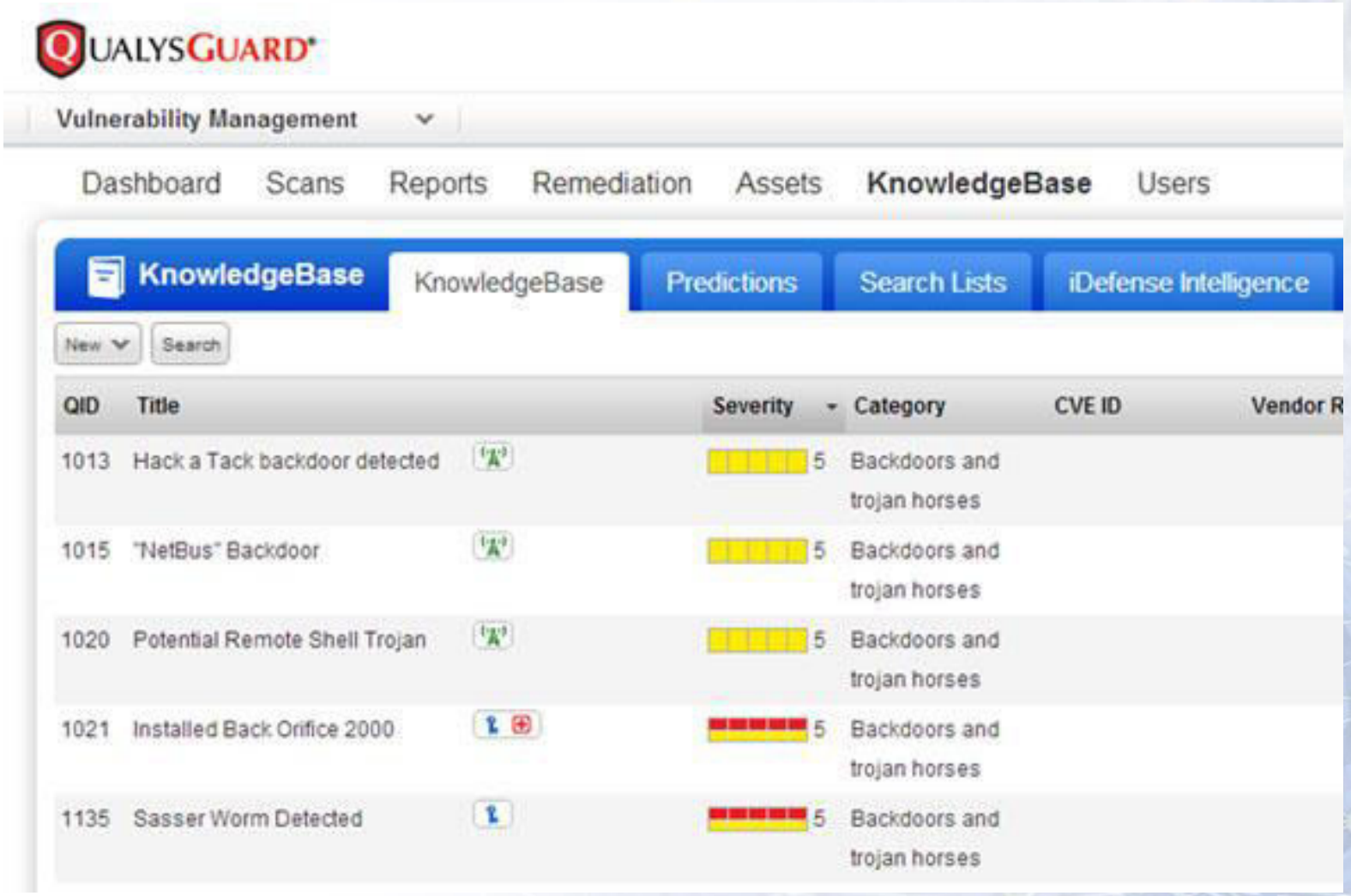
Page 1 of 1 | Filter | 1 - 14 of 14

PATCHES required on '192.168.1.211' (41)

Vendor ID	Sev.	Title	Published
Apache1.3, A...	3	Apache 1.3 and 2.0 Web Server Multiple ...	6 years ago
FEDORA-200...	3	APR-util Library Integer Overflow Vulnera...	4 years ago
Apache 2.2.15	4	Apache HTTP Server Prior to 2.2.15 Multi...	3 years ago
Tomcat5, To...	3	Apache Tomcat Directory Traversal Weak...	3 years ago
Apache Tomc...	3	Apache Tomcat Servlet Host Manager Ser...	5 years ago
Apache Tomc...	3	Apache Tomcat 5 and 6 Host Manager W...	5 years ago
Tomcat4, To...	3	Apache Tomcat RequestDispatcher Infor...	5 years ago
Apache Tomc...	3	Apache Tomcat Java AJP Connector Invali...	4 years ago

Page 1 of 2 | Filter

Qualys Features



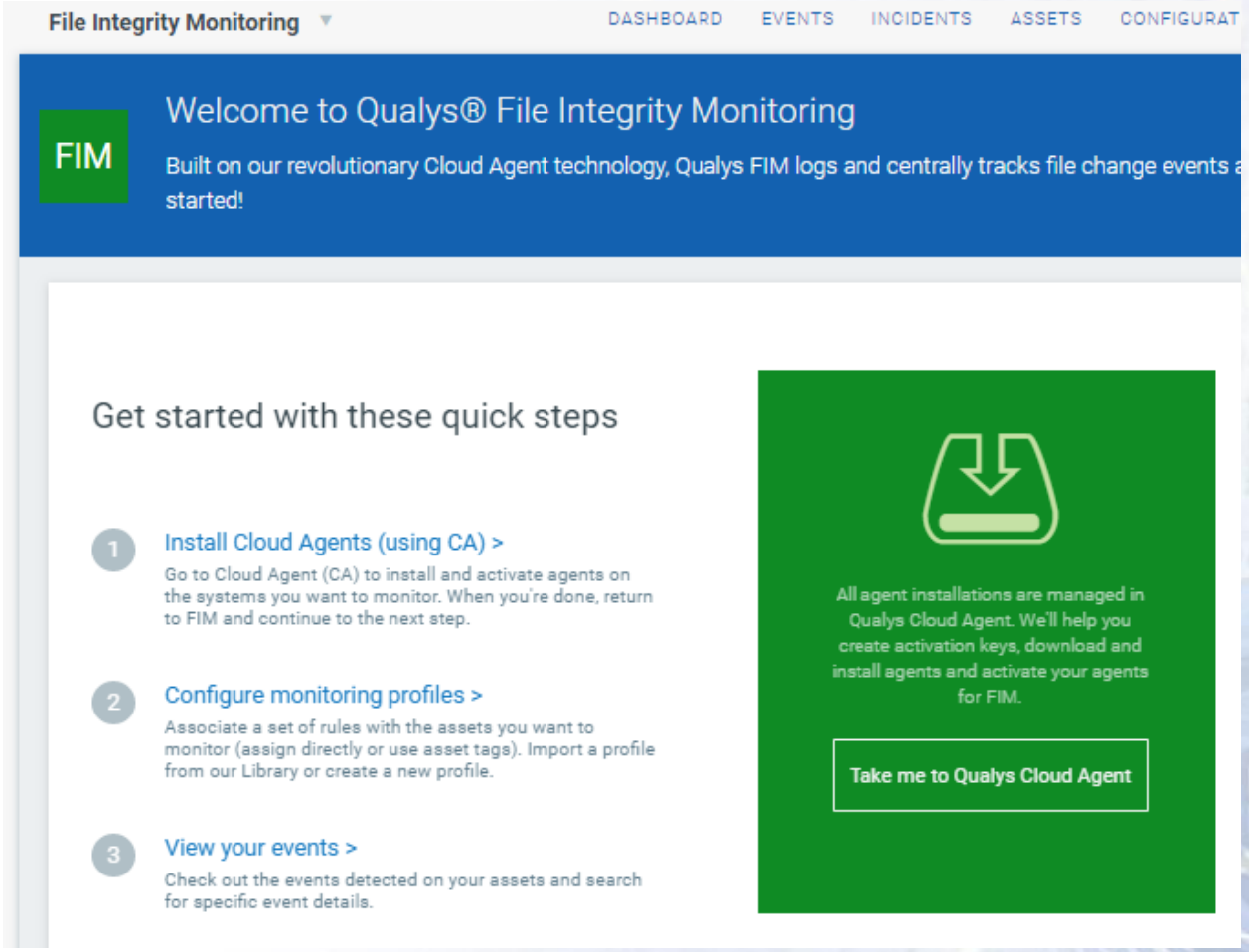
Qualys Features

Secure Seal

- A Secure Seal for websites refers to a visual indicator, such as a badge or logo, displayed on a website to indicate that the site has been verified and is secure.

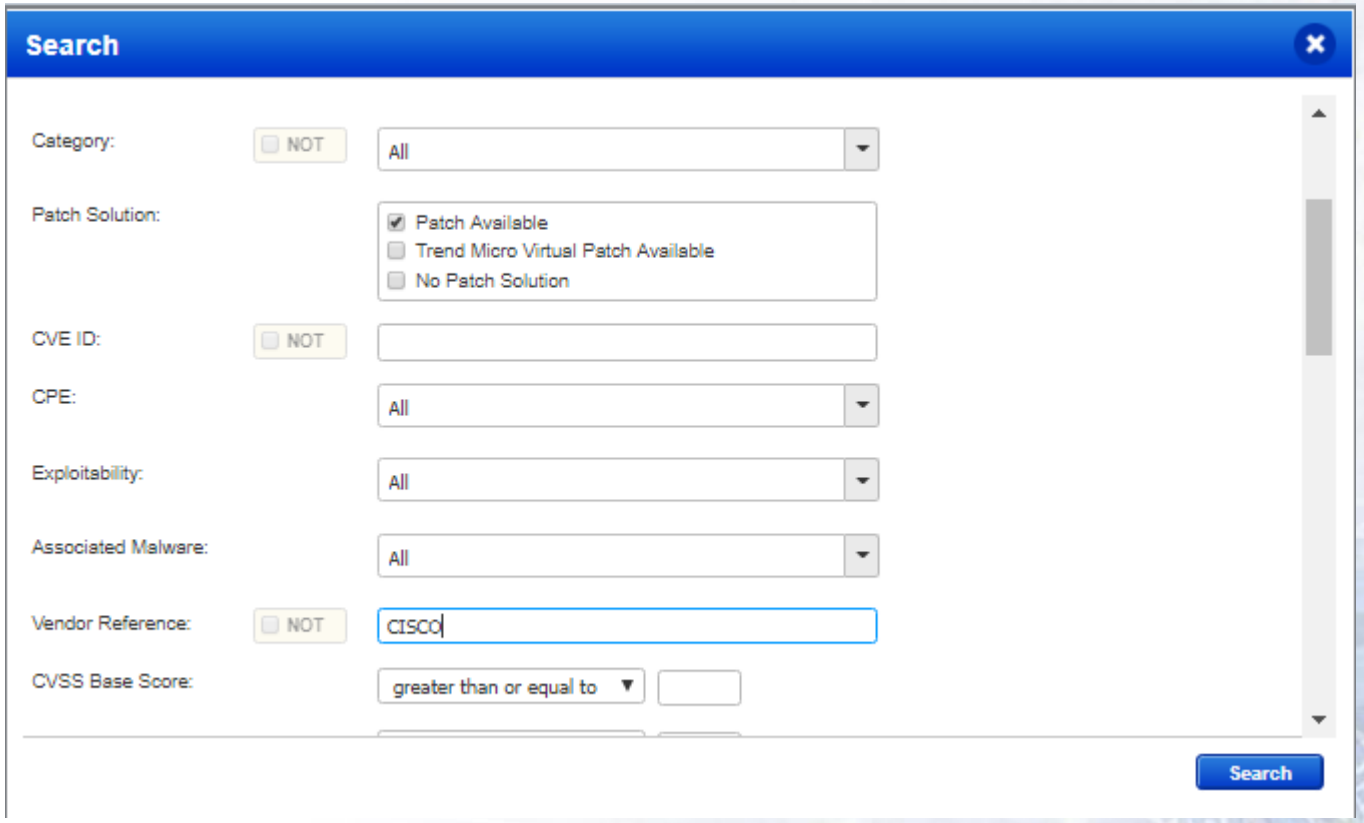
- The purpose of the secure seal is to assure visitors that the website is legitimate, trustworthy, and has taken measures to protect the privacy and security of their personal and financial information.

QUALYS FEATURES



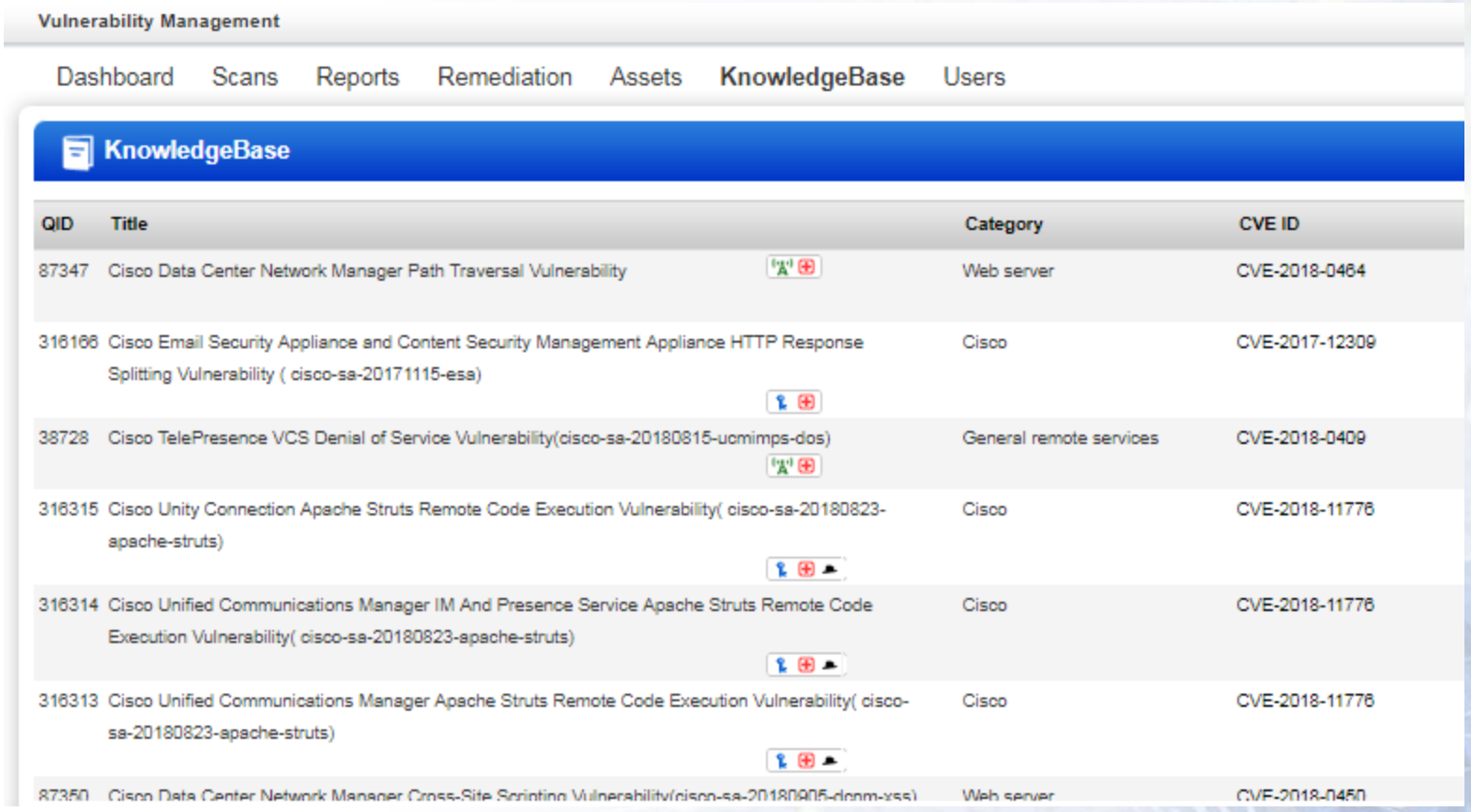
FILE INTEGRITY MONITORING

QUALYS FEATURES



SEARCH KNOWLEDGEBASE

QUALYS FEATURES



QID	Title	Category	CVE ID
87347	Cisco Data Center Network Manager Path Traversal Vulnerability	Web server	CVE-2018-0464
316166	Cisco Email Security Appliance and Content Security Management Appliance HTTP Response Splitting Vulnerability (cisco-sa-20171115-esa)	Cisco	CVE-2017-12309
38728	Cisco TelePresence VCS Denial of Service Vulnerability(cisco-sa-20180815-ucmimps-dos)	General remote services	CVE-2018-0409
316315	Cisco Unity Connection Apache Struts Remote Code Execution Vulnerability(cisco-sa-20180823-apache-struts)	Cisco	CVE-2018-11776
316314	Cisco Unified Communications Manager IM And Presence Service Apache Struts Remote Code Execution Vulnerability(cisco-sa-20180823-apache-struts)	Cisco	CVE-2018-11776
316313	Cisco Unified Communications Manager Apache Struts Remote Code Execution Vulnerability(cisco-sa-20180823-apache-struts)	Cisco	CVE-2018-11776
87350	Cisco Data Center Network Manager Cross-Site Scripting Vulnerability(cisco-sa-20180906-dcnm-xss)	Web server	CVE-2018-0450

CISCO VULNERABILITIES – PATCH AVAILABLE

Qualys Features

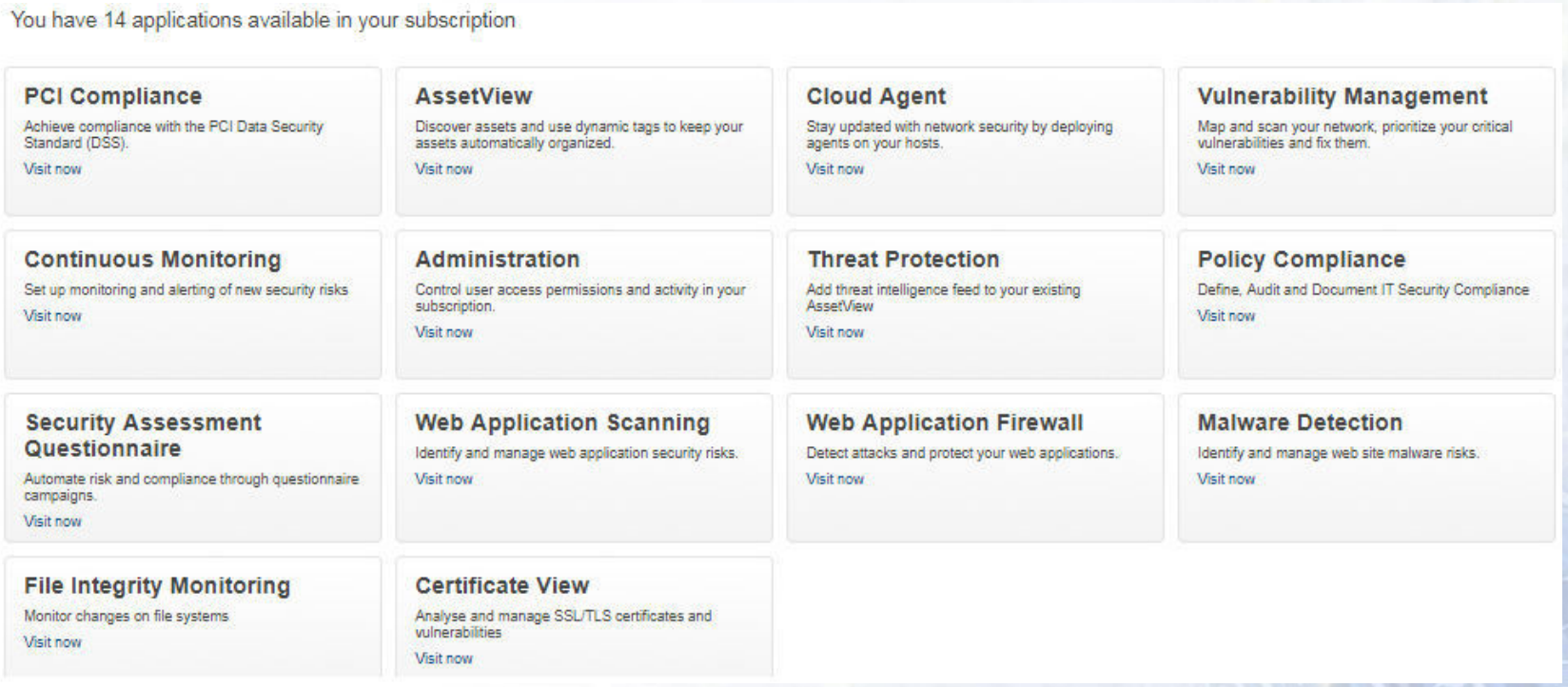
- **Qualys:**
  - Website scanning
  - Annual subscription service model
  - Qualys is a convenient and scalable VM tool that comes with several modules
  - Several advantages due to cloud-based service

Week 6 Topic 18

QUALYS DEMO - PART 2

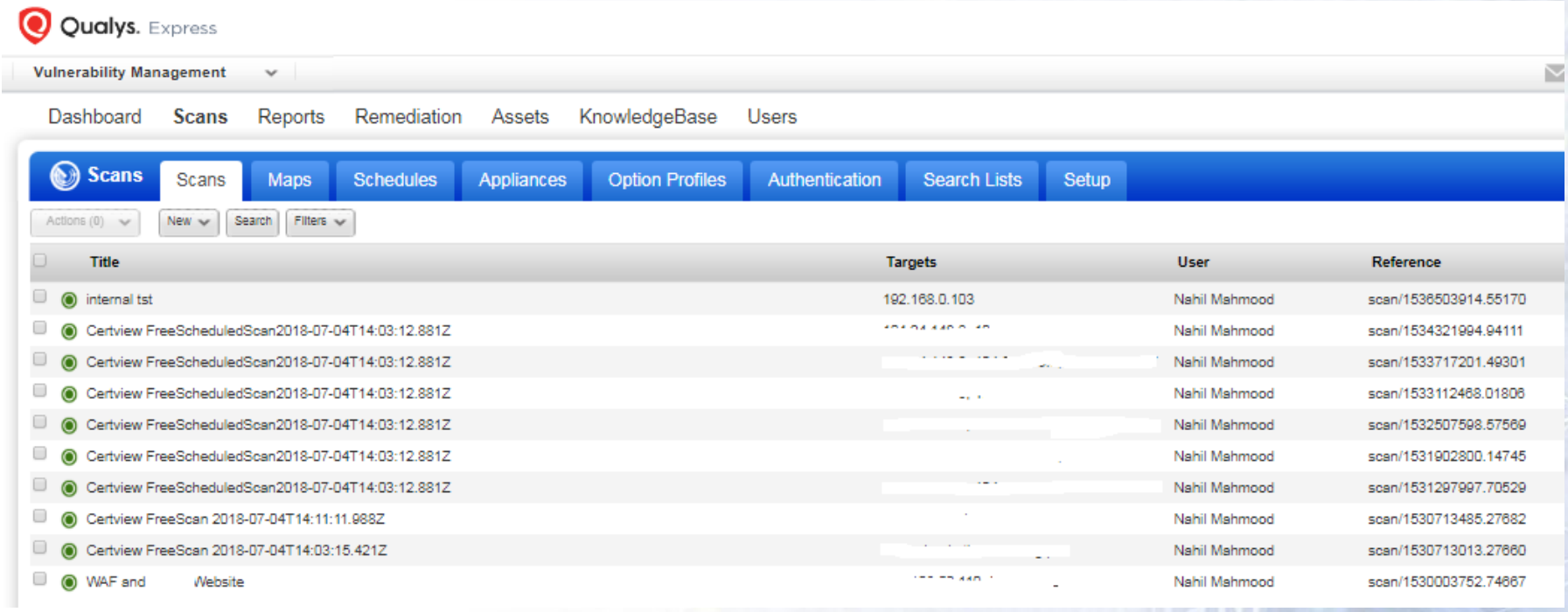
Week 6 Topic 18

QUALYS DEMO - PART 2



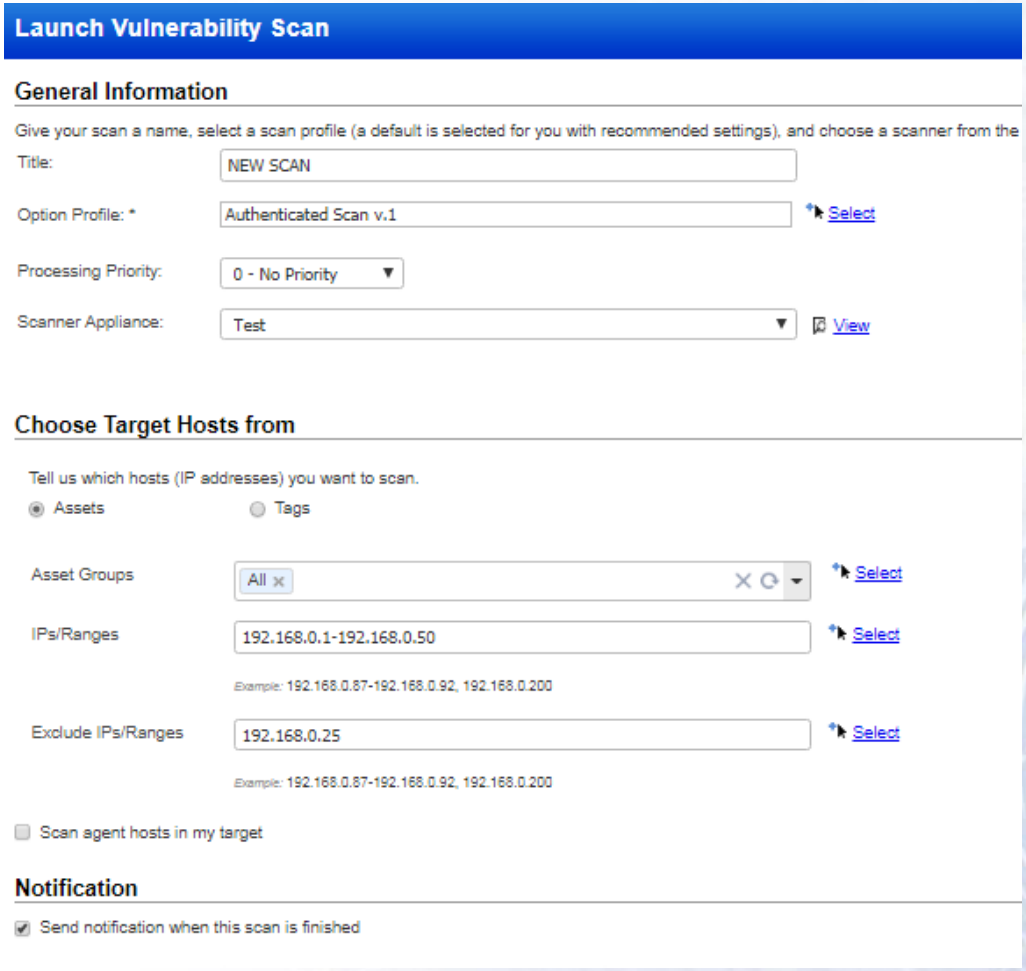
QUALYS
14 APPLICATIONS

QUALYS DEMO - PART 2



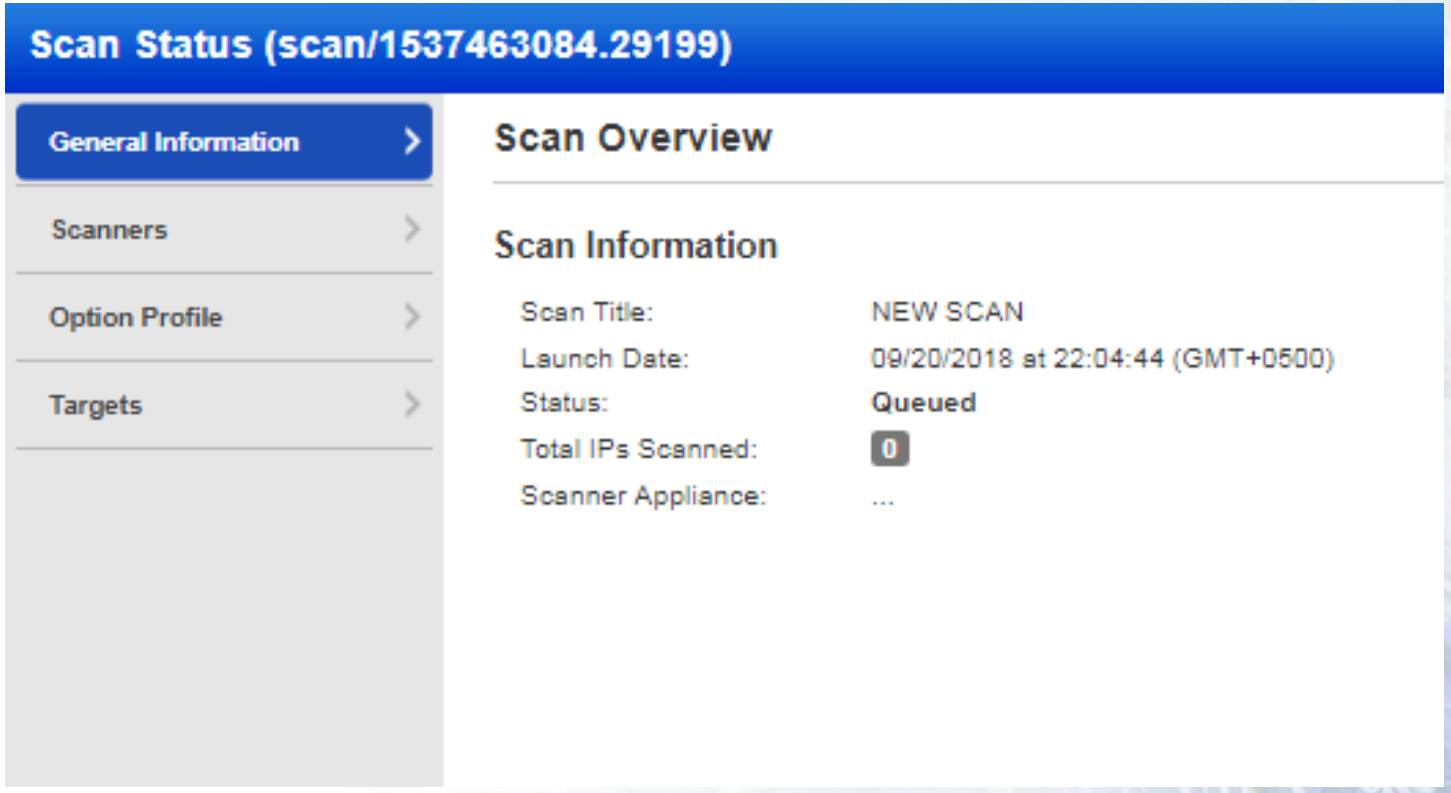
VULNERABILITY MANAGEMENT DASHBOARD

QUALYS DEMO - PART 2



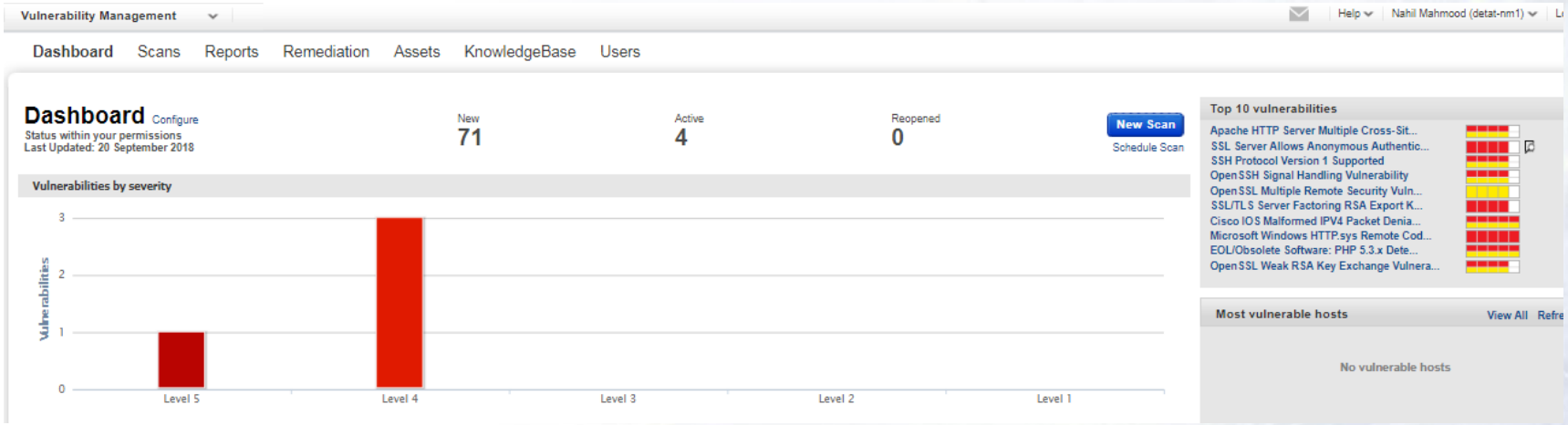
LAUNCH VULNERABILITY SCAN

QUALYS DEMO - PART 2



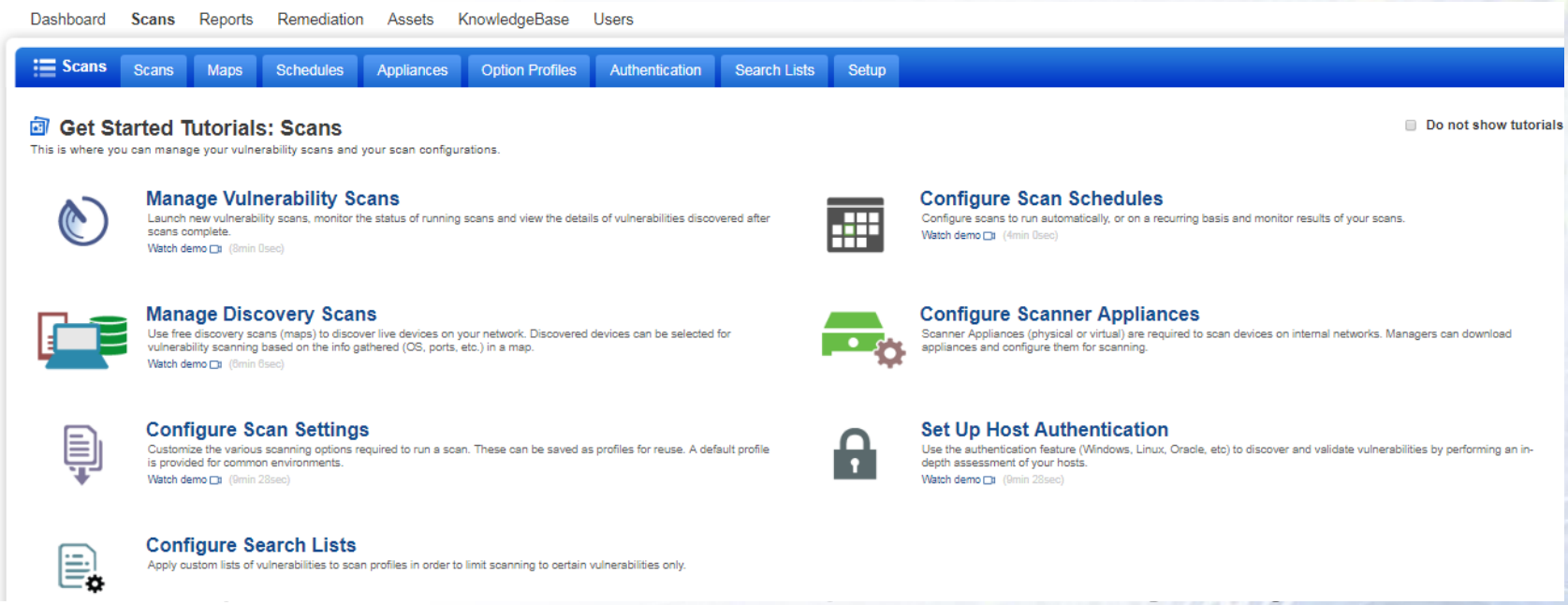
SCAN INITIATED

QUALYS DEMO - PART 2



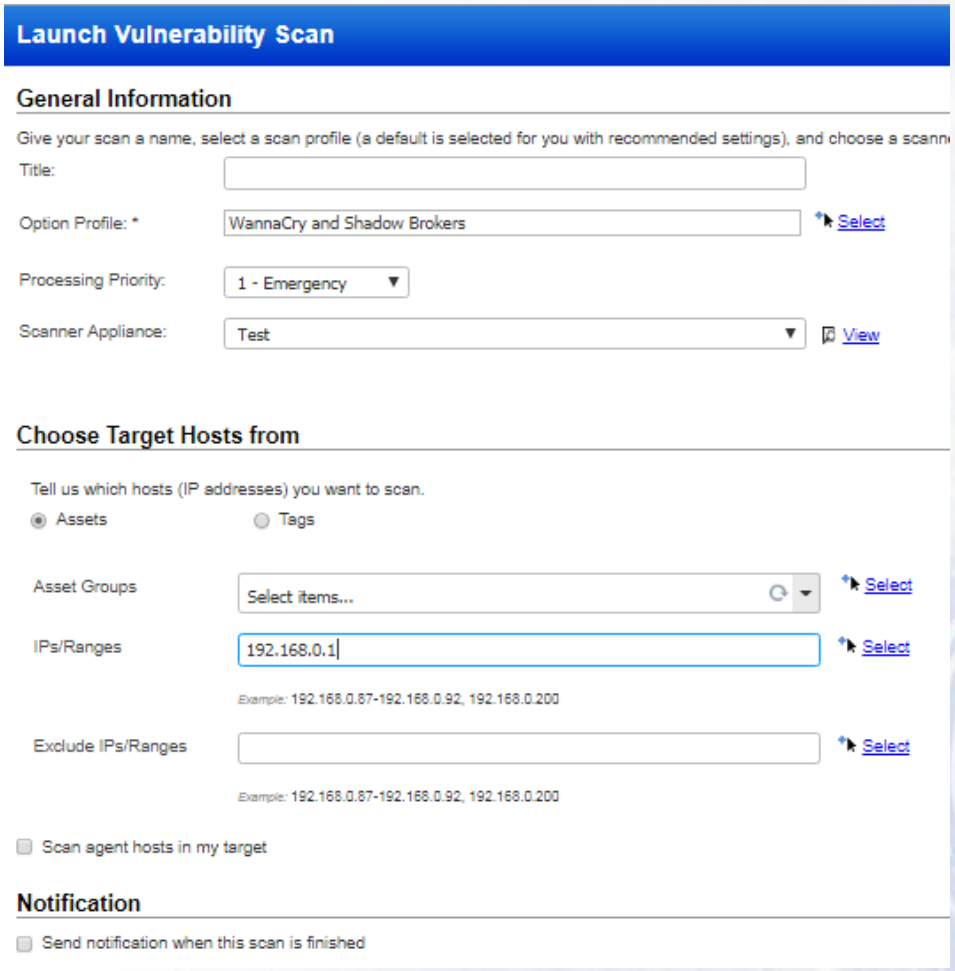
VULNERABILITY MANAGEMENT DASHBOARD

QUALYS DEMO - PART 2



SCAN TUTORIALS

QUALYS DEMO - PART 2

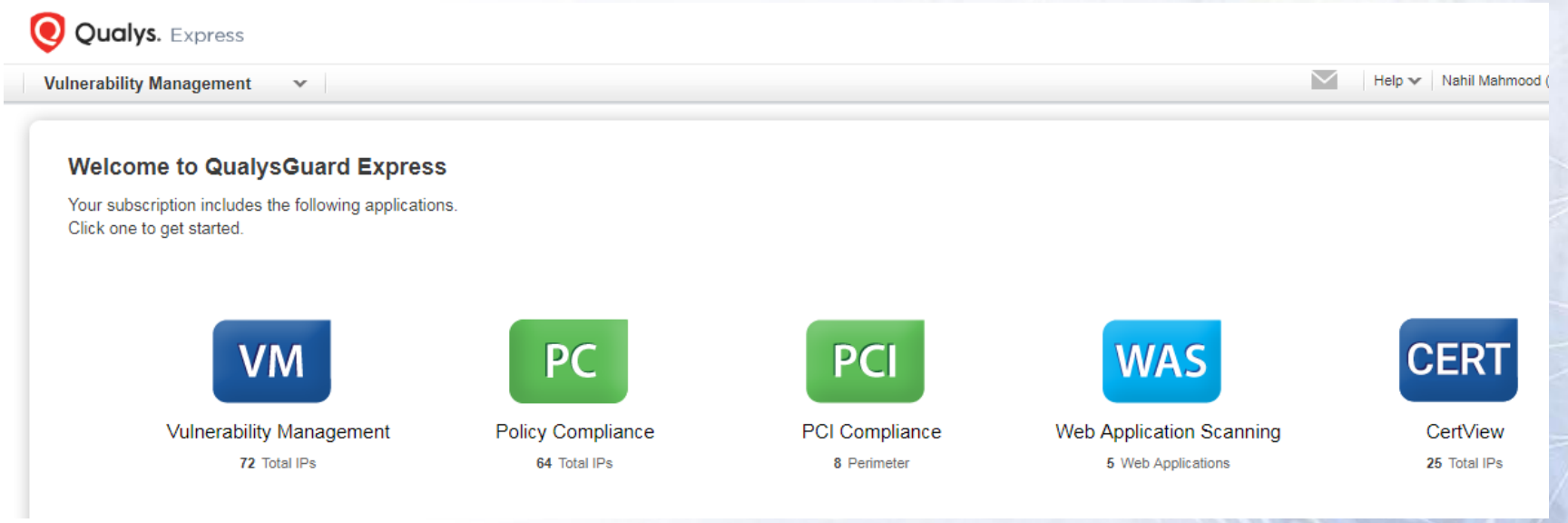


WANNACRY & SHADOW BROKERS SCAN

Week 6 Topic 19

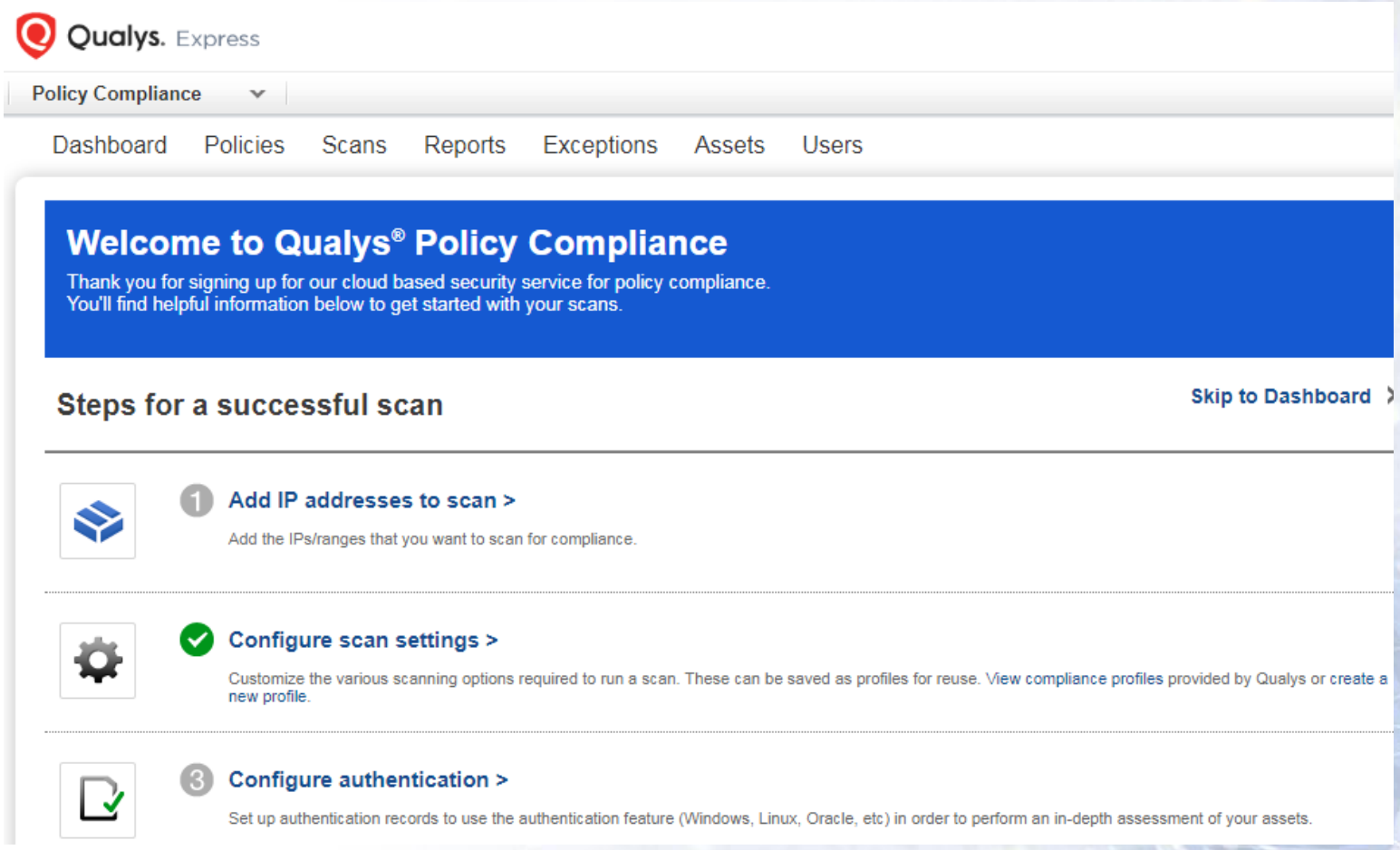
QUALYS DEMO – SECURITY HARDENING

Lets have a look at how Qualys can aid in the security hardening process.



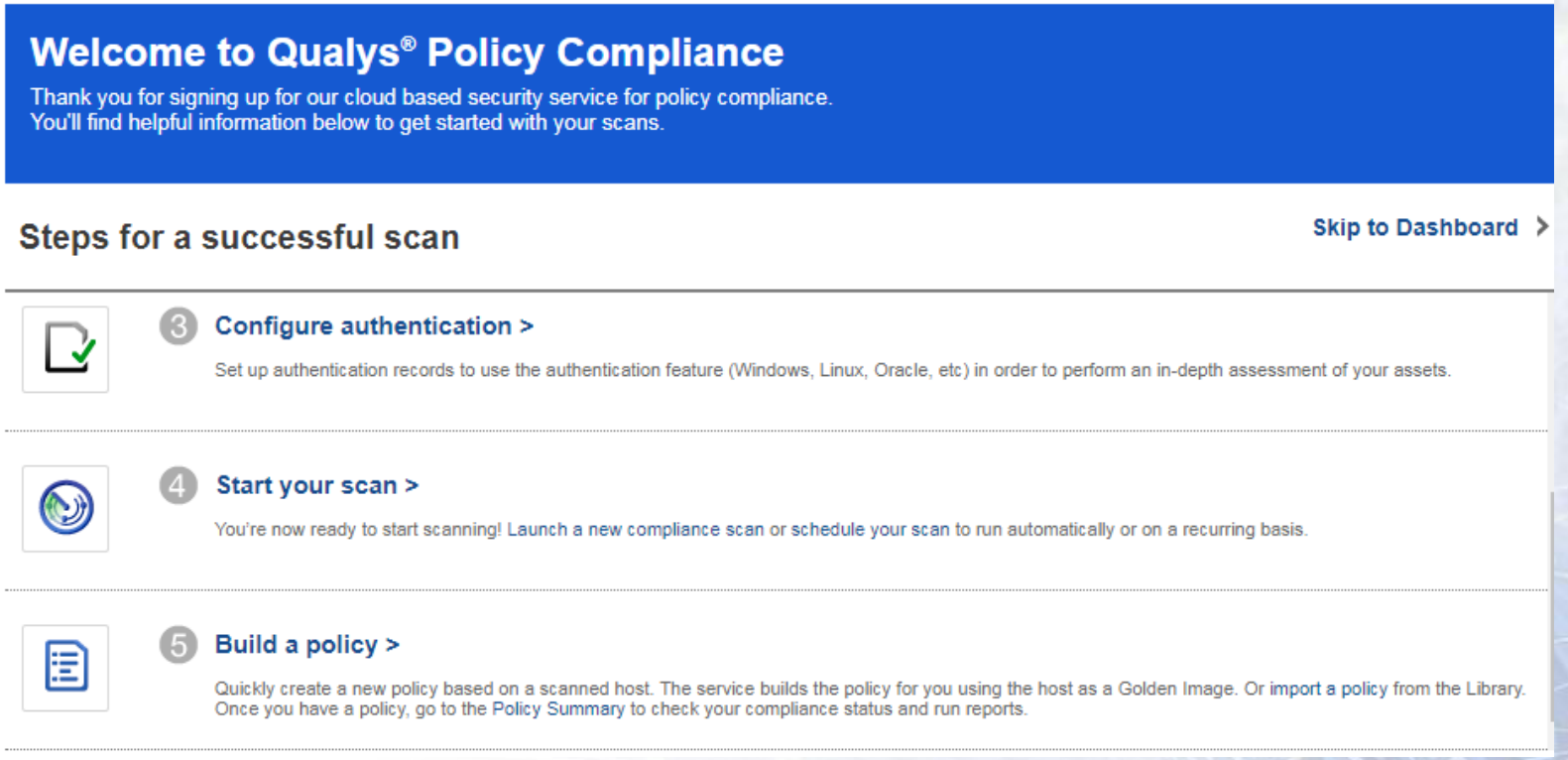
QUALYS GUARD – HOME SCREEN

QUALYS DEMO – SECURITY HARDENING



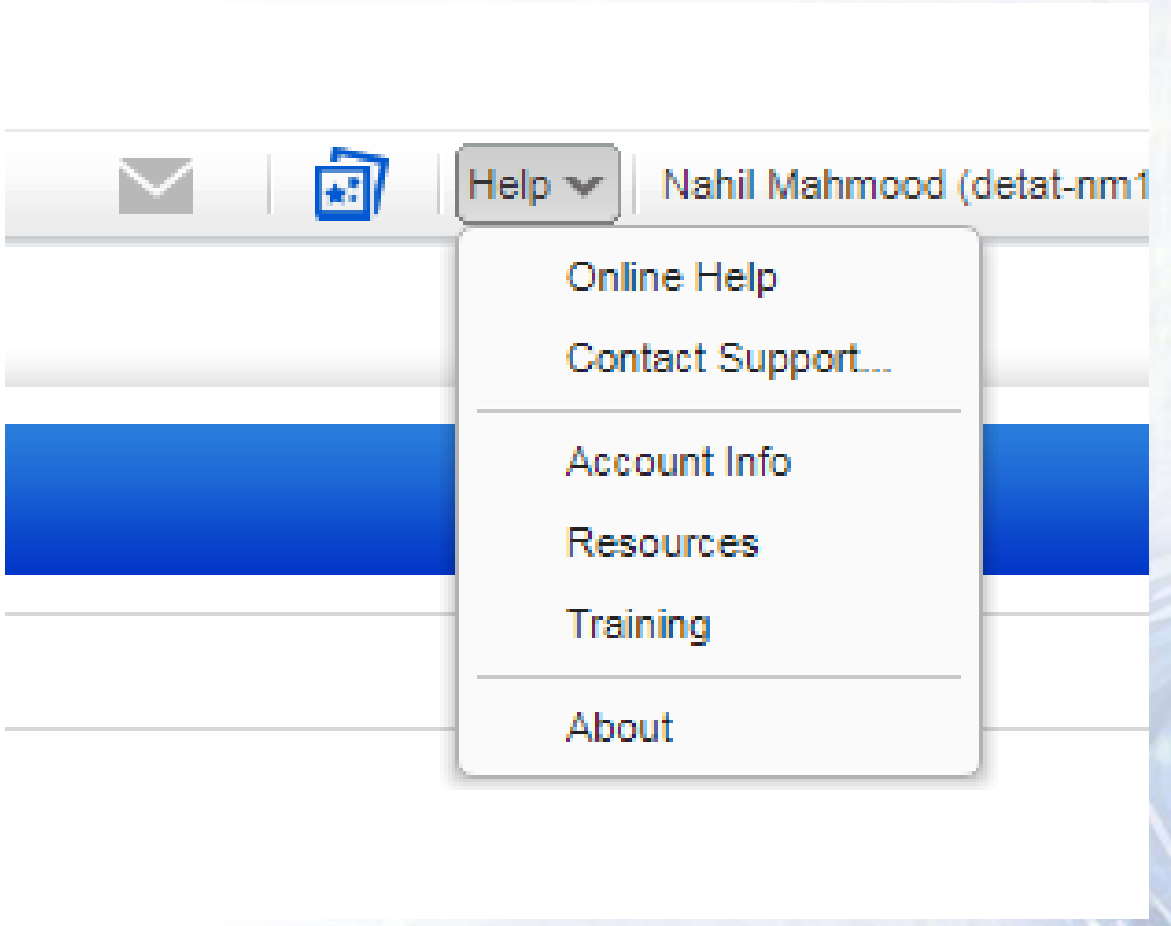
POLICY COMPLIANCE – HOME SCREEN

QUALYS DEMO – SECURITY HARDENING



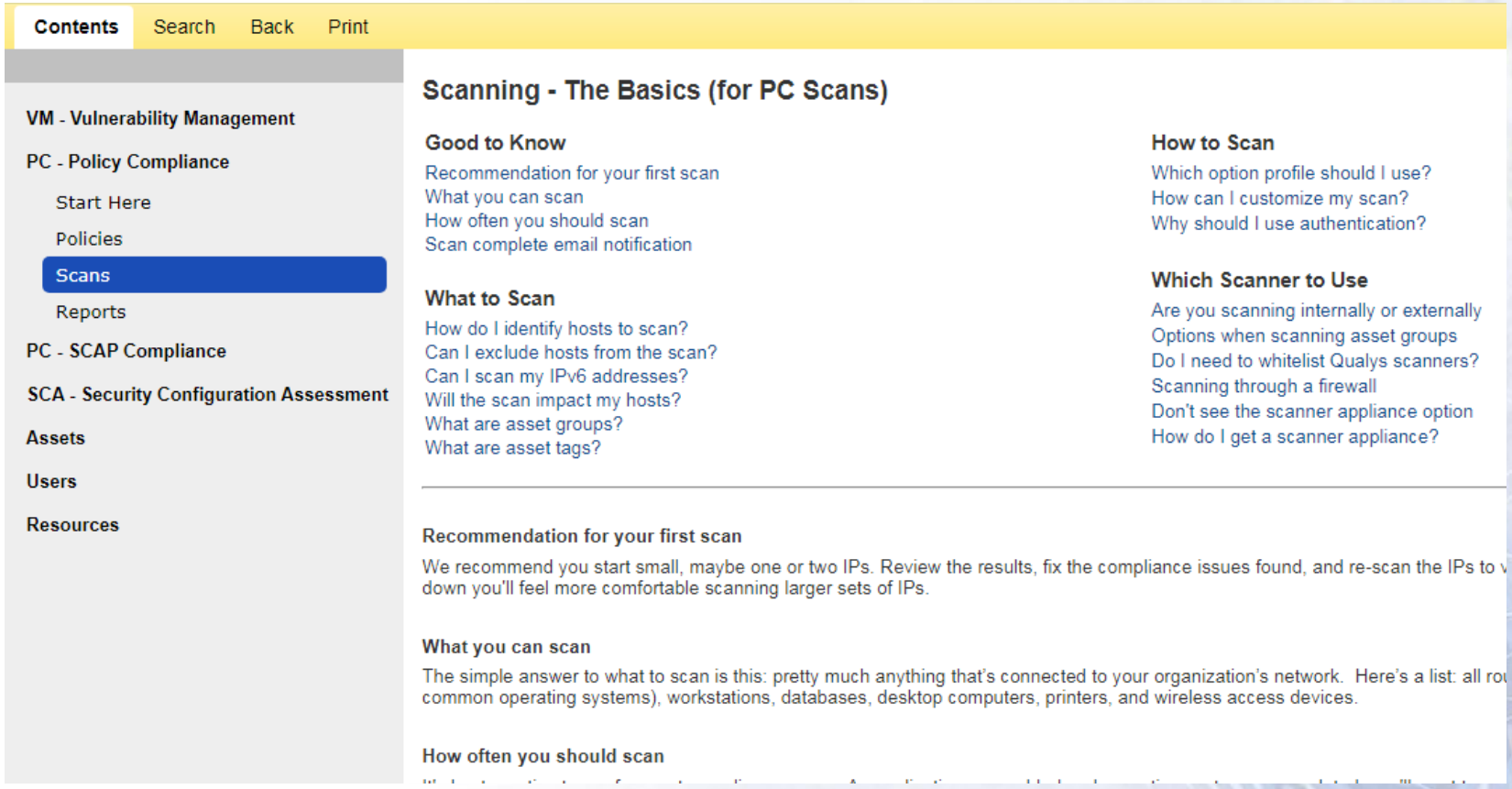
POLICY COMPLIANCE – 5 STEPS

QUALYS DEMO – SECURITY HARDENING



HELP OPTIONS

QUALYS DEMO – SECURITY HARDENING



ONLINE HELP – POLICY COMPLIANCE

QUALYS DEMO – SECURITY HARDENING

Resources

Look to these resources to help you with our cloud security and compliance solutions.

Get Started

Quick Tour
Evaluator's Guide
Community Edition
Securing Amazon Web Services with Qualys

Watch Videos

VM | PC | WAS | WAF | AWS EC2 | Express Lite | More Videos

Get started with your applications

CloudView
Container Security
Indication of Compromise
Web Application Scanning
- Crawling REST services using WAS
- Jenkins Plugin for WAS: user guide | download
- Qualys Browser Recorder: user guide | download
Web Application Firewall
Policy Compliance
SCAP Compliance
Security Configuration Assessment
PCI Compliance
File Integrity Monitoring

Scan Authentication

Get system and account requirements for supported technologies below.

Cloud Agents

Cloud Agent Getting Started Guide
Windows Installation Guide
Linux Installation Guide
Unix Installation Guide
Mac Installation Guide

Using a scanner appliance?

Scanner Appliance User Guide
Scanner Appliance Quick Start (prior version)
Virtual Scanner Appliance User Guide
Offline Scanner Appliance User Guide
Consultant Scanner Personal Edition User Guide
Cloud Platforms: AWS | Azure | GCE | OpenStack
Qualys Scanner - Static Route Configuration
Qualys Scanner - VLAN Scanning Guide
Scanner Appliance FAQs

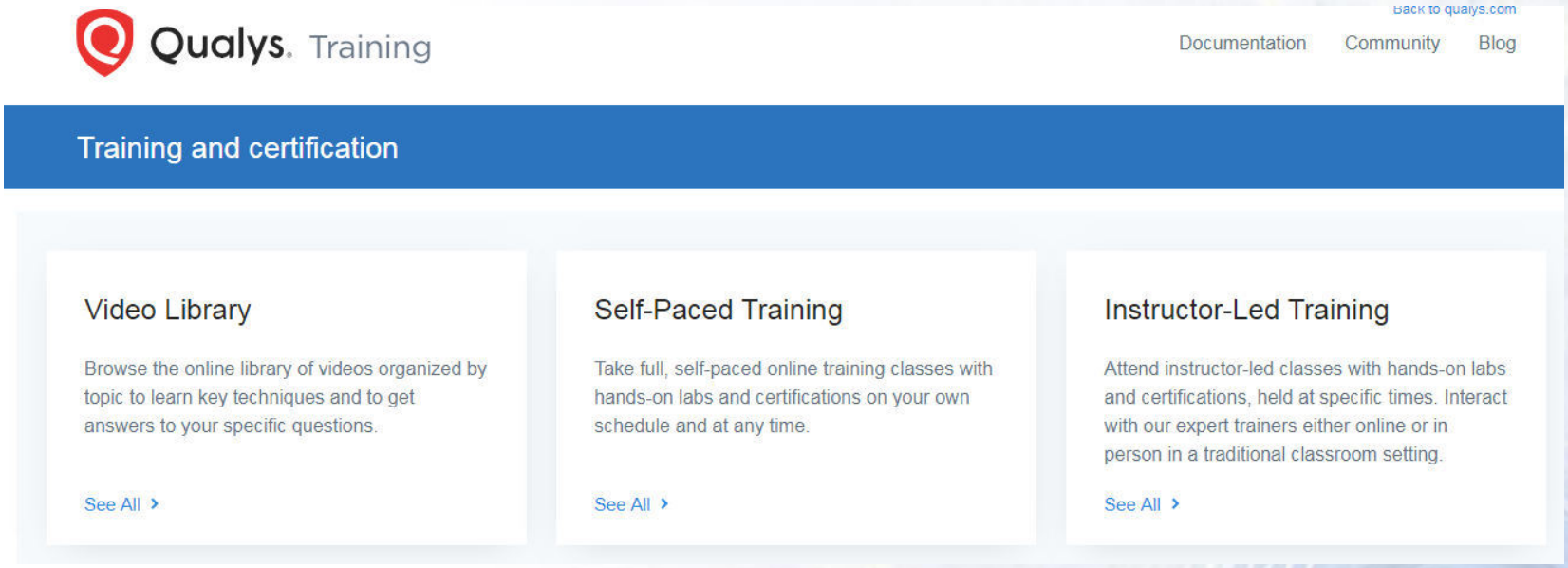
API Documentation

Qualys API Quick Reference for all APIs
Qualys API (VM, SCA, PC)

Cloud Agent (CA) API
Web Application Scanning (WAS) API
Web Application Firewall (WAF) API
Malware Detection (MD) API

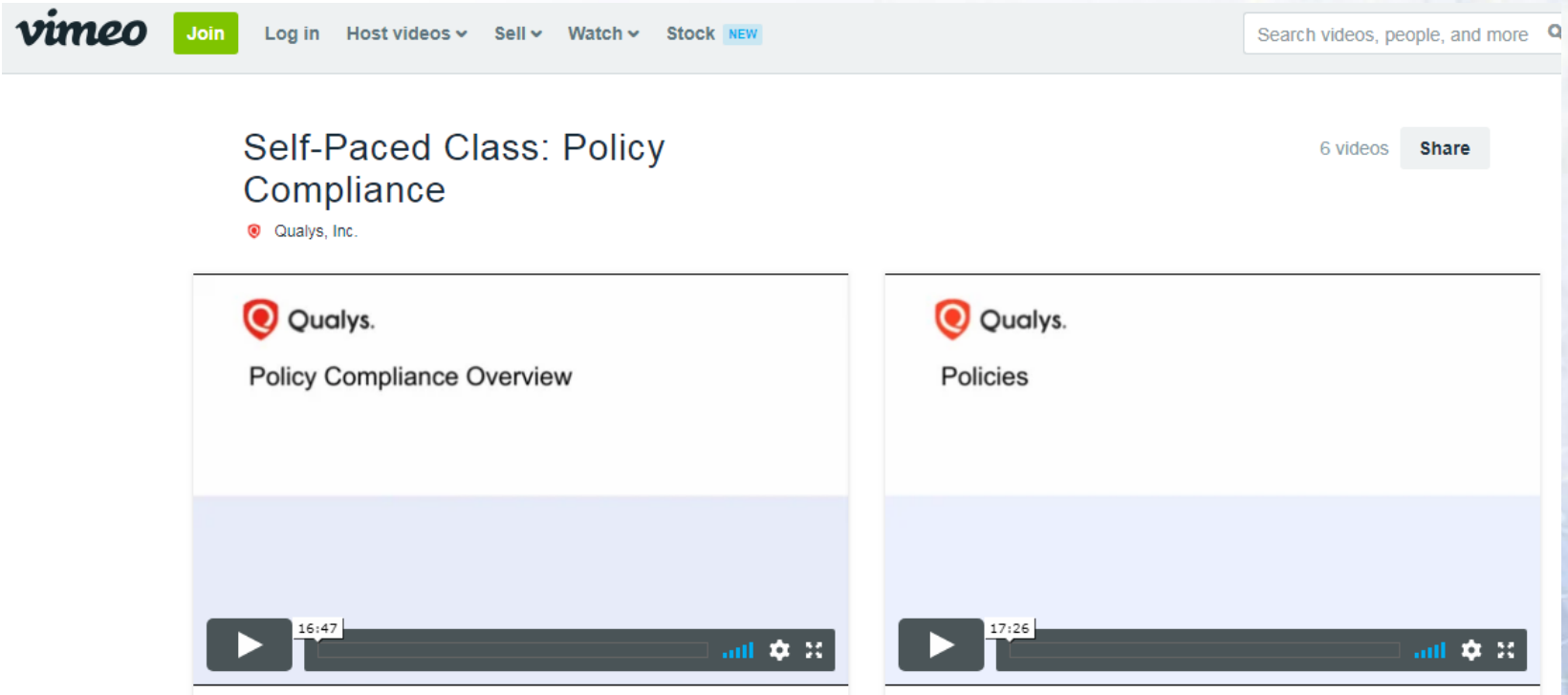
RESOURCES

QUALYS DEMO – SECURITY HARDENING



QUALYS WEBSITE - TRAINING

QUALYS DEMO – SECURITY HARDENING



TRAINING VIDEOS - VIMEO

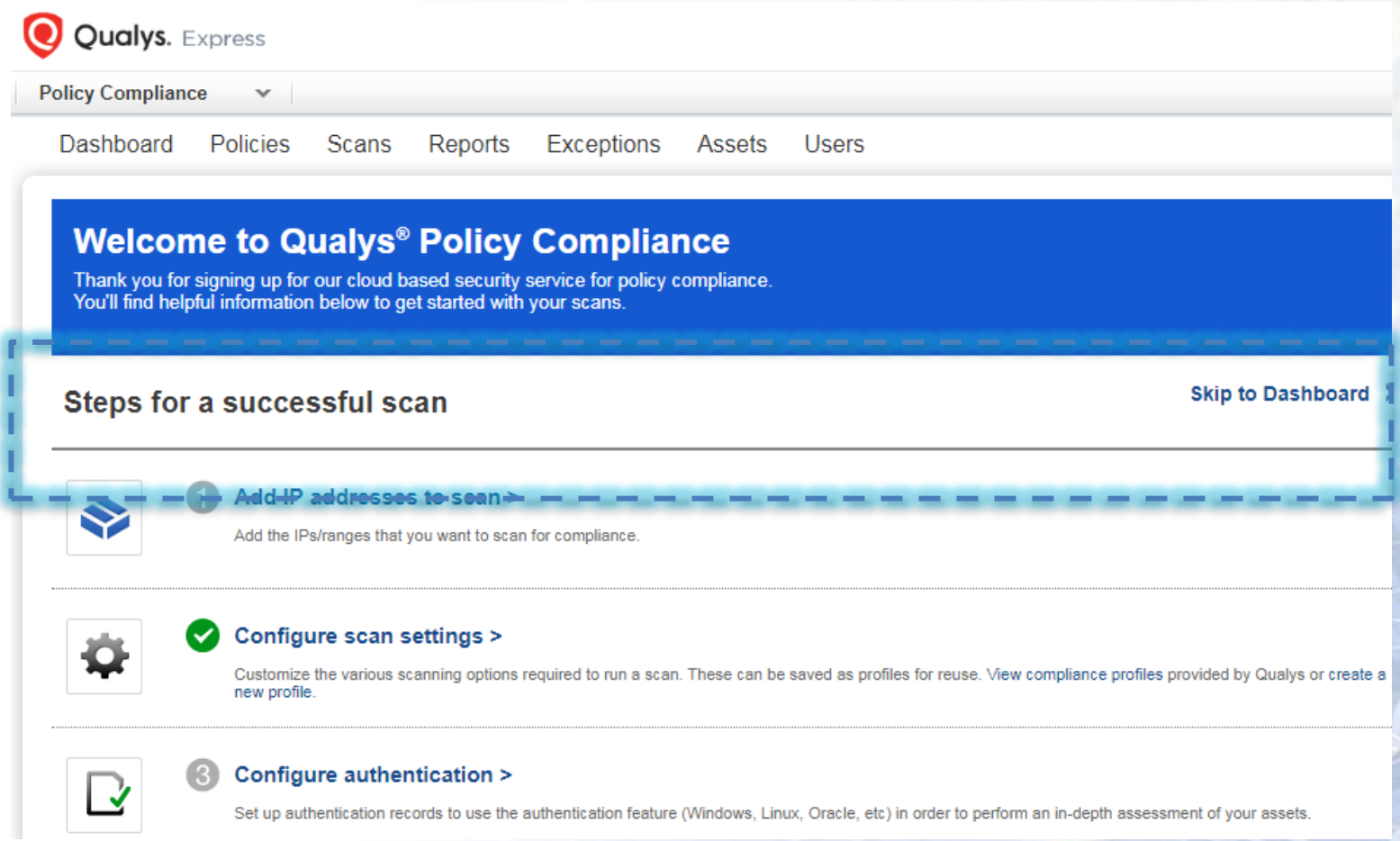
QUALYS DEMO – SECURITY HARDENING

- Qualys is an excellent tool with detailed online help, training, and resources to aid the new user

END

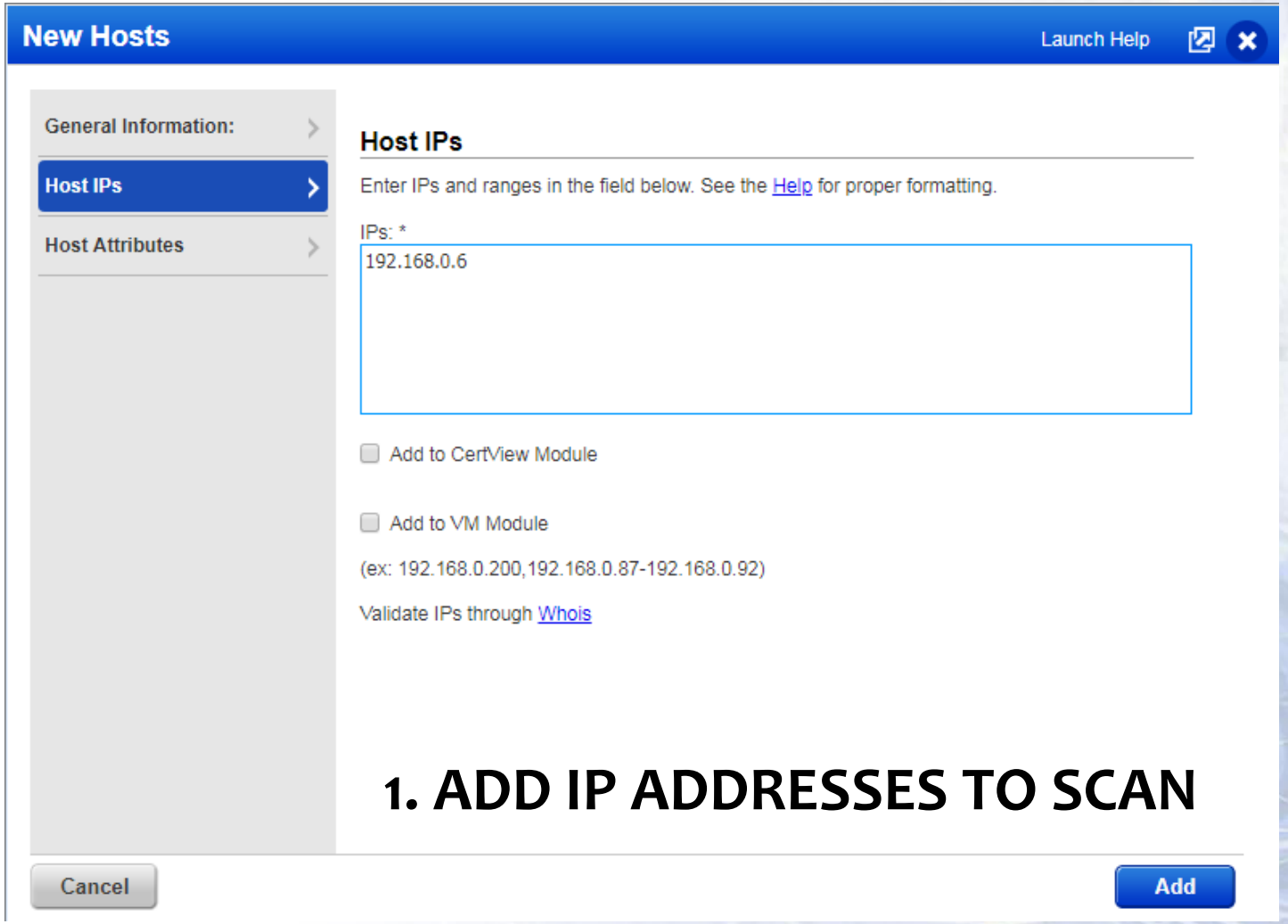
Week 6 Topic 20

QUALYS DEMO – SECURITY HARDENING II

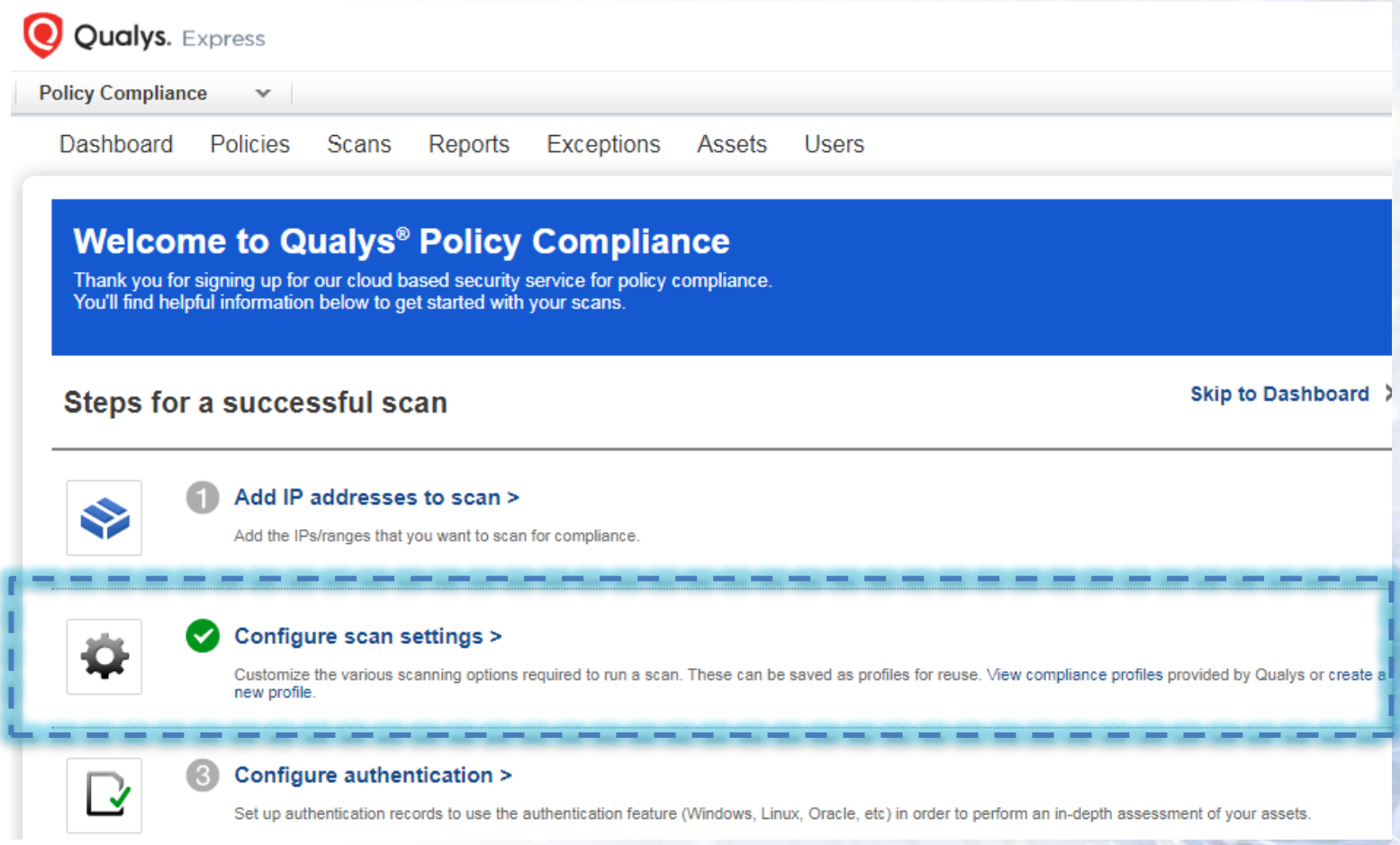


1. ADD IP ADDRESSES TO SCAN

QUALYS DEMO – SECURITY HARDENING

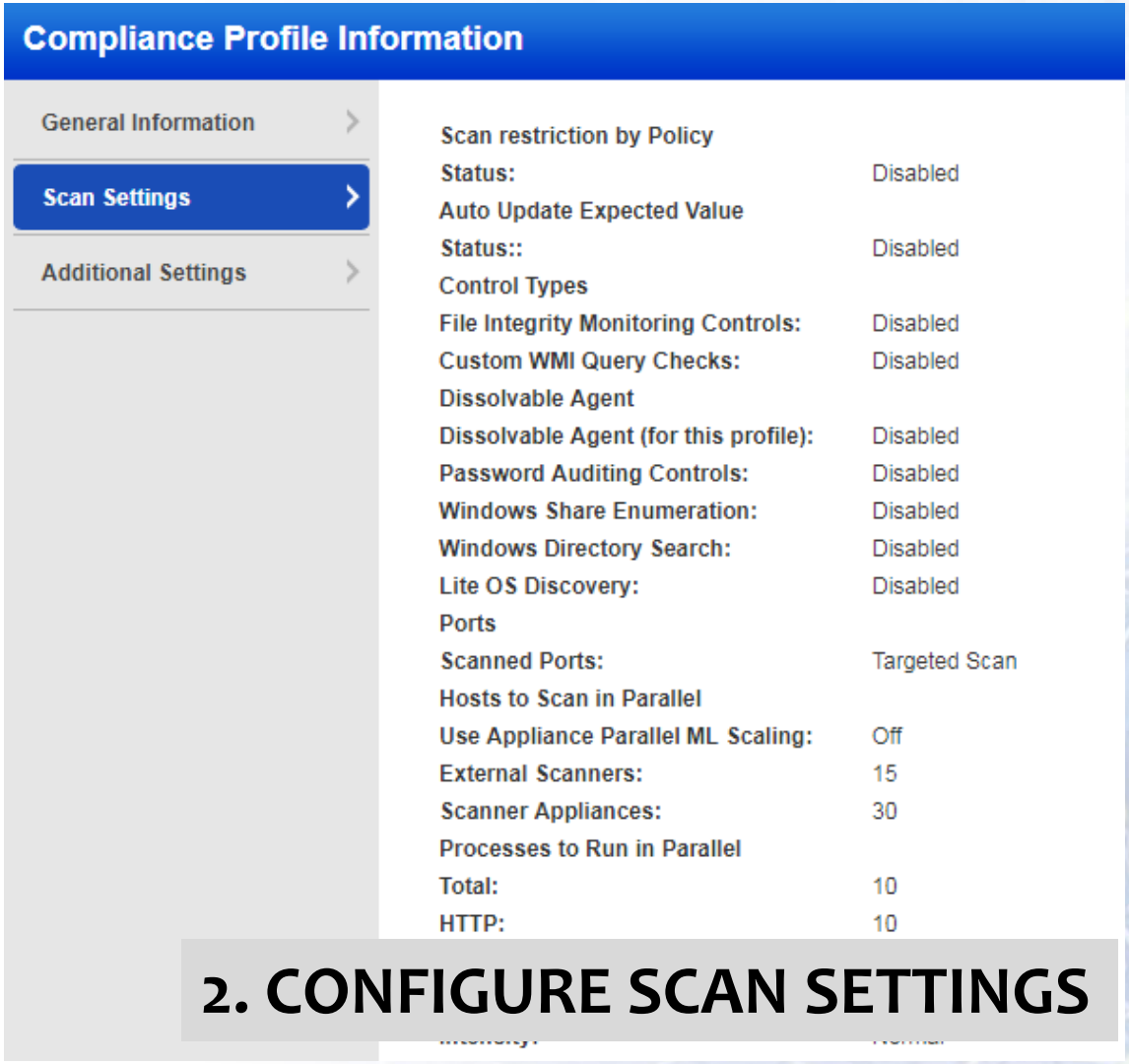


QUALYS DEMO – SECURITY HARDENING



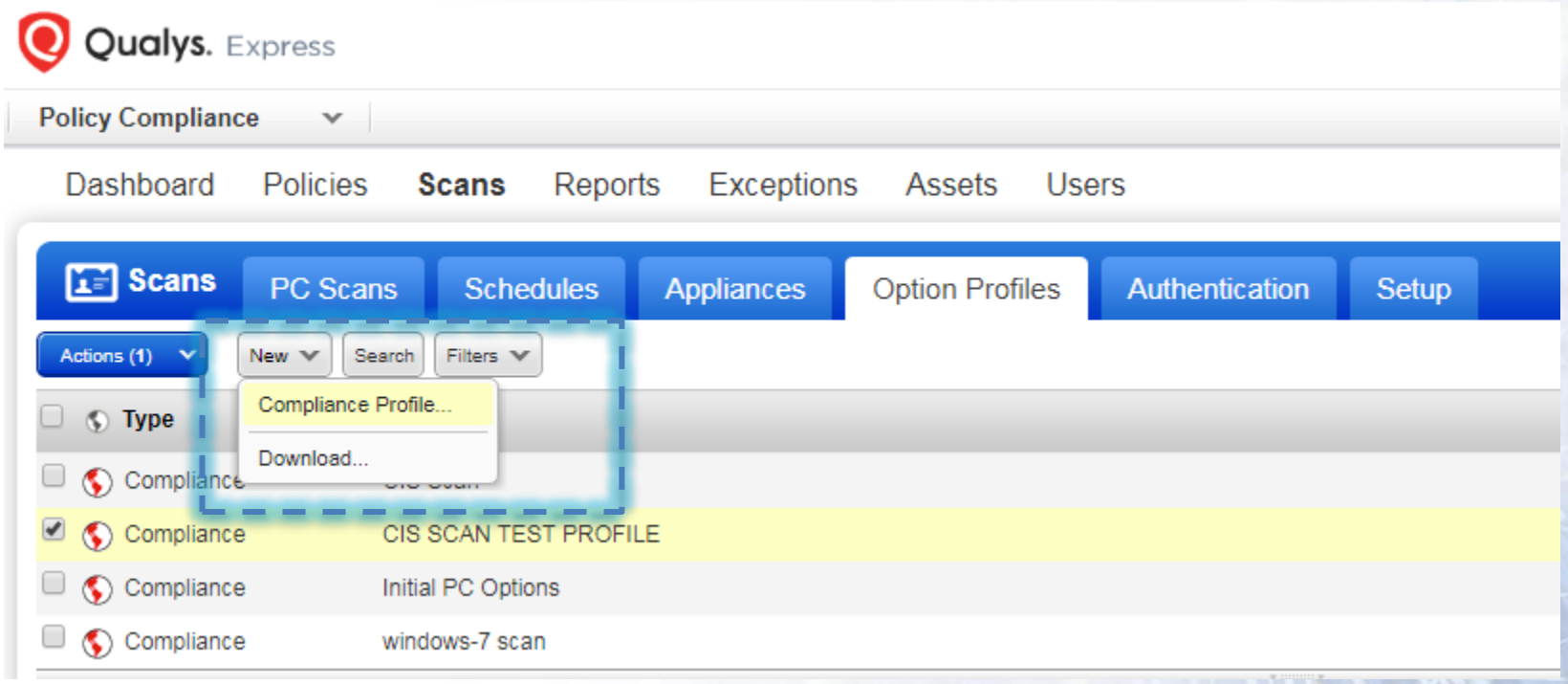
2. CONFIGURE SCAN SETTINGS

QUALYS DEMO – SECURITY HARDENING



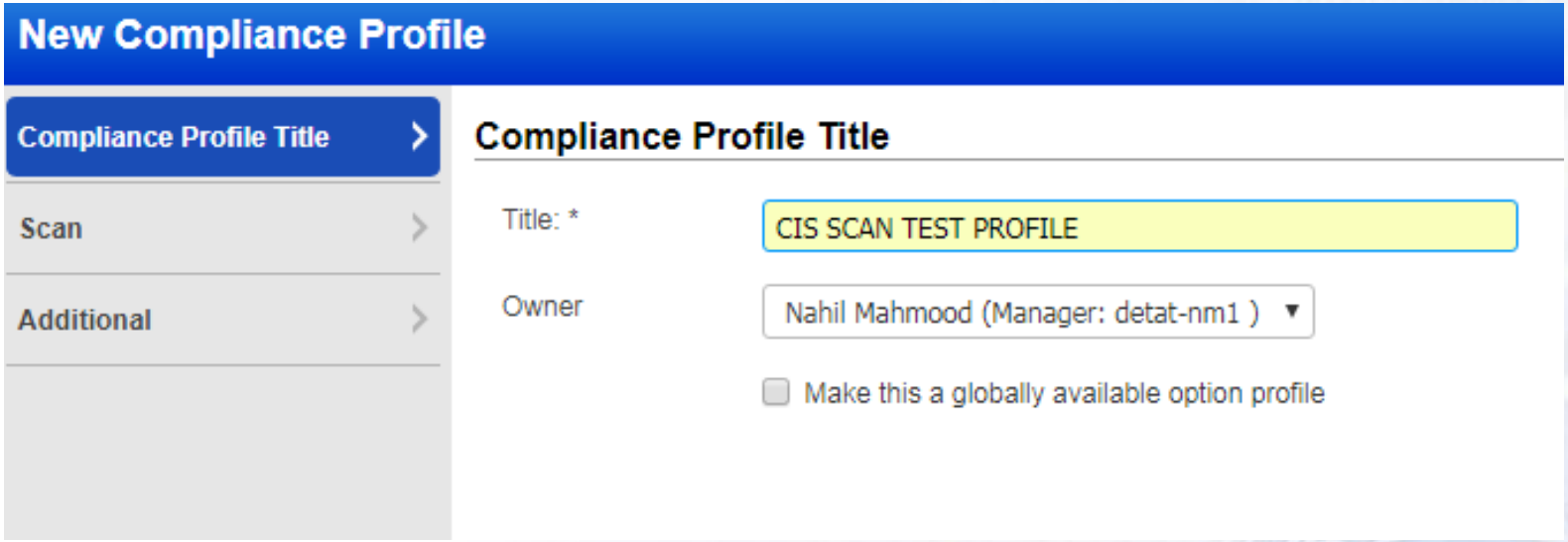
2. CONFIGURE SCAN SETTINGS

QUALYS DEMO – SECURITY HARDENING



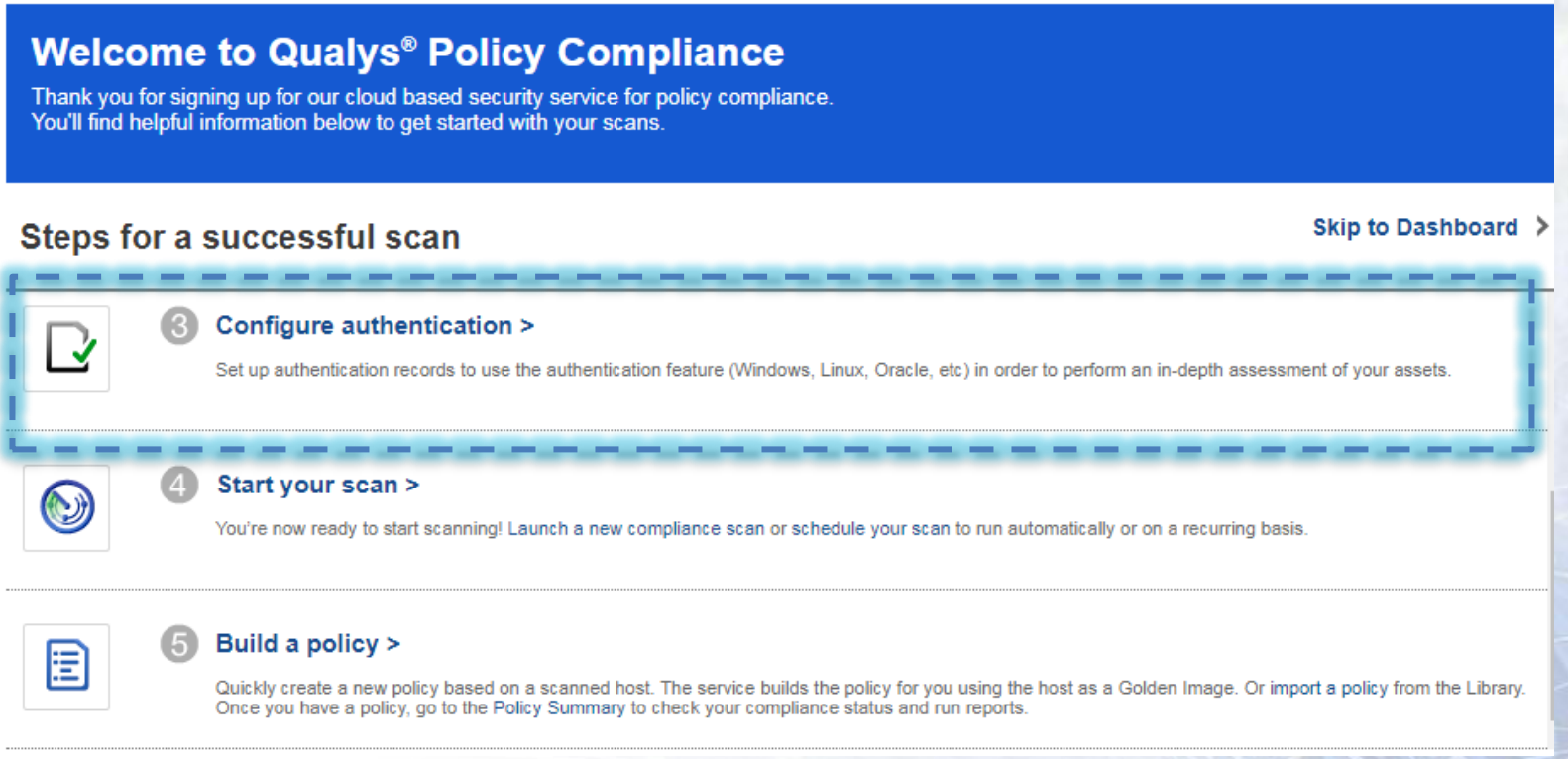
NEW COMPLIANCE PROFILE

QUALYS DEMO – SECURITY HARDENING



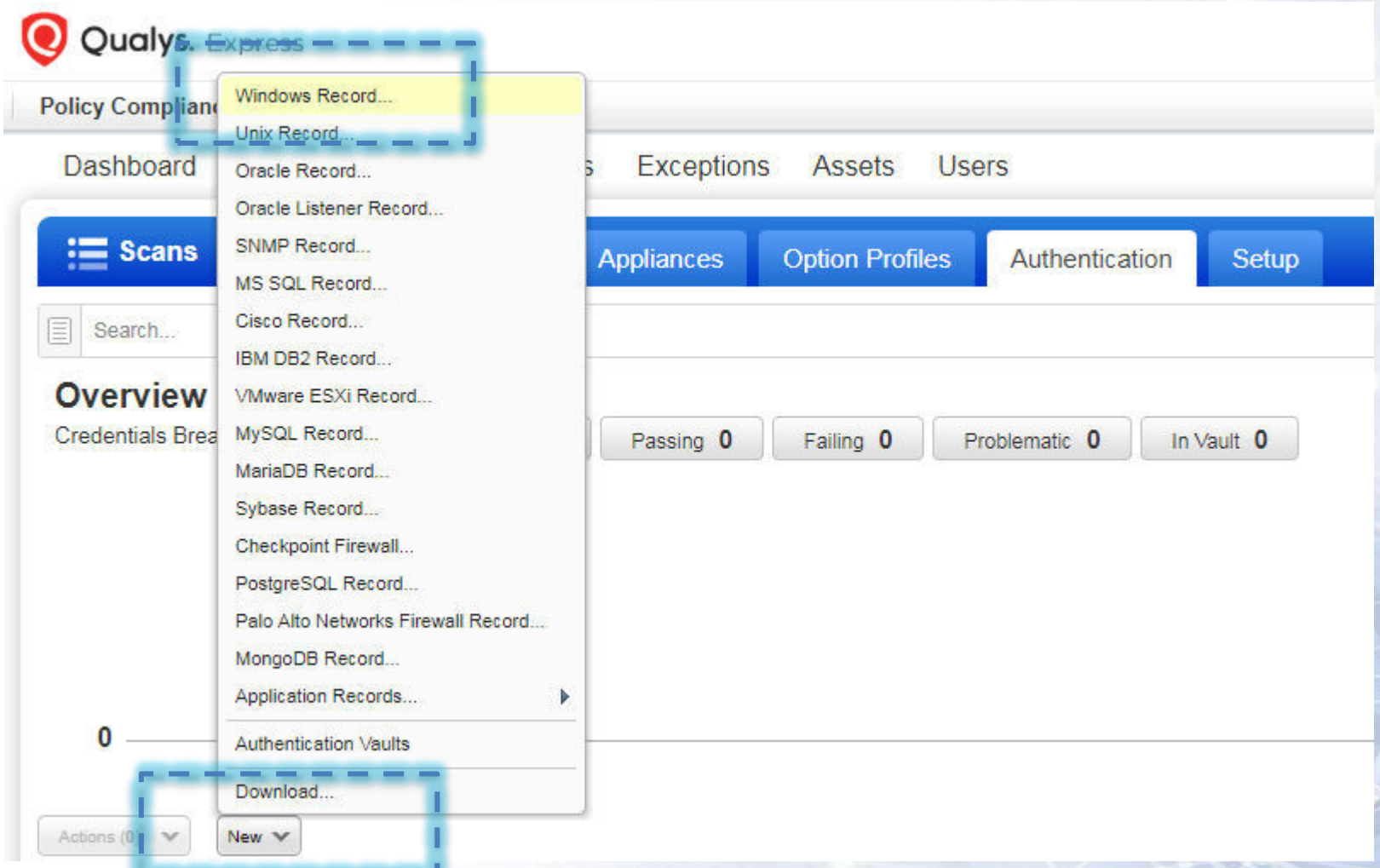
'CIS SCAN TEST PROFILE' CREATED

QUALYS DEMO – SECURITY HARDENING

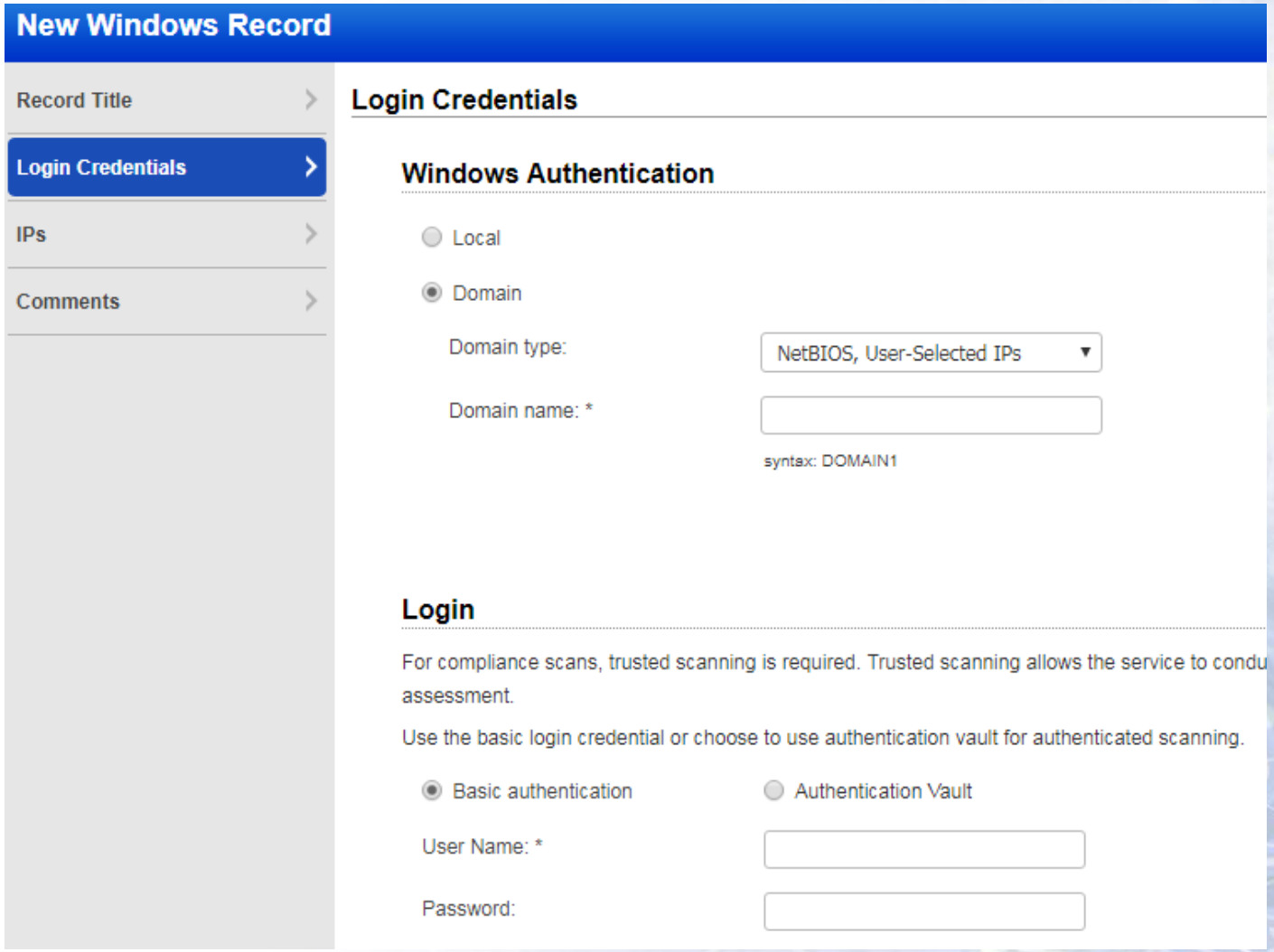


3. CONFIGURE AUTHENTICATION

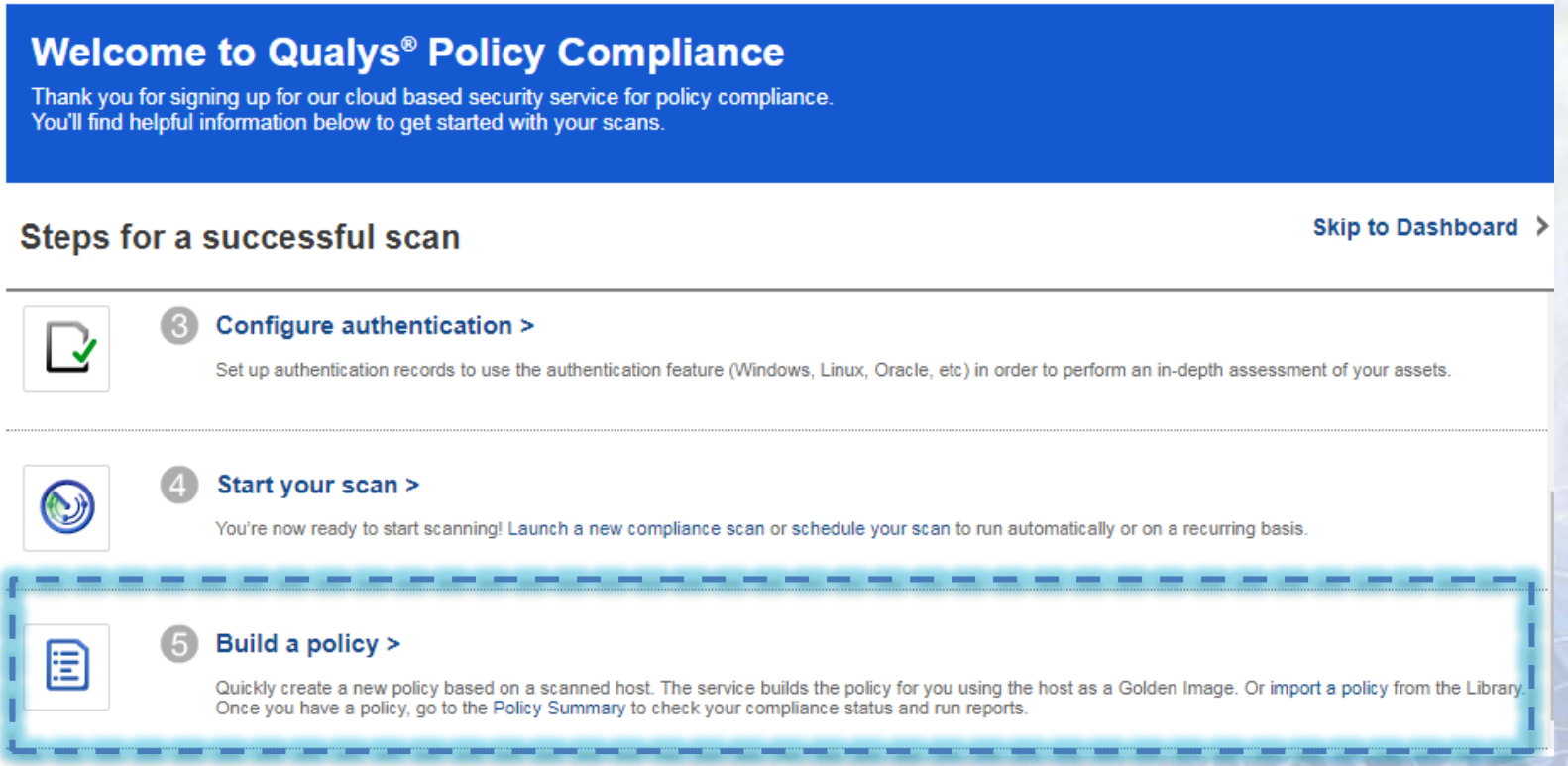
QUALYS DEMO – SECURITY HARDENING



QUALYS DEMO – SECURITY HARDENING

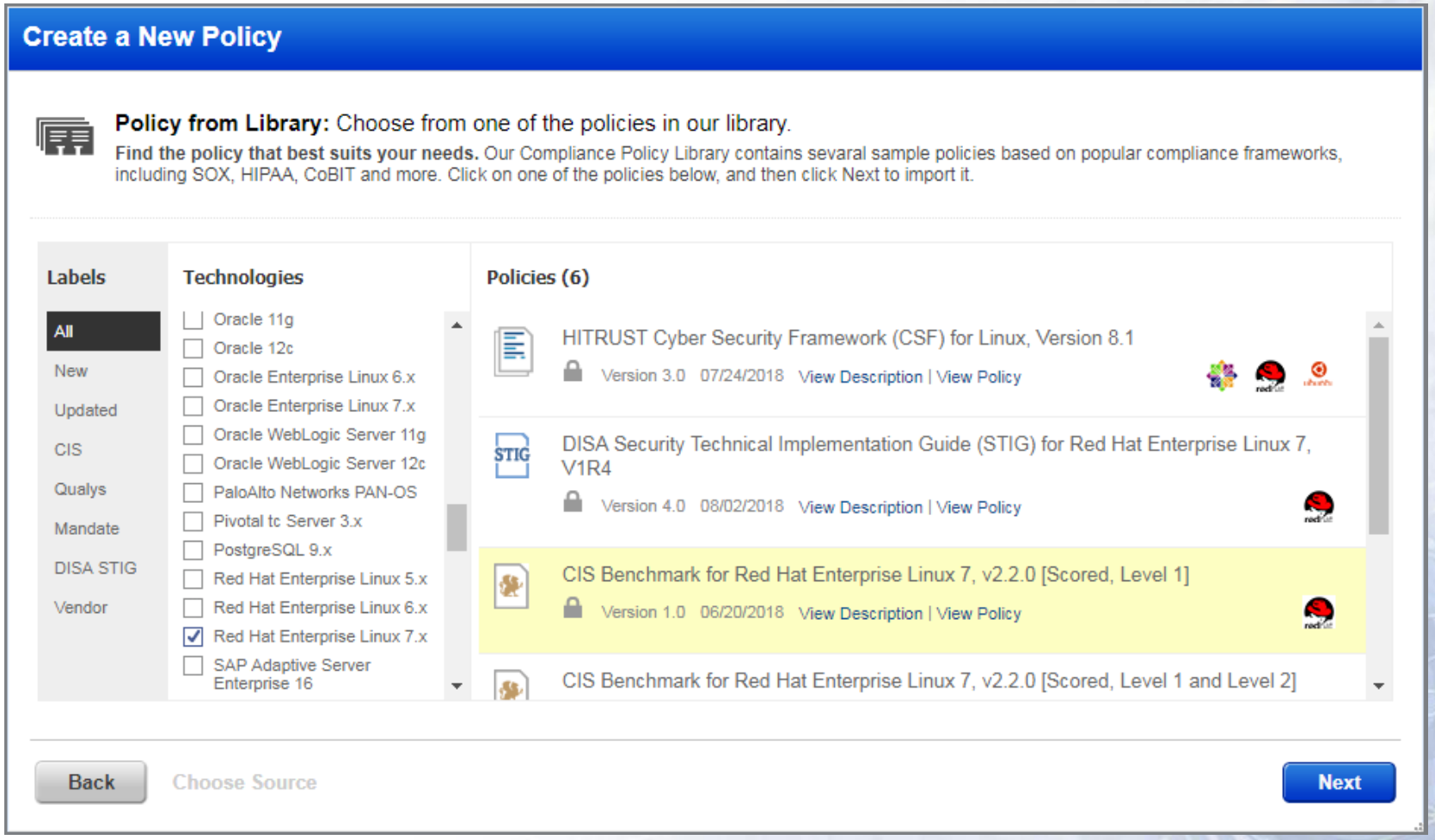


QUALYS DEMO – SECURITY HARDENING



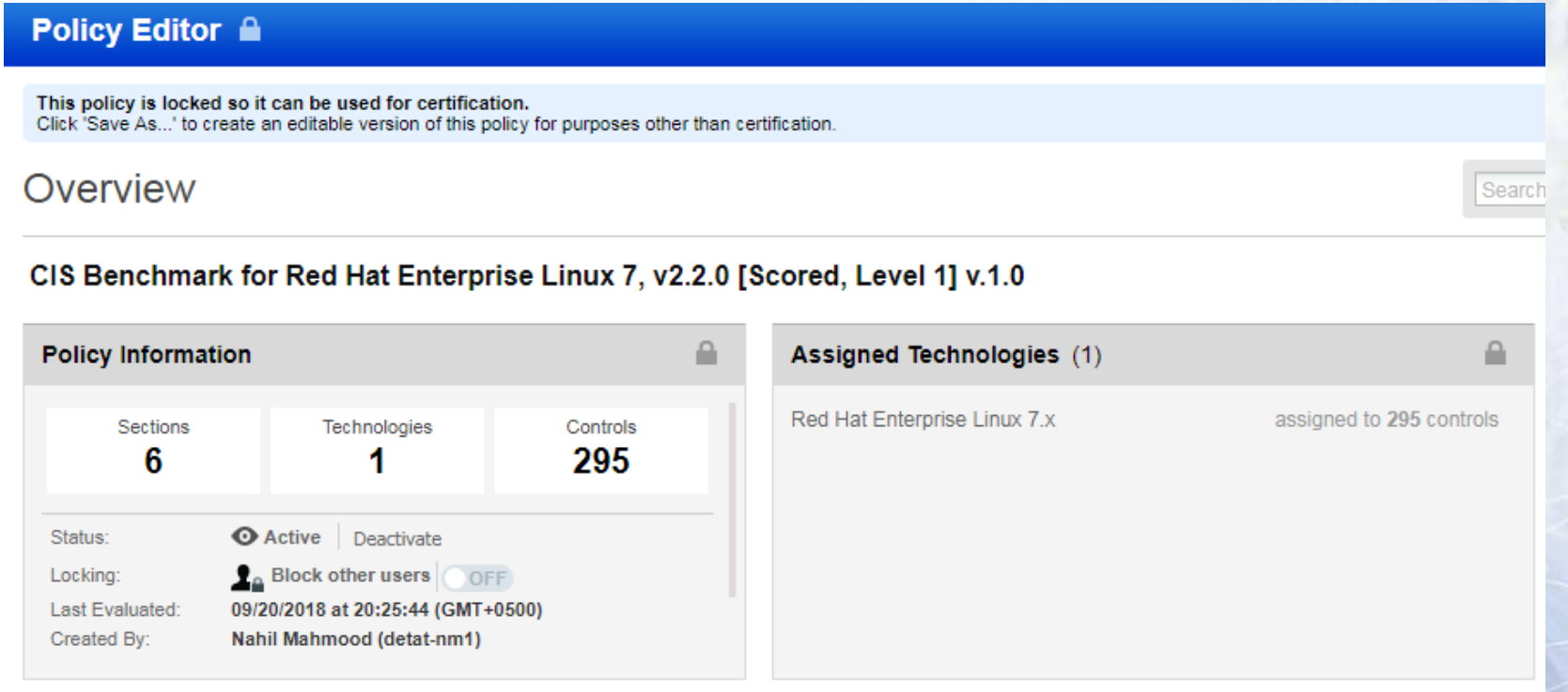
3. CONFIGURE AUTHENTICATION

QUALYS DEMO – SECURITY HARDENING



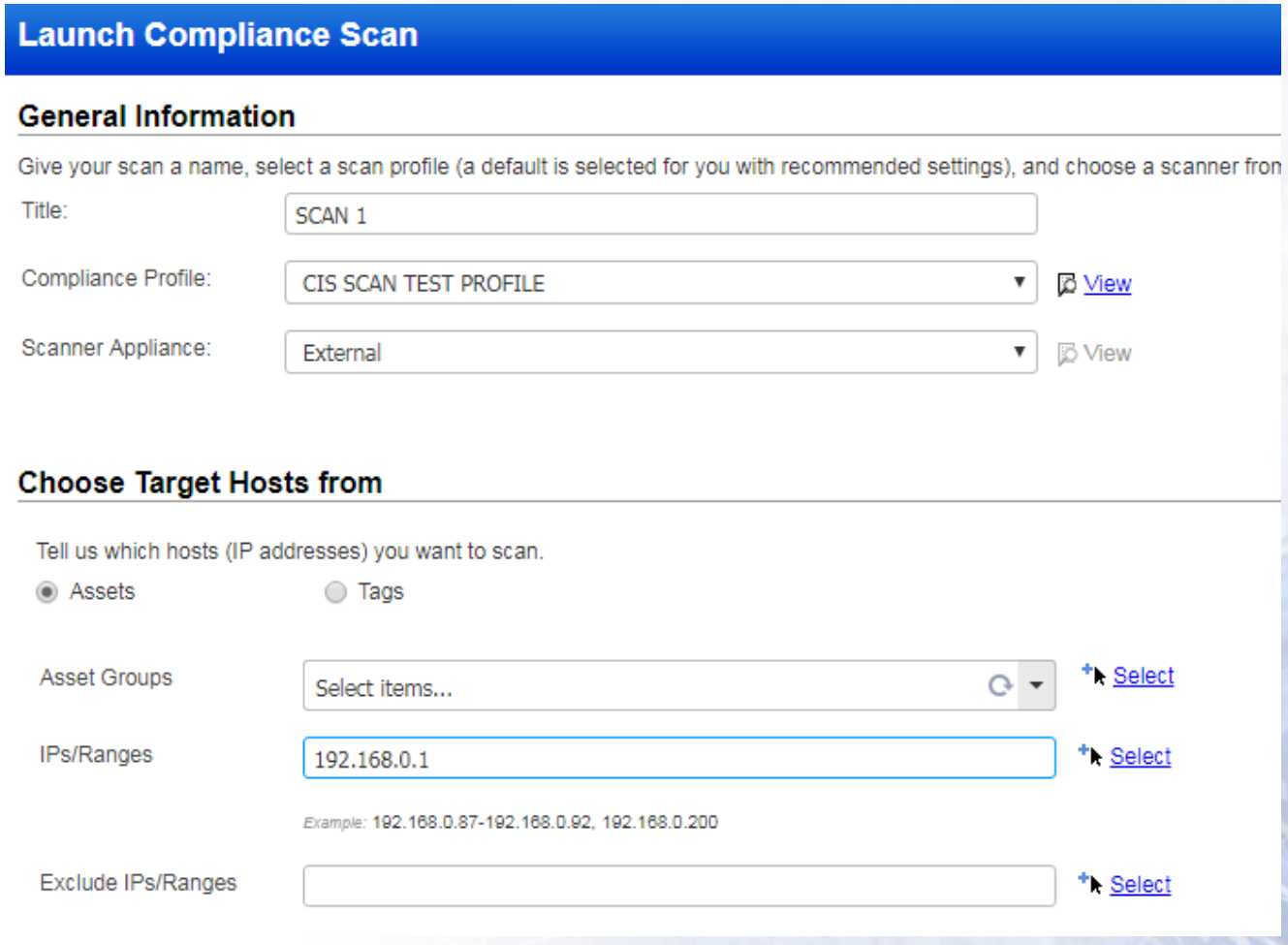
COMPLIANCE LIBRARY: CIS RED HAT ENT. LINUX 7

QUALYS DEMO – SECURITY HARDENING



POLICY EDITOR

QUALYS DEMO – SECURITY HARDENING



LAUNCH COMPLIANCE SCAN

QUALYS DEMO – SECURITY HARDENING II

- The scan features may also be adjusted from the main Qualys dashboard

END